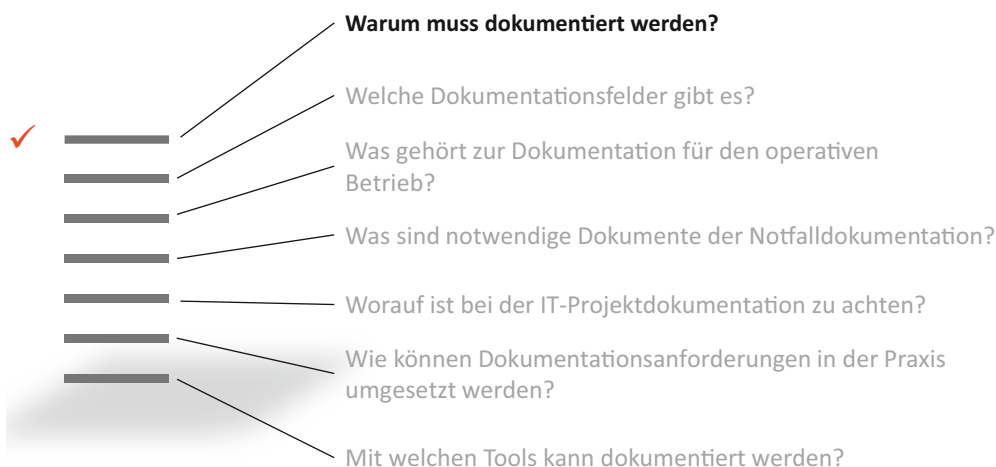


1

Anforderungen an die IT-Dokumentation



Richtigerweise startet ein Projekt zur Erstellung bzw. Optimierung der IT-Dokumentation mit der Frage: »Was muss ich in meiner IT-Organisation eigentlich dokumentieren?« Denn es ist entscheidend, dass man neben individuellen Anforderungen und Zielen im ersten Schritt analysiert, welche verbindlichen Dokumentationsverpflichtungen oder mit anderen Worten, welche Compliance-Anforderungen es für das eigene Unternehmen gibt. Hierbei möchte dieses Kapitel Sie unterstützen. Es beleuchtet, welche Anforderungen sich aus gesetzlichen Anforderungen und Verordnungen für die IT-Dokumentation ableiten lassen.

Unternehmen müssen aber nicht nur sicherstellen, dass Compliance-Anforderungen eingehalten werden, sondern dies auch regelmäßig kontrollieren und im Rahmen der Jahresabschlussprüfung gegebenenfalls auch nachweisen. Welche Anforderungen Prüfer und Revisoren an die IT-Dokumentation stellen, wird daher ebenfalls vorgestellt.

In diesem Kapitel finden Sie die folgenden Themenschwerpunkte:

- Was heißt Compliance?
- Branchenübergreifende Anforderungen an die IT-Dokumentation
- Anforderungen aus branchenspezifischen Vorschriften
- Was prüfen Abschlussprüfer und Revisoren?
- Dokumentationsanforderungen in Österreich und in der Schweiz
- Relevante Normen und Standards

■ 1.1 Was heißt Compliance?

Die Bezeichnung *Compliance* stammt ursprünglich aus dem Englischen und bedeutet so viel wie »Einhaltung« oder »Befolgung«. Leider sucht man eine allgemeingültige Definition für den Begriff vergebens. Bezogen auf gesetzliche Anforderungen verbirgt sich hinter dem Begriff *Compliance* die Bedeutung eines gesetzestreuen Verhaltens. Weiter gefasst bedeutet *Compliance* die Erfüllung aller rechtlichen Vorgaben und aller branchenspezifischen Vorgaben sowie der innerbetrieblichen Richtlinien.

Bei *IT-Compliance* als Teilbereich von *Compliance* bezieht sich die oben genannte Einhaltung internationaler, nationaler und innerbetrieblicher Gesetze, Richtlinien und Bestimmungen auf den Umgang mit der im Unternehmen vorhandenen Informationstechnik. Dabei adressiert *IT-Compliance* vor allem die Bereiche Sicherheit, Verfügbarkeit, Integrität und Datenschutz. Für diese Bereiche müssen Maßnahmen, Prozesse und Kontrollen implementiert und nachvollziehbar dokumentiert werden.

Compliance-Anforderungen mit Relevanz für die IT

Für eine Umsetzung der *Compliance*-Anforderungen ist es aber selbstverständlich erst einmal notwendig, diese zu kennen. Leider gibt es keinen allgemeingültigen Standard, was in eine *IT*-Dokumentation aufzunehmen ist, oder gar ein gesondertes Dokumentationsgesetz.

Es existieren jedoch eine ganze Reihe von Verpflichtungen für die Erstellung und Vorhaltung einer Dokumentation, die deren Inhalt und Aufbau prägen. Branchenübergreifend sind insbesondere Vorschriften aus dem Bereich der Buchführung und Rechnungslegung sowie Datenschutz und steuerliche Thematiken für verschiedenartige Unternehmen relevant. Die Vorschriften des Handelsgesetzbuchs, die Grundsätze ordnungsmäßiger DV-gestützter Buchführungssysteme (GoBS), das Bundesdatenschutzgesetz (BDSG) sowie die entsprechenden Regelungen der Abgabenordnung (AO) gilt es hier zu beachten. Und mit dem amerikanischen Sarbanes-Oxley Act (SOX) und dem europäischen Pendant 8. EU-Richtlinie (auch als »Euro-SOX« bezeichnet) bzw. deren Umsetzung in nationales Recht in Form des Bilanzrechtsmodernisierungsgesetzes (BilMoG) wurden in den letzten Jahren Regelungen mit Gesetzeskraft verabschiedet, die einen erheblichen Einfluss auf die vorzuhaltende *IT*-Dokumentation haben. Wenn auch die meisten gesetzlichen Regelungen von kaufmännischen Grundsätzen wie dem Gläubigerschutz getrieben sind, so haben sie dennoch für die *IT* eine direkte Bedeutung, da die kaufmännischen Kernprozesse wie Buchhaltung und Einkauf in aller Regel *IT*-gestützt ablaufen (z. B. die *ERP*-Anwendung *SAP*). Neben den branchenübergreifenden Vorgaben unterliegen Unternehmen einzelner Branchen z. T. zusätzlichen, sehr spezifischen Anforderungen.

Den Gesetzen und Verordnungen ist allerdings gemein, dass die beschriebenen Anforderungen mehr oder weniger allgemein gehalten sind und die konkrete Umsetzung offen bleibt. Mit der Frage, wie der Aufbau einer gesetzestkonformen *IT*-Dokumentation sichergestellt werden kann, werden die Verantwortlichen allein gelassen. An dieser Stelle lohnt sich ein Blick auf einige relevante Standards und Normen.

Während Gesetze und daraus abgeleitete Rechtsnormen verbindlichen Charakter haben, entfalten Standards ihre Wirkung durch nationale oder internationale Anerkennung wie beispielsweise bei den *ISO*-Normen oder den *DIN*-Standards. Normen und Standards helfen

dabei, gesetzliche Anforderungen einzuhalten, und dienen bei deren Umsetzung als Nachweis der Einhaltung. So weist ein Unternehmen, das eine Zertifizierung nach dem Sicherheitsstandard ISO 27001 erlangt hat, damit nach, dass es einen Sicherheitsprozess und die nach aktuellem Erkenntnisstand möglichen Sicherheitsmaßnahmen implementiert hat. Eine Organisation, die nicht über diese Zertifizierung verfügt, muss hierfür Einzelnachweise erbringen.

■ 1.2 Branchenübergreifende Anforderungen an die IT-Dokumentation

Ein Gesetz ist eine Sammlung von allgemein verbindlichen Rechtsnormen, die in einem förmlichen Verfahren vom Gesetzgeber erlassen worden ist. Und entgegen der landläufigen Meinung gerade auch vieler erfahrener IT-Administratoren gibt es eine Reihe von allgemeinen Unternehmensgesetzen, aus denen sich aufgrund der immer stärkeren Abhängigkeiten der Geschäftsprozesse von der IT direkt oder indirekt Anforderungen an die IT-Dokumentation ergeben.

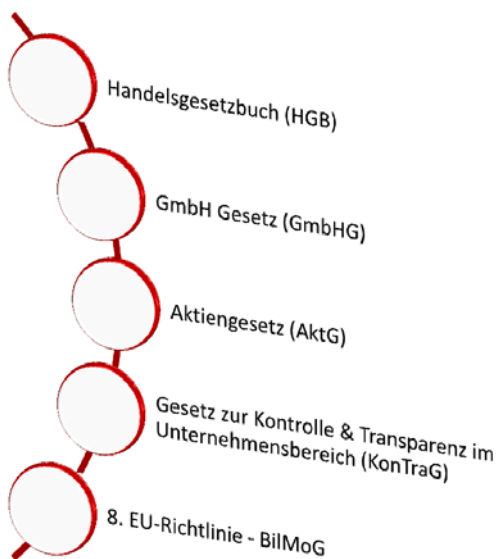


Bild 1.1

Für die IT-Dokumentation relevante allgemeine Unternehmensgesetze

Zusätzlich zu den allgemeinen Unternehmensgesetzen gibt es eine Reihe weiterer Gesetze, Richtlinien und Verordnungen, die ebenfalls Relevanz für die IT-Dokumentation haben. Bei den Richtlinien und Verordnungen handelt es sich um Handlungsvorschriften mit bindendem Charakter, die im Gegensatz zu Gesetzen nicht vom Staat, sondern von einer Organisation ausgegeben werden.

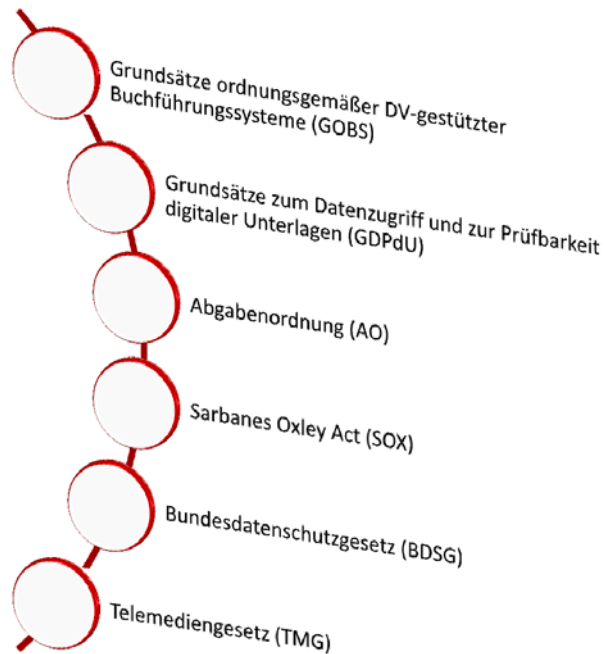


Bild 1.2 Weitere Gesetze und Verordnungen mit Relevanz für die IT-Dokumentation

In den folgenden Abschnitten werden die vorstehend aufgeführten Gesetze und Verordnungen im Überblick vorgestellt und die daraus ableitbaren Anforderungen an die IT-Dokumentation erläutert. Weitere Informationen zu den konkreten Dokumentationsanforderungen finden Sie auch in *Abschnitt 1.4*. In diesem wird beschrieben, welche Anforderungen Wirtschaftsprüfer und Revisoren an die Dokumentation stellen.

1.2.1 Handelsgesetzbuch (HGB)

Das Handelsgesetzbuch (HGB) ist die zentrale Vorschrift für das Handelsrecht in Deutschland. Es enthält sowohl Regelungen für Gesellschaftsformen als auch für Handelsgeschäfte und die Führung der relevanten Handelsbücher.

Im dritten Buch des HGB sind die Vorschriften für das Führen der Handelsbücher enthalten. So ist in § 238 Abs. 1 geregelt, »dass die Buchführung so beschaffen sein muss, dass sie einem sachverständigen Dritten innerhalb angemessener Zeit einen Überblick über die Geschäftsvorfälle und über die Lage des Unternehmens vermitteln kann« (HGB). Die Geschäftsvorfälle müssen sich in ihrer Entstehung und Abwicklung verfolgen lassen. Gemäß § 239 Abs. 2 müssen die Eintragungen in Büchern und die sonst erforderlichen Aufzeichnungen vollständig, richtig, zeitgerecht und geordnet vorgenommen werden. Und in Abs. 4 ist festgelegt, dass »die Handelsbücher und die sonst erforderlichen Aufzeichnungen auch in der geordneten Ablage von Belegen bestehen oder auf Datenträgern geführt werden können, soweit diese Formen der Buchführung einschließlich des dabei angewandten Verfahrens den Grundsätzen ordnungsmäßiger Buchführung entsprechen. Bei der Führung der Handelsbücher und der

sonst erforderlichen Aufzeichnungen auf Datenträgern muss insbesondere sichergestellt sein, dass die Daten während der Dauer der Aufbewahrungsfrist verfügbar sind und jederzeit innerhalb einer angemessenen Frist lesbar gemacht werden können» (HGB).

Ableitbare Anforderungen an die IT-Dokumentation

Die zuvor genannten Absätze sind der Kern der Grundsätze ordnungsgemäßer Buchführung (GoB), die wiederum die Basis für die Grundsätze ordnungsgemäßer DV-gestützter Buchführungssysteme (GoBS) darstellen. Informationen zur GoBS finden Sie in *Abschnitt 1.1.5*. Wichtig ist in diesem Zusammenhang, dass die Zulässigkeit der Speicherung auf Datenträger davon abhängig gemacht wird, dass auch das dabei angewandte Verfahren den Grundsätzen ordnungsmäßiger Buchführung entsprechen muss. Hier ist bereits ein sehr direkter Bezug zur IT und damit zur IT-Dokumentation gegeben.

Auch im Zusammenhang mit den Festlegungen zur Aufbewahrung von Unterlagen in § 257 wird ein Bezug zur IT hergestellt. So ist nach Abs. 1 jeder Kaufmann verpflichtet, Unterlagen wie zum Beispiel Handelsbücher, Inventare, Eröffnungsbilanzen, Jahresabschlüsse, Lageberichte, Konzernabschlüsse, Konzernlageberichte sowie die zu ihrem Verständnis erforderlichen Arbeitsanweisungen und sonstigen Organisationsunterlagen geordnet aufzubewahren, und zwar für zehn Jahre (Abs. 4). Hieraus kann abgeleitet werden, dass damit auch die Verfahrensdokumentation gemeint ist.

Die Art der Aufbewahrung regelt § 257 Abs. 3 des HGB derart, dass mit Ausnahme der Eröffnungsbilanzen, Jahresabschlüsse und Konzernabschlüsse die in Abs. 1 aufgeführten Unterlagen

»auch als Wiedergabe auf einem Bildträger oder auf anderen Datenträgern aufbewahrt werden können, wenn dies den Grundsätzen ordnungsmäßiger Buchführung entspricht und sichergestellt ist, dass die Wiedergabe oder die Daten

- 1. mit den empfangenen Handelsbriefen und den Buchungsbelegen bildlich und mit den anderen Unterlagen inhaltlich übereinstimmen, wenn sie lesbar gemacht werden,*
- 2. während der Dauer der Aufbewahrungsfrist verfügbar sind und jederzeit innerhalb angemessener Frist lesbar gemacht werden können.« (HGB)*

Bemerkenswert hierbei ist, und dies hat Relevanz für die gesamte IT-Dokumentation, dass das HGB Anforderungen definiert, die sich auf drei Teilbereiche eingrenzen lassen: *Verfügbarkeit, Integrität und Ordnungsmäßigkeit*.

- **Verfügbarkeit:** Die Verfügbarkeit der geführten Handelsbücher und der geschäftlichen Unterlagen muss sichergestellt sein. Ein Großteil der geschäftlichen Unterlagen wird mittlerweile elektronisch in Dokumentenmanagementsystemen und anderen IT-Systemen geführt sowie elektronisch archiviert. Wirtschaftsprüfer und Finanzbehörden verlangen daher bei einer Prüfung Nachweise darüber, dass die Daten in angemessener Zeit wiederherzustellen sind.
- **Integrität:** So wie man in den »alten« Buchhaltungskladden keine Veränderung der Buchungen vornehmen durfte, die nicht nachvollziehbar war, so gilt dies auch für die heutigen Buchhaltungssysteme und Daten. Integrität ist zum Beispiel wegen der gesetzlichen Aufbewahrungsfristen eine kritische Anforderung an die E-Mail-Archivierung. Entscheidend sind hierbei die hardwaremäßigen, softwaremäßigen und organisatorischen Sicherheitsfunktionen, die auch nachzuweisen sind.

- **Ordnungsmäßigkeit:** Gemäß HGB müssen die Eintragungen in Büchern und die sonst erforderlichen Aufzeichnungen vollständig, richtig, zeitgerecht und geordnet vorgenommen werden, wobei es heute wohl kaum noch Unternehmen gibt, die für die Buchführung keine IT-gestützten Buchhaltungssysteme im Einsatz haben. Entsprechend gilt dies für die verwendeten Buchhaltungssysteme und muss für diese überprüfbar sein. In enger Verbindung damit steht die Authentizität, für die die Überprüfung der Benutzerrechte wichtig ist.

1.2.2 Aktiengesetz (AktG) und GmbH-Gesetz (GmbHG)

Das Aktiengesetz ist anwendbar auf alle Aktiengesellschaften sowie OHGs und KGs, auf GmbHs bei entsprechender Größe, Branche, Struktur usw. sowie auf Versicherungen und Banken. Es beschreibt die gesetzlichen Anforderungen an eine Aktiengesellschaft und regelt unter anderem die Aufgaben der Organe der Aktiengesellschaft. Im Aktiengesetz wird festgelegt, dass ein Vorstand persönlich haftet, wenn er Entwicklungen, die zukünftig ein Risiko für das Unternehmen darstellen könnten, nicht durch ein Risikomanagement überwacht und durch geeignete Maßnahmen vorbeugt (§ 91 Abs. 2 und § 93 Abs. 2 AktG). (AktG)

Geschäftsführern einer GmbH wird im GmbH-Gesetz »die Sorgfalt eines ordentlichen Geschäftsmannes« (GmbHG) auferlegt (§ 43 Abs. 1 GmbHG), welches ähnliche Folgerungen für das Risikomanagement beinhaltet wie für Vorstände nach dem Aktiengesetz.

Ableitbare Anforderungen an die IT-Dokumentation

Die oben genannten Formulierungen klingen recht allgemein und unverbindlich. Hieraus lassen sich jedoch konkrete Verpflichtungen an die Gewährleistung angemessener IT-Sicherheitsmaßnahmen ableiten, die natürlich auch zu dokumentieren sind. IT-Sicherheitsvorfälle können massive wirtschaftliche Schäden verursachen und gegebenenfalls den Bestand eines Unternehmens gefährden. Erleidet das Unternehmen aufgrund der Verletzung von Organisations- und Aufsichtspflichten einen Schaden, haftet die Geschäftsleitung u. U. persönlich auf Schadensersatz (Organisationsverschulden).

Für bestimmte Berufsgruppen wie Ärzte, Rechtsanwälte oder Angehörige sozialer Berufe gibt es darüber hinaus Sonderregelungen im Strafgesetzbuch, die Freiheitsstrafen vorsehen, wenn vertrauliche Angaben von Patienten, Mandanten bzw. Klienten ohne deren ausdrückliche Einwilligung öffentlich gemacht werden (§ 203 StGB). Ein fahrlässiger Umgang mit Informationstechnik kann diesen Tatbestand unter Umständen bereits erfüllen.

Zusätzlich beinhalten beide Gesetze die klare Aufforderung an die Unternehmensleitung, ein geeignetes Risikomanagementsystem einzurichten und nachzuweisen. Diese zweite Forderung ist erst 1998 in das Gesetz mit aufgenommen worden und bildet die Basis für das Gesetz zur Kontrolle und Transparenz im Unternehmensbereich (KonTraG).

1.2.3 Gesetz zur Kontrolle und Transparenz im Unternehmensbereich (KonTraG)

Ausgehend von den zunehmenden Korruptions- und Bilanzskandalen der 1980er- und 1990er-Jahre des letzten Jahrhunderts wurde 1998 das Gesetz KonTraG verabschiedet. Seine Anwendung erstreckt sich über die Aktiengesellschaft hinaus auch auf GmbH-Gesellschaften. Ziel dieses Gesetzes ist die Stärkung und Verbesserung der Unternehmensführung und Unternehmenskontrolle. Das KonTraG präzisiert dabei die entsprechenden Festlegungen im Aktiengesetz und im Handelsgesetzbuch. (KonTraG)

Das KonTraG ist ein Artikelgesetz und damit eine Änderung und Ergänzung mehrerer vorhandener Gesetze. Es hat bei seiner Verabschiedung auf andere Gesetze Einfluss genommen, beispielsweise durch Änderungen und Ergänzungen des Handelsgesetzbuchs (HGB) und des Aktiengesetzes (AktG), durch die die Corporate Governance in deutschen Unternehmen erhöht werden soll. Demzufolge ist u. a. ein unternehmensweites Risikofrüherkennungs- und Überwachungssystem zu implementieren. Ebenfalls müssen

- Aussagen zu potenziellen Risiken und
- Aussagen zur Risikostruktur des Unternehmens

dokumentiert im Lagebericht des Jahresabschlusses präsentiert werden.

Zu diesem Zweck ist in das Aktiengesetz in § 91 der Absatz 2 neu aufgenommen worden, wonach der Vorstand verpflichtet wird, geeignete Maßnahmen zu treffen. Insbesondere ist *»ein Überwachungssystem einzurichten, damit Entwicklungen, die den Fortbestand der Gesellschaft gefährden, frühzeitig erkannt werden.«* (AktG) Hervorgehoben wird die Betonung der internen Überwachung durch die Aufnahme eines weiteren Absatzes (Nr. 4) in § 317 des HGB, wonach im Rahmen der Jahresabschlussprüfung zu beurteilen ist, *»ob der Vorstand die ihm nach § 91 Abs. 2 des Aktiengesetzes obliegenden Maßnahmen in einer geeigneten Form getroffen hat und ob das danach einzurichtende Überwachungssystem seine Aufgaben erfüllen kann.«* (AktG)

Mit dem § 91 Abs. 2 AktG ist also nicht nur die Vorhaltung einer Revision gefordert, sondern auch, ob diese ihre Aufgaben erfüllen kann. Der Jahresabschlussprüfer hat also zu beurteilen, ob eine im Verhältnis zu den Unternehmensrisiken angemessene Revision existiert. In diesem Zusammenhang wird ebenfalls regelmäßig kontrolliert, wie viel und welche IT-Prüfungen im Berichtsjahr durchgeführt wurden.

Ableitbare Anforderungen an die IT-Dokumentation

Häufig werden für die Organisation und die Berichtserstellung des Risikofrüherkennungs- und -Überwachungssystems Anwendungen als Unterstützung implementiert. Hier ist insbesondere auf die Integrität der Anwendungen und die Eignung sowie auf das Rechte- und Rollenkonzept zu achten.

1.2.4 8. EU-Richtlinie/BilMoG

Nicht nur in Amerika haben Bundesgesetze eine immer stärkere Bedeutung für die IT. Auch in der EU sind mit der Richtlinie über die Abschlussprüfungen von Jahresabschlüssen und konsolidierten Abschlüssen aus dem Jahr 2006 Regelungen geschaffen worden, die eine

Auswirkung auf die IT-Dokumentation entfalten. In journalistischer Vereinfachung wird diese sogenannte 8. EU-Richtlinie als »Euro-SOX« bezeichnet, da sie eine ähnliche Auswirkung auf die Überwachungs- und Nachweispflichten der Unternehmen hat. (Union)

Tatsächlich stellt diese Richtlinie aber eine Harmonisierung und Konkretisierung bereits bestehender EU-Richtlinien aus den Jahren 1978 bis 1984 dar und ist nicht wie SOX direkt an die Unternehmen, sondern an die Mitgliedsstaaten der EU gerichtet. Erfasst werden auch nur Unternehmen von öffentlichem Interesse, wobei jeder Mitgliedsstaat eine eingeschränkte Entscheidungsfreiheit hat.

Ableitbare Anforderungen an die IT-Dokumentation

Für die IT ist insbesondere der Artikel 41 der Richtlinie entscheidend, wonach jedes von der Richtlinie erfasste Unternehmen einen Prüfungsausschuss zu bilden hat, unabhängig von den sonstigen Überwachungsorganen, wie zum Beispiel einer internen Revision. Im Rahmen des BilMoG hat der Prüfungsausschuss die Wirksamkeit des internen Kontrollsystems (IKS) und des Risikomanagements zu überwachen. Dies beinhaltet die Verpflichtung des Abschlussprüfers, entsprechende IKS-Dokumentationen zu prüfen und über wesentliche Schwächen bei der internen Kontrolle des Rechnungslegungsprozesses zu berichten.

Auch wenn sich aus Artikel 41 nicht ableiten lässt, welche Anforderungen an die Prozesse und an das interne Kontrollsystem gestellt werden, so verbirgt sich hinter den Begriffen »Überwachung« und »Wirksamkeit« die Grundforderung nach einer aussagefähigen Dokumentation zum IT-Risiko- und Sicherheitsmanagement.

1.2.5 Grundsätze ordnungsgemäßer DV-gestützter Buchführungssysteme (GoBS)

Die GoBS sind eine Verwaltungsvorschrift und beschreiben in Präzisierung des HGB und der Abgabenordnung die organisatorischen und technischen Anforderungen an die IT-gestützte Buchführung.

Generell stellen die GoBS die gleichen Prinzipien an die DV-gestützte Buchführung, wie sie für eine manuell erstellte Buchführung gelten. Aus Sicht der IT sind insbesondere die *Kapitel 4, Internes Kontrollsystem (IKS)*, und *Kapitel 6, Dokumentation und Prüfbarkeit*, von Bedeutung. (GoBS)

Nach Kapitel 6.1 der GoBS ist eine Verfahrensdokumentation erforderlich, aus der Inhalt, Aufbau und Ablauf des Abrechnungsverfahrens vollständig ersichtlich sind. Die Verfahrensdokumentation für das Abrechnungssystem muss insbesondere folgende Bereiche beinhalten:

- eine Beschreibung der sachlogischen Lösung,
- die Beschreibung der programmtechnischen Lösung,
- eine Beschreibung, wie die Programmidentität gewahrt wird,
- eine Beschreibung, wie die Integrität von Daten gewahrt wird,
- Arbeitsanweisungen für den Anwender.

Allein hinter der Anforderung zur Beschreibung der sachlogischen Lösung verbergen sich gemäß Kapitel 6.2.1 der GoBS die folgenden Dokumentationsanforderungen:

- »Generelle Aufgabenstellung
- Beschreibung der Anwenderoberflächen für die Ein- und Ausgabe einschließlich der manuellen Arbeiten
- Beschreibung der Datenbestände
- Beschreibung von Verarbeitungsregeln
- Beschreibung des Datenaustausches (Datenträgeraustausch/Datentransfer)
- Beschreibung der maschinellen und manuellen Kontrollen
- Beschreibung der Fehlermeldungen und der sich aus den Fehlern ergebenden Maßnahmen
- Schlüsselverzeichnisse
- Schnittstellen zu anderen Systemen« (GoBS)

In Kapitel 4 der GoBS werden die Anforderungen an das interne Kontrollsystem definiert, wobei das IKS als »die Gesamtheit aller aufeinander abgestimmten und miteinander verbundenen Kontrollen, Maßnahmen und Regelungen« verstanden wird. Das IKS hat nach Kapitel 4.1 die folgenden Aufgaben zu erfüllen:

- Sicherung und Schutz des vorhandenen Vermögens und vorhandener Informationen vor Verlusten aller Art;
- Bereitstellung vollständiger, genauer und aussagefähiger sowie zeitnaher Aufzeichnungen;
- Förderung der betrieblichen Effizienz durch Auswertung und Kontrolle der Aufzeichnungen;
- Unterstützung der Befolgung der vorgeschriebenen Geschäftspolitik. (GoBS)



Aus GoBS wird GoBIT

Die GoBS sind in Zusammenarbeit mit der *Arbeitsgemeinschaft für wirtschaftliche Verwaltung (AWV)* entwickelt worden. Aufgrund der Weiterentwicklung der technischen, rechtlichen und organisatorischen Rahmenbedingungen werden die GoBS seit dem Jahr 2005 durch eine Projektgruppe bei der AWV überarbeitet. Die neue Fassung trägt den Namen *GoBIT: Grundsätze ordnungsmäßiger Buchführung beim IT-Einsatz*.

Seit dem 13. 10. 2013 liegt ein öffentlicher Entwurf der GoBIT vor. Sie können diesen in der jeweils aktuellen Fassung (bis zur Veröffentlichung der verabschiedeten Version) von der Website des AWV herunterladen [<http://www.awv-net.de/cms/index-b-267-848.html>] (AWV).

Ableitbare Anforderungen an die IT-Dokumentation

Insgesamt beschreiben die GoBS einen umfangreichen Forderungskatalog an die IT-Dokumentation, der noch um weitere Kapitel wie die Datensicherheit und die Wiedergabe der auf Datenträgern geführten Unterlagen ergänzt wird. Bei Nichtbeachtung der Dokumentationsanforderungen der GoBS und insbesondere beim Fehlen einer Verfahrensdokumentation kann die Ordnungsmäßigkeit der Buchführung formell infrage gestellt werden. Außerdem

werden Buchführungsmängel von den Prüfern im Prüfungsbericht vermerkt, was gegebenenfalls negative Auswirkungen auf das Rating haben kann.

Aus dem HGB leiten sich vor allem Anforderungen an die Archivierung von kaufmännischen Unterlagen ab:

- Ordnungsmäßigkeit,
- Vollständigkeit,
- Sicherheit des Gesamtverfahrens,
- Schutz vor Veränderung und Verfälschung,
- Sicherung vor Verlust,
- Nutzung nur durch Berechtigte,
- Einhaltung der Aufbewahrungsfristen,
- Dokumentation des Verfahrens,
- Nachvollziehbarkeit,
- Prüfbarkeit.

Das eigentliche Dokument mit den Vorgaben zum Thema Verfahrensdokumentation aber ist die GoBS. Demzufolge muss die Verfahrensdokumentation den gesamten organisatorischen und technischen Prozess für Dokumente beschreiben, die nach Handelsrecht und steuerrechtlichen Vorgaben aufbewahrt werden müssen. Dies umfasst:

- die Entstehung (Erfassung),
- die Indizierung,
- die Speicherung,
- das eindeutige Wiederfinden,
- die Absicherung gegen Verlust und Verfälschung und
- die Reproduktion der archivierten Informationen.



Was ist ein Verfahren?

Die Verfahrensdokumentation nach GoBS dient dazu, nachweisen zu können, dass die Anforderungen des Handelsgesetzbuchs (HGB), der Abgabenordnung und der GoBS für die Aufbewahrung von Daten und Belegen erfüllt sind. Auch für bestimmte Branchen gibt es, unabhängig von den HGB-Anforderungen, Vorgaben zur Erstellung von Verfahrensdokumentationen, so zum Beispiel für die Pharmaindustrie.

Im IT-Umfeld wird der Begriff Verfahren jedoch eher im Kontext von Prozessen verwendet. Während die *Prozessbeschreibung* den Prozessablauf strukturiert darstellt und die Abläufe beschreibt, in denen Verfahren abgewickelt werden, stellt eine *Verfahrensanleitung* dar, wie ein Prozess operativ auszuführen ist bzw. wie ein Ergebnis erzielt wird. Auch viele Standards und Normen unterscheiden in diesem Sinne zwischen Prozessen und Verfahren.

Sie sollten daher immer darauf achten, in welchem Kontext der Begriff Verfahren verwendet wird. Dies gilt vor allem bei zahlreichen Artikeln, die im Internet zu diesem Thema zu finden sind.

1.2.6 Abgabenordnung (AO)

Die Abgabenordnung (AO) ist das elementare Gesetz des deutschen Steuerrechts. In ihr sind die grundlegenden Regelungen enthalten, wie die Steuern zu erheben sind. Zusätzlich sind in Anlehnung an das HGB auch Anforderungen an das Führen der Bücher sowie weiterer steuerlich relevanter Unterlagen beschrieben.

Im vierten Teil der AO, in dem es um die Durchführung der Besteuerung geht, konkretisieren die Paragraphen 145 bis 147 die Anforderungen an die Buchführung und an die Aufzeichnungen. Danach muss gemäß § 145 Abs. 1 »die Buchführung so beschaffen sein, dass sie einem sachverständigen Dritten innerhalb angemessener Zeit einen Überblick über die Geschäftsvorfälle und über die Lage des Unternehmens vermitteln kann«. (AO) Dies ist einer der Kernsätze der GoB sowie auch die Basis jeder Ordnungsmäßigkeitsprüfung einer Revision.

Ableitbare Anforderungen an die IT-Dokumentation

Insgesamt lässt sich festhalten, dass bereits die grundlegenden Gesetze für die Wirtschaftsunternehmen eine Grundhaltung normiert haben, die in Richtung einer nachvollziehbaren Dokumentation der Geschäftsvorfälle und Geschäftsabläufe abzielt.

Die weiteren Anforderungen entsprechen weitgehend denen aus dem HGB. Es gibt jedoch in der AO eine kleine Ergänzung zum HGB, die für die IT von erheblicher Relevanz ist. In § 147 Abs. 1 sind zunächst gleichlautend zum § 257 Abs. 1 die aufzuhebenden Unterlagen genannt. Zusätzlich werden in der AO aber noch Unterlagen dazugezählt, wenn diese für die Besteuerung von Bedeutung sind. Im Rahmen wirtschaftlicher Aktivitäten sind aber fast alle Geschäftsvorfälle von steuerlicher Relevanz. Somit können die Anforderungen auf weite Bereiche des IT-Betriebs Anwendung finden.

1.2.7 Grundsätze zum Datenzugriff und zur Prüfbarkeit digitaler Unterlagen (GDPdU)

Im Zusammenhang mit den GoBS sind auch die Grundsätze zum Datenzugriff und zur Prüfbarkeit digitaler Unterlagen (GDPdU), die seit 2002 Anwendung finden, für die IT-Dokumentation wichtig. (GDPdU)

Die GDPdU enthalten Regeln zur Aufbewahrung digitaler Unterlagen und zur Mitwirkungspflicht der Steuerpflichtigen bei Betriebsprüfungen. Es handelt sich dabei um eine Verwaltungsanweisung des Bundesfinanzministeriums, in der dieses bestimmte Rechtsnormen aus der Abgabenordnung und dem Umsatzsteuergesetz zur digitalen Aufbewahrung von Buchhaltungen, Buchungsbelegen und Rechnungen konkretisiert.

In Kapitel I GDPdU wird auf den § 147 Abs. 6 AO Bezug genommen, »wonach der Finanzbehörde das Recht eingeräumt ist, die mithilfe eines Datenverarbeitungssystems erstellte Buchführung des Steuerpflichtigen per Datenzugriff zu prüfen. Diese neue Prüfungsmethode tritt neben die Möglichkeit der herkömmlichen Prüfung. Das Recht auf Datenzugriff steht der Finanzbehörde nur im Rahmen steuerlicher Außenprüfungen zu.« (GDPdU)

Weiter wird in Kapitel I.1 GDPdU ausgeführt, dass sich der digitale Zugriff nur auf steuerlich relevante Daten, also im Wesentlichen auf Daten der Finanz- und Anlagenbuchhaltung bezieht. Im weiteren Verlauf wird jedoch ergänzt, dass, soweit sich auch in anderen Bereichen des Datenverarbeitungssystems steuerlich relevante Daten befinden, diese durch den Steuerpflichtigen nach Maßgabe seiner steuerlichen Aufzeichnungs- und Aufbewahrungspflichten zu qualifizieren und für den Datenzugriff in geeigneter Weise vorzuhalten sind. Diese Ausweitung kann dazu führen, dass ein großer Teil der Geschäftsvorfälle steuerlich relevant sein kann.

Ableitbare Anforderungen an die IT-Dokumentation

Die Verankerung der GoBS in der GDPdU macht deutlich, dass der Umfang der Dokumentationspflichten zunimmt. Sofern Dokumente elektronisch unter Zuhilfenahme einer elektronischen Signatur zu Abrechnungszwecken verarbeitet und dabei gegebenenfalls verschlüsselt werden, muss nach Kapitel II.1 der GDPdU der Originalzustand der übermittelten Dokumente jederzeit überprüfbar sein. Dies setzt neben einer Reihe anderer Tatbestände voraus, dass die Übertragungs-, Archivierungs- und Konvertierungssysteme den Anforderungen der GoBS, insbesondere an die Dokumentation, an das interne Kontrollsystem, an das Sicherungskonzept sowie an die Aufbewahrung, entsprechen.

1.2.8 Sarbanes-Oxley Act (SOX)

Neben nationalen Gesetzen bekommen auch internationale Gesetze eine zunehmende Bedeutung für die IT-Abteilungen und damit auch für die IT-Dokumentation. Wesentliche Gesetze in diesem Zusammenhang stellen der amerikanische Sarbanes-Oxley Act (SOX) sowie die 8. EU-Richtlinie dar, die ihre nationale Umsetzung im Bilanzrechtsmodernisierungsgesetz (BilMoG) findet.

Unter dem Eindruck der Aufsehen erregenden Bilanzskandale in Amerika wurde mit dem Sarbanes-Oxley Act (SOX) 2002 ein US-amerikanisches Bundesgesetz verabschiedet, das die Wiederherstellung des Vertrauens der Öffentlichkeit in die Finanzberichte der Unternehmen durch Anforderungen an die Offenlegung und Genauigkeit von veröffentlichten finanzwirtschaftlichen Informationen zum Ziel hat. Das Gesetz ist auf der Website der U.S. Securities and Exchange Commission erhältlich: [<http://www.sec.gov/about/laws/soa2002.pdf>] (SOX).

Die Gültigkeit dieses Gesetzes erstreckt sich auch auf deutsche Unternehmen, sofern sie an einer amerikanischen Börse gelistet sind oder sich im überwiegenden Besitz einer amerikanischen Muttergesellschaft befinden.

SOX besteht aus elf Hauptsektionen, wobei für die IT die *Section 404* von besonderer Bedeutung ist. In der *Section 404, Management Assessment of Internal Controls*, wird die Notwendigkeit zur Einrichtung eines *Internen Kontrollsystems (IKS)* beschrieben.

Ableitbare Anforderungen an die IT-Dokumentation

Die Brisanz der *Section 404* liegt darin, dass die Einhaltung der Sicherheitsregelungen und die Effizienz des internen Kontrollsystems im Einzelnen nachgewiesen werden müssen – und dies jährlich. Im Fokus stehen hier insbesondere die Integrität der Anwendungen und

das Rechte- und Rollenkonzept. In der Prüfungspraxis haben sich unter anderem die folgenden Anforderungen herauskristallisiert:

- Die Systemdokumentation muss aktuell sein und dem tatsächlichen Verfahren entsprechen.
- Die manuellen Prozesse und insbesondere die manuellen Kontrollen müssen dokumentiert werden.
- Die im Unternehmen selbst entwickelten Anwendungen müssen gegen den Zugriff Unbefugter geschützt werden und einer geregelten Datensicherung unterliegen. Die Regelungen sind zu dokumentieren.
- Die Benutzerkonten ausgeschiedener Mitarbeiter oder nicht aktiver Berater müssen gesperrt werden (im Berechtigungskonzept zu dokumentieren).
- Benutzer dürfen nur diejenigen Berechtigungen erhalten, die sie wirklich brauchen. Besonders kritisch sind in diesem Zusammenhang die »Super-User«-Berechtigungen (im Berechtigungskonzept zu dokumentieren).
- Es ist sicherzustellen, dass Mitarbeiter im Entwicklungsbereich über keine Berechtigungen im Produktivbereich verfügen dürfen (im Berechtigungskonzept zu dokumentieren).
- Die Betriebssysteme und Datenbanken, auf denen Anwendungen wie beispielsweise SAP aufsetzen, sind genauso zu schützen wie die Anwendungssysteme selbst (Sicherheitskonzept erforderlich).

1.2.9 Bundesdatenschutzgesetz (BDSG)

Das Bundesdatenschutzgesetz (BDSG) ist ausgerichtet auf den Schutz der Privatsphäre und regelt sowohl für öffentliche (unter anderem Kommunen, Ämter und staatliche Unternehmen) als auch für nichtöffentliche Stellen (unter anderem natürliche und juristische Personen und Gesellschaften) den Umgang mit personenbezogenen Daten. Es ist eine Reaktion des Gesetzgebers auf das Volkszählungsurteil von 1983, wonach die bisher vorhandenen Datenschutzgesetze nicht den verfassungsrechtlichen Anforderungen genügten. Nachdem daraufhin bereits einige Bundesländer eigene Landesdatenschutzgesetze verabschiedet hatten, trat das Bundesdatenschutzgesetz 1990 in Kraft. Es liegt nach der Novellierung in 2009 in der Fassung vom 14.08.2009 vor.

»Zweck dieses Gesetzes ist es, den Einzelnen davor zu schützen, dass er durch den Umgang mit seinen personenbezogenen Daten in seinem Persönlichkeitsrecht beeinträchtigt wird.« (BDSG)

Das BDSG ist ein Verbotsgesetz, das die Erhebung, Verarbeitung und Nutzung personenbezogener Daten grundsätzlich untersagt. Sie sind nur dann zulässig, wenn dieses oder andere Gesetze es erlaubt oder der Betroffene eingewilligt hat. Die Einwilligung hat in der Regel schriftlich zu erfolgen und hat zur Voraussetzung, dass sie aus freier Entscheidung und in Kenntnis des Zwecks und der Folgen der Verarbeitung gefallen ist. Es ist in sechs Abschnitte unterteilt, wobei im Abschnitt 1 die allgemeinen Bestimmungen enthalten sind. Für den IT-Betrieb wichtig ist auch der Abschnitt 3, in dem die Verarbeitung personenbezogener Daten geregelt ist.

Nach § 3, Abs. 1 sind personenbezogene Daten *»Einzelangaben über persönliche oder sachliche Verhältnisse einer bestimmten oder bestimmaren Person.«* (BDSG) Von besonderem Inte-

resse dabei sind Einzelangaben, aus deren Kombination oder Auswertung sich eine Person ableiten, also bestimmen lässt, so wie beispielsweise aus der Telefonnummer in Kombination mit der Adresse. Besonders schutzwürdig sind Daten zur rassischen und ethnischen Herkunft, politische Meinungen sowie religiöse und philosophische Überzeugungen und Angaben zur Gewerkschaftszugehörigkeit, zur Gesundheit und zum Sexualleben.

Nach § 4f Abs. 1 hat jede nichtöffentliche Stelle, die personenbezogene Daten erhebt, verarbeitet oder nutzt, einen *Datenschutzbeauftragten* zu bestellen, sofern mehr als vier Personen damit beschäftigt sind. Kleinstbetriebe sind also von dieser Vorschrift ausgenommen. Sofern der Betrieb jedoch geschäftsmäßig personenbezogene Daten zum Zwecke der Übermittlung erhebt, gilt diese Einschränkung nicht mehr. Dem Datenschutzbeauftragten ist nach § 4g Abs. 2 eine Übersicht über die in § 4e beschriebenen Verfahren zur Verfügung zu stellen. Nach Abs. 1 des Paragraphen ist er rechtzeitig, also vor der Einführung, zu unterrichten. Weiter hat er die ordnungsgemäße Verwendung der Datenverarbeitungsprogramme, mit deren Hilfe personenbezogene Daten verarbeitet werden sollen, zu überwachen.



Weitergehende Datenschutzregelungen in zusätzlichen Gesetzen

Das wohl bekannteste deutsche Regelwerk zum Datenschutz ist das Bundesdatenschutzgesetz. Es gilt für Bundesbehörden und für die Privatwirtschaft. Daneben haben die deutschen Bundesländer eigene Landesdatenschutzgesetze, die für die jeweiligen Landesbehörden und die Kommunen gelten. Sowohl das Bundesdatenschutzgesetz als auch die Landesdatenschutzgesetze finden nur Anwendung, soweit für den konkreten Sachverhalt kein spezielleres Datenschutzgesetz existiert.

Für Postdienstleister gilt beispielsweise die *Postdienste-Datenschutzverordnung*. Erhebliche Bedeutung haben auch die in den Sozialgesetzen verankerten Vorschriften zum Schutz des Sozialgeheimnisses. Und Internet-Provider müssen bei der Verarbeitung personenbezogener Daten ihrer Kunden die besonderen Datenschutzvorschriften des Telemediengesetzes beachten.

Ableitbare Anforderungen an die IT-Dokumentation

Eine wesentliche Bestimmung des BDSG ist die der Meldepflicht nach § 4d, wonach Verfahren automatisierter Verarbeitungen vor ihrer Inbetriebnahme der zuständigen Aufsichtsbehörde bzw. dem betrieblichen Datenschutzbeauftragten zu melden sind. Eine Produktivsetzung einer Verarbeitung personenbezogener Daten, etwa eines Kundenmanagementsystems, ist danach nicht zulässig und kann gerichtlich untersagt werden.

Aus dem § 4g Abs. 2 Satz 1 leitet sich das Erfordernis zur Aufstellung eines Verfahrensverzeichnis ab, in dem alle meldepflichtigen Verfahren zu dokumentieren sind. Dieses Verzeichnis hat die verantwortliche Stelle zu führen und dem Datenschutzbeauftragten zur Verfügung zu stellen. Nähere Erläuterungen zu Verfahrensbeschreibungen finden Sie in *Kapitel 3 in Abschnitt 3.8.9*.

Diese Bestimmungen führen zu hohen Anforderungen an die Dokumentation von IT-Verfahren. Es muss also vor der Implementierung eines Verfahrens, in dem personenbezogene Daten verarbeitet werden sollen, exakt festgelegt und damit dokumentiert sein, welche

Daten von wem und für wen zu welchem Zweck erhoben, verarbeitet und genutzt werden sollen. Vor allem aber genügt es nicht, nur das Verfahren mitzuteilen. Das Unternehmen hat nach § 9 des BDSG technische und organisatorische Maßnahmen zu treffen, die erforderlich sind, um die Ausführung der Vorschriften dieses Gesetzes – insbesondere die in der Anlage des Gesetzes genannten Anforderungen – zu gewährleisten. Danach sind bei der Verarbeitung von personenbezogenen Daten folgende Kontrollen umzusetzen:

- **Zutritts- und Zugangskontrollen:** Datenschutzrelevante IT-Systeme dürfen nur befugten Personen zugänglich sein und nur von ihnen genutzt werden können. Es ist sicherzustellen, dass nur befugte Personen Zutritt zu Gebäuden, Räumen und IT-Systemen mit personenbezogenen Daten erhalten (Beschreibung des Zutrittskontrollsystems, zum Beispiel Ausweisleser, kontrollierte Schlüsselvergabe etc.)
- **Zugriffskontrollen:** Dies umfasst Maßnahmen, die gewährleisten, dass die zur Benutzung der Datenverarbeitungsverfahren Befugten ausschließlich auf die ihrer Zugriffsberechtigung unterliegenden personenbezogenen Daten zugreifen können (Beschreibung von systemimmanenten Sicherungsmechanismen, Verschlüsselungsverfahren entsprechend dem Stand der Technik). Dies schließt auch die Überwachung des Lebenszyklus von Datenträgern ein, d. h., ob die Anforderungen an die Speicherung von personenbezogenen Daten bei der Initialisierung, der Aufbewahrung, der Verwendung und der Entsorgung der Datenträger erfüllt werden.
- **Weitergabekontrollen:** Es muss nachvollziehbar sein, an welche Stellen welche Daten weitergegeben wurden bzw. falls noch keine Daten weitergegeben wurden, an welche Stellen eine Weitergabe vorgesehen ist. Übermittelte bzw. transportierte personenbezogene Daten dürfen während der Übermittlung oder des Transports nicht unbefugt gelesen, kopiert, verändert oder entfernt werden können (Beschreibung von systemimmanenten Sicherungsmechanismen, Verschlüsselungsverfahren entsprechend dem Stand der Technik). Bei Online-Zugriffen ist klarzustellen, welche Seite für die Ausgabe und Verwaltung von Zugriffssicherungscodes verantwortlich ist.
- **Eingabekontrollen:** Es muss eindeutig nachvollziehbar sein, von wem welche personenbezogenen Daten eingegeben, geändert oder gelöscht wurden. Werden personenbezogene Daten im Auftrag einer anderen Stelle verarbeitet, so muss gewährleistet sein, dass die Benutzer die Daten nicht anders als beauftragt verarbeiten können (sämtliche Systemaktivitäten werden protokolliert; die Protokolle werden mindestens drei Jahre lang durch den Auftragnehmer aufbewahrt).
- **Verfügbarkeitskontrollen:** Maßnahmen, die gewährleisten, dass personenbezogene Daten gegen zufällige Zerstörung oder Verlust geschützt sind (Backup-Konzept, Medium, Aufbewahrungszeit und Aufbewahrungsort für Backup-Kopien.).
- **Trennungskontrollen:** Maßnahmen, die gewährleisten, dass zu unterschiedlichen Zwecken erhobene Daten getrennt verarbeitet werden können. (BDSG)

Für die entsprechende IT-Dokumentation zur Erhebung, Verarbeitung und Nutzung der personenbezogenen Daten hat dies zur Folge, dass sie bereits vor der Implementierung eines neuen Verfahrens vorliegen muss und dem Datenschutzbeauftragten zur Prüfung zu übergeben ist. Dieser beurteilt damit auch die Ordnungsmäßigkeit der IT-Dokumentation im Sinne des Gesetzes.

Besondere Verpflichtungen bei Auftragsdatenverarbeitung

Mit der Novelle II vom 03. Juli 2009 zum BDSG und dem neu gefassten § 11 Erhebung, Verarbeitung oder Nutzung personenbezogener Daten im Auftrag des BDSG haben sich die Bestimmungen zur Auftragsdatenverarbeitung in erheblichen Teilen verändert und die Dokumentationspflichten auf Seiten der Auftragnehmer sowie die Prüfpflichten auf Seiten der Auftraggeber erheblich verschärft. Hauptziel der Gesetzesverschärfung ist die Sicherstellung, dass die datenschutzrechtliche Verantwortung und die inhaltliche Verantwortung nicht auseinanderfallen, sondern in einer Hand beim Auftraggeber verbleiben, was bedeutet, dass sich dieser nicht durch die Auslagerung von Datenverarbeitungsprozessen seiner datenschutzrechtlichen Verpflichtungen entledigen kann.

Auftragsdatenverarbeitung beschreibt das Auslagern von Datenverarbeitungsprozessen durch den Auftraggeber auf externe Dienstleister (Outsourcing). Sind hiervon personenbezogene Daten betroffen, findet *§ 11 BDSG Erhebung, Verarbeitung oder Nutzung personenbezogener Daten im Auftrag* Anwendung. Im klassischen Fall der Auftragsdatenverarbeitung werden personenbezogene Daten, beispielsweise Kundendaten, nicht vom Unternehmer selbst, sondern von einem beauftragten Dritten, dem Dienstleister, verwaltet. In der Praxis liegt in einer Vielzahl von Fällen eine Auftragsdatenverarbeitung vor, ohne dass dies den betroffenen Unternehmen überhaupt bewusst ist, etwa im Fall einer externen Lohn- und Gehaltsabrechnung, bei der Pflege und Aktualisierung von Datenbeständen durch Dritte oder auch bei Cloud Computing. Typischerweise handelt es sich bei den folgenden Beispielen um Auftragsdatenverarbeitung:

- Outsourcing des Rechenzentrums (ganz oder teilweise),
- Marketingaktionen und Kundenumfragen durch eine externe Agentur,
- Auslagerung von Kundensupport oder Kundenakquise an ein Callcenter,
- Papier- und Aktenvernichtung sowie die Vernichtung von Datenträgern durch einen externen Dienstleister,
- externe Lohn- und Gehaltsabrechnung,
- externe Rechnungsbearbeitung/Buchhaltung,
- zentrale Bearbeitung von Reisekostenabrechnungen für mehrere Dienststellen,
- Zugriff des Auftragnehmers auf personenbezogene Daten vor Ort beim Auftraggeber,
- Wartung (auch Fernwartung) von Servern und Computern durch einen externen Dienstleister, wenn Zugriff auf personenbezogene Daten möglich ist,
- Wartungs- und Prüfungsverträge, wenn hierdurch der Zugriff auf personenbezogene Daten möglich ist.

Das Gesetz regelt die Pflichten des Auftraggebers vor einer Auftragsvergabe. So muss der Auftragnehmer unter besonderer Berücksichtigung der Zuverlässigkeit und der Eignung der von ihm getroffenen technischen und organisatorischen Maßnahmen sorgfältig ausgewählt werden. Weiterhin ist in § 11 des BDSG geregelt, dass der Auftrag schriftlich zu erteilen ist und dass regelmäßige Kontrollen zu erfolgen haben. Im Vertrag sind insbesondere die folgenden Punkte zu definieren:

1. *»Der Gegenstand und die Dauer des Auftrags,*
2. *der Umfang, die Art und der Zweck der vorgesehenen Erhebung, Verarbeitung oder Nutzung von Daten, die Art der Daten und der Kreis der Betroffenen,*

3. *die nach § 9 zu treffenden technischen und organisatorischen Maßnahmen,*
4. *die Berichtigung, Löschung und Sperrung von Daten,*
5. *die nach Absatz 4 bestehenden Pflichten des Auftragnehmers, insbesondere die von ihm vorzunehmenden Kontrollen,*
6. *die etwaige Berechtigung zur Begründung von Unterauftragsverhältnissen,*
7. *die Kontrollrechte des Auftraggebers und die entsprechenden Duldungs- und Mitwirkungspflichten des Auftragnehmers,*
8. *mitzuteilende Verstöße des Auftragnehmers oder der bei ihm beschäftigten Personen gegen Vorschriften zum Schutz personenbezogener Daten oder gegen die im Auftrag getroffenen Festlegungen,*
9. *der Umfang der Weisungsbefugnisse, die sich der Auftraggeber gegenüber dem Auftragnehmer vorbehält,*
10. *die Rückgabe überlassener Datenträger und die Löschung beim Auftragnehmer gespeicherter Daten nach Beendigung des Auftrags.*« (BDSG)



Dokumentation bei Outsourcing

Die meisten Unternehmen haben den einen oder anderen Service an externe Diensteanbieter ausgelagert. Dies reicht vom Webhosting über die Nutzung von *Software as a service* bis hin zu einem outgesourcten Service Desk.

In der Praxis führt dies häufig dazu, dass das Thema Dokumentation für diese Bereiche nicht mehr beachtet werden. Jedes Unternehmen muss sich aber bewusst machen, dass mit einer Auslagerung bzw. Outsourcing von Prozessen oder Verfahren kein Abwälzen der Risiken möglich ist. Die Risikoverantwortung obliegt auch bei Auslagerungen bei dem auslagernden Unternehmen. Dieses muss sicherstellen bzw. sich davon überzeugen, dass die Compliance-Vorgaben, wie beispielsweise Datenschutzregelungen durch den Auftragnehmer erfüllt werden.

1.2.10 Telemediengesetz (TMG)

Das Telemediengesetz (TMG) regelt die rechtlichen Rahmenbedingungen für alle elektronischen Informations- und Kommunikationsdienste und ist eine der zentralen Vorschriften des Internetrechts. Es fasst in einem Gesetz zusammen, was bis zum Inkrafttreten am 1. März 2007 in die folgenden drei Regelwerke aufgeteilt war:

- Teledienstgesetz (TDG),
- Teledienstschutzgesetz (TDDSG) und
- Mediendienste-Staatsvertrag (MdStV).

Das TMG kommt zur Anwendung, wenn ein Unternehmen seinen Mitarbeitern die Nutzung von Internet und E-Mail auch zu privaten Zwecken gestattet. Im Falle der privaten Nutzung besteht zwischen Dienstherrn und Beschäftigten ein Anbieter-Nutzer-Verhältnis, da es sich bei der Bereitstellung der Dienste um ein Angebot von Telekommunikation und Telemedien

im Sinne des Telemediengesetzes handelt. Als solcher hat er das Fernmeldegeheimnis nach § 88 TMG zu beachten. Damit ergeben sich vielfältige Fragen zur Wahrung der Privatsphäre der betroffenen Mitarbeiter und es müssen sowohl die Vorschriften des Telemediengesetzes sowie des Bundesdatenschutzgesetzes beachtet werden. Und für Provider ist der Erlaubnisrahmen für die Verarbeitung der Verkehrs-, Nutzungs- und Abrechnungsdaten damit sehr eng gesteckt.

Das TMG unterscheidet explizit zwischen Nutzungs- und Bestandsdaten. Als Nutzungsdaten werden die personenbezogenen Daten eines Nutzers bezeichnet, die erforderlich sind, »um die Inanspruchnahme von Telemedien zu ermöglichen und abzurechnen«, während die Bestandsdaten die personenbezogenen Daten sind, die »für die Begründung, inhaltliche Ausgestaltung oder Änderung eines Vertragsverhältnisses zwischen dem Diensteanbieter und Nutzer über die Nutzung von Telemedien erforderlich sind« (TMG). Diese Bestandsdaten können beispielsweise bei einer Rechtsverfolgung durch die zuständigen Behörden angefordert werden. Wichtig ist, dass das TMG in §15 festlegt, dass der Diensteanbieter personenbezogene Daten ausschließlich im Sinne der oben definierten Nutzungs- und Bestandsdaten erlaubt. Werden diese nicht rechtzeitig gelöscht oder zu einem anderen Zweck erhoben, führt dies zu ordnungswidrigem Verhalten und kann mit einer Geldbuße geahndet werden. Abrechnungsdaten, d. h. Daten, die erhoben werden, um die Abrechnung mit dem Nutzer durchführen zu können, dürfen höchstens bis zum Ablauf des sechsten Monats nach Versendung der Rechnung gespeichert werden.

Ableitbare Anforderungen an die IT-Dokumentation

Anforderungen an die IT-Dokumentation ergeben sich aus den Nachweis- und Überprüfungspflichten. So sind die getroffenen Regelungen und Verfahren zu dokumentieren. Hierzu gehören auch gegebenenfalls getroffene Dienstvereinbarungen. Außerdem besteht die Verpflichtung, diese regelmäßig zu kontrollieren und dies auch zu dokumentieren.

Bei zugelassener privater Nutzung sind zusätzlich die Anforderungen des TMG zu erfüllen. Eine besondere Anforderung, die durch das TMG gefordert wird, sind die maximalen Aufbewahrungsfristen. Somit sind innerhalb der Organisation des Diensteanbieters auch Prozesse zu dokumentieren, die eine regelmäßige Vernichtung von personenbezogenen Daten gewährleisten.

■ 1.3 Anforderungen aus branchenspezifischen Vorschriften

In vielen Branchen gelten zusätzliche Vorschriften, um deren erhöhten Anforderungen an die Sicherheit gerecht zu werden. Hierzu zählen beispielsweise Banken und Versicherungen, aber natürlich auch die Chemie-, Pharma-, Gesundheits- und Lebensmittelbranche. Während es bei den vier letztgenannten vorrangig darum geht, direkte oder indirekte Gefahren für Leib und Leben von Menschen zu verhindern, sind bei den Banken und Versicherungen vorrangig finanzielle Risiken von Interesse.

In Bezug auf die IT-Dokumentation ist es wichtig, mögliche zusätzliche Compliance-Anforderungen zu identifizieren und bei der Konzeption der Dokumentation zu berücksichtigen.

1.3.1 Compliance-Anforderungen der Chemie-, Pharma-, Gesundheits- und Lebensmittelbranche

Die pharmazeutische und chemische Industrie beispielsweise unterliegt einer ganzen Reihe zusätzlicher Vorschriften. Diese betreffen zwar überwiegend die Tests und Erprobung der Produkte, haben jedoch auch Auswirkungen auf andere Unternehmensbereiche wie die Informationstechnologie. Entsprechende Regelungen sind beispielsweise die *Good Laboratory Practice (GLP)* oder die *Chemikalienrichtlinie der EU - REACH (Registration, Evaluation and Authorization of Chemicals)*. GLP ist als ein formaler Rahmen für die Durchführung von Sicherheitsprüfungen an chemischen Produkten und in vielen Ländern gesetzlich vorgeschrieben. Die GLP legen den organisatorischen Ablauf und die Bedingungen fest, unter denen Laborprüfungen geplant, durchgeführt und überwacht werden. Daneben definieren sie auch die erforderlichen Prüfungsberichte.

Ebenso gibt es im Gesundheitswesen spezielle Compliance-Anforderungen an die IT. Stellvertretend soll der US-amerikanische *Health Insurance Portability and Accountability Act II (HIPAA)* genannt werden. HIPAA II soll für die Implementierung von elektronischen Transaktionsstandards sorgen, um die Transaktion von relevanten Patienteninformationen im Gesundheitswesen zu schützen, und stellt hinsichtlich der IT Anforderungen an Leistungserbringer im Gesundheitswesen, Anbieter von Krankenkassenleistungen und Abrechnungsstellen. So sind neben speziellen Regelungen zum Datenschutz auch spezifische Sicherheitsanforderungen an die Verarbeitung von Daten in den betroffenen Unternehmen zu beachten.

Nicht unerwähnt bleiben darf in dieser keineswegs vollständigen Liste der *Good Automated Manufacturing Practice Supplier Guide for Validation of Automated Systems in Pharmaceutical Manufacture (kurz: GAMP)*. Es handelt sich hierbei um ein Standardregelwerk für die Validierung computergestützter Systeme in der pharmazeutischen Industrie (Hersteller und Zulieferer). Die GAMP-Regelwerke haben jedoch keine gesetzliche Bindung.

1.3.2 Compliance-Anforderungen für Finanzdienstleister

Aber auch der Finanzdienstleistungssektor unterliegt einem stark regulierten Umfeld, das in den vergangenen Jahren eine starke Zunahme an Regulierungen erfahren hat. Hier lassen sich eine Reihe Branchenstandards anführen, welche nicht durch einen Gesetzgeber erlassen wurden, wie beispielsweise der *Payment Card Industry Data Security Standard (PCI-DSS)*. Bei diesem handelt es sich um ein Regelwerk im Zahlungsverkehr, das sich auf die Abwicklung von Kreditkartentransaktionen bezieht und von allen wichtigen Kreditkartenorganisationen unterstützt wird. Handelsunternehmen und Dienstleister, die Kreditkartentransaktionen speichern, übermitteln oder abwickeln, müssen diese Regelungen erfüllen. Dieser Standard betrifft aber nicht nur Kreditkartenunternehmen, sondern tangiert auch

Unternehmen und Geschäfte, welche entsprechende bargeldlose Transaktionen ermöglichen. Die Einhaltung der Regeln wird üblicherweise in Abhängigkeit vom Umsatzvolumen des Unternehmens überprüft. Halten sie sich nicht daran, können Strafgebühren verhängt, Einschränkungen ausgesprochen oder ihnen letztlich die Akzeptanz von Kreditkarten untersagt werden.

Letztlich nicht unerwähnt bleiben soll der Standard *SAS 70*. Dieser ermöglicht IT-Dienstleistern, die dem Sarbanes-Oxley Act entsprechen müssen, sich auditieren zu lassen.

Die Entwicklungen im Finanzsektor in den vergangenen Jahren haben aber auch dazu geführt, dass der Gesetzgeber zusätzliche Gesetze erlassen bzw. bestehende verschärft hat. Hierzu zählen u. a. die MaRisk sowie BASEL II und III, die wegen ihrer praktischen Bedeutung im Folgenden ausführlicher vorgestellt werden.

Mindestanforderungen an das Risikomanagementsystem (MaRisk)

Während im KonTraG allgemeine Regelungen zur risikoorientierten Unternehmensführung und Überwachung enthalten sind, enthalten die MaRisk konkrete Anforderungen an die betreffenden Unternehmen (MaRisk). Ziel der MaRisk ist, Missständen entgegenzuwirken, welche die Sicherheit der den Instituten anvertrauten Vermögenswerte gefährden, die ordnungsgemäße Durchführung der Bankgeschäfte oder Finanzdienstleistungen beeinträchtigen oder erhebliche Nachteile für die Gesamtwirtschaft herbeiführen können.

MaRisk sind eine Verwaltungsvorschrift der Bundesanstalt für Finanzdienstleistungsaufsicht (BaFin). Sie wurden in der ursprünglichen Fassung für die Ausgestaltung des Risikomanagements in deutschen Kreditinstituten 2005 veröffentlicht.

2009 veröffentlichte die BaFin neben einer Neufassung der MaRisk zusätzlich die an das Versicherungswesen gerichteten Mindestanforderungen an das Risikomanagement. Diese erhielten den Zusatz (VA), was den Klammerzusatz (BA) bei den Vorgaben für das Bankwesen nötig machte. Bis dahin war MaRisk ohne Klammerzusatz auf das Bankwesen bezogen. Weiterhin hat die BaFin mit dem Rundschreiben vom 30.06.2010 eine weitere MaRisk-Verordnung *InvMaRisk* für Kapitalanlagegesellschaften und sich selbst verwaltende Investmentaktiengesellschaften veröffentlicht (BaFin). Bis zum Dezember 2007 hatten für Kapitalanlagegesellschaften die Mindestanforderungen an das Risikomanagement aus der Bankenaufsicht – die MaRisk (BA) – gegolten. Aufbau und Inhalt der *InvMaRisk* sind jedoch, wie auch bei der MaRisk (VA), eng an die MaRisk (BA) angelehnt.

Damit gibt es die MaRisk für die folgenden Bereiche:

- **MaRisk (BA):** Mindestanforderungen an das Risikomanagement, die sich an Kreditinstitute richten
- **MaRisk (VA):** Mindestanforderungen an das Risikomanagement, die sich an die Versicherungswirtschaft richten
- **MaRisk (Inv):** Mindestanforderungen an das Risikomanagement, die sich an die Investmentgesellschaften richten

Wichtig für die IT-Dokumentation sind die Anforderungen hinsichtlich der Aufbau- und Ablauforganisation und deren Dokumentation sowie die Anforderungen an die Prüfkativitäten der internen Revision, die im Kreditwesen ohnehin obligatorisch sind.

Grundsätzlich sind gemäß Kapitel 4.3.1 des Allgemeinen Teils (AT) »die Prozesse sowie die damit verbundenen Aufgaben, Kompetenzen, Verantwortlichkeiten, Kontrollen sowie Kommunikationswege klar zu definieren und aufeinander abzustimmen. Das gilt auch bezüglich der Schnittstellen zu wesentlichen Auslagerungen.« Weiter wird in AT 5 festgelegt, »dass die Geschäftsaktivitäten auf der Grundlage von Organisationsrichtlinien betrieben werden (zum Beispiel Handbücher, Arbeitsanweisungen oder Arbeitsablaufbeschreibungen). Die Organisationsrichtlinien müssen schriftlich fixiert und den betroffenen Mitarbeitern in geeigneter Weise bekannt gemacht werden. Es ist sicherzustellen, dass sie den Mitarbeitern in der jeweils aktuellen Fassung zur Verfügung stehen. Die Richtlinien sind außerdem bei Änderungen der Aktivitäten und Prozesse zeitnah anzupassen.« (MaRisk)

Die Organisationsrichtlinien müssen gemäß AT 5 folgende Regelungen enthalten:

- »Regelungen für die Aufbau- und Ablauforganisation sowie zur Aufgabenzuweisung, Kompetenzordnung und zu den Verantwortlichkeiten
- Regelungen hinsichtlich der Ausgestaltung der Risikosteuerungs- und Risikocontrollingprozesse
- Regelungen zur internen Revision
- Regelungen, die die Einhaltung gesetzlicher Bestimmungen sowie sonstiger Vorgaben (z. B. Datenschutz oder Compliance) gewährleisten
- Regelungen zu Verfahrensweisen bei wesentlichen Auslagerungen« (MaRisk)

Zudem muss die Ausgestaltung der Organisationsrichtlinien eine Sachprüfung der internen Revision ermöglichen. Die Pflicht zur Dokumentation ergibt sich aus AT 6, wonach Geschäfts-, Kontroll- und Überwachungsunterlagen systematisch und für sachkundige Dritte nachvollziehbar abzufassen sind.

In Bezug auf die IT-Organisation und IT-Dokumentation wird in AT 7.2 ausdrücklich ein Notfallhandbuch gefordert, das Geschäftsfortführungs- sowie Wiederanlaufpläne umfasst. Die Geschäftsfortführungspläne müssen gewährleisten, dass im Notfall zeitnah Ersatzlösungen zur Verfügung stehen. Die Wiederanlaufpläne müssen außerdem innerhalb eines angemessenen Zeitraums die Rückkehr zum Normalbetrieb ermöglichen. Die im Notfall zu verwendenden Kommunikationswege sind festzulegen. Das Notfallhandbuch muss den beteiligten Mitarbeitern zur Verfügung stehen.

Auch hinsichtlich der Prüfungsaktivitäten der internen Revision werden in der MaRisk klare Vorgaben gemacht. So wird im Besonderen Teil (BT) 2.1 ausgeführt, dass sich die Prüfungstätigkeit der internen Revision auf der Grundlage eines risikoorientierten Prüfungsansatzes grundsätzlich auf alle Aktivitäten und Prozesse des Instituts erstreckt. Damit werden die IT-Prozesse ebenfalls zum Prüfungsgegenstand.

Weiter sind gemäß BT 2.3 die Aktivitäten und Prozesse des Instituts, auch wenn diese ausgelagert sind, in angemessenen Abständen, grundsätzlich innerhalb von drei Jahren, zu prüfen. Wenn besondere Risiken bestehen, ist jährlich zu prüfen. Da die Kernprozesse der IT gerade im Kreditgeschäft ein hohes Risiko darstellen, sind diese und ihre zugrunde liegende Dokumentation jährlich zu prüfen.

Der IT-Bereich hat also nicht nur umfangreiche Dokumentationspflichten bezüglich der eingesetzten Technik sowie der Aufbau- und Ablauforganisation. Er hat ebenfalls auch die Umsetzung der Empfehlungen der internen Revision zu dokumentieren.

Basel II und III

Basel II und III steht für die »Eigenkapitalvorschriften vom Basler Ausschuss« und umfasst Regelung des Bankaufsichtsrechts mit dem Ziel, Insolvenzen durch Kreditausfälle zu verhindern, um das internationale Finanzsystem zu sichern. Nach einer »im Jahr 2006 durchgeführten Studie wurde festgestellt, dass für über 45 % der deutschen Unternehmen die Regelungen von Basel II relevant sind« (Klaus Schmidt, 2011).

Die seit 1988 geltende und seither mehrfach ergänzte Eigenkapitalvereinbarung (Basel I) wurde zum 1.1.2007 durch die neue Eigenkapitalvereinbarung (Basel II) ersetzt. Erweiterungen hat die Vereinbarung ab 2013 durch Basel III erfahren. Für die IT ist von Bedeutung, dass Basel II und III auch operationelle Risiken betrachtet und Schwachstellen der IT zu den operationellen Risiken zählen, denen mit geeigneten Maßnahmen zu begegnen ist. Hieraus lässt sich unmittelbar die Verpflichtung zur Einführung eines IT-Risikomanagements sowie eines Sicherheitsmanagements (und damit auch dessen Dokumentation) ableiten.

■ 1.4 Was prüfen Wirtschaftsprüfer und Revisoren?

Unternehmen müssen nicht nur sicherstellen, dass Compliance-Anforderungen eingehalten werden, sondern dies auch regelmäßig kontrollieren und im Rahmen der Jahresabschlussprüfung gegebenenfalls nachweisen.

Das Erfordernis zur Prüfung der Geschäfte eines Unternehmens ergibt sich aus der nationalen und internationalen Rechtslage. Die Prüfung des Jahresabschlusses durch eine Wirtschaftsprüfungsgesellschaft hat dabei die breiteste Gesetzesbasis, nämlich das Aktiengesetz, die 8. EU-Richtlinie bzw. BilMoG und eventuell SOX. Die Prüfung durch die interne Revision ergibt sich aus dem KonTraG sowie gegebenenfalls durch die MaRisk. Die Prüfungspflichten des ab 2009 zu bildenden Prüfungsausschusses wiederum basieren auf entsprechenden Festlegungen der 8. EU-Richtlinie und gegebenenfalls SOX.

Bei vielen Mitarbeitern aber herrscht Unsicherheit darüber, welche Unterlagen und mit welchem Detaillierungsgrad Prüfer und Revisoren im Rahmen derartiger Prüfungen erwarten bzw. fordern. Dieser Abschnitt befasst sich daher mit den folgenden Fragen:

- Auf welcher Grundlage erfolgen Prüfungen?
- Wie prüfen Prüfer die IT?
- Welche Dokumente fordern Prüfer?

Konkret betrachtet werden die Anforderungen der Prüfer im Rahmen der Jahresabschlussprüfung sowie Anforderungen an die Verfahrensdokumentation, wie sie von Seiten der Revision definiert werden.

1.4.1 Jahresabschlussprüfung

Die gesetzlichen Grundlagen, nach denen ein Wirtschaftsprüfer einen Jahresabschluss zu prüfen hat, sind in den Paragraphen §§ 316 ff HGB definiert. Im Fokus der Prüfung stehen dabei die Buchführung und deren Ergebnisse. In der Vergangenheit wurde die IT daher im Rahmen der Jahresabschlussprüfungen nur selten mitbetrachtet. Seit einigen Jahren ist hier jedoch ein Trendwechsel zu erkennen, wonach IT-Prüfungen zunehmend eine Rolle spielen.

Standards des Instituts der Wirtschaftsprüfer in Deutschland (IDW)

Die Durchführung der IT-Prüfungen erfolgt auf Basis von Prüfungsstandards des *Instituts der Wirtschaftsprüfer in Deutschland (IDW)*. IDW ist ein eingetragener Verein mit Sitz in Düsseldorf, der die Arbeit der Wirtschaftsprüfer und Wirtschaftsprüfungsgesellschaften unterstützt. Die Standards sind für die Mitgliedsunternehmen verbindlich und haben insofern Normencharakter. (PS 330)

Die Prüfungsstandards des IDW stellen die Berufsauffassung der Wirtschaftsprüfer zu bestimmten prüferischen Fragestellungen und Themen dar und gelten als Grundsätze ordnungsmäßiger Abschlussprüfung. Sie sind daher von Wirtschaftsprüfern bei der Durchführung von Abschlussprüfungen grundsätzlich zu beachten.

Bei den Prüfungsstandards (PS) des Instituts der Wirtschaftsprüfer in Deutschland e.V. (IDW) ist für die IT im Wesentlichen der *PS 330 – Abschlussprüfung bei Einsatz von IT* von Bedeutung. Dieser stellt eine Umsetzung des internationalen Prüfungsstandards *International Standards on Auditing (ISA) 401* dar.

Bei der Durchführung von IT-Prüfungen finden vor allem die GoBS sowie die GDPdU Anwendung. Danach hat der Abschlussprüfer das IT-gestützte Rechnungslegungssystem dahingehend zu beurteilen, ob die gesetzlichen und im Fachausschuss Informationstechnologie des IDW formulierten Anforderungen an die Ordnungsmäßigkeit und die Sicherheit erfüllt werden.

Der *Fachausschuss für Informationstechnologie (FAIT)* beim Institut der Wirtschaftsprüfer in Deutschland e.V. hat die für die Buchführung geltenden Regelungen in der GoBS in verschiedenen Rechnungslegungsstandards konkretisiert:

- IDW RS1 FAIT 1 – GoB bei Einsatz von Informationstechnologie
- IDW RS FAIT 2 – GoB bei Einsatz von Electronic Commerce
- IDW RS FAIT 3 – GoB beim Einsatz elektronischer Archivierungsverfahren

Damit werden die GoBS als rechtliche Basis für den Prüfungsstandard herangezogen und entsprechend bei der Abschlussprüfung berücksichtigt. Das Vorgehen dabei resultiert aus dem IDW PS 330 und wird dort genau beschrieben. Auch wenn gemäß den gesetzlichen Anforderungen nur die rechnungslegungsrelevanten Prozesse und Systeme geprüft werden, ist doch ein großer Teil der IT davon betroffen. So werden zum Beispiel die Sicherheits- und Kontrollstrukturen nicht nur im Hinblick auf die Anwendungssysteme, sondern auch im Hinblick auf die Datenbank- und Systembasis geprüft. Für die konkrete Prüfung ist im Einzelfall demnach festzulegen, welcher Teil der IT geprüft werden soll (Prüfungsgegenstand und Prüfungsziel) und welche Anforderungen an die IT dazu geprüft werden sollen (Prüfungskriterien).

Daneben sind – wenn auch nicht für Jahresabschlussprüfungen – die Prüfungsstandards 850 und 880 relevant. Während die Prüfungen nach dem PS 330 auf implementierte Anwendungen und Systeme ausgerichtet sind, stellt der *PS 880 – Erteilung und Verwendung von Softwarebescheinigungen* einen Prüfungsstandard dar, der die Anwendungen (Softwareprodukte) vor der Implementierung prüft. Ein derartiges Prüftestat bescheinigt dem Unternehmen, dass seine entwickelte Software den Grundsätzen ordnungsgemäßer DV-gestützter Buchführungssysteme entspricht.

Relevanz hat auch der 2008 veröffentlichte Standard *PS 850 – Projektbegleitende Prüfung bei Einsatz von Informationstechnologie*. Dieser beschreibt auf Basis der Ordnungsmäßigkeitsanforderungen des PS 330 die Prüfungsanforderungen zu den Projektphasen:

- »Planung
- Entwicklung bei Individualsoftware
- Test
- Datenmigration
- Produktivsetzung« (PS 850)

Entsprechend der umfassenden Bedeutung des Projektbegriffs werden durch den Prüfungsstandard die Planung, Einführung sowie die Änderung von IT-Systemen im Rahmen eines Projekts erfasst.

Zunehmend an Bedeutung gewinnt außerdem der Standard *PS 951 – Die Prüfung des internen Kontrollsystems beim Dienstleistungsunternehmen für auf das Dienstleistungsunternehmen ausgelagerte Funktionen*. Häufige Anwendungsfälle für Prüfungen nach diesen Standards sind ausgelagerte Buchhaltungen und Lohn- und Gehaltsabrechnungen sowie ausgelagerte IT-Dienstleistungen in unterschiedlicher Ausprägung. Die Prüfung bezieht sich auf die ausgelagerten Prozesse und Dienste.

Mit der Auslagerung der Prozesse werden auch die damit verbundenen Risiken an den externen Dienstleister transferiert. Geprüft werden die Existenz und Wirksamkeit des internen Kontrollsystems sowie die IT-Organisation mit der IT-Sicherheit und dem Notfallmanagement bei Dienstleistungsunternehmen (Outsourcing-Unternehmen). Eine Grundvoraussetzung für eine erfolgreiche Prüfung ist eine vollständige und aktuelle Dokumentation der Unternehmensorganisation, der IT-Organisation und der IKS-bezogenen Sachverhalte.

Dokumentationsanforderungen

Im Mittelpunkt einer jeden Prüfung steht die Prüfung der Dokumente, die dann gegebenenfalls stichprobenartig überprüft werden. Die wichtigste Frage für IT-Verantwortliche ist deshalb, welche Unterlagen zu erstellen sind. Hilfreich bei der Beantwortung dieser Frage ist ein Blick in den Prüfungsstandard 330. Demnach sind im Rahmen der IT-Systemprüfungen die folgenden Inhalte zu prüfen, d. h. diese Bereiche müssen dokumentiert sein:

- »IT-Umfeld und IT-Organisation
- IT-Infrastruktur
- IT-Anwendungen
- IT-Geschäftsprozesse
- Aufbauprüfung (Beurteilung der Angemessenheit)
- Funktionsprüfung (Prüfung und Beurteilung der Wirksamkeit« (PS 330)

Zur Dokumentation der genannten Bereiche finden sich im PS 330 einige Anhaltspunkte:

»Die Aufbauprüfung des IT-Umfelds und der IT-Organisation erfolgt auf Basis des vorgelegten Sicherheitskonzeptes, der IT-Strategie, der Regelungen zur Aufbau- und Ablauforganisation (Organisationsplan, Richtlinien und Arbeitsanweisungen) sowie auf Grundlage von Prozess- und Funktionsbeschreibungen.« (PS 330)

Welche Informationen Prüfer konkret für eine Bewertung der einzelnen Teilbereiche benötigen führen Klaus Schmidt und Dirk Brand in ihrem Buch IT-Revision in der Praxis (Klaus Schmidt, 2011) wie folgt aus:

Tabelle 1.1 Von Abschlussprüfern benötigte Informationen

Bereich	Erforderliche Informationen
IT-Umfeld und Organisation	▪ Grundeinstellung zum Einsatz von IT-Systemen, beispielsweise dokumentiert im IT-Sicherheitskonzept (Unternehmensleitlinien, IT-Sicherheitshandbücher u. a.) ▪ IT-Strategie, abgeleitet aus der Unternehmensstrategie ▪ High Level Controls ▪ Organigramme und Ablaufpläne ▪ Verantwortlichkeiten und Kompetenzen ▪ Regelungen und Verfahren zur Steuerung des IT-Betriebs ▪ Maßnahmen und Regelungen für die Entwicklung, Einführung und Änderung von IT-Anwendungen
IT-Infrastruktur	▪ Hardware (Großrechner, Client-Server-Systeme, PC und PC-Netzwerke) ▪ Betriebssysteme (z. B. UNIX-Derivate, Netzwerkbetriebssysteme, PC-Systeme) sowie Middleware (z. B. Archivierungs- oder Bibliothekssysteme) ▪ Netzwerke (Local Area Network (LAN), Wide Area Network (WAN), Internet/Intranet/Extranet) ▪ IT-Betrieb (Organisation, Systemverwaltung, Produktionsabwicklung, Ressourcen-, Change- und Problemmanagement) ▪ Sicherheitskonzept (Zugriffskontrollsysteme, Firewalls, Datensicherung)
IT-Anwendungen	▪ Bezeichnung der Software, Kurzbeschreibung des Aufgabengebiets und zugrunde liegende Hardware-Plattform ▪ Klassifizierung der Software nach Dialog- und/oder Batch-Anwendung ▪ Software-Typ (Individual-Software, Standard-Software, modifizierte Standard-Software, Hersteller und eingesetzte Version) ▪ Angaben zu den verwendeten Programmiersprachen und zur Datenhaltung (Datenbank- bzw. Dateiorganisation)
IT-Geschäftsprozesse	▪ Rechnungslegungsrelevante Unternehmensabläufe anhand der funktions- oder prozessorientierten Beschreibung der Ablauforganisation ▪ Hierfür eingesetzte IT-Infrastruktur und IT-Anwendungen sowie relevante Schnittstellen ▪ Datenfluss (Datenherkunft, Verarbeitung, Datenübergabe) ▪ Verbindung zur Buchführung

Ein eventueller Dokumentationsmangel, sei es wegen fehlender oder unvollständiger Unterlagen, führt gegebenenfalls zu einer entsprechenden Feststellung im Abschlussbericht.

1.4.2 Prüfungen durch die Revision

Im Gegensatz zu den auf den Jahresabschluss ausgerichteten Prüfungshandlungen der Abschlussprüfer sind die Prüfungsaktivitäten der Revision in erster Linie nicht anlassbezogen, sondern sie stellen eine permanente Überwachung der Aufbau- und Ablauforganisation des Unternehmens dar. Die interne Revision ist Teil des internen Überwachungssystems, das die Geschäftsleitung gemäß § 91 AktG (und damit gemäß KonTraG) einzurichten hat.

Standards des Deutschen Instituts für Interne Revision e. V. (DIIR)

Während die Prüfungsstandards des IDW konkrete Prüfungsfelder und -themen zum Gegenstand haben, beschreiben die Revisionsstandards die grundsätzliche Arbeitsweise und die qualitativen Anforderungen an die Revisionsausübung. Dabei decken sie die gesamte Breite der Unternehmensprozesse als Prüfungsgegenstand ab. Sie formulieren jedoch keine Anforderungen an den zu überprüfenden Bereich. Es ist Aufgabe der IT-Revision, aus geltenden Vorschriften und Gesetzen auf Basis der Prüfungsstandards Sollvorgaben für die einzelnen Prüfungsbereiche abzuleiten.

Für Prüfungen in der IT ist insbesondere der Revisionsstandard Nr. 2 relevant, da dort die Anforderungen der Prüfung des Risikomanagements beschrieben werden. Dieser eher allgemein gehaltene Ansatz ergibt sich direkt aus dem KonTraG und hat für die IT im Hinblick auf die Organisation und Dokumentation des internen Kontrollsystems entsprechende Bedeutung.

Das DIIR hat bislang fünf Standards herausgegeben, die sich inhaltlich an die Standards des amerikanischen *The Institute of Internal Auditors (IIA)* anlehnen.

Revisionsstandard Nr. 1 – Zusammenarbeit von interner Revision und Abschlussprüfer

Gemäß dem Revisionsstandard Nr. 1 werden die Prüfungen der internen Revision nach folgenden Kriterien durchgeführt:

- »Risiken
- Ordnungsmäßigkeit
- Sicherheit
- Wirtschaftlichkeit
- Zukunftssicherung
- Zweckmäßigkeit« (DIIR)

Zusätzlich zu den Revisionsstandards hat das DIIR eine Sammlung von »Praktischen Ratschlägen« veröffentlicht, die eine Übernahme der Practice Advisory des IIA darstellen.

Mit den Standards deckt die interne Revision nicht nur inhaltlich ein breiteres Prüfungsfeld ab als der Abschlussprüfer, der sich bei seiner Prüfung auf rechnungslegungsrelevante Daten und Verfahren konzentriert. Auch die Kriterien, nach denen geprüft wird, sind bei der internen Revision breiter als bei einem Abschlussprüfer, der im Wesentlichen die Ordnungsmäßigkeit sowie die Übereinstimmung mit Gesetzen und unternehmensbezogenen Regelungen wie dem Gesellschaftsvertrag überprüft.

Revisionsstandard Nr. 2 – Prüfung des Risikomanagements durch die interne Revision

Der Prüfung des Risikomanagements wird eine besondere Bedeutung im Rahmen der Revisionsaufgaben eingeräumt, was in dem Revisionsstandard Nr. 2 zum Ausdruck kommt. Hier werden wesentliche Prüfungsansätze beschrieben, die auch bei der Prüfung von IT-Verfahren angewandt werden.

Ein zentraler Prüfungsgegenstand dabei sind die Organisationsgrundlagen wie Richtlinien, Handbücher und Arbeitsanweisungen, in denen die organisatorischen Regelungen zur Planung, Steuerung und Kontrolle der Prozesse als Sollvorgaben beschrieben sind. Zu prüfen sind aber nicht nur die Sollvorgaben selbst, sondern insbesondere auch, ob die tatsächlichen Abläufe, also die Ist-Abläufe, den Sollvorgaben entsprechen. Insgesamt hat die interne Revision zu bewerten, ob die geprüften Organisationseinheiten oder Prozesse die genannten Prüfungskriterien erfüllen. Sie hat gegebenenfalls Empfehlungen zur Zielerreichung zu unterbreiten. In den »Praktischen Ratschlägen« sind die Anforderungen an die Prüfungstätigkeiten konkretisiert.

Revisionsstandard Nr. 3 – Qualitätsmanagement in der internen Revision

Das Ziel des Qualitätsmanagements in der internen Revision besteht insgesamt darin, die Revisionsarbeit im Sinne eines kontinuierlichen Verbesserungsprozesses zu optimieren. Der Standard bietet eine Hilfestellung für den Aufbau und das Betreiben des Qualitätsmanagements einer internen Revision.

Revisionsstandard Nr. 4 – Standard zur Prüfung von Projekten

Der 2009 veröffentlichte Revisionsstandard Nr. 4 beschreibt Art, Inhalt und Umfang der Projektrevision mit dem Schwerpunkt *Projekt Management Revision*. Kern des Standards ist die Project-Audit-Universe-Matrix, die die Prüfgebiete, Projektphasen und Prüfgegenstände darstellt. Die Struktur des Project Audit Universe ist an die Projektmanagementprozesse des PMBoK (Project Management Body of Knowledge) (PMI, 2013) angelehnt. Aus den enthaltenen Prüfgegenständen ergibt sich unmittelbar die Verpflichtung zur Erstellung der benannten Projektmanagementdokumente.

Revisionsstandard Nr. 5 – Standard zur Prüfung des Anti-Fraud-Management Systems durch die Interne Revision

Ziel des Revisionsstandards Nr. 5 ist es, ein Rahmenwerk für die risikoorientierte Prüfung des Anti-Fraud-Management-Systems (AFM) in Organisationen zu schaffen. Als »Fraud« definiert der Standard *»bewusst begangene unerlaubte Handlungen, die direkt oder indirekt zur Schädigung oder Gefährdung des Vermögens einer Organisation und/oder zu operationellen Risiken in den Geschäftsprozessen der Organisation führen können«*. (DIIR) Alle Maßnahmen zur Vorbeugung (Prevention), Aufdeckung (Detection) sowie Untersuchung und Reaktion (Investigation) von Fraud werden als AFM verstanden und als integraler Bestandteil eines organisationsweiten Compliance-Management-System und Internen Kontrollsystems (IKS) gesehen. Ziel ist es, Haftungsrisiken und Reputationsschäden zu vermeiden. Die Anforderungen an ein AFM als wesentlicher Bestandteil des Risikomanagementsystems ergeben sich aus allgemeinen gesetzlichen Anforderungen.

**DIIR-Standards kostenlos verfügbar**

Während Sie die IDW-Standards nur kostenpflichtig beziehen können, stellt das DIIR die vier Revisionsstandards auf seiner Website [<http://www.diir.de>] zum kostenlosen Download zur Verfügung (DIIR).

Dokumentationsanforderungen

Einen großen Raum der IT-Revision nimmt die Prüfung von IT-Prozessen bzw. IT-Verfahren ein, weshalb im Folgenden die Anforderungen an eine solche Dokumentation erläutert werden sollen. Zu den wichtigsten Sollvorgaben gehören die Verfahrensbeschreibungen für alle Systeme, wobei die Verfahrensdokumentation nach GoBS als Blaupause dient.

Die Verfahrensdokumentation nach GoBS dient zum Nachweis, dass für Systeme, die handels- und steuerrechtliche Daten und Dokumente verarbeiten und speichern, die Anforderungen des Handelsgesetzbuchs (HGB), der Abgabenordnung und der GoBS für die Verwaltung und Aufbewahrung von Daten und Belegen erfüllt sind. Umfang und Aufbau einer Verfahrensdokumentation sind in der GoBS nicht vorgeschrieben, grundsätzlich sollte eine Verfahrensdokumentation sich aber an den im Folgenden benannten Bereichen orientieren und die in der Tabelle vorgestellten Inhalte enthalten:

- eine Beschreibung der sachlogischen Lösung,
- die Beschreibung der technischen Lösung,
- eine Beschreibung, wie die Programmidentität gewahrt wird,
- eine Beschreibung, wie die Integrität von Daten gewahrt wird,
- Arbeitsanweisungen für den Anwender.

Tabelle 1.2 erläutert die Dokumentationsanforderungen der einzelnen Abschnitte.

Tabelle 1.2 Erforderliche Bestandteile einer Verfahrensbeschreibung

Abschnitt	Inhalt
Allgemeine Beschreibung des Einsatzgebiets (sachlogische Lösung)	Dieser Abschnitt muss vorrangig die drei folgenden Fragen beantworten: ▪ Für welchen Zweck wird das Verfahren im Unternehmen verwendet? ▪ In welchem (fachlichen) Gebiet wird es eingesetzt? ▪ Für was und wie wird es genutzt?
Beschreibung der technischen Lösung	In diesem Abschnitt ist zu beschreiben, wie die Lösung technisch aufgebaut ist, aus welchen Komponenten sie besteht und wie diese Komponenten zusammenwirken.
IT-Sicherheit und Datenschutz	Die IT-Sicherheit ist ein wichtiger Prüfungsaspekt. Im Abschnitt IT-Sicherheit ist das Sicherheitskonzept für die technische Lösung zu beschreiben. Hierbei sollte dargestellt werden, auf welche Weise und mit welchen Sicherheitsmechanismen die erforderliche Sicherheit (einschließlich Datensicherheit und -integrität sowie Datenschutz) im Regelbetrieb technisch und organisatorisch gewährleistet wird.
Technischer Betrieb und Wartung	Wichtig sind eine Beschreibung aller notwendigen Maßnahmen und deren Einhaltung zur Gewährleistung des ordnungsgemäßen Betriebs sowie der Betriebsbedingungen und Voraussetzungen. Weiterhin sind Beschreibungen erforderlich zu den durchzuführenden Prüfungs- und den präventiven Wartungsmaßnahmen.
Arbeitsanweisungen für Anwender	Aus den Arbeitsanweisungen muss hervorgehen, was die Anwender des Verfahrens zu tun haben. Die Anweisungen müssen so gestaltet sein, dass sie für den Anwender verständlich sind und alles enthalten, was zur sachgerechten Erledigung der Aufgaben notwendig ist.

■ 1.5 Dokumentationsanforderungen in Österreich und in der Schweiz

Viele Dokumentationsanforderungen, die aus den in den vorstehenden Kapiteln vorgestellten Regularien resultieren, gelten in gleicher oder ähnlicher Form auch für andere europäische Länder. Dies trifft naturgemäß auf die beschriebenen ISO-Normen und die vorgestellten Frameworks zu. Und auch die Anforderungen der beschriebenen Prüfungsstandards des IDW finden mit den entsprechenden nationalen Anpassungen in allen Ländern Anwendung, deren Berufsorganisationen der Wirtschaftsprüfung den Vorgaben der *International Federation of Accountants (IFAC)* verpflichtet sind.

Zusätzlich gibt es aber auch nationale Ausprägungen vor allem in Form gesetzlicher Regelungen. Für die beiden deutschsprachigen Länder Österreich und Schweiz werden daher in diesem Kapitel die wichtigsten länderspezifischen Gesetze, die mittelbar oder unmittelbar Dokumentationsanforderungen formulieren, vorgestellt.

1.5.1 Dokumentationsrelevante Regularien – Schweiz

Die Schweiz hat, obgleich sie kein Mitglied der EU ist, einen mit Deutschland vergleichbaren Rechtsrahmen im Unternehmens- und im Wirtschaftsrecht, so dass viele der für Deutschland beschriebenen gesetzlichen Anforderungen an die IT-Dokumentation auch für die Schweiz gelten. Zusätzlich gibt es einige für die Schweiz spezifische Regularien, die auch Dokumentationsanforderungen definieren.

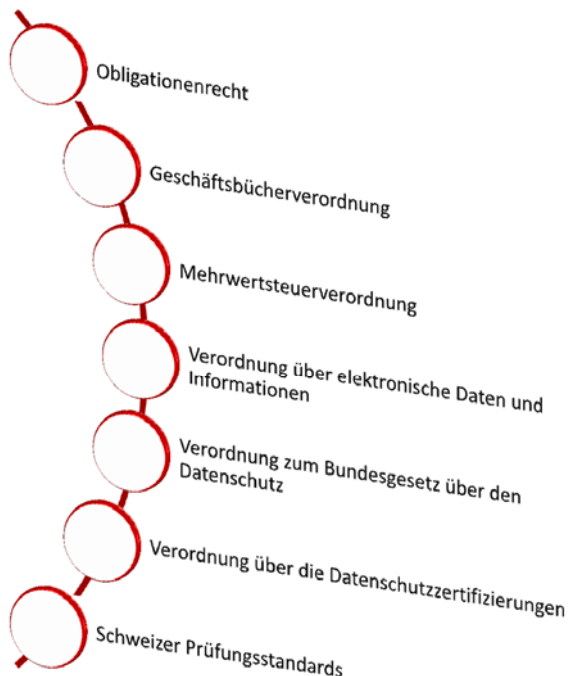


Bild 1.3

Für die Dokumentation relevante gesetzliche Regelungen und Standards in der Schweiz

Obligationenrecht

Eine wesentliche Grundlage für das unternehmerische Handeln bildet das Obligationenrecht (Schuldrecht). Das *Schweizerische Obligationenrecht (OR)* ist der fünfte Teil des Schweizerischen Zivilgesetzbuchs (ZGB) und wurde 2011 in einer Neufassung verabschiedet. In der dritten Abteilung des Obligationenrechts sind die Handelsgesellschaften und deren grundsätzliche Anforderungen beschrieben. In der vierten Abteilung sind ab Artikel 958 die wesentlichen Aufgaben der kaufmännischen Buchführung formuliert.

Die Erfüllung der allgemeinen Sorgfaltspflicht ist in Artikel 717 verankert. Danach müssen die Mitglieder des Verwaltungsrats sowie Dritte, die mit der Geschäftsführung befasst sind, *»ihre Aufgaben mit aller Sorgfalt erfüllen und die Interessen der Gesellschaft in guten Treuen wahren«*. (OR) Es ist naheliegend, dass der Nachweis dieser Sorgfalt nur mit entsprechender Dokumentation erbracht werden kann.

Auf die Nachweisbarkeit geht auch Artikel 728a ein, wo die Aufgaben der Revisionsstelle festgelegt werden. Danach hat sie u. a. zu prüfen, *»ob ein internes Kontrollsystem existiert«*. Gemäß Art 728b hat die Revisionsstelle hierüber *»umfassend«* (OR) zu berichten.

Artikel 958 regelt die Pflicht zur Führung und Aufbewahrung der Geschäftsbücher. Wesentlich hier ist die Einräumung der Möglichkeit, die Bücher, die Buchungsbelege und die Geschäftskorrespondenz auch elektronisch oder in vergleichbarer Weise führen zu können. Als Voraussetzung wird bereits in diesem Artikel festgeschrieben, dass die elektronisch geführten Dokumente *»jederzeit«* lesbar gemacht werden müssen. Diese Forderung hat weitreichende Konsequenzen für die IT. So ist es leicht nachvollziehbar, dass die Verfahren zur Sicherstellung der jederzeitigen Lesbarkeit eine Schlüsselfunktion haben und damit entsprechend gut dokumentiert werden müssen. Konkretisiert werden die Anforderungen in der Geschäftsbücherverordnung, auf die nachfolgend näher eingegangen wird.

Geschäftsbücherverordnung

Die in Artikel 958 des Obligationenrechts angekündigte nähere Umschreibung wird mittels der Verordnung über die Führung und Aufbewahrung der Geschäftsbücher (Geschäftsbücherverordnung, GeBüV) in der Fassung von 2013 vorgenommen. Hier sind auch die Dokumentationsanforderungen in Artikel 4 genau beschrieben.

»Je nach Art und Umfang des Geschäfts sind die Organisation, die Zuständigkeiten, die Abläufe und Verfahren und die Infrastruktur (Maschinen und Programme), die bei der Führung und Aufbewahrung der Geschäftsbücher zur Anwendung gekommen sind, in Arbeitsanweisungen so zu dokumentieren, dass die Geschäftsbücher, die Buchungsbelege und die Geschäftskorrespondenz verstanden werden können. Arbeitsanweisungen sind zu aktualisieren und nach den gleichen Grundsätzen und gleich lang aufzubewahren wie die Geschäftsbücher, die danach geführt wurden.« (GeBüV)

Während die Aufbau- und Ablauforganisation in der Zuständigkeit der Finanzabteilung liegt, ist die IT direkt von der Forderung nach einer Dokumentation der Infrastruktur (Maschinen und Programme) betroffen.

Die Pflicht zur Dokumentation wird nicht nur auf die aktuelle Führung der Bücher bezogen, sondern auch auf archivierte bzw. anderweitig aufbewahrte Unterlagen ausgedehnt (Artikel 9). Danach ist die Verwendung von veränderbaren Informationsträgern u. a. nur dann zulässig, wenn technische Verfahren zur Anwendung kommen, welche die Integrität der

gespeicherten Informationen gewährleisten. Die Abläufe und Verfahren zu deren Einsatz müssen dokumentiert sowie die entsprechenden Hilfsinformationen (wie Protokolle und Log-Dateien) ebenfalls aufbewahrt werden.

In Artikel 10 ist die Datenmigration, also das Übertragen von Daten in andere Formate oder Informationsträger, beschrieben. Es besteht eine Protokoll- und damit eine Dokumentationspflicht bei Datenmigrationen.

Mehrwertsteuerverordnung

In der Mehrwertsteuerverordnung in der Fassung von 2012 wird in Artikel 122 die Übermittlung von Steuerdaten auf elektronischem Wege geregelt und verschiedene Nachweispflichten werden festgeschrieben. Für die IT ist insbesondere die Nachweispflicht der Integrität der elektronisch übermittelten Daten von Bedeutung. Nachkommen kann die IT dieser Nachweispflicht nur mit entsprechender Dokumentation. In Artikel 125 wird auf Ausführungsbestimmungen verwiesen, die mit der Verordnung über elektronische Daten und Informationen von dem Eidgenössischen Finanzdepartement erlassen wurden. (MWSTV)

Verordnung über elektronische Daten und Informationen

Aus den folgenden Artikeln der Verordnung von 2009 können unmittelbar Dokumentationsanforderungen abgeleitet werden:

- Gemäß Artikel 1 regelt diese Verordnung die technischen, organisatorischen und verfahrenstechnischen Anforderungen an die Beweiskraft und die Kontrolle von elektronisch oder in vergleichbarer Weise erzeugten Daten und Informationen.
- In Artikel 5 (Prüfbarkeit) sind umfassende Dokumentationspflichten festgeschrieben. Danach ist für jedes Datenverarbeitungssystem (z. B. Buchführungssystem) eine Verfahrensdokumentation zu erstellen, die die Anforderungen der Geschäftsbücherverordnung, Artikel 4, zu erfüllen hat. Ebenso sind Stammdaten und Steuerungstabellen zu dokumentieren.
- In Artikel 6 ist nochmals das Dokumentationserfordernis beschrieben, indem gefordert wird, dass die steuerpflichtige Person gewährleisten muss, »dass die für die Steuererhebung relevanten Daten und die zu ihrem Verständnis erforderlichen Arbeitsanweisungen und sonstigen Organisationsunterlagen wie Tabelleneinstellungen ohne unzumutbare zeitliche Verzögerung lesbar gemacht werden können«. (EFD) In Artikel 8 ist auch die Protokollierungspflicht für die Archivierung von Daten beschrieben.

Datenschutzgesetz und Datenschutzverordnung

Der Schutz der Persönlichkeit und der Grundrechte von Personen, über die Daten bearbeitet werden, werden im Allgemeinen im *Bundesgesetz über den Datenschutz (Datenschutzgesetz)* und im Besonderen in der *Datenschutzverordnung* normiert, die in einer Neufassung 2010 verabschiedet wurde. Entsprechend der großen Bedeutung werden in der Datenschutzverordnung umfangreiche Dokumentationspflichten beschrieben.

So wird in Artikel 3 festgelegt, welche Informationen über die Datensammlung beim Eidgenössischen Datenschutz- und Öffentlichkeitsbeauftragten (Beauftragter) vor der Eröffnung der Datensammlung mitzuteilen sind. Danach muss die Anmeldung die folgenden Angaben enthalten und diese müssen regelmäßig aktualisiert werden.

- *»Name und Adresse des Inhabers der Datensammlung*
- *Name und vollständige Bezeichnung der Datensammlung*
- *Person, bei der das Auskunftsrecht geltend gemacht werden kann*
- *Zweck der Datensammlung*
- *Kategorien der bearbeiteten Personendaten*
- *Kategorien der Datenempfänger*
- *Kategorien der an der Datensammlung Beteiligten« (VDSG)*

In Artikel 10 wird eine Protokollierungspflicht bei der automatisierten Verarbeitung von Personendaten gefordert, »wenn die präventiven Maßnahmen den Datenschutz nicht gewährleisten können«. Im Umkehrschluss können die Inhaber der Datensammlung nur dann auf eine (sehr aufwendige) Protokollierung verzichten, wenn die präventiven Datenschutzmaßnahmen wirkungsvoll sind. Dieser Nachweis ist jedoch nur mittels aussagefähiger Dokumentation zu gewährleisten.

Die umfangreichsten Anforderungen an die IT-Dokumentation werden jedoch in Artikel 11 festgeschrieben. Danach hat der Inhaber einer Datensammlung ein Bearbeitungsreglement zu erstellen, »das insbesondere die interne Organisation sowie das Datenbearbeitungs- und Kontrollverfahren umschreibt und die Unterlagen über die Planung, die Realisierung und den Betrieb der Datensammlung und der Informatikmittel enthält«. Auch hier gibt es wieder die Verpflichtung, die Dokumentation einer regelmäßigen Aktualisierung zu unterziehen. Verstärkt wird die Bedeutung dieser Dokumentation dadurch, dass der Beauftragte oder der Datenschutzverantwortliche eine Aushändigung des Bearbeitungsreglements in einer für sie verständlichen Form verlangen kann.

Bei klärungsbedürftigen Sachverhalten nach Artikel 29 Datenschutzgesetz kann der Beauftragte vom Inhaber der Datensammlung Informationen verlangen über:

- *»technische und organisatorische Maßnahmen, die getroffen wurden oder geplant sind*
- *die Regelungen betreffend Berichtigung, Sperrung, Anonymisierung, Speicherung, Aufbewahrung und Vernichtung von Personendaten*
- *die Konfiguration der Informatikmittel*
- *die Verknüpfungen mit anderen Datensammlungen*
- *die Art der Bekanntgabe der Daten*
- *die Beschreibung der Datenfelder und die Organisationseinheiten, die darauf Zugriff haben*
- *Art und Umfang des Zugriffs der Benutzer auf die Daten der Datensammlung« (VDSG)*

Verordnung über die Datenschutzzertifizierungen

Um den Datenschutz und die Datensicherheit zu verbessern, können gemäß Artikel 11 Datenschutzgesetz die Hersteller von Datenbearbeitungssystemen oder -programmen sowie private Personen oder Bundesorgane, die Personendaten bearbeiten, ihre Systeme, Verfahren und ihre Organisation einer Bewertung durch anerkannte unabhängige Zertifizierungsstellen unterziehen.

In der *Verordnung über die Datenschutzzertifizierungen* in der Fassung von 2010 sind die Anforderungen an eine solche Zertifizierung beschrieben. Nach Artikel 4 umfasst eine Begutachtung des Datenschutzmanagementsystems folgende Bereiche:

- »die Datenschutzpolitik
- die Dokumentation von Zielen und Maßnahmen zur Gewährleistung des Datenschutzes und der Datensicherheit
- die organisatorischen und technischen Vorkehrungen zur Verwirklichung der festgelegten Ziele und Maßnahmen, insbesondere die Vorkehrungen zur Behebung festgestellter Mängel« (VDSZ)

Auch die Berücksichtigung internationaler Normen und Standards für die Errichtung, den Betrieb, die Überwachung und die Verbesserung von Managementsystemen wird in Artikel 11 festgeschrieben. Explizit werden hier die ISO 9001:2005 und die ISO 27001:2005 genannt.

Sofern Produkte, die hauptsächlich der Bearbeitung von Personendaten dienen oder bei deren Benutzung Personendaten, namentlich Daten über die Benutzerin oder den Benutzer, generiert werden, zertifiziert werden sollen, werden in Artikel 5 weitere detaillierte Anforderungen an die Dokumentation beschrieben.

Schweizer Prüfungsstandards (PS)

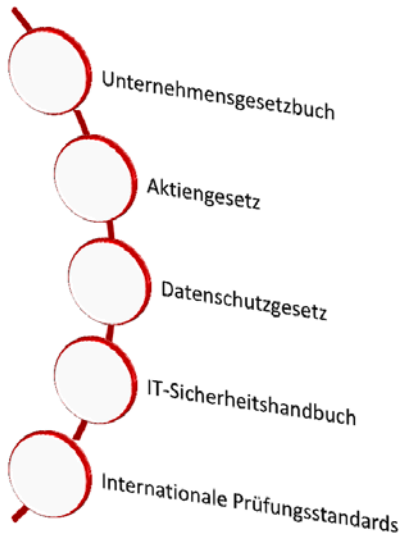
Die PS werden von der schweizerischen Kammer der Wirtschaftsprüfer, Steuerexperten und Treuhandexperten (Treuhandkammer) herausgegeben. Sie bilden die Arbeitsgrundlage für die in der Kammer akkreditierten Abschlussprüfer. Nach eigenem Bekunden der Treuhand-Kammer verkörpern die PS eine Umsetzung aller International Standards on Auditing. Die PS stellen somit einen allgemein anerkannten Anforderungsrahmen für den Nachweis der Ordnungsmäßigkeit der Rechnungslegung und aller damit tangierten Bereiche und Systeme (PS).

Ebenso wie für die deutschen Prüfungsstandards des IDW, basieren die schweizer Prüfungsstandards auf den *International Standards on Auditing (ISA)* (IAASB, 2012). Hierbei sind die Neuerungen der ISA in die überarbeiteten und 2013 verabschiedeten Prüfungsstandards eingeflossen. Die in *Abschnitt 1.3.1* beschriebenen Inhalte der Standards gelten daher weitgehend auch für die schweizer Prüfungsstandards.

1.5.2 Dokumentationsrelevante Regularien – Österreich

Österreich ist traditionell an das deutsche Wirtschaftsrecht angebunden, so dass viele der für Deutschland beschriebenen gesetzlichen Anforderungen an die IT-Dokumentation auch für Österreich gelten. Jedoch gibt es auch erhebliche Abweichungen, wie beispielsweise beim Datenschutzgesetz.

Die wichtigen für Österreich spezifischen Dokumentationsanforderungen beschreibt dieses Kapitel.

**Bild 1.4**

Für die Dokumentation relevante gesetzliche Regelungen und Standards in Österreich

Unternehmensgesetzbuch

Die Prüfungs- und Auskunftspflichten der Abschlussprüfer von Kapitalgesellschaften sind in den letzten Jahren ausgeweitet worden. So ist in der Fassung von 2013 in § 273, Abs. 2, die folgende Regelung enthalten:

»Stellt der Abschlussprüfer bei Wahrnehmung seiner Aufgaben Tatsachen fest, die den Bestand des geprüften Unternehmens oder Konzerns gefährden oder seine Entwicklung wesentlich beeinträchtigen können oder die schwerwiegende Verstöße der gesetzlichen Vertreter oder von Arbeitnehmern gegen Gesetz, Gesellschaftsvertrag oder Satzung erkennen lassen, so hat er darüber unverzüglich zu berichten. Darüber hinaus hat er unverzüglich über wesentliche Schwächen bei der internen Kontrolle des Rechnungslegungsprozesses zu berichten.« (UGB)

Diese Pflicht zur Berichterstattung macht es für Unternehmen unumgänglich, die Angemessenheit des internen Kontrollsystems zu dokumentieren. Die IT als wesentlicher Träger der Rechnungslegungsprozesse ist hier im Besonderen gefordert.

Die Bedeutung der Vorhaltung eines internen Kontrollsystems ergibt sich auch aus dem Aktiengesetz, in dem eine entsprechende Verpflichtung verankert ist.

Aktiengesetz

Die vorstehend beschriebene Verpflichtung ergibt sich aus § 82, wonach der Vorstand dafür zu sorgen hat, dass ein internes Kontrollsystem geführt wird. Dass dieses jedoch nicht nur vorhanden, sondern auch angemessen und wirksam sein muss, ergibt sich aus dem zuvor beschriebenen § 273 des Unternehmensgesetzbuchs.

Aber auch im Aktiengesetz ist die Nachweispflicht für die Wirksamkeit des internen Kontrollsystems enthalten. Sofern die Gesellschaft bestimmte wertmäßige Schwellenwerte ihrer Bilanz überschreitet, ist vom Aufsichtsrat ein Prüfungsausschuss zu bilden, der nach § 92, 4a u. a., folgende Aufgaben hat:

- die »Überwachung des Rechnungslegungsprozesses
- die Überwachung der Wirksamkeit des internen Kontrollsystems, gegebenenfalls des internen Revisionssystems, und des Risikomanagementsystems der Gesellschaft« (AktG)

Damit stellen die Regelungen aus dem Aktiengesetz sowie dem Unternehmensgesetz eine nationale Umsetzung u.a. der 8. EU-Richtlinie (Abschlussprüferrichtlinie) dar, in der der Nachweis der Wirksamkeit der internen Kontrollen in Anlehnung an den amerikanischen Sarbanes-Oxley Act (SOX) für alle Mitgliedsstaaten der EU normiert wurde.

Internationale Prüfungsstandards

Gemäß § 269a Unternehmensgesetzbuch sind internationale Prüfungsstandards bei der Abschlussprüfung anzuwenden, wenn diese von der Europäischen Kommission übernommen wurden. Das trifft auf die *International Standards of Auditing* (IAASB, 2012) zu. Die für die IT relevanten Standards sind:

- ISA 315 – Understanding the Entity and its Environment and Assessing Risks of Material Misstatement
- ISA 330 – The Auditor's Responses to Assessed Risks

Für Österreich sind die Prüfungsstandards anhand des im Folgenden beschriebenen Fachgutachtens konkretisiert.

Fachgutachten zur Abschlussprüfung bei Einsatz von Informationstechnik

Die Festlegungen in diesem Fachgutachten, das von der österreichischen Kammer der Wirtschaftstreuhänder in 2004 herausgegeben wurde, sind von den Abschlussprüfern, zusätzlich zu ihren eigenen Prüfungsstandards, bei den Abschlussprüfungen zu beachten.

Danach hat sich der Abschlussprüfer einen Überblick über die Informationstechnik des geprüften Unternehmens zu verschaffen. Gemäß Kapitel 2 sind hierzu u.a. folgende Informationen sinnvoll:

- Beschreibung der für das Unternehmen wichtigen IT-Prozesse,
- Feststellung der verwendeten Geräte,
- wichtige Schnittstellen und Datenflüsse,
- Feststellung der Unternehmensabläufe und Geschäftsprozesse, bei deren Infrastruktur Anwendungen der Informationstechnik eingesetzt werden,
- Beschreibung der für die Rechnungslegung wesentlichen Prozesse,
- Inhalt der Dokumentationen für Anwender (KFS/PG 1).

Gemäß Kapitel 5 sind Schwerpunkte und Umfang der Prüfung des internen Kontrollsystems danach auszurichten, welche internen Kontrollen eingerichtet und ob diese wirksam sind, also auch angewendet werden. Daraus lässt sich ableiten, dass die Dokumentation des internen Kontrollsystems und der tatsächlich durchgeführten internen Kontrollen unabdingbar ist.

Wie bereits im Unternehmensgesetzbuch ist auch in dem Fachgutachten die Verpflichtung des Abschlussprüfers festgeschrieben, über wesentliche Mängel, hier bei der IT, dem Vorstand bzw. dem Aufsichtsrat, zu berichten. Das Fachgutachten enthält als Beilage den Ver-

weis auf das COBIT-Prozessmodell, in dem die wesentlichen IT-Prozesse mit Ihren Kontroll- bzw. Steuerungszielen beschrieben sind.

Fachgutachten zur Ordnungsmäßigkeit von EDV-Buchführungen

Die Grundsätze ordnungsgemäßer Buchführung werden durch dieses Fachgutachten der österreichischen Kammer der Wirtschaftstreuhänder von 1998 bzw. in der aktuellen Fassung von 2011 für die IT-gestützte Buchhaltung und Rechnungslegung konkretisiert. Hier wird die Prüfbarkeit als wesentliches Ordnungsmäßigkeitskriterium festgelegt.

Die Prüfbarkeit umfasst dabei neben dem einzelnen Geschäftsvorfall auch das Verarbeitungsverfahren sowie dessen Dokumentation. Dazu gehören die technischen und organisatorischen Kontrollen (vgl. Teil II). Präzisiert werden die Anforderungen an eine Verfahrensdokumentation durch folgenden Wortlaut in Kapitel 4 des Fachgutachtens zur Abschlussprüfung bei Einsatz von Informationstechnik:

»Eine ordnungsgemäße Verfahrensdokumentation hat die Beschreibung aller zum Verständnis der Buchführung erforderlichen Verfahrensbestandteile zu umfassen. Dazu zählen die Anwenderdokumentation, die technische Systemdokumentation sowie die Betriebsdokumentation. Bei Einsatz von Standardsoftware ist die vom Produkthersteller gelieferte Dokumentation um die Beschreibung der unternehmensspezifischen Anpassungen zu ergänzen.

Die Anwenderdokumentation muss alle Informationen enthalten, die für eine sachgerechte Bedienung einer IT-Anwendung erforderlich sind. Neben einer allgemeinen Beschreibung der durch die IT-Anwendung abgedeckten Aufgabenbereiche sowie einer Erläuterung der Beziehungen zwischen einzelnen Anwendungsmodulen sind Art und Bedeutung der verwendeten Eingabefelder, die programminterne Verarbeitung (insbesondere maschinelle Verarbeitungsregeln) und die Vorschriften zur Erstellung von Auswertungen anzugeben.

Die technische Systemdokumentation enthält eine technische Darstellung der IT-Anwendung. Sie ist Grundlage für die Einrichtung eines sicheren und geordneten IT-Betriebs sowie für die Wartung der IT-Anwendung durch den Programmhersteller. Art und Umfang der technischen Dokumentation sind abhängig von der Komplexität der IT-Anwendung. Die Dokumentations-technik und die formale Gestaltung der technischen Dokumentation liegen im Ermessen des Programmherstellers. Die Dokumentation hat in einer Weise zur Verfügung gestellt zu werden, die einem sachverständigen Dritten den Nachvollzug der programminternen Verarbeitung, insbesondere der Verarbeitungsfunktionen und -regeln, in angemessener Zeit ohne Kenntnis der Programmiersprache erlaubt. Eine nur auf den Programm Quellcode gestützte Dokumentation ist zur Sicherstellung der Nachvollziehbarkeit des Buchführungsverfahrens nicht ausreichend.« (KFS/DV 1)

Weiterhin werden die Anforderungen an das interne Kontrollsystem beschrieben und damit auch das Erfordernis zur Dokumentation. In Kapitel 4 wird gefordert, dass alle Maßnahmen, die zum internen Kontrollsystem zu zählen sind, entsprechend zu dokumentieren sind. Dazu gehört insbesondere:

- Sicherung der ordnungsgemäßen Programmanwendung,
- Zugriffsberechtigungen auf allen Systemebenen,
- ungewöhnliche Vorkommnisse (z. B. aufgetretene Fehler und deren Bearbeitung).

Abhängig von Art und Größe eines Unternehmens ist auch der Nachweis der ordnungsgemäßen Programmanwendung zu dokumentieren.

Datenschutzgesetz

Eine Verarbeitung personenbezogener Daten ist nach dem Gesetz in der Fassung von 2013 nur zulässig, wenn vor der Verarbeitung Zweck und Umfang der Verarbeitung festgelegt werden und eine entsprechende Meldung bei der österreichischen Datenschutzkommission erfolgt ist. Gemäß § 19 muss die Meldung folgende Informationen beinhalten:

1. *»den Namen (die sonstige Bezeichnung) und die Anschrift des Auftraggebers sowie eines allfälligen Vertreters gemäß § 6 Abs. 3 oder eines Betreibers gemäß § 50 Abs. 1, weiterhin die Registernummer des Auftraggebers, sofern ihm eine solche bereits zugeteilt wurde*
2. *den Nachweis der gesetzlichen Zuständigkeit oder der rechtlichen Befugnis für die erlaubte Ausübung der Tätigkeit des Auftraggebers, soweit dies erforderlich ist*
3. *den Zweck der zu registrierenden Datenanwendung und ihre Rechtsgrundlagen, soweit sich diese nicht bereits aus den Angaben nach Z 2 ergeben*
4. *die Kreise der von der Datenanwendung Betroffenen und die über sie verarbeiteten Datenarten*
5. *die Kreise der von den beabsichtigten Übermittlungen Betroffenen, die zu übermittelnden Datenarten und die zugehörigen Empfängerkreise – einschließlich allfälliger ausländischer Empfängerstaaten – sowie die Rechtsgrundlagen der Übermittlung*
6. *die Geschäftszahl der Genehmigung durch die Datenschutzkommission, soweit eine Genehmigung der Datenschutzkommission notwendig ist*
7. *allgemeine Angaben über die getroffenen Datensicherheitsmaßnahmen im Sinne des § 14, die eine vorläufige Beurteilung der Angemessenheit der Sicherheitsvorkehrungen erlauben« (DSG 2000)*

Die Dokumentation der Datensicherheitsmaßnahmen ist in § 14 detailliert beschrieben. Danach ist u. a.

1. *»die Aufgabenverteilung bei der Datenverwendung zwischen den Organisationseinheiten und zwischen den Mitarbeitern ausdrücklich festzulegen,*
2. *die Verwendung von Daten an das Vorliegen gültiger Aufträge der anordnungsbefugten Organisationseinheiten und Mitarbeiter zu binden,*
3. *jeder Mitarbeiter über seine nach diesem Bundesgesetz und nach innerorganisatorischen Datenschutzvorschriften einschließlich der Datensicherheitsvorschriften bestehenden Pflichten zu belehren,*
4. *die Zutrittsberechtigung zu den Räumlichkeiten des Auftraggebers oder Dienstleisters zu regeln,*
5. *die Zugriffsberechtigung auf Daten und Programme und der Schutz der Datenträger vor der Einsicht und Verwendung durch Unbefugte zu regeln,*
6. *die Berechtigung zum Betrieb der Datenverarbeitungsgeräte festzulegen und jedes Gerät durch Vorkehrungen bei den eingesetzten Maschinen oder Programmen gegen die unbefugte Inbetriebnahme abzusichern und*
7. *Protokoll zu führen, damit tatsächlich durchgeführte Verwendungsvorgänge, wie insbesondere Änderungen, Abfragen und Übermittlungen, im Hinblick auf ihre Zulässigkeit im notwendigen Ausmaß nachvollzogen werden können.« (DSG 2000)*

Die Dokumentation dieser Maßnahmen dient der Kontrolle und Beweissicherung.

Österreichisches Informationssicherheitshandbuch

Das österreichische Informationssicherheitshandbuch, das 2004 von der Stabsstelle IKT-Strategie des Bundes herausgegeben wurde, beinhaltet in Teil 1 konkrete Anleitungen zur Etablierung eines umfassenden und kontinuierlichen IT-Sicherheitsprozesses (IT-Sicherheitsmanagement). In Teil 2 (IT-Sicherheitsmaßnahmen) werden grundsätzliche Maßnahmen auf organisatorischer, personeller, infrastruktureller und technischer Ebene beschrieben. Es wurde 2010 überarbeitet und dabei vor allem an die ISO 27001 und ISO 27002 angepasst. Außerdem wurde es von IT-Sicherheitshandbuch in Informationssicherheitshandbuch umbenannt.



Hilfreiche Online-Version verfügbar

Das Bundeskanzleramt Österreich stellt unter [<https://www.sicherheitshandbuch.gv.at/#100001>] eine Online-Version des österreichischen Informationssicherheitshandbuchs in der aktuellen Version 3.1 (Stand August 2013) zur Verfügung.

Eine wesentliche Basis des IT-Sicherheitshandbuchs bildet das Grundschutzhandbuch des deutschen Bundesamts für Sicherheit in der Informationstechnik (BSI). Insofern sind die Standards des BSI (siehe hierzu die Erläuterungen *Abschnitt 1.5.2*) mittelbar auch auf österreichische Unternehmen anwendbar.

Ähnlich wie in Deutschland wurde das österreichische IT-Sicherheitshandbuch zunächst für den öffentlichen Bereich entwickelt. Aufgrund des generellen Ansatzes wird die Anwendung des IT-Sicherheitshandbuchs auch in der Privatwirtschaft empfohlen. In Teil 1, Kapitel 1.1, sind die Ziele und Aufgaben des IT-Sicherheitsmanagements wie folgt festgelegt (A-SIT):

- Festlegung der IT-Sicherheitsziele, -strategien und -politiken der Organisation,
- Festlegung der IT-Sicherheitsanforderungen,
- Ermittlung und Analyse von Bedrohungen und Risiken,
- Festlegung geeigneter Sicherheitsmaßnahmen,
- Überwachung der Implementierung und des laufenden Betriebs der ausgewählten Maßnahmen,
- Förderung des Sicherheitsbewusstseins innerhalb der Organisation,
- Entdecken von und Reaktion auf sicherheitsrelevante Ereignisse.

Für die Erreichung der Ziele bzw. die erfolgreiche Umsetzung der Aufgaben ist eine entsprechende Dokumentation erforderlich.

In Teil 2, Sicherheitsmaßnahmen, wird der Aufbau des IT-Sicherheitsmanagements beschrieben. Danach sind im Zusammenhang mit der Festlegung von Verantwortlichkeiten detaillierte Regelungen u. a. für die folgenden Bereiche zu treffen:

- Datensicherung,
- Datenarchivierung,
- Datenübertragung,
- Dokumentation von IT-Verfahren, Software, IT-Konfiguration,
- Zutritts-, Zugangs- und Zugriffsberechtigungen,

- Datenträger- und Betriebsmittelverwaltung,
- Anwendungsentwicklung,
- Abnahme und Freigabe von Software,
- Wartungs- und Reparaturarbeiten,
- Datenschutz,
- Schutz gegen Software mit Schadensfunktion (Viren, Würmer, trojanische Pferde ...),
- Notfallvorsorge.

Weiterhin sind die Regelungen regelmäßig zu aktualisieren. (A-SIT)

■ 1.6 Relevante Normen und Standards

Während Gesetze und daraus abgeleitete Rechtsnormen verbindlichen Charakter haben, entfalten Standards ihre Wirkung durch nationale oder internationale Anerkennung, entweder durch öffentlich legitimierte Organisationen wie bei den ISO-Normen und beispielsweise dem IT-Grundschutz.

Gleichzeitig helfen Normen und Standards dabei, gesetzliche Anforderungen einzuhalten, und dienen bei deren Umsetzung als Nachweis der Einhaltung. So weist ein Unternehmen, das eine Zertifizierung nach dem Sicherheitsstandard ISO 27001 erlangt hat, damit nach, dass es einen Sicherheitsprozess und die nach aktuellem Erkenntnisstand möglichen Sicherheitsmaßnahmen implementiert hat. Eine Organisation, die nicht über diese Zertifizierung verfügt, muss hierfür Einzelnachweise erbringen. So wird beispielsweise in einer Verlautbarung des IDW das Vorgehen nach ISO 27001 auf Basis von IT-Grundschutz des BSI als probates Mittel anerkannt, um die Anforderungen der Wirtschaftsprüfung in diesem Bereich zu erfüllen. Sollte das geprüfte Unternehmen eine Zertifizierung vorweisen, so kann eine Prüfung in einem Minimalumfang erfolgen.

Ein weiterer Vorteil einer Zertifizierung betrifft den Bereich der Haftung. Bei haftungstechnischen Problemen geht es immer auch um die Frage, ob die gebotene verkehrsübliche Sorgfaltspflicht eingehalten wurde. Die Einhaltung von Normen und Standards ist hierbei ein wichtiges Kriterium. Der Nachweis einer Zertifizierung wird dann in der Regel als Beleg anerkannt, dass die gebotene Sorgfaltspflicht eingehalten wurde.

Und Krankenhäuser und Reha-Kliniken sind darüber hinaus gemäß Sozialgesetzbuch V, §§ 135 ff. zur Einführung eines Qualitätsmanagementsystems auf Basis von ISO 9001 und zu dessen Nachweisbarkeit verpflichtet.

Dieser Abschnitt stellt, nach einem Blick auf ein paar Begriffe und Abkürzungen, die wichtigsten Standards und Normen mit Relevanz für die IT-Dokumentation im Überblick vor.

1.6.1 Normierungsorganisationen

Entsprechend dem Deutschen Institut für Normung e. V. (DIN) gibt es auch ein internationales Pendant – die *International Organization for Standardization (ISO)*. Sie ist ein Zusammenschluss internationaler Organisationen und entwickelt und veröffentlicht, mit wenigen Ausnahmen, für alle Bereiche der Wirtschaft Normen. Die ISO ist eine Vereinigung von Vertretern aus über 150 Ländern zur Entwicklung von weltweiten Standards, wobei Unternehmen sich nach einigen dieser Standards zertifizieren lassen können. Sie arbeitet eng mit diversen Partnern zusammen, insbesondere mit der *International Electrotechnical Commission (IEC)*, einem internationalen Normierungsgremium für Elektrotechnik mit Sitz in Genf. Zertifizierungen nach den ISO-Normen sind in der Regel drei Jahre gültig und beinhalten einen jährlichen unternehmensinternen Auditprozess.

Alle ISO-Normen können kostenpflichtig über den Store der ISO oder den Beuth-Verlag bezogen werden.

Da diese ISO-Normen vom DIN als deutsche Norm übernommen werden, findet man häufig die Bezeichnung *DIN ISO*, *DIN EN* oder *DIN EN ISO*. Hierbei ist eine DIN ISO eine unveränderte nationale Übernahme einer ISO-Norm und DIN EN die unveränderte deutsche Ausgabe einer europäischen Norm. DIN EN ISO spiegelt alle drei Wirkungsebenen wider, die eine Norm haben kann: national, europäisch und weltweit.

Im Buch werden der Übersichtlichkeit halber die ISO-Bezeichnungen verwendet.



Tipp

Im Bereich Normen und Normierung werden verwirrend viele Begriffe und Abkürzungen verwendet, die den Umgang damit erschweren. Hilfreich ist hier die Website des Deutschen Instituts für Normung e. V. Auf dieser finden Sie nicht nur Erklärungen für die in diesem Umfeld verwendeten Begriffe und Abkürzungen, sondern auch verständliche Erläuterungen der Zusammenhänge [<http://www.din.de>].

Auf nationaler Ebene stellt das Bundesamt für Sicherheit in der Informationstechnik (BSI) eine durch ein entsprechendes Bundesgesetz (BSIG von 1990) legitimierte Organisation dar, die in erster Linie für die Verwaltungen in Bund, Ländern und Gemeinden zuständig ist, sich aber auch an private Nutzer und Hersteller richtet. Nach § 3 des BSIG hat das BSI unter anderem folgende Aufgaben:

- »Untersuchung von Sicherheitsrisiken bei der Anwendung der Informationstechnik sowie Entwicklung von Sicherheitsvorkehrungen – insbesondere von informationstechnischen Verfahren und Geräten für die Sicherheit in der Informationstechnik,
- Entwicklung von Kriterien, Verfahren und Werkzeugen für die Prüfung und Bewertung der Sicherheit von informationstechnischen Systemen oder Komponenten,
- Prüfung und Bewertung der Sicherheit von informationstechnischen Systemen oder Komponenten und Erteilung von Sicherheitszertifikaten,

- *Unterstützung der für Sicherheit in der Informationstechnik zuständigen Stellen des Bundes, insbesondere soweit sie Beratungs- oder Kontrollaufgaben wahrnehmen. Dies gilt vorrangig für den Bundesbeauftragten für den Datenschutz, dessen Unterstützung im Rahmen der Unabhängigkeit erfolgt, die ihm bei der Erfüllung seiner Aufgaben nach dem Bundesdatenschutzgesetz zusteht,*
- *Beratung der Hersteller, Vertreiber und Anwender in Fragen der Sicherheit in der Informationstechnik unter Berücksichtigung der möglichen Folgen fehlender oder unzureichender Sicherheitsvorkehrungen.» (BSIG)*

Für die IT von Bedeutung ist das BSI-Regelwerk zum IT-Grundschutz, das den Unternehmen Methoden an die Hand gibt, dem Stand der Technik entsprechende IT-Sicherheitsmaßnahmen zu identifizieren und umzusetzen. Dieses seit den 1990er-Jahren bestehende Regelwerk ist 2005 in *IT-Grundschutzkataloge* umbenannt worden, die nun in Form von Bausteinen Maßnahmen für die Umsetzung der *BSI-Standards 100-1 bis 100-4* beschreiben. In die BSI-Standards sind bereits auch Kernelemente der ISO 27001 mit eingeflossen. Die Idee von IT-Grundschutz aber ist immer noch die gleiche: Typische IT-Komponenten und Abläufe sind überall ähnlich. Diese unterliegen typischen Gefährdungen, Schwachstellen und Risiken. Ziel von IT-Grundschutz ist es, durch eine geeignete Kombination von organisatorischen, personellen, infrastrukturellen und technischen Standardsicherheitsmaßnahmen ein Sicherheitsniveau zu erreichen, das für den normalen Schutzbedarf angemessen und ausreichend ist. Die Vereinfachung liegt vor allem im Verzicht auf eine detaillierte Risikoanalyse

Eine Sonderrolle nimmt die *TÜV Informationstechnik GmbH (TÜVIT)* als Unternehmen der Unternehmensgruppe TÜV Nord ein. Sie ist zum einen bei nationalen und internationalen Organisationen akkreditiert und kann somit Zertifikate nach ISO- oder BSI-Standard vergeben und bietet zum anderen in Kooperation mit IT-Herstellern eigene Zertifizierungsdienstleistungen an, so beispielsweise mit Microsoft oder der Deutschen Telekom.

1.6.2 Normen und Standards im Bereich IT-Sicherheit

Fragt man Unternehmen in Deutschland, welche Sicherheitszertifizierung sie entweder schon haben oder aber planen, so wird an erster Stelle die ISO-27001-Zertifizierung genannt. Dies liegt sicherlich auch daran, dass die Norm *DIN ISO/IEC 27001:2008-09 Informationstechnik – IT-Sicherheitsverfahren – Informationssicherheits – Managementsysteme – Anforderungen* (im Folgenden kurz als ISO 27001 bezeichnet) als erster internationaler Standard zum IT-Sicherheitsmanagement eine Zertifizierung ermöglichte. (27001:2005)

Eine zunehmende Bedeutung hat die ISO 27001 mit der Einführung der IT-Grundschutz-Zertifizierung erfahren. Das BSI bietet seit Januar 2006 die ISO-27001-Zertifizierung auf der Basis von IT-Grundschutz an. Hierüber kann nachgewiesen werden, dass die IT-Infrastruktur eines Unternehmens die wesentlichen Anforderungen der ISO 27001 erfüllt und diese unter Anwendung der IT-Grundschutz-Vorgehensweise (BSI-Standard 100-2) und gegebenenfalls einer ergänzenden Risikoanalyse (BSI-Standard 100-3) umgesetzt wurden. Im Folgenden werden die ISO 27001 und die Standards des BSI im Überblick vorgestellt.

ISO 27001

Zu den bekanntesten und wichtigsten Standards gehört die ISO 2700x-Reihe. Die ISO/IEC 27001:2005 wurde aus dem britischen Standard BS 7799-2:2002 entwickelt und als internationale Norm erstmals am 15. Oktober 2005 veröffentlicht. Inhaltlich besteht die Norm aus einem Katalog von Anforderungen, die ein *Information Security Management System (ISMS)* beschreiben und detaillierte Anforderungen definieren, die eine Zertifizierung ermöglichen. Damit ist die ISO 27001 der einzige internationale auditierbare Standard, der die Anforderungen an ein ISMS definiert.

Die ISO 27001 ist Teil einer Normenfamilie, die aus diversen Normen und Subnormen besteht. Mit Ausgabe 9.2008 liegt die Norm auch als DIN-Norm DIN ISO/IEC 27001 vor. Im Rahmen der Standardisierung wurde in der Zusammenarbeit von ISO und IEC beschlossen, verschiedene Standards zur IT-Sicherheit unter dem Nummernkreis 2700x zusammenzufassen. Zu den mittlerweile mehr als 20 Standards gehören u. a. die Folgenden:

- **ISO/IEC 27000:** Beschreibt grundlegende Prinzipien, Konzepte, Begriffe und Definitionen für ein Information Security Management System. (27000:2012)
- **ISO/IEC 27001:** Gibt allgemeine Empfehlungen zur Einführung, zu dem Betrieb und der Verbesserung eines dokumentierten ISMS, auch unter Berücksichtigung der Risiken. Sie ist als einziger Standard der Reihe zertifizierbar. (27001:2005)
- **ISO/IEC 27002:** Beinhaltet die Beschreibung der erforderlichen Schritte, um ein funktionierendes Sicherheitsmanagement aufzubauen und in der Organisation zu verankern. Enthält den Inhalt der ISO 17799:2005. (27002:2005)
- **ISO/IEC 27003:** Enthält einen Leitfaden zur Umsetzung der ISO 27001-2. (27003:2010)
- **ISO/IEC 27005:** Ist an den BS 7799-3:2006 angelehnt und enthält Rahmenempfehlungen zum Risikomanagement für Informationssicherheit. (27005:2011)

Die internationale Zertifizierung nach ISO 27001 richtet sich an Firmen, Behörden und sonstige Organisationen, die ein wirksames Sicherheitsmanagement nachweisen wollen bzw. müssen. Da die ISO 27001 international als Methode für Informationssicherheit anerkannt ist, stellt sie ein wichtiges Instrument zum Nachweis der Einhaltung von gesetzlichen Anforderungen sowie von Vorgaben durch Kunden, Aufsichtsbehörden oder Banken dar. Hierzu zählen neben gesetzlichen Regeln wie SOX, Basel II/III und MaRisk auch eine Reihe von nationalen Vorschriften, die ein ISMS fordern, wie das Produkthaftungsgesetz oder das Telemediengesetz. Beachtenswert ist aber noch ein weiterer Punkt: Zunehmend werden Zertifizierungen zur Teilnahme an Ausschreibungen verlangt. Da öffentliche Auftraggeber an die für diesen Bereich gültigen europäischen Richtlinien gebunden sind, ist ein nationaler Ausweis nicht ausreichend. Praktisch erfüllt damit derzeit nur die ISO 27001 die Anforderungen öffentlicher Auftraggeber.

Die ISO 27001 spezifiziert die Anforderungen für die Konzipierung und Einführung sowie für den Betrieb, die Überwachung und die Verbesserung eines dokumentierten Informationssicherheits-Managementsystems unter Berücksichtigung der organisationsweiten Risiken. Kernpunkt ist das Verständnis von Informationssicherheit als geplanter, gelebter, überwachter und sich kontinuierlich verbessernder Prozess. Dem zugrunde liegt das »Plan-Do-Check-Act«-Modell, auch bekannt unter den Namen PDCA-Modell oder Deming-Cycle. Grundsätzlich gilt es nachzuweisen, dass ein solcher Prozess implementiert wurde und nachhaltig im Unternehmen gelebt wird. Hierbei ist hervorzuheben, dass die Norm nicht

die IT im Fokus hat, sondern die Informationssicherheit in den Geschäftsprozessen eines Unternehmens adressiert.

Die Überprüfung umfasst sowohl eine Dokumentenprüfung als auch eine Umsetzungsprüfung der erforderlichen IT-Sicherheitsmaßnahmen vor Ort. Als Nachweise fordert der Standard eine umfassende Dokumentation der Ergebnisse aus den vier Phasen des PDCA-Modells, insbesondere eine Beschreibung von Inhalt und Umfang des ISMS sowie das Vorgehen und die Ergebnisse des Risikomanagements. Hierbei ist darauf zu achten, dass die Dokumente geordnet abgelegt werden, Änderungen kontrolliert erfolgen und zeitnah den betroffenen Personen kommuniziert werden.

Hinsichtlich der Dokumentation benennt sie folgende Anforderungen:

»Dokumentationen müssen Aufzeichnungen von Managemententscheidungen enthalten, sicherstellen, dass sich Aktivitäten auf Managemententscheidungen und Grundsätze zurückverfolgen lassen, und sicherstellen, dass die aufgezeichneten Ergebnisse reproduzierbar sind. Es ist wichtig, dass es möglich ist, die Beziehung von den ausgewählten Maßnahmen zurück zu den Resultaten des Risikoeinschätzungs- und Risikobehandlungsprozesses nachzuweisen, und weiterhin zurück zu der ISMS-Leitlinie und den Zielen.

Die Dokumentation des ISMS sollte Folgendes enthalten:

- a) eine dokumentierte Erklärung der ISMS-Leitlinie und der ISMS-Ziele;*
- b) den Anwendungsbereich des ISMS;*
- c) Verfahren und Maßnahmen, die das ISMS unterstützen;*
- d) eine Beschreibung der Methode zur Risikoeinschätzung;*
- e) den Bericht der Risikoeinschätzung;*
- f) den Risikobehandlungsplan;*
- g) dokumentierte Verfahren, die die Organisation zur Sicherstellung der wirksamen Planung, Durchführung und Kontrolle ihrer Informationssicherheitsprozesse benötigt, und die beschreiben, wie die Wirksamkeit von Maßnahmen zu messen ist;*
- h) von dieser Internationalen Norm geforderte Aufzeichnungen und*
- i) die Erklärung zur Anwendbarkeit.« (27001:2005)*

Der Begriff »dokumentiertes Verfahren« bedeutet im Rahmen dieser internationalen Norm »ein festgelegtes, dokumentiertes, umgesetztes und instand gehaltenes Verfahren«.

ISO 27002

Die ISO 27001 beschreibt jedoch weder spezifische Verfahren noch definiert sie Implementierungsmethoden zum Erlangen einer Zertifizierung. Für eine konkrete Umsetzung der Maßnahmenziele und Maßnahmen verweist sie stattdessen auf die ISO-Norm *27002 IT-Sicherheitsverfahren – Leitfaden für das Informationssicherheits-Management*, die daher bei einer Zertifizierung zwingend berücksichtigt werden muss. Hervorgegangen ist ISO 27002 aus dem Britischen Standard BS 7799-1, weshalb dieser Standard in vielen Verweisen zu finden ist. Um eine einheitliche Namensgebung zu verwenden, wurde der Britische Standard im Juli 2007 in ISO/IEC 27002:2005 umbenannt. Inhaltlich unterscheiden sich beide Standards jedoch nicht.

Die ISO-Norm 27002 enthält elf Abschnitte mit Sicherheitsmaßnahmen, die zusammen insgesamt 39 wesentliche Sicherheitskategorien enthalten. Damit bildet der Leitfaden einen guten Überblick hinsichtlich der Anforderungen an ein Sicherheitsmanagement bzw. an die Dokumentation, auch wenn keine Zertifizierung geplant ist.

- »a) Sicherheitsleitlinie;
- b) Organisation der Informationssicherheit;
- c) Management von organisationseigenen Werten;
- d) Sicherheit im Personalbereich;
- e) physische und umgebungsbezogene Sicherheit;
- f) Management der Kommunikation und des Betriebs;
- g) Zugangskontrolle;
- h) Beschaffung, Entwicklung und Wartung von Informationssystemen;
- i) Management von Informationssicherheitsvorfällen;
- j) Aufrechterhaltung des Geschäftsbetriebs;
- k) Einhaltung von Verpflichtungen.« (27002:2005)

Standards des Bundesamts für Sicherheit in der Informationstechnik (BSI)

Als Erweiterung einer Zertifizierung nach ISO 27001 bietet das BSI seit 2006 eine ISO-27001-Zertifizierung auf der Basis von IT-Grundschutz an. Ein Kritikpunkt an der ISO 27001 ist, dass sie zwar die Elemente eines ISMS definiert, es jedoch dem Unternehmen überlässt, detaillierte Prozesse und Einzelmaßnahmen auszuwählen. Bei einer ISO-27001-Zertifizierung auf der Basis von IT-Grundschutz wird für das zu zertifizierende System auch die konkrete Umsetzung von Sicherheitsmaßnahmen auf der Basis von IT-Grundschutz geprüft, was die Aussagekraft eines solchen Zertifikats deutlich erweitert.

Wie bereits zu Beginn dieses Abschnitts dargelegt, hat das BSI gemäß dem BSI-Gesetz unter anderem die Aufgabe, Kriterien, Verfahren und Werkzeuge für die Prüfung und Bewertung der Sicherheit von informationstechnischen Systemen oder Komponenten zu entwickeln. Im Jahr 1995 hat das BSI das erste Grundschutzhandbuch herausgegeben, das sich als eine Referenz für die IT-Sicherheit verstanden hat und Vorgehensweisen zur Erstellung von IT-Sicherheitskonzepten enthielt. Es setzte sich damals aus 18 Grundschutzbausteinen und 200 Maßnahmen zur Erlangung des Grundschutzes zusammen. Während der Weiterentwicklung bis 2004 wuchs das »Handbuch«, das sich zwischenzeitlich auf mehrere Ordner erstreckte, auf 58 Grundschutzbausteine mit über 700 Maßnahmen an. Mit der Veröffentlichung der ISO-Norm 27001 hat das BSI das Handbuch zugunsten einer Zweiteilung des IT-Grundschutzes aufgegeben. Zum einen hat das BSI die Standards 100-1 bis 100-4 entwickelt, in denen die grundsätzlichen Anforderungen beschrieben sind. Zum anderen wurden aus den Bausteinen und Maßnahmen die IT-Grundschutzkataloge in Form einer Loseblattsammlung erstellt. Standards und Kataloge bilden dabei eine inhaltliche Einheit, wobei die Standards die Klammer um die Grundschutzkataloge bilden.

Zusätzlich verbunden war mit der Veröffentlichung der Standards und der Grundschutzkataloge ein grundlegender Paradigmenwechsel. Demzufolge ist IT-Sicherheit nunmehr als Managementprozess für Informationssicherheit zu implementieren. Zusätzlich wurde ein

Wechsel weg von der reinen IT-Sicherheit hin zur unternehmensweiten Informationssicherheit vollzogen. Im Folgenden werden die BSI-Standards im Überblick vorgestellt. Die vollständige Dokumentation ist kostenfrei auf den Webservern des BSI im PDF-Format verfügbar.

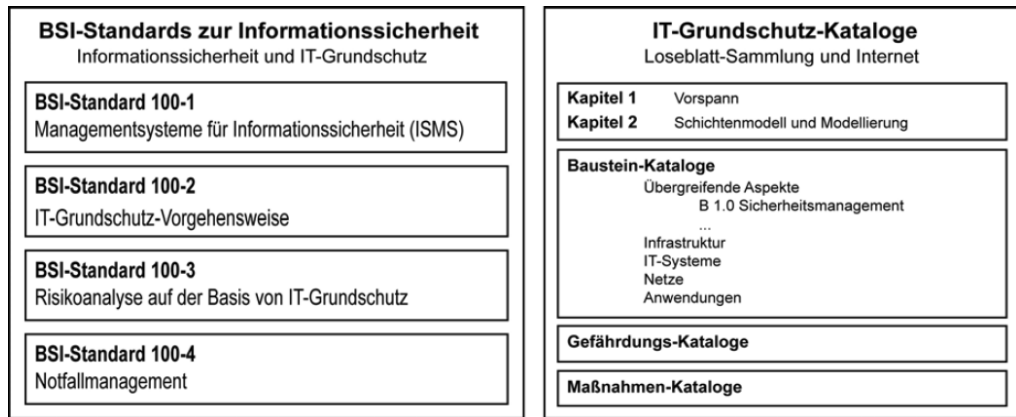


Bild 1.5 Übersicht über BSI-Publikationen zum Sicherheitsmanagement (BSI 100-1)

Standard 100-1

Der Standard beschreibt den Aufbau von Managementsystemen für Informationssicherheit und beinhaltet dabei alle für die Zielerreichung erforderlichen Regelungen. Dabei ist die Verantwortung für das Informationssicherheitsmanagement auf der obersten Leitungsebene zu etablieren. Neben den beiden einleitenden Kapiteln enthält der Standard 100-1 die folgenden Kapitel:

- Kapitel 1–2: Vorwort und allgemeine Hinweise,
- Kapitel 3: ISMS-Definition und Prozessbeschreibung,
- Kapitel 4: Management-Prinzipien,
- Kapitel 5: Ressourcen für Informationssicherheit,
- Kapitel 6: Einbindung der Mitarbeiter in den Sicherheitsprozess,
- Kapitel 7: Der Informationssicherheitsprozess,
- Kapitel 8: Sicherheitskonzept,
- Kapitel 9: Das ISMS des BSI: IT-Grundschutz.

Während in den Kapiteln 3 bis 7 allgemeine Anforderungen an das ISMS beschrieben werden, ist in Kapitel 8 die Notwendigkeit, ein Sicherheitskonzept zu erstellen, dargelegt.

Das *IT-Sicherheitskonzept* regelt die Struktur und beschreibt detaillierte Sicherheitsmaßnahmen und Handlungsanweisungen zum Umgang mit IT-Sicherheit. Gemäß BSI muss das IT-Sicherheitskonzept folgende Fragen beantworten:

- »Wie sicher ist die Informationstechnik des Unternehmens?
- Welche IT-Sicherheitsmaßnahmen müssen ergriffen werden?
- Wie müssen diese Maßnahmen konkret umgesetzt werden?
- Wie hält bzw. verbessert das Unternehmen das erreichte Sicherheitsniveau?« (BSI 100-1)

Damit ist es das zentrale Dokument im IT-Sicherheitsprozess jedes Unternehmens und jeder Behörde. Jede konkrete Maßnahme muss sich letztlich darauf zurückführen lassen. Nähere Erläuterungen zum IT-Sicherheitskonzept finden Sie in *Kapitel 3 – IT-Betriebsdokumentation*.

Zusätzlich erforderlich ist eine *Leitlinie zur Informationssicherheit*. Hierbei handelt es sich um ein strategisches Papier, das die zentralen Vorgaben für die IT-Sicherheit in einem Unternehmen festschreibt. Sie definiert die Sicherheitsziele und die Grundsätze für den Umgang mit Informationen sowie die Verantwortungsbereiche für die IT-Sicherheit. Sinnvollerweise sollte die Leitlinie zur Informationssicherheit Bestandteil einer übergeordneten Sicherheitsleitlinie für das unternehmensweite Sicherheitsmanagement sein. Im Rahmen der Überwachung und Erfolgskontrolle sind deshalb entsprechende Managementberichte zu erstellen, die zum einen die Aktivitäten dokumentieren und zum anderen die Basis für die Optimierung bilden. Nähere Erläuterungen zur Leitlinie für Informationssicherheit finden Sie in *Kapitel 2 in Abschnitt 2.3.2.3*.

Standard 100-2

Dieser Standard beschreibt im Wesentlichen die Initiierung des Sicherheitsprozesses und die Umsetzung der Sicherheitskonzeption. Dabei wird bei der Maßnahmenauswahl explizit auf die gesonderten Grundschutzkataloge verwiesen. Die Grundschutzkataloge sind zur besseren Erweiterbarkeit modular aufgebaut.

Im Rahmen des IT-Grundschutzes wird so vorgegangen, dass für jeden infrage kommenden Baustein die individuellen Gefährdungen anhand der Gefährdungskataloge identifiziert werden. Hiermit soll nach den Angaben des BSI ein verringerter Analyseaufwand bei typischen Anwendungsfällen erforderlich sein und somit kostengünstig ein angemessenes Sicherheitsniveau bei durchschnittlichem Schutzbedarf erreicht werden. Ebenfalls ist in diesem Standard die Zertifizierung nach ISO 27001 beschrieben, für die das BSI zugelassen ist. (BSI 100-2)

Standard 100-3

Sofern ein Unternehmen bereits eine IT-Grundschutzanalyse durchgeführt hat, liefert das BSI mit diesem Standard darüber hinaus die Möglichkeit einer weitergehenden Risikoanalyse für den IT-Bereich. Diese zusätzliche Risikoanalyse bietet sich bei einem erhöhten Schutzbedarf an, beispielsweise beim Thema Vertraulichkeit oder bei Anwendungsfällen, die in den Grundschutzkatalogen nicht ausreichend beschrieben sind.

Im Rahmen des Sicherheitsprozesses schließt sich nach der Standardsicherheitsüberprüfung die ergänzende Sicherheitsanalyse an, bevor die Realisierung der Sicherheitsmaßnahmen vorgenommen wird. (BSI 100-3)

Standard 100-4

Der BSI-Standard 100-4 wurde Ende 2008 veröffentlicht und beschreibt eine Methode zum Aufbau eines eigenständigen Managementsystems (*Business Continuity Management – BCM*) für die Notfallvorsorge und die Notfallbewältigung. Er ist nicht auf das IT-Notfallmanagement beschränkt. Ziel ist es, einen systematischen Weg aufzuzeigen, um bei Notfällen und Krisen, die zu einer Geschäftsunterbrechung führen, schnell reagieren zu können. Wichtig ist, wie auch beim Sicherheitsmanagement, eine ganzheitliche Betrachtungsweise mit Fokus auf die Geschäftsprozesse.

Ähnlich wie der Standard 100-3 stellt auch dieser Standard eine Ergänzung des Standards 100-2 dar, um gezielt auf die Besonderheiten des Notfallmanagements eingehen zu können. Das grundsätzliche Erfordernis zur Einrichtung eines Notfallmanagements leitet sich

bereits aus den allgemeinen Anforderungen an das Sicherheitsmanagement ab, wie sie im Standard 100-1 beschrieben werden. (BSI 100-4)



Gesondertes Kapitel zum Thema Notfalldokumentation

Ausführliche Erläuterungen zu den Inhalten des Standards 100-4 finden Sie in *Kapitel 4 – IT-Notfalldokumentation*. Dieses Kapitel erläutert die erforderlichen Inhalte der Notfalldokumentation gemäß BSI-Standard 100-4 sowohl aus Sicht der Notfallvorsorge als auch vor allem aus Sicht der Notfallbewältigung.

Welche Nachweise sind erforderlich?

Ein Audit im Rahmen einer Zertifizierung umfasst sowohl eine Dokumentenprüfung als auch eine Umsetzungsprüfung der erforderlichen IT-Sicherheitsmaßnahmen vor Ort. Hierbei wird die in den BSI-Standards beschriebene Vorgehensweise zur Implementierung eines ISMS und die Anwendung der in den IT-Grundschutzkatalogen empfohlenen Maßnahmen geprüft. Als Nachweis dienen die gemäß Zertifizierungsschema zu erstellenden Referenzdokumente:

- Leitlinie und Richtlinien für Informationssicherheit (A.0),
- Strukturanalyse (A.1),
- Schutzbedarfsfeststellung (A.2),
- Modellierung des Informationsverbunds (A.3),
- Ergebnis des Basis-Sicherheitschecks (A.4),
- Ergänzende Sicherheitsanalyse (A.5),
- Risikoanalyse (A.6),
- Risikobehandlungsplan (A.7).

Besonderes Gewicht wird der Einbeziehung der Geschäftsführung in den Sicherheitsprozess und der Schaffung organisatorischer Rahmenbedingungen beigemessen. Aus diesem Grund müssen mindestens folgende Richtlinien dokumentiert sein:

- Richtlinie zur Risikoanalyse,
- Richtlinie zur Lenkung von Dokumenten und Aufzeichnungen,
- Richtlinie zur internen ISMS-Auditierung (Auditierung des Managementsystems für Informationssicherheit),
- Richtlinie zur Lenkung von Korrektur- und Vorbeugungsmaßnahmen.

Hinsichtlich der Dokumentation ist zu beachten, dass Dokumente geordnet abgelegt werden, Änderungen kontrolliert erfolgen und zeitnah den betroffenen Personen kommuniziert werden.



Erläuterungen zu den Referenzdokumenten

Zusätzliche Informationen zur geforderten Dokumentation liefert das vom BSI bereitgestellte Dokument »*Hinweise zur Bereitstellung der Referenzdokumente im Rahmen der Zertifizierung nach ISO 27001 auf der Basis von IT-Grundschutz; Version 1.0 vom 30. März 2011*«.

Die Umsetzung der Maßnahme aus den Grundschutzkatalogen und die Erstellung der geforderten Dokumente erfordert einen erheblichen finanziellen und personellen Aufwand, der bedeutend höher ist als bei einer nativen ISO-27001-Zertifizierung. Hierzu trägt auch bei, dass es lange Zeit nur wenig Freiheitsgrade hinsichtlich der Umsetzung der geforderten Maßnahmen gab. Mit der im November 2011 erschienenen 12. Ergänzungslieferung der IT-Grundschutzkataloge hat das BSI auf die zunehmende Komplexität reagiert und den zusätzlichen Gefährdungskatalog »Elementare Gefährdungen« eingeführt. Damit wird nun erstmalig zwischen elementaren, d.h. zertifizierungsrelevanten und vertiefenden Bausteinen unterschieden, was die Zertifizierungsanforderungen reduziert.

1.6.3 Normen und Standards im Bereich Notfallmanagement

Aus zahlreichen gesetzlichen Anforderungen oder anderen Verpflichtungen ergibt sich eine Notwendigkeit zu einer aktiv betriebenen Notfallvorsorge und zur Planung von Notfallbewältigungsmaßnahmen. Beispielsweise sind die Vorstände größerer Kapitalgesellschaften durch KonTraG zu einem angemessenen Risikomanagement verpflichtet. Dieses wiederum erfordert auch, dass das Unternehmen ausreichend gegen Krisen und Notfälle vorgebeugt hat.

Weitere Gesetze und Verordnungen, aus denen für die betroffenen Unternehmen und Behörden Verpflichtungen zur Notfallprävention folgen, sind u. a.

- Aktiengesetz (AktG),
- Börsengesetz (BörsG),
- Mindestanforderungen an das Risikomanagement (MaRisk),
- Kreditwesengesetz (KWG 25 Abs. 1 Pkt. 3),
- Arbeitsschutzgesetz (ArbSchG),
- Störfallverordnung (12. BImSchV – StörfallV),
- Gefahrstoffverordnung (GefStoffV),
- Betriebssicherheitsverordnung (BetrSichV).

Da verwundert es nicht, dass vor allem in den letzten Jahren eine Reihe von Standards und Normen entwickelt wurden, die das Thema Notfallmanagement adressieren. Diese werden durch diverse Organisationen und Berufsverbände definiert und zyklisch verbessert. Aus rechtlicher Sicht ist die Einhaltung solcher Standards ein wichtiges Indiz dafür, dass den rechtlichen Vorgaben genüge getan ist.

Zu finden sind derartige Standards unter dem Begriff »Business Continuity Management (BCM)«. BCM ist ein seit mittlerweile mehr als 15 Jahren geprägter Begriff, der Methoden und Maßnahmen beschreibt, die eine Geschäftsfortführung – Business Continuity – im Notfall sicherstellen.

Kapitel 4 – IT-Notfalldokumentation behandelt ausführlich das Thema Notfalldokumentation. Hier finden Sie auch Erläuterungen zu maßgeblichen BCM-Standards und Leitfäden.

1.6.4 Weitere Normen mit Relevanz für die IT-Dokumentation

Abhängig von den individuellen Compliance-Anforderungen können eine Reihe weiterer Standards und Normen für das eigene Unternehmen relevant sein.

IT-Dienstleister zum Beispiel unterliegen speziell durch die von den Kunden erwartete hohe Servicequalität besonderen Anforderungen hinsichtlich der Servicequalität und Betriebssicherheit. Der Servicestandard ITIL® bietet hier ein Rahmenwerk, welches umfassende Anforderungen an die IT-Dienstleister stellt und auch Hilfestellungen zur Erfüllung von Anforderungen seitens der Gesetzgeber und der Kunden leistet. Jedoch ist eine Zertifizierung nach ITIL® nicht möglich. Die erfolgreiche Umsetzung eines IT Servicemanagements kann mit einer Zertifizierung nach ISO/IEC 20000 nachgewiesen werden.

Eine der bekanntesten ISO-Normen für die Unternehmensorganisation ist die Qualitätsmanagementnorm ISO 9001. Da diese allgemeine managementbezogene Normen darstellt, kann sie für jedes Unternehmen für eine Zertifizierung herangezogen werden. Gerade für kleinere und mittlere Unternehmen kann das Vorweisen eines derartigen Zertifikats erforderlich sein, um überhaupt Aufträge einer gewissen Größenordnung zu bekommen. Und Krankenhäuser und Reha-Kliniken sind darüber hinaus gemäß Sozialgesetzbuch V, § 135 ff. zur Einführung eines Qualitätsmanagementsystems auf Basis von ISO 9001 und zu dessen Nachweis verpflichtet.

Im Folgenden werden die beiden Normen ISO 20000 – IT-Servicemanagement und ISO 90001 – Qualitätsmanagement im Überblick vorgestellt.

ISO 9001

Eine der bekanntesten ISO-Normen für die Unternehmensorganisation ist die Qualitätsmanagementnorm ISO 9000 bzw. ihr Nachfolger ISO 9001 sowie die damit in Zusammenhang stehenden Normen ISO 9004 und ISO 19011.

EN ISO 9001 legt die Mindestanforderungen an ein Qualitätsmanagementsystem (QM-System) fest, denen ein Unternehmen zu genügen hat, um Produkte und Dienstleistungen bereitstellen zu können, welche die Kundenerwartungen erfüllen. Zugleich soll das Managementsystem einem stetigen Verbesserungsprozess unterliegen.

Die ISO-9001-Normenreihe wurde aus einer Reihe von Vorgängernormen entwickelt und erstmals 1994 veröffentlicht. Aktuell liegt die Norm in der Version 9001:2008 vor. Im Zuge der Weiterentwicklung wurde der ursprünglich funktionsorientierte Ansatz in einen prozessorientierten Ansatz verändert. Außerdem wurden Teile der Normenreihe zusammengefasst und einheitliche Begriffsdefinitionen ergänzt.

Die Grundlage für die Zertifizierung der Unternehmen stellt aktuell die ISO 9001:2008 dar, die die Anforderungen an ein Qualitätsmanagementsystem festlegt. Die Norm ist in acht Kapitel unterteilt, wobei die ersten drei Kapitel allgemeine Aussagen enthalten. Die Kapitel 4 bis 8 haben folgenden Inhalt:

- Kapitel 1–3: Vorwort und allgemeine Hinweise,
- Kapitel 4: Qualitätsmanagementsystem,
- Kapitel 5: Verantwortung der Leitung,
- Kapitel 6: Management von Ressourcen,

- Kapitel 7: Produktrealisierung,
- Kapitel 8: Messung, Analyse und Verbesserung.

Während die Kapitel 4–7 die Anforderungen an das Management allgemein und an die Kundenorientierung beschreiben, wird mit Kapitel 8 die Anlehnung an den Deming-Kreis deutlich. Hier wird der kontinuierliche Änderungsprozess dargestellt, der im Deming-Kreis mit den Prozessteilen *Plan, Do, Check* und *Act* dargestellt ist.

Grundsätzlich fordert die ISO 9001 die Einführung und die Dokumentation mindestens der folgenden sechs Verfahren:

- »Lenkung der Dokumente
- Lenkung der Qualitätsaufzeichnungen
- Durchführung der internen Audits
- Lenkung fehlerhafter Produkte
- Korrekturmaßnahmen
- Vorbeugungsmaßnahmen« (9001:2008)

Für die IT-Dokumentation ist insbesondere das Kapitel 4 von Bedeutung, da hier die Dokumentationsanforderungen beschrieben werden. Diese sind zwar nicht speziell auf die IT ausgerichtet. Wenn aber ein Unternehmen seine IT-Abteilung nach ISO 9001 zertifizieren möchte, so sind die Anforderungen nach Kapitel 4.2 direkt auf die IT anzuwenden.

Für die Dokumentation gelten folgende Anforderungsbereiche:

- Es muss ein Qualitätsmanagement-Handbuch erstellt werden, das neben der Darstellung der unternehmensbezogenen Qualitätspolitik alle für die Produkterstellung und deren Absatz erforderlichen Verfahren beschreibt. Dazu gehört ebenfalls eine Beschreibung der Wechselwirkungen mit anderen Prozessen (z. B. eine Schnittstellenbeschreibung).
- Weiter ist die Lenkung von Dokumenten und von Aufzeichnungen zu beschreiben. Wichtig sind in diesem Zusammenhang unter anderem der Nachweis der jeweils gültigen Fassung, die Kennzeichnung von Änderungen an den Dokumenten und deren lesbare Bereitstellung. Als operatives Ziel der Lenkung von Dokumenten ist zu vermeiden, dass veraltete Versionsstände verwendet werden. Zu der Beschreibung gehören auch Festlegungen zu Aufbewahrungsfristen sowie zur Archivierung.

ISO 20000

Die ISO 20000 ist eine speziell auf das IT-Servicemanagement ausgerichtete Norm und wurde im Jahr 2005 auf der Basis der gleichnamigen britischen Norm BS 15000 veröffentlicht. 2011 wurde die ISO/IEC 20000-1 einem Review unterzogen und dabei grundlegend überarbeitet. Die aktuellste Version wurde am 12.04.2011 mit der neuen Version der ISO/IEC 20000-1 veröffentlicht.

Das Ziel der Norm ISO/IEC 20000 ist es, einen gemeinsamen Referenzstandard für alle Unternehmen bereitzustellen, welche die IT-Services für interne oder externe Kunden erbringen. Ein weiteres Ziel besteht in der Förderung einer gemeinsamen Terminologie. Wie die meisten aktuellen Standards ist sie prozessorientiert ausgerichtet, beschreibt aber weniger das produktbezogene Qualitätsmanagement im Allgemeinen, sondern das IT-Servicemanagement im Besonderen. Die prozessorientierten Festlegungen orientieren sich an den Prozessbeschreibungen gemäß ITIL® und ergänzen diese.

Es besteht aber ein wesentlicher formaler Unterschied zu ITIL®. Im Gegensatz zu ITIL®, das keinen Standard darstellt, sind die Prozesse des IT-Servicemanagements nach ISO 20000 international anerkannt zertifizierbar.

Die ISO-20000-Norm ist in drei Hauptteile unterteilt:

- Teil 1 Specification – Service management system requirements (20000-1:2011),
- Teil 2 Code of Practice – Guidance on the application of Service Management System SMS (20000-2:2012),
- Teil 3 Guidance on scope definition and applicability of ISO/IEC 20000-1 (20000-3:2012).

Dabei stellt Teil 1 die zwingend erforderlichen Anforderungen dar (*must have*), während Teil 2 weitere optionale Anforderungen beschreibt (*should have*). Eine ISO/IEC-20000-Zertifizierung kann auf einen Kunden, einen IT-Serviceoder einen Standort des IT-Service-Providers begrenzt werden. Durchgeführt werden die Zertifizierungsaudits durch unabhängige Prüforganisationen.

Für eine Zertifizierung erforderlich sind eine Reihe von Dokumenten und Reports, die die Effektivität und Effizienz des Servicemanagements sowie die Planung, das Handling und die Steuerung der Serviceprozesse belegen, und es ist sicherzustellen, dass das Service-Management-System auditier- und damit nachvollziehbar ist und bleibt. Erforderlich sind:

- Richtlinien und Managementpläne,
- Service Level Agreements,
- Dokumentation der Prozesse und Prozeduren,
- aktuelle Reports.

Während aber die ISO 9001 die Dokumentationsanforderungen stark betont, sind in der ISO 20000 die Dokumentationsanforderungen implizit Voraussetzung, um die Prozesse nachvollziehbar und prüfbar zu machen.

■ 1.7 Zusammenfassung

Weder für Deutschland noch für Österreich oder die Schweiz gibt es eine allgemein gültige Verordnung oder gar ein Gesetz, die bzw. das festlegt, wie eine IT-Dokumentation auszusehen hat. Den Gesetzen und Verordnungen ist gemein, dass die beschriebenen Anforderungen mehr oder weniger allgemein gehalten sind und die konkrete Umsetzung offen bleibt. Mit der Frage, wie der Aufbau einer gesetzeskonformen IT-Dokumentation sichergestellt werden kann, werden die Verantwortlichen allein gelassen.

Normen und Standards können dabei helfen, gesetzliche Anforderungen einzuhalten, und dienen bei deren Umsetzung als Nachweis der Einhaltung. So weist ein Unternehmen, das eine Zertifizierung nach dem Sicherheitsstandard ISO 27001 erlangt hat, damit nach, dass es einen Sicherheitsprozess und die nach aktuellem Erkenntnisstand möglichen Sicherheitsmaßnahmen implementiert hat. Eine Organisation, die nicht über diese Zertifizierung verfügt, muss hierfür Einzelnachweise erbringen. So wird beispielsweise in einer Verlautbarung des IDW das Vorgehen nach ISO 27001 auf Basis von IT-Grundschutz des BSI als

probates Mittel anerkannt, um die Anforderungen der Wirtschaftsprüfung in diesem Bereich zu erfüllen. Sollte das geprüfte Unternehmen eine Zertifizierung vorweisen, so kann eine Prüfung in einem Minimalumfang erfolgen.

Ein weiterer Vorteil einer Zertifizierung betrifft den Bereich der Haftung. Bei haftungstechnischen Problemen geht es immer auch um die Frage, ob die gebotene verkehrsübliche Sorgfaltspflicht eingehalten wurde. Die Einhaltung von Normen und Standards ist hierbei ein wichtiges Kriterium. Der Nachweis einer Zertifizierung wird dann in der Regel als Beleg anerkannt, dass die gebotene Sorgfaltspflicht eingehalten wurde.

Betrachtet man die gesetzlichen Dokumentationspflichten genauer, lassen sich zusammenfassend die folgenden Inhalte bzw. Anforderungen an die IT-Dokumentation ableiten:

- Dokumentation der Organisation, Abläufe und Prozesse,
- Definition und Dokumentation der Verantwortlichkeiten,
- Sicherstellung der Nachvollziehbarkeit durch Aufzeichnungen und Protokolle.

Im Spannungsfeld der verschiedenen Anforderungen stellt sich für viele IT-Verantwortliche die Frage, wo man am besten anfängt und welche Bereiche in die Konsolidierung der IT-Dokumentation einzubeziehen sind. Was lässt sich für diese aber konkret aus den betrachteten Gesetzen, Normen und Modellen ableiten?

Neben den Anforderungen an das Qualitätsmanagement rückt die Sicherheit der IT immer stärker in den Vordergrund und die Sicherheit der betrieblichen IT ist zunehmend Gegenstand diverser Prüfungen. Zu nennen ist hier vor allem die ISO 27001 (sie beschreibt die Anforderungen an das Informationssicherheitsmanagement), die die Grundlage der Prüfungen des BSI darstellt. Und auch bei den auf den Jahresabschluss ausgerichteten Prüfungshandlungen der Abschlussprüfer sowie bei den Prüfungsaktivitäten der internen Revision ist die IT-Sicherheit ein wichtiger Gegenstand. Hierbei wird das IT-Sicherheitsmanagement als Teil des Risikomanagements des Unternehmens geprüft und bewertet. Das Unternehmen ist dabei selbst verantwortlich für eine hohe IT-Sicherheit – unabhängig davon, ob es die IT selbst betreibt oder ausgelagert hat.

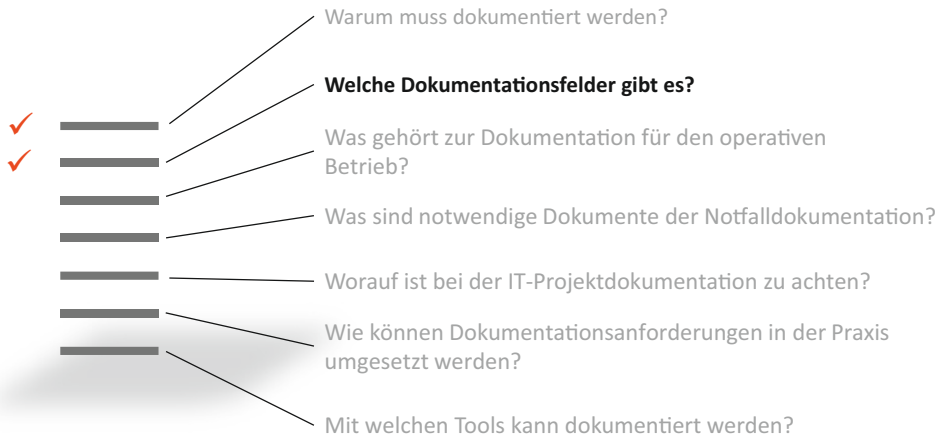
Vor allem aber ist die IT-Sicherheit die Grundlage für eine störungsfreie Geschäftstätigkeit: Sie gewährleistet, dass erforderliche Daten tatsächlich verfügbar sind, dass schützenswerte Daten vertraulich bleiben und dass ein Unternehmen mit unverfälschten und zuverlässigen Daten arbeiten kann. An die Sicherheit von Finanzdienstleistern werden zusätzliche hohe gesetzliche und aufsichtsrechtliche Anforderungen gestellt. So haben diese bereits heute die MaRisk zu erfüllen.

Während das Informationssicherheitsmanagement den Schutz der Informationen des Unternehmens adressiert, fokussiert das Notfallmanagement die kritischen Geschäftsprozesse. Ziel ist es, dass Unternehmen ihre überlebensnotwendigen, organisationsentscheidenden Schlüsselprozesse und Werte erkennen, sie vor schädlichen Einflüssen oder bedauernden Vorfällen schützen und für größtmögliche Ausfallsicherheit sorgen. Nicht nur die MaRisk fordert daher ausdrücklich die Implementierung geeigneter Notfallmanagementprozesse sowie ein Notfallhandbuch, das Geschäftsfortführungs- sowie Wiederanlaufpläne umfasst.

Häufig nicht bekannt ist, dass auch für die Projektdokumentation Vorgaben existieren. Mit den beiden Standards des IDW und des DIIR zur Prüfung von Projekten rücken auch die Projektdokumente in das Blickfeld der Abschlussprüfer. Die Art und Weise der Projektdokumentation sind somit nicht mehr in das Belieben des einzelnen Unternehmens gestellt, sondern unterliegen künftig den Anforderungen der einschlägigen Prüfungsstandards.

2

Strukturierung einer ganzheitlichen IT-Dokumentation



»Wir wollen nun endlich unsere IT-Dokumentation optimieren.« Häufig scheitert dieser gut gemeinte Vorsatz daran, dass man einfach nicht weiß, wo man beginnen soll und was alles zu berücksichtigen ist.

Zwingend erforderlich ist es deshalb, zunächst eine Strukturierung für die eigene Dokumentation zu definieren und auf dieser Basis eine Bestandsanalyse durchzuführen. Dieses Kapitel will dabei unterstützen. Im ersten Teil des Kapitels geht es um die Beantwortung der beiden Fragen: Welche Dokumentationsfelder gibt es? Wie sieht eine sinnvolle Struktur für die IT-Dokumentation aus?

Nachdem damit gewissermaßen der »Schränk« für die IT-Dokumentation steht, werden in den nachfolgenden Kapiteln »die Schubladen dieses Schränks gefüllt« und die einzelnen Bereiche detailliert vorgestellt. Dabei wird eine dieser Schubladen bereits in diesem Kapitel betrachtet. Der zweite Teil behandelt das Thema Rahmendokumente: Was sind Rahmendokumente? Welche sind erforderlich?

In diesem Kapitel finden Sie die folgenden Themenschwerpunkte:

- Services, Prozesse, Systeme – was muss dokumentiert werden?
- Bausteine einer ganzheitlichen IT-Dokumentation
- Rahmendokumente
- Abgrenzung zur Technischen Dokumentation

■ 2.1 Services, Prozesse, Systeme – was muss dokumentiert werden?

Lange Zeit war die vorherrschende Organisationsform von Unternehmen funktionsorientiert. Eine funktionsorientierte Ausrichtung ist geprägt durch vertikale Hierarchien, eine entsprechende aufbauorganisatorische Struktur und eine starke Trennung zwischen Fach- und Ressourcenverantwortung. Das heißt, jede einzelne Organisationseinheit ist nur für jeweils den eigenen Schritt in dieser Kette zuständig.

Doch immer mehr Unternehmen erkennen, dass ein ausgeprägter Servicegedanke mit einer gut funktionierenden Kundenbeziehung entscheidend für den Geschäftserfolg ist. Serviceorientierung, Prozessorientierung und Kundenorientierung stehen daher zunehmend im Fokus der Unternehmen. Und diese neue Ausrichtung erfordert veränderte Organisationsstrukturen, die auch die IT-Organisationen betreffen. Diese stehen immer häufiger in der Pflicht, sich auch als interne Service-Provider aufzustellen, die ihren internen Kunden vertraglich geregelte Dienstleistungen mit definierten SLAs anbieten. Gleichzeitig drängen in immer kürzeren Abständen neue Technologien in den Markt, die von der IT evaluiert und bereitgestellt werden müssen. Zusammen mit einer steigenden Abhängigkeit der Geschäftsprozesse von der IT ergeben sich daraus auch zunehmende Anforderungen an die IT-Dokumentation. So reicht es nicht mehr allein die vorhandenen Systeme zu dokumentieren.

2.1.1 Komponenten eines serviceorientierten IT-Betriebs

Den beschriebenen Anforderungen entsprechend, muss eine ganzheitliche IT-Dokumentation die in Bild 2.1 gezeigten Komponenten berücksichtigen. Welche Komponenten davon im Einzelfall zu berücksichtigen sind, hängt auch vom jeweiligen Grad der Service- und Prozessorientierung der IT-Organisation ab.

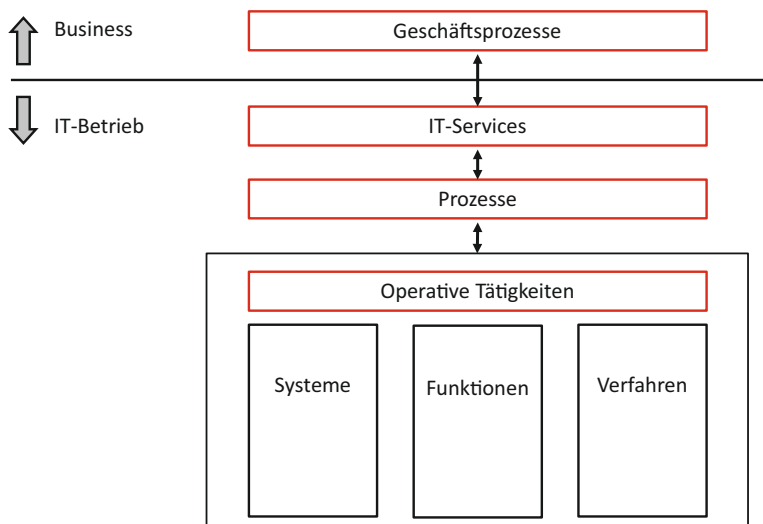


Bild 2.1 Bereiche eines serviceorientierten IT-Betriebs und deren Abhängigkeiten

Ein *Service* ist ein Mittel zur Generierung von Nutzen für den Kunden. Er liefert vereinbarte Ergebnisse, ohne dass die Kunden für die servicespezifischen Kosten und Risiken Verantwortung tragen müssen. Und ein *IT-Service* ist gemäß Definition des *IT Service Management Forum (itSMF) Arbeitskreis Publikation ITIL® Version 3 Translation Project* »eine Dienstleistung, die für einen oder mehrere Kunden von einem IT Service Provider bereitgestellt wird. Ein IT-Service basiert auf dem Einsatz der Informationstechnologie und unterstützt die Geschäftsprozesse des Kunden. Ein IT-Service besteht aus einer Kombination von Personen, Prozessen und Technologien und sollte über ein Service-Level-Agreement (SLA) definiert werden. Eine IT-Dienstleistung wird nach dem Dienstleistungsgedanken als abgeschlossene Einheit ähnlich einem Produkt angeboten«. (itSMF)

Die Serviceerbringung erfolgt durch Prozesse, für die wiederum Personen und Technologien, d. h. Ressourcen, benötigt werden.

Ein *Prozess* ist hierbei als eine Kette aufeinander aufbauender, funktionsübergreifender Arbeitsschritte bzw. Aktivitäten zu betrachten, durch die ein klar definierter Input in einen definierten (materiellen oder immateriellen) Output umgewandelt wird. Er beginnt mit einem definierten Auslöser und endet mit einem definierten Ergebnis.

Bei einer prozessorientiert agierenden IT-Organisation stehen die Geschäftsprozesse im Mittelpunkt der betrieblichen IT-Organisation und der Betrieb erfolgt auf Basis definierter Prozesse und standardisierter Verfahren. Hierbei wird das gesamte Handeln als eine Kombination von Prozessen betrachtet und Aufgaben werden organisationsübergreifend anhand von in Prozessen beschriebenen Aktivitäten bearbeitet und über Rollendefinitionen den Ressourcen aus den Organisationsbereichen zugeordnet. Alle Prozesse sind jeweils einem Prozessverantwortlichen unterstellt. Dieser ist für das Prozessergebnis verantwortlich und übernimmt die Koordination innerhalb der Prozesse und zwischen diesen. Die Mitarbeiter werden dabei bestimmten Prozessteams zugeordnet, die einen Prozess von Anfang bis Ende betreuen. Dadurch entstehen flache Hierarchien mit kurzen Informationswegen. Im Idealfall werden die Selbstorganisationsfähigkeiten der Teams gestärkt.



Beispiel: Funktionsorientierung versus Prozessorientierung

Bei einer an den Funktionen orientierten Organisationsstruktur gibt es ein Team, das für die Clientrechner und jeweils ein Team, das für Active Directory bzw. das Mailsystem zuständig ist. Außerdem gibt es noch ein Team, das den Benutzersupport verantwortet und auch Serviceanfragen abwickelt. Kommt nun ein neuer Mitarbeiter in das Unternehmen, werden in vollkommen separaten Arbeitsschritten durch unterschiedliche Personen mit dementsprechend eingeschränkten Befugnissen ein neues Benutzerkonto, ein Postfach und ein Arbeitsplatzrechner für den neuen Mitarbeiter eingerichtet. Es ist leicht vorstellbar, dass es hierbei an den Schnittstellen zu Kommunikationsproblemen und Schwierigkeiten bei der Abgrenzung der Verantwortung kommen kann.

Beim prozessorientierten Ansatz hingegen gibt es einen Prozess »Neuer Mitarbeiter«. Der Mitarbeiter benötigt einen Arbeitsplatz mit Tisch und Stuhl, einen Rechner, ein Benutzerkonto, ein Postfach und diverse Zugriffe. Alle diese Aufgaben werden als eine Abfolge von Aktivitäten betrachtet, die von einer (einzigen) Person verantwortet und koordiniert werden. Alle Informationen bleiben damit in einer Hand und die Abstimmungsprozesse werden reduziert, da die Schnittstellen und die jeweiligen Inputs und Outputs definiert sind.

Ein *Geschäftsprozess*, auch *Unternehmensprozess* genannt, ist ein Prozess, der am Unternehmenszweck ausgerichtet ist und zum Erfolg eines Unternehmens beiträgt. Typischerweise werden die Geschäftsprozesse eines Unternehmens in drei Gruppen unterteilt:

- Der wertschöpfende Betriebsablauf eines Unternehmens besteht aus *Kernprozessen* (auch als *Wertschöpfungsprozesse* bezeichnet). Durch diese Prozesse wird der Mehrwert bzw. die Wertsteigerung des Unternehmens geschaffen. Beispiele hierfür sind Produktionsprozesse, Dienstleistungsprozesse und Vertriebsprozesse.
- Daneben gibt es sogenannte *Unterstützungsprozesse* (auch als *Supportprozesse* bezeichnet). Unterstützungsprozesse stellen Ressourcen und Services zur Verfügung und sind darauf ausgerichtet, die Kernprozesse des Unternehmens zu unterstützen. Diese Prozesse erzeugen keinen direkten Kundennutzen. Zu den Unterstützungsprozessen zählen beispielsweise das interne und externe Rechnungswesen sowie das Personalwesen und auch die Informationstechnologie.
- *Managementprozesse* (auch als *Steuerungsprozesse* bezeichnet) dienen der Steuerung des Unternehmens und sind für die Verbesserung und Steuerung der Wertschöpfungsprozesse und Unterstützungsprozesse zuständig. Sie ermöglichen es, die Unternehmensziele zu verfolgen, die damit verbundenen Risiken zu definieren und zu bewerten sowie die Zielerreichung zu überwachen. Zu den Managementprozessen zählen u. a. Prozessoptimierungsprozesse, Innovationsprozesse, Strategieentwicklungsprozesse, aber auch Qualitätsmanagement- und Risikomanagementprozesse.

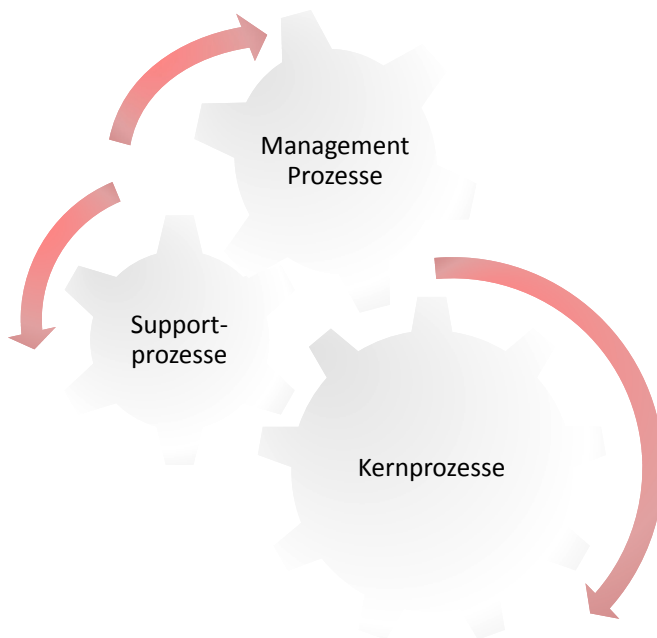


Bild 2.2 Die Kernprozesse werden von den Supportprozessen unterstützt und von den Managementprozessen gesteuert.



IT-Prozesse können auch Kernprozesse sein

IT-Prozesse werden allgemein den Unterstützungsprozessen zugeordnet. Bei einem Softwarehersteller, dessen Kerngeschäft die Entwicklung und Vermarktung von Softwareprodukten ist, gehören Softwareentwicklungsprozesse natürlich zu den Kernprozessen, die wiederum durch IT-interne Supportprozesse unterstützt werden.

Historisch bedingt sind die genannten Prozessbereiche in der Regel sehr unterschiedlich gut dokumentiert. Während viele technische Abläufe innerhalb der Kernprozesse sehr gut beschrieben sind, wurde für die meisten Unterstützungsprozesse eine Dokumentation häufig als nicht erforderlich angesehen. So gibt es wohl kaum einen Produktionsprozess oder eine technische Anlage, für die nicht in irgendeiner Form eine Betriebsanleitung vorliegt. Aber erst mit der immer stärkeren Marktdurchdringung der SAP-Software wurden auch die kaufmännischen Prozesse häufiger dokumentiert. Ähnlich verhält es sich mit den IT-Prozessen. Hier gab und gibt es viele Insellösungen, die bereits sehr gut dokumentiert sind – insbesondere im Mainframe-Bereich. Für andere IT-Bereiche fehlt eine Dokumentation häufig jedoch völlig. Außerdem ist die Dokumentation in aller Regel an den Systemen und nicht an den Prozessen ausgerichtet. Eine gesamtheitliche Dokumentation oder gar die Einbindung der IT-Dokumentation in die Strukturen einer Unternehmensdokumentation ist bisher eher selten anzutreffen.

Wie bereits ausgeführt werden für die Ausführung der Prozesse *Ressourcen* benötigt. Ressourcen für IT-Prozesse sind neben Personen vor allem die IT-Systeme, d. h. Hardware, Software, Netzwerke, Anlagen etc., die für die Entwicklung, Tests, die Bereitstellung, das Monitoring, die Steuerung oder den Support von IT-Services erforderlich sind. In diesem Zusammenhang gilt es noch den Begriff der *Funktion* zu verstehen. Aus der Perspektive von IT-Servicemanagement handelt es sich bei einer Funktion um »Ein Team oder eine Gruppe von Personen und die Hilfsmittel, die eingesetzt werden, um einen oder mehrere Prozesse oder Aktivitäten durchzuführen. Ein Beispiel dafür ist das Service Desk.« (itSMF)

Der Begriff *IT-System* ist keineswegs einheitlich definiert. So sind gemäß Bundesamt für Sicherheit in der Informationstechnik (BSI) »IT-Systeme technische Anlagen, die der Informationsverarbeitung dienen und eine abgeschlossene Funktionseinheit bilden. Typische IT-Systeme sind Server, Clients, Einzelplatz-Computer, Mobiltelefone, Router, Switches und Sicherheitsgateways.« (Glossar)

Im Duden Informatik hingegen wird der Systembegriff deutlich weiter gefasst und so auch im Buch verwendet: »System: In der Informatik versteht man hierunter die Zusammenfassung mehrerer Komponenten zu einer als Ganzes aufzufassenden Einheit. Die Komponenten können von gleicher Art (homogene Systeme, z. B. Programme) oder sehr unterschiedlich sein (z. B. die Zusammenfassung von Hardware- und Softwaresystemen zu einem System. [...]) Ein System löst oder bearbeitet in der Regel ein definiertes Bündel von Aufgaben.« (Duden, 1993)

2.1.2 Dokumente und Aufzeichnungen

Die IT-Organisation muss sicherstellen, dass das Service-Management-System nachvollziehbar ist und bleibt. Dazu sind *Dokumente* und *Aufzeichnungen* notwendig.

Was ist der Unterschied zwischen einem Dokument und einer Aufzeichnung?

- **Dokumente** (englisch Documents) sind veränderbar. Sie unterliegen formalen Anforderungen und müssen revisorische Anforderungen an Nachvollziehbarkeit, Vollständigkeit, Aktualität und Richtigkeit erfüllen. Dokumente können in einem papierbasierten oder elektronischen Format vorliegen. Typische Dokumente sind Konzepte, Prozessbeschreibungen, Richtliniendokumente, Handbücher, SLAs u. a.
- **Aufzeichnungen** (englisch Records) werden nach der Erstellung nicht mehr verändert. Sie dienen der Nachweispflicht für ordnungsgemäße Geschäftsführung und der Einhaltung von Anforderungen. Aufzeichnungen werden vielfach automatisiert erstellt. Da Aufzeichnungen nach der Erstellung nicht veränderbar sind, gibt es für diese keine Revisionsstände. Typischerweise handelt es sich bei Protokollen, Systemlogs, ausgefüllten Formularen und Berichten um Aufzeichnungen.

Wichtig ist, dass Dokumente und Aufzeichnungen unterschiedlich zu verwalten sind. Hier liefert die Qualitätsmanagementnorm DIN EN ISO 9001:2008 mit ihrer Forderung zur Einrichtung zweier Verfahren zur Lenkung von Dokumenten und zur Lenkung von Aufzeichnungen wertvolle Hinweise. Die beiden Verfahren sind wie folgt definiert:

»4.2.3 Lenkung von Dokumenten

Die vom Qualitätsmanagementsystem geforderten Dokumente müssen gelenkt werden. Aufzeichnungen stellen einen besonderen Dokumententyp dar und müssen nach den in 4.2.4 genannten Anforderungen gelenkt werden.

Ein dokumentiertes Verfahren zur Festlegung der erforderlichen Lenkungsmaßnahmen muss eingeführt werden, um

- a) *Dokumente bezüglich ihrer Angemessenheit vor ihrer Herausgabe zu genehmigen,*
- b) *Dokumente zu bewerten, sie bei Bedarf zu aktualisieren und erneut zu genehmigen,*
- c) *sicherzustellen, dass Änderungen und der aktuelle Überarbeitungsstatus von Dokumenten gekennzeichnet werden,*
- d) *sicherzustellen, dass gültige Fassungen zutreffender Dokumente an den jeweiligen Einsatzorten verfügbar sind,*
- e) *sicherzustellen, dass Dokumente lesbar und leicht erkennbar bleiben,*
- f) *sicherzustellen, dass Dokumente externer Herkunft, die die Organisation als notwendig für die Planung und den Betrieb des Qualitätsmanagementsystems eingestuft hat, gekennzeichnet werden und ihre Verteilung gelenkt wird, und*
- g) *die unbeabsichtigte Verwendung veralteter Dokumente zu verhindern und diese in geeigneter Weise zu kennzeichnen, falls sie aus irgendeinem Grund aufbewahrt werden.*

»4.2.4 Lenkung von Aufzeichnungen

Aufzeichnungen, die erstellt werden, um Nachweise der Konformität mit den Anforderungen und des wirksamen Funktionierens des Qualitätsmanagementsystems bereitzustellen, müssen gelenkt werden.

Die Organisation muss ein dokumentiertes Verfahren erstellen, um die Lenkungsmaßnahmen festzulegen, die für die Kennzeichnung, die Aufbewahrung, den Schutz, die Wiederauffindbarkeit und die Aufbewahrungsfrist von Aufzeichnungen sowie die Verfügung über Aufzeichnungen erforderlich sind.

Aufzeichnungen müssen lesbar, leicht erkennbar und wieder auffindbar bleiben.» (9001:2008)



Begriff »Dokumentation«

Im Buch finden Sie häufig den Begriff *Dokumentation*. Hierunter wird eine Zusammenstellung von Dokumenten zu einem bestimmten Sachverhalt verstanden.

■ 2.2 Bausteine einer ganzheitlichen IT-Dokumentation

Wie in *Kapitel 1* ausgeführt, ist in den vergangenen Jahren die Anzahl an gesetzlichen Anforderungen, Richtlinien und branchenspezifischen Regelungen deutlich angestiegen. Eine gut strukturierte, vollständige und aktuelle Dokumentation ist die Basis für die Umsetzung aller Compliance-Anforderungen und dient darüber hinaus als Nachweis für die Umsetzung von Maßnahmen, beispielsweise zur Sicherstellung eines angemessenen internen Kontrollsystems (IKS).

Die Schwierigkeit beim Aufbau bzw. bei der Strukturierung der IT-Dokumentation besteht aber darin, dass diese sehr unterschiedlichen Sichten von verschiedenen Benutzern Rechnung tragen muss. Und Auditoren und Prüfer haben zwangsläufig eine andere Sicht auf die Dokumentation als die Mitarbeiter des Help Desk.

Der im Folgenden vorgeschlagene und im Buch verwendete Aufbau zeigt daher lediglich eine mögliche logische Struktur, nicht jedoch die physische Strukturierung im Filesystem oder in anderen Anwendungen. In der Praxis hat es sich bewährt, mit einer solchen Strukturierung zu arbeiten, und diese als Basis für den Aufbau einer IT-Dokumentation zu verwenden. Ob die Umsetzung dann in Form von Ordnern oder beispielsweise als Metadaten im Dokumentenmanagementsystem erfolgt, spielt für die Strukturierung keine Rolle und ist unternehmensspezifisch festzulegen.

Ausgangspunkt der hier vorgestellten Struktur einer ganzheitlichen Dokumentation für den IT-Bereich sind die Geschäftsprozesse. In einer solchen Unternehmensdokumentation ist die IT-Dokumentation ein Teilbereich, der aber diverse Schnittstellen zu anderen Bereichen aufweist.

Einordnung in die Unternehmensdokumentation

Bild 2.3 zeigt die mögliche Struktur einer unternehmensweiten und an Geschäftsprozessen ausgerichteten Dokumentation. Entsprechend der im vorstehenden Kapitel dargestellten Unterscheidung in die Kernprozesse, Supportprozesse und Managementprozesse, können die nachstehenden Bereiche unterschieden werden:

- Dokumentation der Kernprozesse.
- Dokumentation der Unterstützungsprozesse. Hierzu zählt auch die IT-Dokumentation.
- Dokumentation der Managementprozesse. Beispielsweise können die Dokumente des Qualitätsmanagements, des Risikomanagements und auch des unternehmensweiten Sicherheits- und Notfallmanagements diesem Bereich zugeordnet werden.

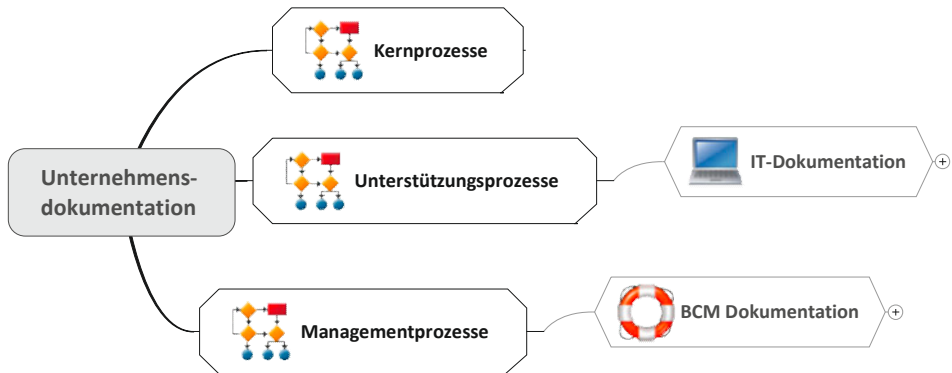


Bild 2.3 Die IT-Dokumentation als Teil der Unternehmensdokumentation

Die dargestellte Struktur bietet den Vorteil, dass zusätzliche unternehmensspezifische Dokumentationsbereiche wie beispielsweise das Qualitätsmanagement problemlos integriert werden können. Im Fokus des Buchs steht die IT-Dokumentation. Deshalb wird auf eine weitergehende Betrachtung der Unternehmensdokumentation verzichtet. Sofern sinnvoll, wird aber in den nachfolgenden Kapiteln auf die entsprechenden Schnittstellendokumente der Unternehmensdokumentation hingewiesen.

Aufbau der IT-Dokumentation

Bei der Strukturierung der IT-Dokumentation hat sich wiederum in der Praxis eine Aufteilung in vier Dokumentationsbereiche bewährt:

- **Betriebsdokumentation:** Der IT-Betrieb umfasst neben den operativen Aufgaben zur Steuerung und zur Optimierung der Systeme alle Aufgaben, die zur Erbringung von IT-Services erforderlich sind. Dies beinhaltet u. a. alle Dokumente, die zur Sicherstellung des laufenden Betriebs, zur Instandhaltung und zur Fehlerbehebung benötigt werden.
- **IT-Notfalldokumentation:** Das unternehmensweite Notfallmanagement beinhaltet alle Aufgaben der Notfallvorsorge und der Notfallbewältigung und das IT-Notfallmanagement ist ein Teil davon. Die IT-Notfalldokumentation muss daher Teil einer übergeordneten Notfalldokumentation sein. Als solche muss sie vor allem sicherstellen, dass die kritischen IT-Services auch in Notfällen verfügbar sind bzw. gemacht werden können.

- **Projektdokumentation:** Dieser Bereich beinhaltet alle Dokumente, die im Rahmen von Projekten erstellt werden und der Entwicklung und der Einführung neuer oder geänderter IT-Systeme und -Verfahren dienen.
- **IT-Rahmendokumente:** Rahmendokumente sind vor allem strategische Dokumente mit allgemeinen Vorgaben und Normierungen, sofern diese nicht auf Unternehmensebene geregelt sind. Aber auch die Dokumente des IT-Managements können den Rahmendokumenten zugeordnet werden.

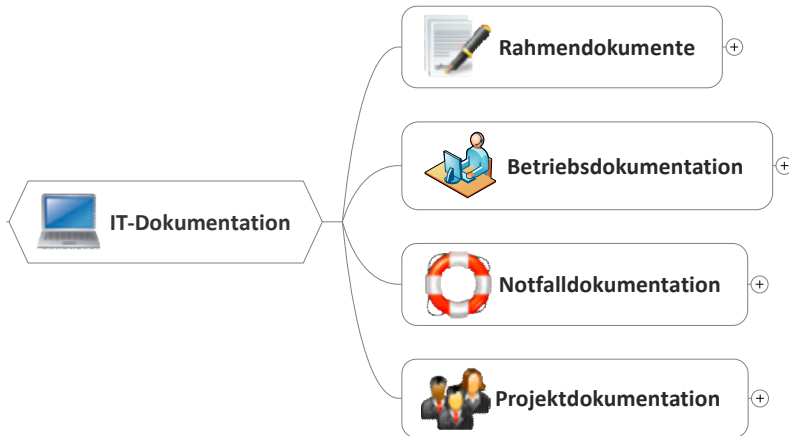


Bild 2.4 Die vier Dokumentationsbereiche der IT-Dokumentation



Ausführliche Vorstellung der Bereiche in gesonderten Kapiteln

Die folgenden Ausführungen stellen die drei Bereiche *Betriebsdokumentation*, *Notfalldokumentation* und *Projektdokumentation* im Überblick vor und bieten damit eine kurze Einführung in das jeweilige Thema.

Zusätzlich werden die drei Bereiche jeweils gesondert in einem Kapitel behandelt.

2.2.1 Betriebsdokumentation

In der Praxis besteht die Herausforderung vor allem darin, die vielen verschiedenen Dokumente, die für den IT-Betrieb benötigt werden bzw. während des Betriebs erstellt werden, zu strukturieren und sicherzustellen, dass alle Dokumente und Informationen jeweils aktuell für die unterschiedlichen Einsatzbereiche zur Verfügung stehen.

Die Strukturierung der Dokumente ist deshalb der erste und wichtigste Schritt auf dem Weg zu einer nachhaltigen Dokumentation, die nicht nur die Compliance-Anforderungen erfüllt, sondern auch die betrieblichen Abläufe unterstützt. Das in *Kapitel 3 Abschnitt 3.1* vorgestellte Strukturierungsmodell für die IT-Betriebsdokumentation kann dabei unterstützen. Dieses unterscheidet auf der obersten Ebene eine Dokumentation für die folgenden Bereiche:

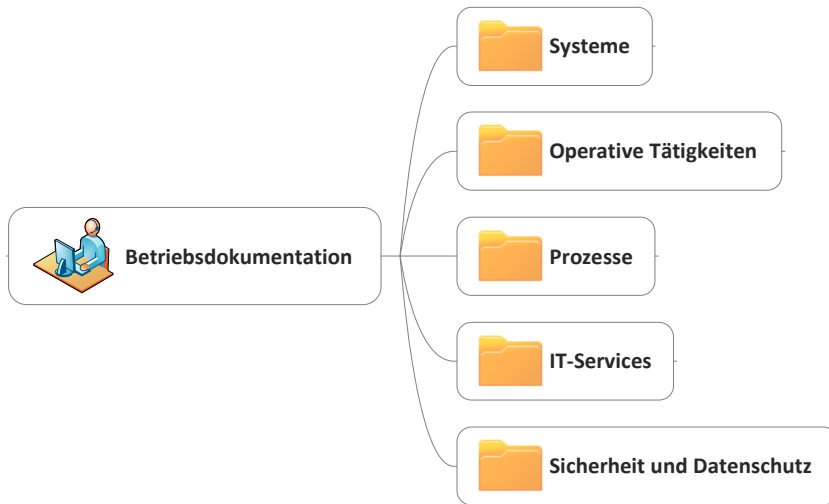


Bild 2.5 Bereiche der IT-Betriebsdokumentation

- **Systeme:** Systeme bilden die Basis für die Bereitstellung von IT-Dienstleistungen, unabhängig davon, welchen Reifegrad eine IT-Organisation hinsichtlich Service- und Prozessorientierung erreicht hat. Die Einrichtung und Pflege einer Systemdokumentation als Bestandteil der IT-Betriebsdokumentation sind daher zwingend erforderlich. Diese muss die eingesetzten Hardwarekomponenten (Server- und Clientsysteme) genauso beinhalten wie Beschreibungen des Verzeichnisdienstes, der Server- und Netzwerkdienste, der eingesetzten Anwendungen sowie der Netzwerkkomponenten. Zusätzlich gehören diverse Pläne, wie beispielsweise Netzwerkpläne, zur Systemdokumentation.
- **Operative Tätigkeiten:** Dieser Teil der IT-Dokumentation unterstützt in Form von Verfahrensbeschreibungen und Arbeitsanleitungen die Abläufe des täglichen operativen IT-Betriebs. Sind die operativen Tätigkeiten gut und nachvollziehbar dokumentiert, erleichtern sie nicht nur die Routinearbeiten. Außerdem können personelle Ausfälle leichter kompensiert werden und neue Mitarbeiter sich schneller einarbeiten. Zudem bleibt wertvolles Know-how erhalten, wenn Mitarbeiter das Unternehmen verlassen. Bei ITIL® findet man diese Dokumente unter der Bezeichnung *Standard operating procedures (SOPs)*. Damit beschreibt ITIL® ein »Set« an Dokumenten, die zum einen detaillierte Anleitungen und Zeitpläne für die täglichen Routinearbeiten und zum anderen Anleitungen zur Durchführung von Änderungen umfassen.
- **Prozesse:** Definierte, dokumentierte, wiederholbare und gelebte Prozesse sind die Basis einer erfolgreichen Serviceerbringung. Die Basis hierfür ist die Prozessdokumentation. Die Prozessdokumentation setzt sich zusammen aus den Prozessbeschreibungen der Einzelprozesse.
- **IT-Services:** In dieser Kategorie wird die Ausprägung des IT-Servicemanagements (ITSM) betrachtet. Die Aufgabe von IT-Servicemanagement ist es, die Qualität und Quantität der IT-Services zu planen, zu überwachen und zu steuern, mit dem übergeordneten Ziel, dass die IT-Services die bestmögliche Unterstützung für die Geschäftsprozesse der Kunden bieten. Die Ausprägung von IT-Servicemanagement reicht von zusammenhanglos defi-

nierten IT-Services über einen definierten Servicekatalog bis hin zu gelebten Service-Lebenszyklus-Prozessen. Dem steht eine IT-Dokumentation gegenüber, die von einzelnen Servicebeschreibungen bis hin zur Abbildung der Services in Form von Configuration Items in entsprechenden Datenbanken reicht.

- **Sicherheit und Datenschutz:** Unabhängig von der Größe oder dem aktuellen Grad der Prozess- und Serviceorientierung unterliegt jede IT-Organisation Anforderungen an die Informationssicherheit und den Datenschutz und muss diese entsprechend nachweisen. Vor allem aber ist Sicherheit die Grundlage für einen störungsfreien IT-Betrieb. Sie gewährleistet, dass erforderliche Daten tatsächlich verfügbar sind, dass schützenswerte Daten vertraulich bleiben und dass ein Unternehmen mit unverfälschten und zuverlässigen Daten arbeiten kann.



Individuelle Ausprägungen bestimmen die Struktur der Dokumentation

Jedes Unternehmen und jede IT-Organisation sind anders. Die Dokumentation muss daher ebenfalls individuell betrachtet werden und an die eigenen Anforderungen angepasst werden. Eine IT-Organisation, die serviceorientiert aufgestellt ist, benötigt auch die zugehörige Servicemanagement-Dokumentation. IT-Organisationen, deren Arbeitsweise hingegen überwiegend an den Funktionen und Systemen ausgerichtet ist, können darauf nachvollziehbarerweise verzichten. Ein Buch kann Ihnen aber natürlich nur einen generischen Ansatz liefern.

Um Sie bei der Adaption bestmöglich zu unterstützen, wurde für die Betriebsdokumentation ein fünfstufiges Strukturierungsmodell entwickelt, bei dem jede Stufe die komplette IT-Betriebsdokumentation für die beschriebene Stufe abbildet. Nachdem Sie anhand verschiedener Aspekte hinsichtlich Prozess- und Serviceorientierung des IT-Betriebs die für Sie passende Stufe ermittelt haben, finden Sie in einem gesonderten Abschnitt die für Ihre Organisation geeignete Struktur der Betriebsdokumentation sowie die erforderlichen Inhalte.

2.2.2 Notfalldokumentation

Aus einer Reihe der in *Kapitel 1* beschriebenen Anforderungen ergibt sich die Verpflichtung zur Einführung eines effektiven unternehmensweiten Notfallmanagements. Dabei herrscht noch immer in vielen Unternehmen der Irrglaube, dass mit der einmaligen Erstellung eines IT-Notfallhandbuchs, das aufzeigt, wie die Systeme im Notfall wiederherzustellen sind, alles für den Notfall getan ist. Doch nicht die Wiederherstellung der Systeme steht bei einem Notfall im Vordergrund, sondern die Wiederherstellung der Geschäftsprozesse, wie das nachfolgende Beispiel verdeutlicht.



Beispiel: BCM

Um den Fortbestand des Unternehmens im Notfall zu sichern, fordern gesetzliche Regelungen die Einführung eines unternehmensweiten Notfallmanagements. Ziel eines solchen Notfallmanagements (*Business Continuity Management – BCM*) ist die Aufrechterhaltung bzw. die Wiederaufnahme der wichtigen Geschäftsprozesse im Notfall.

Wird beispielsweise das Hauptgebäude eines Unternehmens durch einen Brand vernichtet, gilt es, an einem Ausweichstandort so schnell wie möglich einen Notbetrieb aufzubauen. Dazu gehört, abhängig vom Unternehmenszweck, in mehr oder weniger großem Umfang auch die Bereitstellung von IT-Systemen, die wahrscheinlich nicht identisch sind mit den Systemen für den Produktivbetrieb. Die Dokumentation der IT-Komponenten für den Notbetrieb sowie eine Beschreibung des Wiederanlaufs der IT-Systeme bei Rückkehr in den Normalbetrieb müssen daher Bestandteil eines übergeordneten Notfallplans sein bzw. diesen ergänzen.

Da hierbei ausschließlich die für das Überleben des Unternehmens erforderlichen Kernprozesse betrachtet werden, sind im Rahmen des Notfallmanagements IT-seitig lediglich die Systeme zu betrachten, die für eine Aufrechterhaltung dieser Prozesse bzw. für den Notbetrieb auch tatsächlich erforderlich sind.

Dass sich hinter dem Begriff Notfallmanagement außerdem ein komplexer Prozess verbirgt, wird ebenfalls gerne übersehen. Diesen Prozess beschreibt u. a. das Bundesamt für Sicherheit in der Informationstechnik (BSI) im *Standard 100-4 Notfallmanagement*, der im Februar 2009 in der finalen Version veröffentlicht wurde. Demzufolge muss der Notfallmanagementprozess sowohl die Notfallvorsorge, die Notfallbewältigung wie auch die Notfallnachsorge umfassen und besteht aus den folgenden Phasen:

- Initiierung eines Notfallprozesses und Erstellung eines Notfallvorsorgekonzepts,
- Erstellung eines Notfallhandbuchs zur Notfallbewältigung,
- Planung (Dokumentation) und Durchführung von Übungen und Tests,
- kontinuierliche Verbesserung des Notfallprozesses.

Dabei genügt es nicht, »Standardnotfälle« wie Brand- oder Wasserschäden in einem klassischen Notfallhandbuch einfach nur zu beschreiben. Vielmehr muss das Notfallhandbuch alle Informationen enthalten, um im Notfall die erforderlichen Maßnahmen zur Wiederaufnahme des wegen des Notfalls unterbrochenen Betriebs durchführen zu können. Außerdem muss es u. a. die erforderlichen Systemdaten bereitstellen, Beschreibungen der im Notfall auszuführenden Prozesse enthalten, Melde- und Eskalationswege festlegen und Wiederanlaufpläne und Ausweichprozesse für den Notbetrieb beschreiben. Wichtig ist dabei, dass es trotz der umfangreichen Anforderungen und der notwendigen Komplexität einfache und vollständige Handlungsanweisungen bietet. Und tritt ein Notfall ein, ist die Aufregung meist groß und die Gefahr, die Situation durch fehlerhaftes Verhalten zu verschlimmern, darf nicht unterschätzt werden. Um in einer Notfallsituation handlungsfähig zu bleiben, muss jeder wissen, was zu tun ist. Das aber ist nur möglich, wenn die Inhalte der Notfallpläne regelmäßig getestet und trainiert werden. In den meisten Unternehmen werden zwar Not-

fallhandbücher bzw. Notfallpläne erstellt, aber entweder gar nicht oder nur einmal getestet bzw. geübt. Viele dieser Pläne versagen dann beim ersten umfassenden Test oder schlimmstenfalls im konkreten Notfall. Aufgrund der Bedeutung und der weitreichenden Konsequenzen muss der Notfallmanagementprozess von der obersten Leitungsebene initiiert, gesteuert und kontrolliert werden.

Wie die Ausführungen zeigen, ist die IT-Notfalldokumentation zwingend als Bestandteil der Notfalldokumentation für das Unternehmen zu behandeln. Auch aus diesem Grund wird sie im Buch als eigenständiger Bereich und von der Betriebsdokumentation getrennt behandelt. Außerdem unterliegt das Management eines Notfalls anderen Abläufen – mit vom Betrieb abweichenden Regelungen.

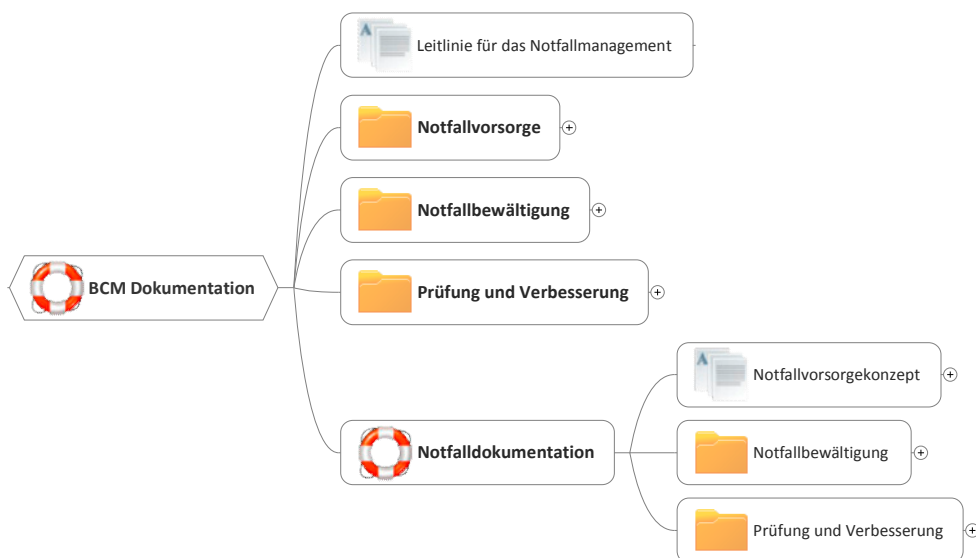


Bild 2.6 IT-Notfallmanagement muss Teil eines unternehmensweiten Notfallmanagements sein.



Gesondertes Kapitel zur Notfalldokumentation

Ausführliche Erläuterungen zu den hier angesprochenen Themen und Anleitungen zur Erstellung der erforderlichen Notfalldokumente finden Sie in *Kapitel 4*.

2.2.3 Projektdokumentation

Im Bereich der IT spielen Änderungsprozesse eine wesentliche Rolle, denn nur wenige Branchen sind wohl derartig häufig Änderungen und Anpassungen unterworfen wie die IT. Dabei können die Auslöser von Änderungen sehr unterschiedlicher Natur sein:

- gesetzliche Anforderungen,
- organisatorische Anforderungen (beispielsweise organisatorische Umstrukturierungen),

- technische Anforderungen,
- Anforderungen, die sich aus Optimierungsprozessen ergeben.

Änderungsaufgaben können sowohl innerhalb des IT-Regelbetriebs erfolgen als auch im Rahmen von Projekten. Insbesondere größere Veränderungen, die eine gesonderte Organisation und deshalb zusätzliche Ressourcen erfordern, werden meist als Projekt durchgeführt. Einen weiteren eigenständigen Baustein der IT-Dokumentation bildet die IT-Projektdokumentation.

Was aber ist überhaupt ein Projekt bzw. wodurch ist ein Projekt definiert? Einen guten Ansatz zur Projektdefinition liefert die DIN 69901-5:2009. Demzufolge ist ein Projekt ein *»Vorhaben, das im Wesentlichen durch die Einmaligkeit der Bedingungen in ihrer Gesamtheit gekennzeichnet ist«* (472, 2009) und sich durch folgende Kriterien auszeichnet:

- Zielvorgaben,
- zeitliche, finanzielle, personelle oder andere Begrenzungen,
- projektspezifische Organisation.

Die *Deutsche Gesellschaft für Projektmanagement e. V. (GPM)* erweitert diese Definition um den Aspekt der Arbeitsteilung und definiert Projekte als arbeitsteilige Prozesse. (Heinz Schelle, 2008)



DIN 69901 Projektmanagement – Projektmanagementsysteme

Die DIN 69901 »Projektmanagement – Projektmanagementsysteme« ist im Januar 2009 erschienen. Hervorgegangen ist sie aus diversen Vorgängernormen. So wurden die aus der Netzplantechnik entstandenen und mehrmals ergänzten bisherigen Normen DIN 69901, DIN 69902, DIN 69903, DIN 69904 und DIN 69905 der Projektwirtschaft in den Teilen der DIN 69901 zusammengefasst, neu strukturiert, durchgängig aktualisiert und um wesentliche Teile ergänzt. Im Mittelpunkt der neuen fünfteiligen DIN 69901 unter dem Haupttitel *Projektmanagement – Projektmanagementsysteme* steht ein Modell der Prozesse im Projektmanagementsystem. Neu hinzugekommen ist außerdem ein Datenmodell. Wichtig ist aber auch *Teil 5 – Begriffe*. Dieser Normteil fasst die bisher auf mehrere Normen verteilten Begriffe zusammen. Dabei wurde die Zahl der genormten Begriffe stark reduziert.

Bei IT-Projekten handelt es sich demzufolge um zielgerichtete sowie zeitlich, personell und sachlich abgegrenzte IT-Vorhaben. Sie beinhalten die Konzeption, die Entwicklung, die Einführung bzw. wesentliche Änderungen von IT-Systemen und IT-Verfahren. Damit dienen IT-Projekte der Erweiterung und dem Umbau des IT-Betriebs. Die Abgrenzung eines Projekts zum Betrieb ergibt sich aus der funktionalen und organisatorischen Unterschiedlichkeit. So gibt es häufig eine eigene Projektorganisation, die von der Betriebsorganisation abweicht. Gerade bei extern vergebenen Projekten ist zudem noch eine wichtige zivilrechtliche Abgrenzung wichtig. Erst nach der Implementierung und der Abnahme der Prozesse bzw. Systeme geht die Verantwortung auf das auftraggebende Unternehmen über. Eine wesentliche Grundlage für den Projekterfolg sowie die anschließende Wartung und Pflege der Systeme bzw. IT-Prozesse ist die Qualität der erstellten Unterlagen. Qualitativ hochwer-

tige Projektarbeit ist nur möglich, wenn durch die Dokumente die Projektschritte und Projektergebnisse nachvollziehbar sind.

■ 2.3 Rahmendokumente

Zusätzlich werden noch Rahmendokumente benötigt, die zum einen allgemeine Vorgaben und Normierungen regeln, sofern diese nicht auf Unternehmensebene definiert sind, und zum anderen die aufbauorganisatorischen Zuordnungen sowie die Funktionszuordnungen festlegen. Die Rahmendokumente stellen somit die Klammer für die den drei anderen Bereichen zugeordneten Dokumente dar. Sie werden im nachfolgenden Abschnitt ausführlich vorgestellt.

Ein typisches Beispiel hierfür ist die IT-Sicherheitsleitlinie. Diese ist ein Grundsatzdokument der Unternehmensleitung zum Stellenwert von IT-Sicherheit, den verbindlichen Prinzipien und dem anzustrebenden Niveau der Informationssicherheit und hat damit einen übergeordneten Charakter.

2.3.1 Rahmendokumente bilden die Klammer

Bevor die Rahmendokumente im Einzelnen vorgestellt werden, gilt es zunächst zu klären, was überhaupt ein Rahmendokument ist.

Wie bereits ausgeführt, besteht die IT-Dokumentation neben den Rahmendokumenten aus drei wesentlichen Dokumentationsbereichen:

- Betriebsdokumentation,
- Notfalldokumentation,
- Projektdokumentation.

Bei den Dokumenten, die diesen drei Bereichen zugeordnet sind, handelt es sich vorwiegend um operative Dokumente. Im Gegensatz dazu sind Rahmendokumente, wie beispielsweise die IT-Sicherheitsleitlinie oder eine Namenskonvention, allgemeine Regelwerke. Diese regeln übergreifend die allgemeinen Vorgaben und Normierungen.

IT-Management-Dokumente

Die meisten Rahmendokumente sind ein Ergebnis von IT-Management-Prozessen. Das IT-Management ist zuständig für die Steuerung der IT. Wie die Steuerung der IT erfolgt, hat ebenfalls Auswirkungen auf die Dokumentation. Viele IT-Organisationen haben eine flache Organisationsstruktur und die IT-Management-Aufgaben liegen bei der Unternehmensleitung. Bei anderen gibt es eine vielschichtige Organisationsstruktur und das IT-Management steuert alle Aufgabenbereiche. Grundsätzlich werden neben der Dokumentation für das Management der Aufbauorganisation daher auch Dokumente für das Management der Ablauforganisation benötigt.

Wichtig ist zum Beispiel die Erstellung eines Organigramms, das den Aufbau der IT-Organisation sowie die Einordnung der IT-Organisation in den Unternehmensstrukturen zeigt. Ein solches Dokument wird beispielsweise im Rahmen des Jahresabschlusses einer GmbH von den Wirtschaftsprüfern gefordert.

Zusätzlich sollten auch die Aufgabenbereiche in Form von Stellenbeschreibungen dokumentiert werden. Diese müssen Aussagen zu Tätigkeitsmerkmalen, Verantwortungsbereich, Einordnung in die betriebliche Hierarchie, Über- und Unterstellungsverhältnis sowie Stellvertretungsregelungen enthalten.



Aufgabenbereiche des IT-Managements

Gemäß Gabler Wirtschaftslexikon [<http://wirtschaftslexikon.gabler.de>] können die folgenden vier Aufgabenbereiche des IT-Managements unterschieden werden:

- *IT-Ressourcen-Management*: Das IT-Ressourcen-Management hat die Steuerung von relevanten Ressourcen, z. B. Hardware, Software, Informationen und Personal, zum Inhalt.
- *IT-Servicemanagement*: Dieses dient der Ausrichtung der IT auf ihre Kunden und bezeichnet die Gesamtheit von Maßnahmen und Methoden, die nötig sind, um die bestmögliche Unterstützung von Geschäftsprozessen durch die IT-Organisation zu erreichen.
- *IT-GRC-Management*: GRC steht als Zusammenfassung von Governance-, Risk- und Compliance-Management und dient dazu, die IT transparent und damit steuerbar zu machen, Risiken zu planen und sicherzustellen, dass die IT sich konform (compliant) zu externen Regelwerken, insbesondere Gesetzen verhält.
- *IT-Programm- und Portfolio-Management*: Im IT-Programm- und Portfolio-Management werden konkrete IT-Leistungen mit der IT-Strategie und der Geschäftsstrategie der Kunden und der Gesamtorganisation in Einklang gebracht und in sog. Programme mit ähnlichen Leistungen gruppiert, z. B. Anwendungsentwicklung, Netzwerkbetrieb oder Innovationsberatung. Innerhalb dieser Programme werden später konkrete Leistungen geplant und erbracht. (Wirtschaftslexikon)

Verwaltung der Rahmendokumente

Die Aufgaben der einzelnen Rahmendokumente können dabei sehr unterschiedlich sein. Während einige überwiegend strategisch ausgerichtet sind, wie beispielsweise das IT-Konzept, handelt es sich bei anderen um dynamische Dokumente. Zu Letzteren zählt beispielsweise das Glossar. Der von den Autoren bewusst gewählte Begriff *Rahmendokumente* (im Gegensatz zum eingrenzenden Begriff *Richtliniendokumente*) soll den übergreifenden Charakter verdeutlichen.

Rahmendokumente können sowohl auf der Ebene der IT-Dokumentation als auch auf Unternehmensebene verwaltet werden. Welche Dokumente als Rahmendokumente der IT-Dokumentation zuzuordnen sind, hängt vom Unternehmen und von dessen Dokumentenverwaltung ab und muss im Einzelfall betrachtet werden. So ist es möglich, dass bereits Dokumente

für das Unternehmen existieren, die auch für die IT-Organisationseinheiten Gültigkeit haben. Ein typisches Beispiel stellt das *Risikohandbuch* dar. Im Rahmen des gesetzlich verankerten Risikomanagements pflegen Unternehmen ein unternehmensweites Risikohandbuch, in dem grundlegende Festlegungen zum Risikomanagementprozess und zur Risikoklassifikation enthalten sind. Da aber für den Bereich der IT nicht nur unternehmensgefährdende, sondern auch servicegefährdende operative Risiken betrachtet werden müssen, kann es sinnvoll sein, ein gesondertes IT-Risikohandbuch zu führen. Dieses stellt somit eine Detaillierung des unternehmensweiten Risikohandbuchs dar.



Begriffsschaos nicht nur bei den Rahmendokumenten

Leider gibt es keine verbindlichen Definitionen oder Richtlinien für die Verwendung von Dokumentbezeichnungen. Sucht man beispielsweise im Internet nach dem Begriff »IT-Konzept«, findet man mehrere Tausend Einträge. Und fast genauso unterschiedlich ist das, was inhaltlich in einem IT-Konzept dargestellt wird. Während die einen unter einem IT-Konzept ein strategisches Papier der Unternehmensleitung verstehen, verwenden andere den Begriff IT-Konzept als Synonym für das Betriebshandbuch.

Außerdem ist der Begriff »Konzept« besonders beliebt (Berechtigungskonzept, Sicherheitskonzept, Administrationskonzept, Rollenkonzept, IT-Konzept). Dabei haben die meisten dieser Dokumente gar keinen konzeptionellen Charakter. Gemäß dem Duden ist ein Konzept ein erster Entwurf bzw. die erste Fassung einer Rede oder eines Schriftstücks. Wikipedia erweitert diese Definition um die Begriffe Plan und Programm für ein Vorhaben. Konzepte haben also grundsätzlich planerischen und strategischen Charakter.

Wichtig ist es daher, die Verwendung der Begriffe für das eigene Unternehmen festzulegen. Der folgende Abschnitt möchte für eine derartige Standardisierung Anhaltspunkte liefern. Er stellt die wichtigsten Rahmendokumente exemplarisch vor und zeigt, wie sich diese Dokumente gegen die übrigen im vorliegenden Buch beschriebenen Dokumentationen abgrenzen.

Hierbei werden Dokumente mit den dafür üblicherweise verwendeten Begriffen bezeichnet. Diese Vorgehensweise gilt auch für Dokumente mit dem Begriff »Konzept« im Namen wie beispielsweise Sicherheitskonzept und Berechtigungskonzept, auch wenn sie definitionsgemäß keine Konzepte sind. Werden für Dokumente in der Literatur bzw. im üblichen Sprachgebrauch verschiedene Namen verwendet, so werden diese (soweit bekannt) zusätzlich angegeben.

2.3.2 Die Rahmendokumente im Überblick

In diesem Kapitel werden einige wichtige Rahmendokumente im Überblick vorgestellt. Dabei steht nicht deren Inhalt oder eine detaillierte Anleitung zur Erstellung im Vordergrund, sondern vielmehr eine Beschreibung der Aufgaben des jeweiligen Rahmendokuments. Dies hat mehrere Gründe: Zum einen könnte allein die Betrachtung des zu den

Rahmendokumenten zählenden IT-Risikohandbuchs und der dahinter stehenden Prozesse das Kapitel füllen. Dies würde den Rahmen des Buchs schnell sprengen. Zum anderen gibt es aufgrund der Wichtigkeit dieser Dokumente zu den meisten der betrachteten Rahmen-dokumente umfangreiche Literatur. Bild 2.7 zeigt die wichtigsten Rahmendokumente der IT-Dokumentation. Welche Dokumente im Einzelfall zu erstellen sind und ob darüber hinaus noch Dokumente benötigt werden, hängt vom Unternehmen und dessen Aufgaben ab und muss im Einzelfall entschieden werden.

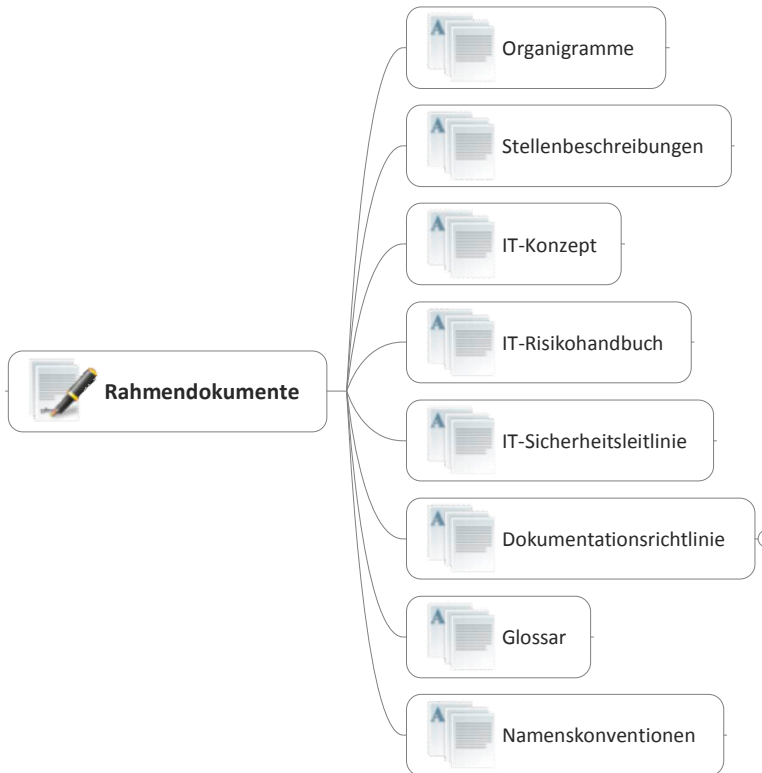


Bild 2.7 Wichtige Rahmendokumente der IT-Dokumentation

2.3.2.1 IT-Konzept

Der Begriff IT-Konzept wird sehr unterschiedlich verstanden. Beispielsweise findet man bei Wikipedia eine Gleichsetzung von IT-Konzept mit DV-Konzept: »Das DV-Konzept (ausführlich Datenverarbeitungskonzept) oder IT-Konzept ist eine Fortführung des Fachkonzeptes bei der Erstellung von Datenbanken oder bei der Programmierung. Es beschreibt die relevanten Daten und deren Verarbeitung. Die im Fachkonzept ermittelten Informationen werden auf die jeweilige Datenbank bzw. Programmiersprache angepasst. Die Aufgabenstellungen aus dem Fachkonzept werden bezüglich der Datenstrukturen und Verarbeitungsschritte strukturiert und dokumentiert«. (Wikipedia)

Im Buch wird mit dem IT-Konzept ein strategisches Dokument bezeichnet, das der grundsätzlichen Einordnung der IT in das Unternehmen dient und die übergeordnete strategische Ausrichtung des Unternehmens im Hinblick auf die IT festlegt. So wird typischerweise im IT-Konzept festgelegt, ob die IT zentral oder dezentral strukturiert ist und mit welcher Ausprägung.

Es sollte auch für die IT beschreiben, mit welchen Verfahren (z. B. nach welchen Standards) das Unternehmen welche Zwecke verfolgt. Damit kann es einen Orientierungsrahmen für die weitere Entwicklung und geplante Maßnahmen aufzeigen. Was im IT-Konzept letztendlich geregelt wird, liegt allein in der Verantwortung des Unternehmens. So kann ein IT-Konzept durchaus auch Festlegungen (Methoden und Verfahren) zur Einordnung von IT-Projekten beinhalten. Wichtig ist aber, dass es keine Details beschreibt, sondern nur grundsätzliche Regelungen festschreibt, ohne diese zu spezifizieren. Die nachstehende Liste zeigt exemplarisch eine mögliche Gliederung für ein Betriebskonzept:

- Allgemeines
 - Grundsätze
 - Zielsetzung
 - Anforderungen aus gesetzlichen Vorschriften
 - Abgrenzung zu anderen IT-Richtlinien
 - Geltungsbereich
- Organisation
 - Verantwortliche Bereiche
 - Struktur (Organigramm)
- Verantwortung
 - Aufgabenbereiche
 - Rollen
 - Kompetenzen
 - Zentrale IT-Dienstleister
 - Entscheidungspyramide

Hinsichtlich der Rollenbeschreibungen kann es sinnvoll sein, im IT-Konzept die High-Level-Rollen zu definieren. Dies ersetzt jedoch nicht das in *Kapitel 3 Abschnitt 3.8.6* beschriebene Rollenkonzept für die Betriebsrollen. Mögliche Rollendefinitionen im IT-Konzept können beispielsweise folgendermaßen aussehen:

- **Systemadministratoren:** Systemadministratoren installieren, konfigurieren und betreiben IT-Systeme. Der ordnungsgemäße Betrieb der IT-Systeme beinhaltet die Einhaltung der vereinbarten Verfügbarkeitsanforderungen, die Datenschutzvereinbarungen sowie die Anwendung und Einhaltung der jeweiligen Sicherheitsrichtlinien. Systemadministratoren haben die erforderlichen Qualifikationen für die Systemumgebung nachzuweisen.
- **Anwenderbetreuer:** Anwenderbetreuer bilden die Schnittstelle zwischen den Administratoren und dem Anwender. Sie nehmen Leistungen des 1st-Level-Supports wahr und bereiten die Serviceanfragen und Störungsmeldungen der Nutzer systematisch auf.

Können Probleme nicht vor Ort gelöst werden, organisieren und überwachen Anwenderbetreuer die Problemeskalation und Lösung. Außerdem übernehmen sie Schulungsaufgaben in der unmittelbaren Anwenderumgebung.

- **Anwendungsadministratoren:** Applikationen werden von den jeweiligen Administratoren konfiguriert und gewartet. Sie entwerfen Berechtigungskonzepte und setzen diese in der Benutzerverwaltung um. Die administrative und technische Betreuung erfolgt in enger Verbindung zur System- und Datenbankadministration. Änderungserfordernisse, die nicht durch Customizing der Anwendung und/oder des Systems erreicht werden können, sind als Entwicklungsaufgaben an das Change-Management weiterzuleiten.
- **Key-User:** Als Key-User werden Anwender eines Verfahrens verstanden, wenn sie über besondere Kenntnisse im Umgang mit und in den Funktionalitäten des Verfahrens verfügen. Sie stellen ein Bindeglied zwischen der Anwenderbetreuung und dem »Standard«-Nutzer dar und werden zu Multiplikatoren bei der Verbreitung von Know-how, bezogen auf das jeweilige Verfahren.

2.3.2.2 IT-Risikohandbuch

Ein unternehmensweites Risikohandbuch bildet die Grundlage eines unternehmensweiten Risikomanagements. Es stellt organisatorische Maßnahmen und Regelungen dar, die zur Risikoerkennung, -quantifizierung, -kommunikation, -steuerung und -kontrolle zu beachten sind. Zusätzlich liefert dieses Handbuch die Basis für die Prüfung des Risikomanagements, die sowohl extern durch den Abschlussprüfer als auch intern durch die interne Revision oder den Aufsichtsrat vorgenommen werden kann.

Nicht nur das 1998 verabschiedete *Gesetz zur Kontrolle und Transparenz im Unternehmensbereich (KonTraG)* (siehe Kapitel 1 Abschnitt 1.2.3) fordert, bestehende Risiken aufzuzeigen und der Unternehmensleitung sowie den Anteilseignern oder Investoren transparent zu machen. Während früher aber vor allem Finanzrisiken betrachtet wurden, treten heute zunehmend auch die operativen Risiken in den Vordergrund, wie sie sich beispielsweise aus dem IT-Betrieb ergeben. Zumindest in großen Unternehmen wird deshalb zunehmend vom IT-Bereich ein eigenes IT-Risikohandbuch verlangt.

Aus der historischen Entwicklung heraus ergibt sich aber ein Problem mit der Abgrenzung zum IT-Sicherheitshandbuch. Wie bereits mehrfach betont, bleiben an dieser Stelle nur eine klare Definition der Begrifflichkeiten und die Abgrenzung zu anderen Dokumenten. So kann beispielsweise das IT-Risikohandbuch als strategisches Dokument für das Risikomanagement behandelt werden, während das IT-Sicherheitskonzept einen konkreten Maßnahmenkatalog auf der Grundlage einer Risikoanalyse liefert, die zum Beispiel gemäß BSI-Standard erstellt wurde.

Da die Gewährleistung der IT-Sicherheit ein kontinuierlicher Prozess ist, genügt es nicht, das IT-Risikohandbuch einmal zu erstellen und dann alle Sicherheitsmaßnahmen umzusetzen. Vielmehr muss das Risikomanagement auf neue technische Entwicklungen reagieren und das Risikohandbuch ständig überprüfen und aktualisieren.



Business-Impact-Analyse als Basis der Risikoanalyse

Im Zusammenhang mit der Risikoanalyse taucht häufig der Begriff *Business-Impact-Analyse (BIA)* auf. Was aber verbirgt sich hinter einer »Auswirkungsanalyse«, d. h. einer BIA? Die Business-Impact-Analyse ist eine Methode des Business Continuity Management und dient der Identifizierung und Erfassung der kritischen Geschäftsprozesse eines Unternehmens. Ziel ist es, wechselseitige Abhängigkeiten zwischen den Prozessen und/oder den Unternehmensbereichen aufzuzeigen und die Auswirkungen bei Ausfall von Prozessen bzw. die notwendigen Wiederanlaufzeiten zu ermitteln.

Zusammen mit der Risikoanalyse bildet die BIA die Grundlage für eine effektive Sicherheits- und Notfallvorsorgestrategie und die Basis für das Notfallvorsorgekonzept. Weitere Erläuterungen zur Bedeutung einer Business-Impact-Analyse für das Notfallmanagement finden Sie in *Kapitel 4*. Da es sich bei der Business-Impact-Analyse um eine Unternehmensaufgabe handelt und alle Geschäftsprozesse eines Unternehmens in die Analyse einbezogen werden sollten, sind die dabei entstehenden Dokumente nicht der IT-Dokumentation zuzuordnen.

2.3.2.3 Leitlinie für die Informationssicherheit

Aufgrund der Bedeutung und der weitreichenden Konsequenzen der zu treffenden Entscheidungen sollte der IT-Sicherheitsprozess (wie auch der Notfallmanagementprozess) von der obersten Leitungsebene initiiert, gesteuert und kontrolliert werden. Zu verankern ist die Verantwortung der Unternehmensleitung für das Informationssicherheitsmanagement, ebenso wie für das Notfallmanagement, in entsprechenden Leitlinien.

Die IT-Sicherheitsleitlinie ist demzufolge ein strategisches Papier, das die zentralen Richtlinien für die IT-Sicherheit in einem Unternehmen festschreibt. Sie definiert die Sicherheitsziele und die Grundsätze für den Umgang mit Informationen sowie die Verantwortungsgebiete für die IT-Sicherheit. Sinnvollerweise sollte die Leitlinie zur Informationssicherheit Bestandteil einer übergeordneten Sicherheitsleitlinie sein.

Kleinere Unternehmen können zwar gegebenenfalls auf eine IT-Sicherheitsleitlinie verzichten, sollten aber ein IT-Sicherheitskonzept erstellen, das dann zusätzlich die strategischen Richtlinien beinhalten kann. Für eine Sicherheitszertifizierung nach BSI-Grundschutz ist die Sicherheitsleitlinie ein unverzichtbares Dokument und muss Aussagen zu den nachfolgenden Punkten enthalten:

- Stellenwert der IT-Sicherheit und Bedeutung der IT für die Aufgabenerfüllung,
- Ziele und Strategien des Unternehmens in Bezug auf die IT-Sicherheit unter Berücksichtigung geschäftlicher, gesetzlicher und vertraglicher Sicherheitsverpflichtungen,
- Organisationsstruktur für die Umsetzung der IT-Sicherheitsleitlinie und Benennung der Verantwortlichen (zum Beispiel die Ernennung eines IT-Sicherheitsbeauftragten),
- Maßnahmen zur regelmäßigen Überprüfung der Einhaltung der Sicherheitsstandards.

Vergleichbar zum IT-Konzept beschreibt die IT-Sicherheitsleitlinie keine Details, sondern sie macht grundsätzliche Vorgaben, ohne diese zu spezifizieren. Sie sollte kurz und prä-

nant sein und wird in der Regel nur selten geändert. Weiterhin wird ein IT-Sicherheitskonzept benötigt. Dieses regelt die Struktur und die konkrete Umsetzung der IT-Sicherheit (Erläuterungen zum Sicherheitskonzept finden Sie in *Kapitel 3 in Abschnitt 3.8.11*). Während also die Leitlinie Schutzziele und allgemeine Sicherheitsmaßnahmen im Sinne offizieller Vorgaben des Unternehmens vorgibt, beschreibt das IT-Sicherheitskonzept detaillierte Sicherheitsmaßnahmen und Handlungsanweisungen zum Umgang mit IT-Sicherheit im Betrieb.

Wie alle Richtliniendokumente muss die IT-Sicherheitsleitlinie sowohl in regelmäßigen Abständen wie auch anlassbezogen bei Änderungen von Rahmenbedingungen, Geschäftszielen, Aufgaben oder Strategien auf ihre Aktualität hin überprüft und gegebenenfalls angepasst werden. Zu empfehlen ist ein Reviewzyklus von zwei Jahren.

2.3.2.4 IT-Dokumentationsrichtlinie

Mit wachsender Unternehmensgröße werden die Erstellung und die Durchsetzung einer Dokumentationsrichtlinie zunehmend wichtiger. Diese wird sinnvollerweise übergeordnet auf Unternehmensebene definiert. Wo eine solche übergeordnete Richtlinie fehlt, sollte sie zumindest für die Ebene der IT-Dokumentation entwickelt werden.

Die Aufgabe einer Dokumentationsrichtlinie ist es, verbindliche Regelungen für den formalen Aufbau einzelner Dokumente festzulegen sowie verbindliche Dokumentationsprozesse zu definieren. Dazu sollte sie u. a. die folgenden Punkte regeln:

- Richtlinien und Klassifizierungen, die für alle Dokumente gelten (Namenskonventionen, Bearbeitungsstatus, Nummerierungssystem u. Ä.),
- formaler Aufbau der Einzeldokumente,
- Dokumentationsprozesse (Freigabeprozesse, Beauftragungsprozesse, Review-Verfahren usw.),
- grundsätzliche Regelungen zur Speicherung der Dokumente im Dateisystem bzw. im Dokumentenmanagementsystem.

Weitergehende Informationen zu den möglichen Inhalten einer Dokumentationsrichtlinie sowie zum Thema Standardisierung finden Sie in *Kapitel 6 in Abschnitt 6.2*.

2.3.2.5 Glossar

Ein Glossar ist definiert als eine Zusammenstellung ausgewählter (Fach-)Begriffe, die mit knappen Sätzen erklärt werden. Handelt es sich dabei um Fremdwörter oder Wörter in einer anderen Sprache, ist zusätzlich eine Übersetzung sinnvoll.

Üblicherweise befindet sich in Dokumenten im Anhang ein Glossar, das die im Dokument verwendeten Fachbegriffe und Abkürzungen erläutert. Es soll den richtigen Gebrauch der Fachausdrücke und deren eindeutiges Verständnis sicherstellen. Wichtig ist dabei, dass das Glossar definiert, wie die Begriffe im betreffenden Dokument verwendet werden. So gibt es viele Fachbegriffe, die nicht eindeutig definiert sind. Für diese Fälle ist es zwingend erforderlich, im Glossar deren jeweilige Verwendung im Dokument zu erläutern.

Um eine einheitliche Verwendung von Begriffen sicherzustellen, ist die Pflege eines zentralen Glossars sinnvoll. Dieses sollte für den Bereich der IT-Dokumentation auch die Verwendung von Dokumentenbezeichnungen definieren und diese deutlich voneinander abgren-

zen. Weiter muss die verbindliche Verwendung der Begriffe kommuniziert und sichergestellt werden, dass jeder, der Dokumente erstellt, die Bezeichnungen wie definiert verwendet.

Wird ein zentrales Glossar gepflegt, ist in den Dokumenten nur dann ein Glossar notwendig, wenn das Dokument (auch) extern Verwendung findet.

2.3.2.6 Namenskonventionen

Auf den ersten Blick mögen Namenskonventionen zweitrangig erscheinen, jedoch wird ihre Bedeutung häufig unterschätzt. Namenskonventionen gehören vielmehr zu den wichtigsten Richtliniendokumenten. Die Erarbeitung und die Umsetzung von Namenskonventionen sind der erste Schritt zur Erreichung einer konsistenten IT-Dokumentation.

Beispielsweise ist ein im Vorfeld sorgfältig geplantes, einheitliches Schema der Namenskonventionen für alle Objekte der Active-Directory-Gesamtstruktur insbesondere in großen Unternehmen unerlässlich, um Wildwuchs bei den Objektbezeichnungen zu vermeiden. Wichtig ist, dass alle mit der Vergabe von Namen betrauten Mitarbeiter von den Regelungen – dies gilt vor allem auch für externe Berater – Kenntnis haben und sie auch anwenden.

Die nachstehende Aufstellung zeigt beispielhaft die wichtigsten Systeme und Komponenten, für die typischerweise in einer Active-Directory-Umgebung die Namen standardisiert werden sollten. Die Auflistung erhebt keinen Anspruch auf Vollständigkeit und muss im Einzelfall angepasst werden.

- Server,
- Cluster-Systeme (virtuelle Server und Clusterknoten),
- Linux-/UNIX-Server,
- Clients,
- Domänen (Root-Domäne und Sub-Domänen),
- Standorte im Active Directory (Standorte, Standort-Links und Standorteigenschaften),
- Organisationseinheiten (OUs),
- Gruppenrichtlinien (GPOs),
- Gruppen,
- Benutzer (Anmeldename, angezeigter Name, E-Mail-Adresse, Beschreibung),
- administrative Benutzer (Anmeldename, angezeigter Name, E-Mail-Adresse, Beschreibung),
- Funktionsbenutzer, z.B. Hotline-Benutzer (Anmeldename, angezeigter Name, E-Mail-Adresse, Beschreibung),
- Dienstkonten,
- Dateinamen, Verzeichnisnamen, Freigabebezeichnungen, persönliche Ordner, servergespeicherte Benutzerprofile,
- Drucker (Druckername, Druckerstandort),
- Messaging-Dienst, z.B. Exchange (Exchange Server-Name, Routing Group, Connectoren, öffentliche Ordner, Verteilerlisten, persönliche Postfächer, Postfach-Alias, Funktionspostfächer).

Sind für die Produktionsumgebung und die Testumgebung unterschiedliche Namensrichtlinien erforderlich, sollte dies entsprechend berücksichtigt werden.

Daneben gibt es für den IT-Betrieb aber noch weitere Komponenten, für die eine Standardisierung von Namen sinnvoll ist. Hierzu zählen beispielsweise Konventionen zur Benennung von Prozessen und Unterprozessen sowie Regelungen zur Benennung von Rollen (beispielsweise ob englische oder deutsche Bezeichnung). Und schließlich sollten für Dokumente verbindliche Namensregeln (sowohl für Dokumententitel als auch für Dateinamen) festgelegt werden.

■ 2.4 Abgrenzung zur technischen Dokumentation

Die in den vorstehenden Kapiteln dargestellte Struktur mag fälschlicherweise den Eindruck erwecken, dass damit alle Dokumentationsbereiche erfasst sind.

Es gibt aber noch eine Reihe weiterer Dokumentationsfelder mit Bezug zur IT, die im Buch nicht berücksichtigt werden. Hierzu zählen beispielsweise die Bereiche Softwaredokumentation und Architekturdokumentation. Dies liegt daran, dass diese, wie der übrige Bereich der technischen Dokumentation ein völlig eigenständiges Aufgabengebiet darstellen mit speziellen Anforderungen und Vorgaben.

Die nachstehenden Ausführungen sollen lediglich einen Überblick über die Aufgabenbereiche der technischen Dokumentation vermitteln. Für weitere Informationen sei auf die zahlreich vorhandene Spezialliteratur verwiesen.

Technische Dokumentation

Wohl jeder hat schon einmal über die scheinbar banalen Sicherheitshinweise geschmunzelt, die in der mehrsprachigen Bedienungsanleitung auch einfachster Produkte zu finden sind. Diese sind jedoch keineswegs banal, sondern basieren auf einer ganzen Reihe gesetzlicher Anforderungen. Die Erstellung derartiger Anleitungen gehört in den Bereich der technischen Dokumentation.

Die Erstellung von Gebrauchsanweisungen für technische Produkte ist aber nur ein Teilbereich. Vielmehr ist der Begriff *Technische Dokumentation* der allgemeine Oberbegriff für die Dokumentation zu einem Produkt. Diese umfasst eine Reihe an Unterlagen, die beispielsweise eine Herstellerfirma für ihr Produkt bereitzustellen hat:

- Bedienungsanleitungen,
- Betriebsanleitungen,
- Serviceanleitungen,
- Installationshandbücher,
- Softwarehandbücher,
- ...

Diese Liste ist jedoch keineswegs vollständig, wie Bild 2.8 zeigt, das einen Eindruck von der Vielschichtigkeit der Produktdokumentation vermitteln soll.

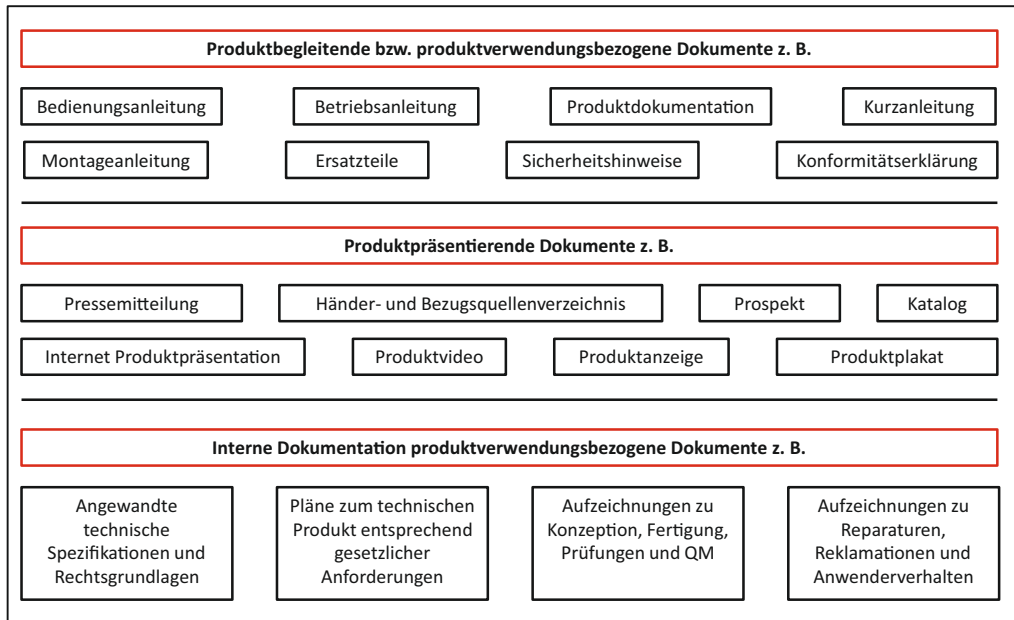


Bild 2.8 Teile der technischen Dokumentation nach (Grupp, 2008)

Eine Definition des Begriffs Technische Dokumentation, der sehr gut deren Aufgaben beschreibt, gibt Josef Grupp in seinem *Handbuch Technische Dokumentation*:

»Technische Dokumentation ist die geordnete Zusammenstellung ausgewählter Dokumente und Sprachmaterialien des Herstellers zu einem von ihm erstellten technischen Produkt, mit der er dem Verwender des Produkts den sicheren und nützlichen Umgang vermittelt und mit der er dem Gesetzgeber ein beweiskräftiges Zeugnis für die Erfüllung der gesetzlichen Anforderungen liefert bzw. ihm einen anschaulichen Beweis für die Erfüllung dieser Anforderungen gibt.« (Grupp, 2008)

Die *tekom*, der deutsche Fachverband für Technische Kommunikation und Informationsentwicklung, benennt darüber hinaus in ihrer Definition die verschiedenen Zwecke, für die technische Dokumente benötigt werden. Hierzu gehören: Produktdefinition und Produktspezifikation, Konstruktion, Herstellung, Qualitätssicherung, Produkthaftung, Produktdarstellung, Beschreibung von Funktionen und Schnittstellen, bestimmungsgemäße, sichere und korrekte Anwendung, Instandhaltung und Reparatur eines technischen Produkts sowie gefahrlose Entsorgung.

Notwendigkeiten zur Erstellung einer technischen Dokumentation ergeben sich demzufolge aus einer ganzen Reihe von Anforderungen. Um beispielsweise die Sicherheit von Produkten sicherzustellen fordern Gesetze und Vorschriften privatrechtlicher Organisationen entsprechende Dokumente von Seiten der Hersteller. Hierzu gehören in der EU Richtlinien wie die *Maschinenrichtlinie* oder die Produktsicherheitsrichtlinie, die in Deutschland in Form des *Produktsicherheitsgesetzes (ProdSG)* in nationales Recht umgesetzt wurden. Das ProdSG ersetzt seit 1. Dezember 2011 das Geräte- und Produktsicherheitsgesetz (GPSG). Es regelt die Sicherheitsanforderungen an technische Arbeitsmittel und Verbraucherprodukte und

verpflichtet Hersteller und Händler, sichere Produkte auf den europäischen Markt zu bringen. Als ein wesentliches Kriterium für die Beurteilung der Sicherheit von Produkten nennt § 3, Absatz 2, Ziffer 3 GPSG ausdrücklich die Gebrauchs- und Bedienungsanleitung und die sonstigen produktbezogenen Angaben oder Informationen, insbesondere Warnhinweise. Und § 2, Absatz 4 ProdSG betont, dass eine Gebrauchsanleitung in deutscher Sprache dem Produkt beizuliegen hat.

Es gibt aber nicht nur zahlreiche Gesetze und Richtlinien, die die Verpflichtung zur Erstellung der Dokumentation regeln, sondern auch zahllose Normen und Richtlinien, die eine Standardisierung sicherstellen und die Gestaltung technischer Dokumente regeln. In diesem Punkt unterscheidet sich die IT-Dokumentation sehr deutlich von der technischen Dokumentation, für die es zahllose Vorgaben gibt.

Softwaredokumentation

Auch die Softwaredokumentation wird zumindest rechtlich der technischen Dokumentation zugeordnet, denn demnach handelt es sich bei einer Software um ein Produkt, für das alle Aspekte von Verbraucherschutz, Haftung und Gewährleistung u. a. zum Tragen kommen und für das eine entsprechende Dokumentation zu erstellen ist. Das findet seinen Niederschlag in zahlreichen Normen und Standards zur Softwaredokumentation. Hierzu zählen u. a. die folgenden:

- »ISO/IEC 26514:2008 System and Software Engineering – Requirements for designers and developers of user documentation Die Norm ist eine Zusammenfassung und Aktualisierung der Normen IEEE 1063:2001 und ISO/IEC 18019:2004. Sie enthält sowohl die Richtlinien für den Erstellungsprozess als auch die Kriterien für das Dokumentationsprodukt.
- IEEE 1063:2001 Software user documentation Die internationale Norm beschreibt, wie eine qualitativ gute Softwaredokumentation aufgebaut und gestaltet sein sollte. Die Norm greift sowohl die Dokumentation in Papierform als auch elektronische Medien auf. Die Norm gliedert sich in Forderungen an Struktur, Inhalt und Form von Softwaredokumentation« (Grünwied)

Die vollständige Dokumentation zu einem Softwareprodukt besteht demzufolge aus unterschiedlichen Teilen, die auf verschiedene Zielgruppen ausgerichtet sind:

- Programmiererdokumentation,
- Methodendokumentation,
- Installationsdokumentation,
- Benutzerdokumentation,
- Datendokumentation,
- Testdokumentation,
- Entwicklungsdokumentation.

Nähere Informationen zu diesem Dokumentationsbereich und einen Überblick über weitere Normen finden Sie auf der Website der tecom unter dem folgenden Link: [<http://www.tekom.de>].

■ 2.5 Zusammenfassung

Aus den Ausführungen der vorstehenden Kapitel lassen sich für den Bereich der IT-Dokumentation vier wesentliche Dokumentationsbereiche ableiten:

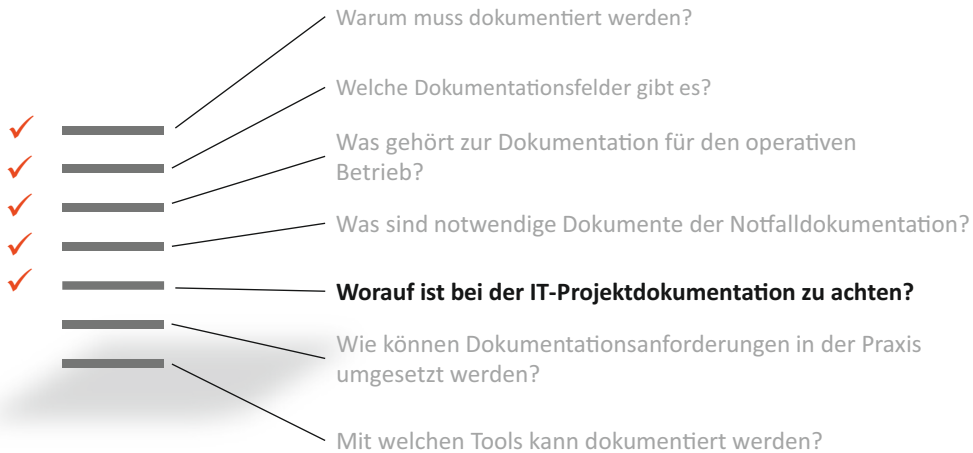
- Rahmendokumente,
- Betriebsdokumentation,
- Notfalldokumentation,
- Projektdokumentation.

Die in Bild 2.4 gezeigte Struktur bildet die Basis für das vorliegende Buch. In den folgenden Kapiteln werden diese Bereiche ausführlich vorgestellt. Die Beschreibung der Dokumentationsbereiche beinhaltet sowohl Erläuterungen zu deren Strukturierung als auch Anleitungen zur Erstellung der erforderlichen Dokumente.

Wie in diesem Kapitel ebenfalls gezeigt wurde, gibt es eine Reihe von Dokumenten, die übergeordneten Charakter haben und Regelungen und Richtlinien definieren. Sie werden im vorliegenden Buch als *Rahmendokumente* bezeichnet.

5

Dokumentation von IT-Projekten



Eigentlich gelten die für den IT-Betrieb definierten Regeln, Vorgehensweisen und Strukturen zur Erstellung und Verwaltung von Dokumenten in gleicher Weise auch für Projekte. Und doch ist bei Projekten vieles anders. Bei IT-Projekten handelt es sich um einmalige, zielgerichtete und zeitlich, personell und sachlich abgegrenzte IT-Vorhaben, die der Konzeption, Entwicklung, Einführung bzw. Änderung von IT-Systemen und IT-Verfahren dienen. Da sich Projekte gerade durch das Merkmal der Einmaligkeit vom IT-Regelbetrieb unterscheiden, steht hier nicht die Dokumentation wiederkehrender Prozesse und Tätigkeiten im Vordergrund.

Vielmehr geht es um die Dokumentation der Konzeptionierung und Realisierung von Lösungen für eine konkret gestellte Aufgabe. Konzepte gehören daher, neben den im Projekt zu erstellenden Betriebsführungsdokumenten, zu den wichtigsten Ergebnisdokumenten eines Projekts. Die in den Konzepten beschriebenen Lösungen müssen realisiert, getestet, abgenommen und gegebenenfalls noch einmal geändert werden. Die dafür erforderlichen Dokumente gehören zu den Ergebnisdokumenten, die den Schwerpunkt dieses Kapitels bilden. Daneben ist ein Projekt durch eine eigene Projektorganisation geprägt. Da sich Projekte per Definition durch eine Begrenzung an zeitlichen, personellen und finanziellen Ressourcen auszeichnen, muss mit diesen sorgsam umgegangen werden, was entsprechende

Planungen erfordert. Diese Planungsdokumente gehören zu den Projektmanagementdokumenten.

Die alleinige Betrachtung, was zu dokumentieren ist, genügt aber auch hier nicht. Denn Projekte stellen besondere Anforderungen an die Organisation der Dokumentenablage. Daher ist die Verwaltung der Projektdokumentation ebenfalls Gegenstand dieses Kapitels.

In diesem Kapitel finden Sie die folgenden Themenschwerpunkte:

- Bestandteile der Projektdokumentation
- Anforderungsgerechte Projektdokumentation
- Wichtige Dokumentationsbereiche
- Best Practices

■ 5.1 Bestandteile der Projektdokumentation

In diesem Abschnitt wird zunächst die mögliche Struktur einer Projektdokumentation näher beleuchtet. Diese ist auf der obersten Ebene sehr einfach gehalten.

Die *Projektdokumentation* (manchmal als PDO abgekürzt) ist gemäß DIN 69901-5 »die Gesamtheit aller relevanten Dokumente, die in oder aus einem Projekt entstehen, Verwendung und Anwendung finden oder anderen Bezug zum Projekt haben.« (472, 2009)

In der Literatur und im Internet wird häufig der Begriff »Projektakte« als Sammelbegriff für alle Dokumente eines Projekts und damit als Synonym für den Begriff der Projektdokumentation verwendet. Dem schließen sich die Autoren an und verwenden im Buch die Begriffe wie folgt:

- Der Begriff *Projektdokumentation* dient als übergeordnete Bezeichnung für alle Dokumente, die Bestandteil der IT-Dokumentation sind und im Rahmen von Projekten erstellt werden oder für IT-Projekte gelten. Die Projektdokumentation umfasst die Zusammenstellung und Archivierung aller Unterlagen und ermöglicht es, sich jederzeit umfassend über alle Projekte zu informieren.
- Die Projektdokumentation besteht wiederum aus den *Projekttakten*. Projekttakten bezeichnen die Zusammenstellung aller auf ein Projekt bezogenen Dokumente. Hierbei kann es sich sowohl um Dokumente des Projektmanagements, als auch um Ergebnisdokumente handeln. Für jedes Projekt ist innerhalb der Projektdokumentation eine Projektakte zu führen. Der Begriff der Projektakte wurde gewählt, da er nach Ansicht der Autoren eindeutiger ist.

Die nachstehende Grafik zeigt die Struktur der Projektdokumentation auf der obersten Ebene.

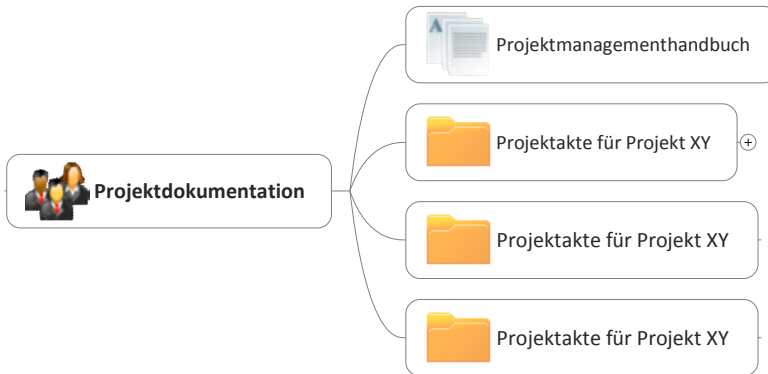


Bild 5.1 Oberste Ebene der Projektdokumentation

5.1.1 Projektmanagement-Handbuch

Das Projektmanagement-Handbuch (PM-Handbuch) enthält verbindliche Sollvorgaben für die Projektdurchführung und definierte Verfahren, nach denen Projekte im Unternehmen durchzuführen sind. Es ist nach DIN 69901-5:2009-01 eine »Zusammenstellung von Regelungen, die innerhalb einer Organisation generell für die Planung und Durchführung von Projekten gelten« (472, 2009). Das bedeutet, es enthält Richtlinien, die für alle im Unternehmen durchzuführenden Projekte gelten, mit dem Ziel, dass alle Projekte im Unternehmen nach einheitlichen Standards durchgeführt werden. Hierzu sollte das PM-Handbuch Aussagen zu den folgenden Aspekten enthalten:

- Festlegungen, was ein Projekt ist und welche Rahmenbedingungen zur Durchführung eines Projekts führen,
- Definition und Abgrenzungen der Projektarten (Entwicklungsprojekte, Organisationsprojekte, externe Projekte bei Kunden, Großprojekte usw.),
- Vorgehensmodelle für die verschiedenen Projektarten,
- grundlegender Aufbau der Projektorganisation,
- standardisierte Projektmanagementprozesse,
- Methoden und Instrumente der Projektplanung und der Projektsteuerung,
- Projektmanagementglossar mit der unternehmensspezifischen Terminologie.

Demzufolge hat das PM-Handbuch übergeordneten Charakter und ist den Unternehmensdokumenten zuzuordnen. Möglich ist aber auch, dass das unternehmensweite Projektmanagement-Handbuch lediglich allgemeine Vorgaben macht (beispielsweise die Projektorganisation vorgibt), für IT-Projekte aber zusätzlich ein gesondertes IT-Projektmanagement-Handbuch existiert. In Letzteren kann beispielsweise festgelegt werden, dass IT-Projekte grundsätzlich nach dem PRINCE2-Projektmodell durchzuführen sind.



PRINCE2 (PRojects IN Controlled Environments)

Dieser Projektstandard wurde von dem britischen *Office of Government Commerce (OGC)* entwickelt und ist eine Methode zur Organisation, zum Management und zur Steuerung von Projekten. PRINCE2 enthält verschiedene in der Praxis bewährte Methoden und liefert standardisierte Projekte, die ein einheitliches Vorgehen, einheitliches Vokabular und einheitliche Dokumente haben.

Existiert ein IT-Projektmanagement-Handbuch, so regelt dieses die verbindlichen Sollvorgaben, die für alle IT-Projekte gelten, und ist Bestandteil der Projektdokumentation wie in Bild 5.1 dargestellt. Darüber hinaus kann das IT-Projektmanagement-Handbuch Ergänzungen zu anderen unternehmensweit gültigen Dokumenten oder zu Rahmendokumenten beinhalten. Hierbei kann es sich beispielsweise um projektspezifische Namenskonventionen oder ergänzende Teile zur Dokumentationsrichtlinie handeln.



Mustervorlagen

Im Internet sind diverse Vorlagen für Projektmanagement-Handbücher zu finden. Beispielsweise finden Sie unter dem folgenden Link [<http://www.Projektmanagement-Handbuch.de/>] nicht nur ein Beispiel-PM-Handbuch, sondern auch diverse Vorlagen für Projektmanagementdokumente.

Auch wenn die Vorgaben eines solchen Projektmanagement-Handbuchs grundsätzlich für alle Projekte gelten, sollte die Umsetzbarkeit im Hinblick auf das spezielle Projekt überprüft und darauf abgestimmt werden. So kann beispielsweise bei einem kleinen Projekt die Organisationsstruktur durchaus flacher sein als gefordert.

Auch hinsichtlich der zu erstellenden Dokumente ist eine Überprüfung sinnvoll. Schließlich ist es schwierig, in einem übergreifenden Regelwerk alle Besonderheiten für alle Projekte abzudecken. Sinnvoll ist es beispielsweise, eine Liste zu erstellen, die wesentliche projektbezogene Dokumente auflistet und vorgibt, ob diese verpflichtend zu erstellen und in die Projektakte aufzunehmen sind. Zur Kennzeichnung der Dokumentationspflicht ist die folgende Unterscheidung empfehlenswert:

- **Obligatorisch:** Das Dokument ist vorgeschrieben.
- **Projektabhängig:** Das Dokument ist abhängig von der Projektkategorie oder beim Vorliegen der genannten Vorgaben verpflichtend zu erstellen. So kann beispielsweise ein Schulungskonzept verpflichtend vorgeschrieben sein, sofern sich aus dem Projekt die Notwendigkeit für Schulungen ergibt.
- **Optional:** Die Entscheidung, ob eine Dokumentation erforderlich ist, ist von den Projektverantwortlichen zu treffen.

Die nachstehende Tabelle zeigt exemplarisch einen Ausschnitt aus einer derartigen Übersichtsliste:

Tabelle 5.1 Beispiel – Festlegung der im Projekt zu erstellenden Dokumente

Dokument	Beschreibung	Verbindlichkeit	Kategorie
Projektmanagementdokumente			
Projektsteckbrief	Er enthält alle wichtigen Daten und Rahmenbedingungen. Bei extern zu vergebenden Projekten kann er die Grundlage für den Projektauftrag bilden.	Obligatorisch	Alle
Machbarkeitsstudie	Um Fehlinvestitionen zu verhindern, wird bei Zweifeln an der Erreichbarkeit des Projektziels eine Machbarkeitsstudie durchgeführt.	Projektabhängig	Großprojekte und im Vorfeld von Forschungs- und Entwicklungsprojekten
Meilensteinplan	Im Meilensteinplan sind alle Meilensteine des Projekts zusammengefasst. Damit strukturiert er das Projekt durch das zeitliche Festlegen von Teilzielen.	Obligatorisch	Alle
Interne Veröffentlichungen	Broschüren, Flyer, Newsletter, Intranetveröffentlichungen usw. Bei vielen Projekten (insbesondere Großprojekten) ist das Akzeptanzmanagement ein wesentlicher Erfolgsfaktor.	Projektabhängig	Großprojekte. Soweit Informationen oder Unterlagen erarbeitet werden, sind diese der Projektdokumentation beizufügen.
Pressemitteilungen	Sind im Rahmen der Presse- und Öffentlichkeitsarbeit zu erstellen.	Optional	Ist bei Großprojekten oftmals üblich.
Change-Request-Bericht	Änderungen (Change Requests), die sich im Hinblick auf den ursprünglichen Projekteinhalt ergeben und wesentliche Auswirkungen haben, sind in einem Bericht zusammenzufassen.		Alle
usw.	usw.	usw.	usw.
Ergebnisdokumente			
Konzepte	Konzepte beschreiben die technisch zu realisierende Lösung für eine bestimmte Aufgabe. Sie liefern damit für einen spezifischen Themenbereich eine Absichtserklärung über das, was gemacht werden soll, und beschreiben den Weg zum Ziel.	Obligatorisch	Die Art der erforderlichen Konzepte ist projekt- und prozessabhängig.
Schulungskonzept	Schulungen sollen die anwenderbezogene Nutzung im täglichen Betrieb sicherstellen. Das Schulungskonzept dient der Planung der Schulungen.	Projektabhängig	Sofern Anwenderschulungen erforderlich sind, ist ein Schulungskonzept zu erstellen.
Testkonzept	Umfasst Testorganisation, Testpläne, Testabläufe, konkrete Testfallbeschreibungen und Testtools.	Obligatorisch	Alle
Übergabeprotokoll	Dokumentation des Überförungsprozesses (Verantwortliche und Beteiligte, Zeitpunkt, Ergebnisse, Mängel usw.)	Obligatorisch	Alle
usw.	usw.	usw.	usw.

5.1.2 Projektakten

Die Projektdokumentation besteht aus den einzelnen Projektakten wie in Bild 5.1 dargestellt. Für jedes Projekt ist eine gesonderte Projektakte einzurichten und zu pflegen. Innerhalb der Projektakten ist eine Unterscheidung in Dokumente für das Projektmanagement und in Ergebnisdokumente sinnvoll. Zu den Ergebnisdokumenten zählen alle Dokumente, die vom Projekt zu erstellen sind. Hierzu zählen u. a. alle Anforderungsdokumente, aber auch Konzepte und Testdokumente (siehe *Abschnitt 5.3*).

Eine Unterscheidung ist auch deshalb sinnvoll, da es hierfür unterschiedliche Verantwortlichkeiten gibt. Für die Dokumente der Projektsteuerung und Projektüberwachung ist die Projektleitung verantwortlich, während die Ergebnisdokumente vom Projektteam zu erstellen sind.

Bild 5.2 zeigt eine Möglichkeit für den inhaltlichen Aufbau einer Projektakte.

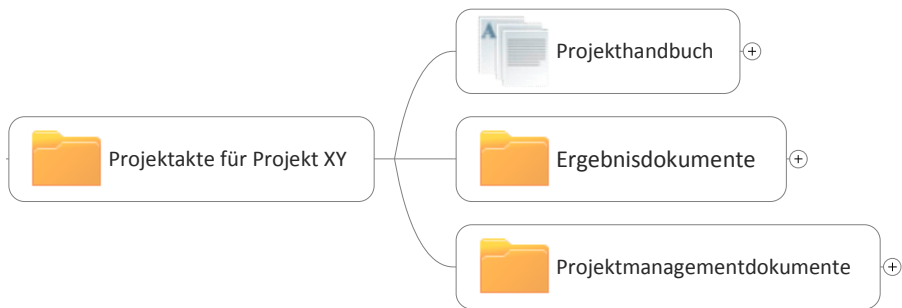


Bild 5.2 Exemplarische Gliederung einer Projektakte

Projekthandbuch

Wie beschrieben ist das Projektmanagement-Handbuch eine Zusammenstellung von Regelungen, die übergeordnet für alle Projekte gelten. Zusätzlich kann es sinnvoll sein (vor allem für größere Projekte), ein Projekthandbuch zu erstellen. Das Projekthandbuch ist die »Zusammenstellung von Informationen, Standards und Regelungen, die für ein bestimmtes Projekt gelten« (472, 2009).

Im Gegensatz zu einem Projektmanagement-Handbuch enthält das *Projekthandbuch* also die speziell für das betrachtete Projekt geltenden Vereinbarungen und ergänzt gegebenenfalls das Projektmanagement-Handbuch. In ihm finden sich zentral alle wichtigen Informationen zum spezifischen Projekt. Hierbei sollte auf Wiederholungen aus dem PM-Handbuch verzichtet und stattdessen referenziert werden. Außerdem ist das Projekthandbuch ein »lebendes Dokument«, das während des Projekts bei Bedarf erweitert und aktualisiert wird.

Bild 5.3 zeigt beispielhaft die mögliche Gliederung eines Projekthandbuchs.

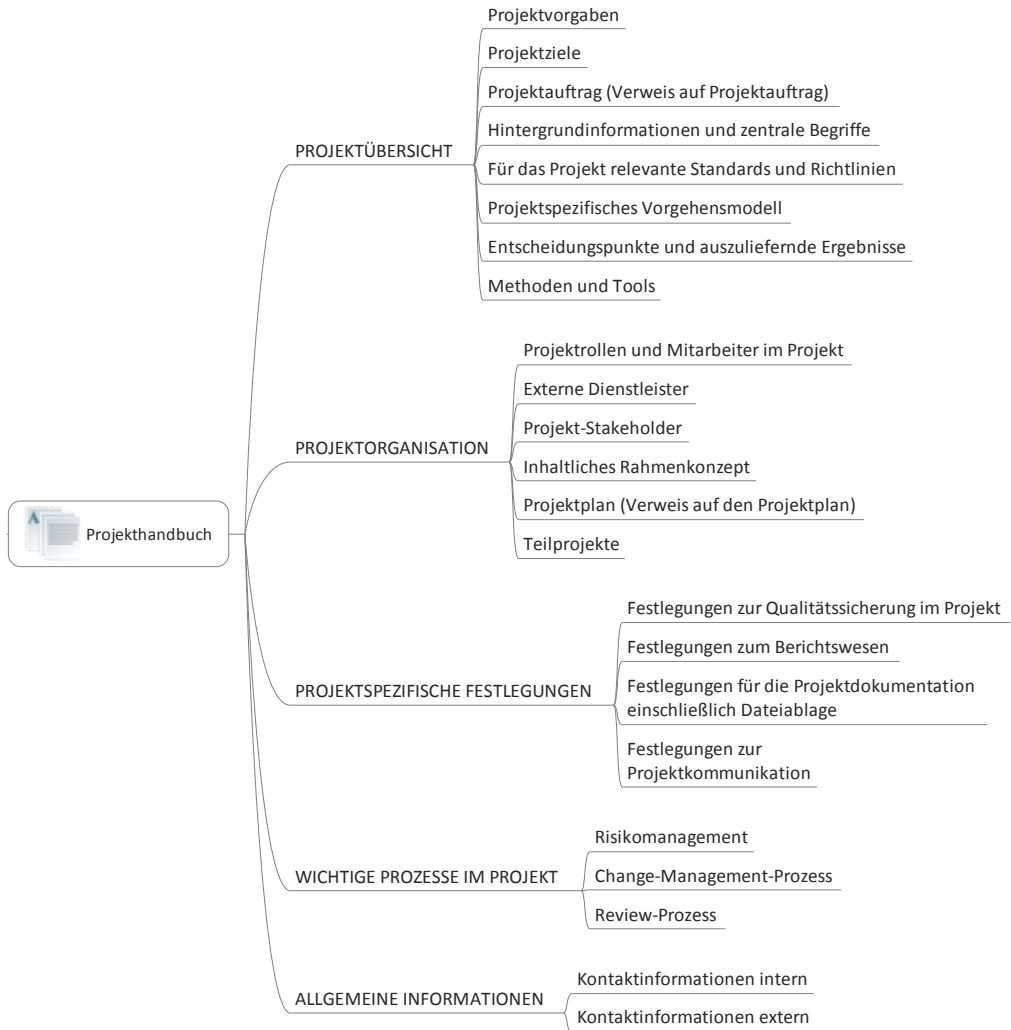


Bild 5.3 Mögliche Inhalte eines Projekthandbuchs

■ 5.2 Anforderungsgerechte Projektdokumentation

Eine erfolgreiche Projektdurchführung erfordert ein wirksames Projektmanagement. Wie bereits in Kapitel 1 ausgeführt, können Normen und Standards dabei helfen, Anforderungen einzuhalten, und dienen gleichzeitig als Nachweis der Einhaltung.

In Bezug auf das Projektmanagement kann vor allem die *DIN 69901 Projektmanagement – Projektmanagementsysteme* hilfreich sein. Diese definiert Projektmanagement als die »Gesamt-

heit von Führungsaufgaben, -organisation, -techniken und -mitteln für die Initiierung, Definition, Planung, Steuerung und den Abschluss von Projekten.» (472, 2009) Damit verbunden ist die Erstellung zahlreicher Dokumente. Wer sich darüber informieren möchte, welche Projektmanagementdokumente mit welchen Inhalten zu erstellen sind, findet hierzu zahlreiche Literatur in Form von Printmedien und im Internet.

Die DIN 69901 »Projektmanagement – Projektmanagementsysteme« ist im Januar 2009 auf der Grundlage von Vorgängernormen erschienen und besteht aus fünf Teilen:

- DIN 69901-1 *Grundlagen*
- DIN 69901-2 *Prozesse, Prozessmodell*
- DIN 69901-3 *Methoden*
- DIN 69901-4 *Daten, Datenmodell*
- DIN 69901-5 *Begriffe*

Im Mittelpunkt der fünfteiligen DIN 69901 unter dem Haupttitel Projektmanagement – Projektmanagementsysteme steht ein Modell der Prozesse im Projektmanagementsystem. Neu hinzugekommen ist außerdem ein Datenmodell. Wichtig ist aber auch Teil 5 – Begriffe. Dieser Normteil fasst die bisher auf mehrere Normen verteilten Begriffe zusammen. Dabei wurde die Zahl der genormten Begriffe stark reduziert.

Vielfach übersehen wird jedoch, dass die Projektdokumentation auch Compliance-Anforderungen unterliegt. Die Bedeutung von Projekten als strategischer Erfolgsfaktor für die Zukunftsfähigkeit von Unternehmen hat zwar in den letzten Jahren weiter zugenommen, aber Projekte liefern häufig nicht die gewünschten Ergebnisse. Viele IT-Projekte scheitern und das Scheitern ist zum größten Teil direkt oder indirekt auf unzureichendes Projektmanagement zurückzuführen. Da ist es nur folgerichtig, dass Projekte verstärkt Prüfungen unterzogen werden.

An dieser Stelle lohnt zunächst ein Blick in den *IDW Standard PS 850 – Projektbegleitende Prüfung bei Einsatz von Informationstechnologie*. Dieser beschreibt auf Basis der Ordnungsmäßigkeitsanforderungen des PS 330 »die Prüfungsanforderungen an die in den jeweiligen Projektphasen getroffenen Entscheidungen des Managements zu Neuentwicklungen, Änderungen oder Erweiterungen IT-gestützter Rechnungslegungssysteme, in Bezug auf die für die Buchführung bestehenden Ordnungsmäßigkeits-, Sicherheits- und Kontrollanforderungen.« (PS 850). Zwar bezieht sich der Standard auf Projekte zur Einführung IT-gestützter Rechnungslegungssysteme, doch findet er auch darüber hinausgehend Anwendung.

Im Standard heißt es »Das Management des Unternehmens ist für die sachgerechte Planung, Durchführung, Organisation und Überwachung von IT-Projekten verantwortlich und muss angemessene Maßnahmen ergreifen, um den Risiken aus der Projektdurchführung (Projektrisiken) begegnen zu können. Das Projektmanagement regelt die Einrichtung und Anwendung geeigneter aufbau- und ablauforganisatorischer Anweisungen und Verfahren (Projektorganisation) und die Überwachung der Projektziele und Projektkosten (Projektcontrolling).« (PS 850)

Ziel der projektbegleitenden Prüfung ist es, frühzeitig Risiken aus dem Projekt zu erkennen und diesen rechtzeitig entgegenzusteuern. Die Prüfung des Projektmanagements richtet sich insbesondere darauf, ob eine der Komplexität des IT-Projekts angemessene phasenorientierte Projektsteuerung gewährleistet sowie ein entsprechendes Projektcontrolling vorgesehen ist und ob die projektbezogenen Kommunikations- und Dokumentationsverfahren eingehalten werden.

Aber auch Revisionen prüfen verstärkt im Rahmen der risikoorientierten Prüfung der Aufbau- und Ablauforganisation die Projektmanagementorganisationen und -prozesse. Grundlage ist hierbei häufig der *DIIR Standard Nr. 4 – Standard zur Prüfung von Projekten*. Der Standard beschreibt Art, Inhalt und Umfang der Projektrevision mit dem Schwerpunkt Projektmanagementrevision und gibt erste, allgemein gehaltene Empfehlungen zur Prüfungsdurchführung. Die Prüfgebiete eines Projekts enthalten weitere Teilgebiete, sogenannte Prüffelder (Prozesse, Produkte, Dokumente und Organisationselemente). Beide werden in einer Matrix dargestellt, der *Project Audit Universe*, die damit eine gute Übersicht über die Anforderungen an die Projektdokumentation bietet.

Prüfgebiete und Projektphasen	PROJEKT PHASE I Findung	PROJEKT PHASE II Planung	PROJEKT PHASE III Durchführung	PROJEKT PHASE IV Abschluss	PROJEKT PHASE V Nachschau
I. Prüfgebiet Projektmanagement					
1. Projektorganisation	Projekt-auftraggeber	Plan, Projekt-organisation, Projektleiter	Projekt-organisation, Projektrollen	Projekt-organisation, Projektrollen	Auflösung Projekt-organisation
2. Integrationsmanagement	Projektmandat, Vorläufiger Projektauftrag, Offene-Punkte-Liste	Projektplan, Projektstrukturplan, Projektmanagement-Plan, Bearbeitung der Offene-Punkte-Liste	Projektleitungssitzungen, Lenkungsausschusssitzungen, Dokumentierte Entscheidungen, Offene-Punkte-Management	Übergabe der Offenen Punkte an Linie	Ideen für Anschluss-Projekte
3. Inhalts- und Umfangsmanagement		Change Management Plan, Change Request Formular	Änderungsanträge, Update des Projektplans	Übergabe der Projektergebnisse an Linie	
4. Zeitmanagement		Meilensteinplan, Aktivitätenplan und Reihenfolgeplanung, Ressourcen und Arbeitspakete, Kritischer Pfad	Zeitmanagement, Maßnahmen zur Einhaltung, Update der Pläne		

Bild 5.4 Ausschnitt aus der *Project Audit Universe*-Matrix – Quelle: DIIR Standard Nr. 4 (DIIR)

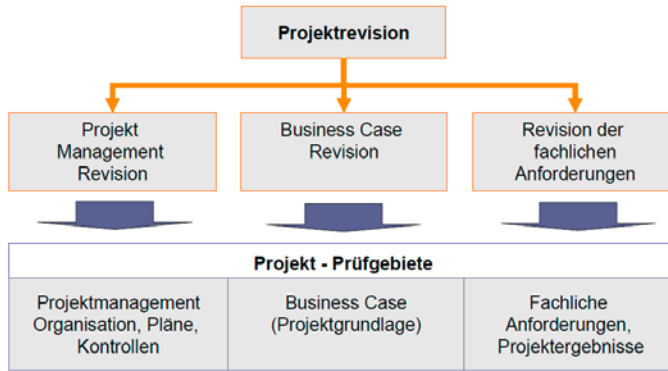


Bild 5.5 Prüfgebiete der Projektrevision – Quelle: DIIR Standard Nr. 4 (DIIR)

Die folgenden Abschnitte erläutern auf der Basis der vorgestellten Anforderungen den möglichen Aufbau und die Inhalte einer Projektdokumentation.



Weitergehende Informationen

In *Kapitel 1 in Abschnitt 1.4* finden Sie weitere Erläuterungen zu den hier vorgestellten Standards des IDW und des DIIR sowie Ausführungen zu den allgemeinen Anforderungen von Prüfern und Revisoren an die Dokumentation.

5.2.1 Phasen- und prozessorientierte Dokumentenstruktur

Eine Unterteilung eines Projekts ist nicht nur für die Projektsteuerung wichtig, sondern bietet auch eine gute Strukturierungsmöglichkeit für die Dokumentation und kann ebenso bei der Identifizierung der erforderlichen Projektmanagementdokumente hilfreich sein.

5.2.1.1 Projektphasen

Projektphasen bilden die oberste Ebene der ablaufbezogenen Projektstruktur. Auch die DIN 69901-2:2009-01 strukturiert das Projektmanagement entlang der Projektphasen. Während die *Projektphasen* den Lebensweg eines Projekts in handhabbare Abschnitte unterteilen, beschreiben die *Projektprozesse* alle Tätigkeiten, die zur Planung und Steuerung eines Projekts sowie zur Erzeugung des Projektprodukts erforderlich sind.

Eine Projektphase ist ein zeitlicher Abschnitt im Projektverlauf, der sachlich von anderen Abschnitten getrennt ist und mit einem definierten Ergebnis endet. Die Unterteilung eines Projekts in Projektphasen erlaubt es, die anstehenden Aufgaben detailliert zu planen. Der Übergang von einer abgeschlossenen Phase zur nächsten ermöglicht außerdem einen Rückblick auf die bislang erreichten Ergebnisse und eine Kontrolle hinsichtlich der Projektziele.

Die Phasengliederung ist grundsätzlich abhängig von der Art des Projekts und vom verwendeten Vorgehensmodell. Bei den Projektarten wird üblicherweise zwischen Investitionsprojekten, Organisationsprojekten und Forschungs- und Entwicklungsprojekten unterschieden. Zusätzlich werden zunehmend IT-Projekte als eigene Projektart behandelt. So

unterscheidet sich beispielsweise der Ablauf eines Investitionsprojekts, das dem Bau eines Rechenzentrums dient, nachvollziehbarerweise vom Ablauf eines Systemmigrationsprojekts.

Projektmanagementmethoden und Vorgehensmodelle bieten einen Rahmen, in dem ein Projekt geordnet ablaufen kann. Sie bestimmen die Methoden und Elemente des Projektmanagements und geben Prozesse und Phasen eines standardisierten Projektablaufs vor. Aus diesem Grund bilden die jeweils eingesetzten Vorgehensmodelle und Methoden einen zentralen Bestandteil des Projektmanagement-Handbuchs. Bekannte Vorgehensmodelle sind u. a. das V-Modell und das Wasserfallmodell. Daneben gibt es noch herstellerabhängige Modelle. Zu Letzteren zählt beispielsweise das *Microsoft Solutions Framework (MSF-Modell)*, das speziell für die Einführung von Microsoft-Technologien entwickelt wurde. MSF hilft dabei, Lösungen auf Basis von Microsoft-Produkten zu entwickeln bzw. in den Betrieb zu überführen, und stellt dafür eine Sammlung von Konzepten, Methoden und Best Practices zur Verfügung.



Wasserfallmodell und V-Modell

Das Wasserfallmodell ist das wohl bekannteste Vorgehensmodell für die Softwareentwicklung. Software wird nach diesem Modell in mehreren Phasen entwickelt. Dabei gehen die Phasenergebnisse wie bei einem Wasserfall immer als bindende Vorgaben für die nächst tiefere Phase ein.

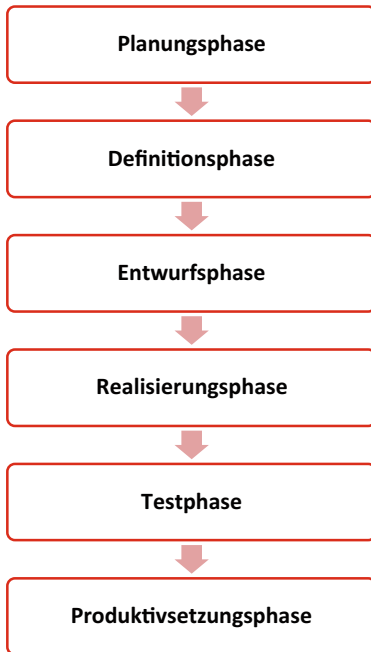
Eine Erweiterung des Wasserfallmodells ist das V-Modell. Das V-Modell ist ein Entwicklungsstandard für die Planung und Durchführung von IT-Systementwicklungsprojekten und wurde zunächst für die Bundeswehr und dann für Behörden entwickelt und ist eine geschützte Marke der Bundesrepublik Deutschland.

Das Modell hat vier Submodelle:

- PM: Projektmanagementmodell
- QS: Qualitätssicherungsmodell
- KM: Konfigurationsmanagementmodell
- SE: Systemerstellungsmodell

Die aus dem IDW Standard PS 850 stammenden Phasen sind so oder ähnlich bei fast allen Modellen bzw. Standards zu finden. Sie werden hier exemplarisch vorgestellt.

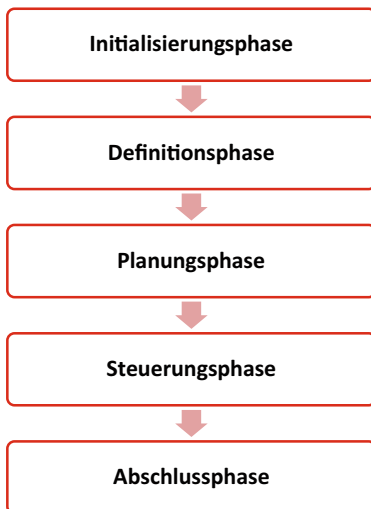
- *»In der Planungsphase werden der Projektplan und die Projektkalkulation erarbeitet sowie die Aufgabenbeschreibung (Lastenheft) festgelegt.*
- *Die Definitionsphase dient der Erstellung der fachlichen Pflichtenhefte.*
- *In der Entwurfsphase wird das fachliche Pflichtenheft in technische Entwurfsspezifikationen überführt.*
- *In der Realisierungsphase wird das Programm erstellt und Entwicklungstests unterzogen.*
- *In der Testphase werden die Modul-, Integrations- und Lasttests durchgeführt und das Programm für den Regelbetrieb freigegeben.*
- *In der Produktivsetzungsphase wird die Individualsoftware in den Regelbetrieb und in die Geschäfts- und Kontrollprozesse integriert.« (PS 850)*

**Bild 5.6**

Projektphasen gemäß IDWStandard PS 850

5.2.1.2 Projektmanagementphasen

Zusätzlich zu den Projektphasen definiert Norm DIN 69901-3:2009-01 fünf *Projektmanagementphasen*. Diese orientieren sich an den logisch zusammenhängenden Aufgaben des Projektmanagements:

**Bild 5.7**

Projektmanagementphasen gemäß DIN 69901-3:2009-01

Eine Unterscheidung zwischen Projektphasen und Projektmanagementphasen erscheint auf dem ersten Blick ungewöhnlich, zumal in der Praxis die Phasen parallel ablaufen. Sie erleichtert aber insbesondere in Bezug auf die Dokumentation eine Strukturierung. Außerdem ermöglicht dieser Ansatz eine Betrachtung aller Projektmanagementaktivitäten in Form von Prozessen, die unabhängig von der Projektart für alle Projekte Anwendung finden können.

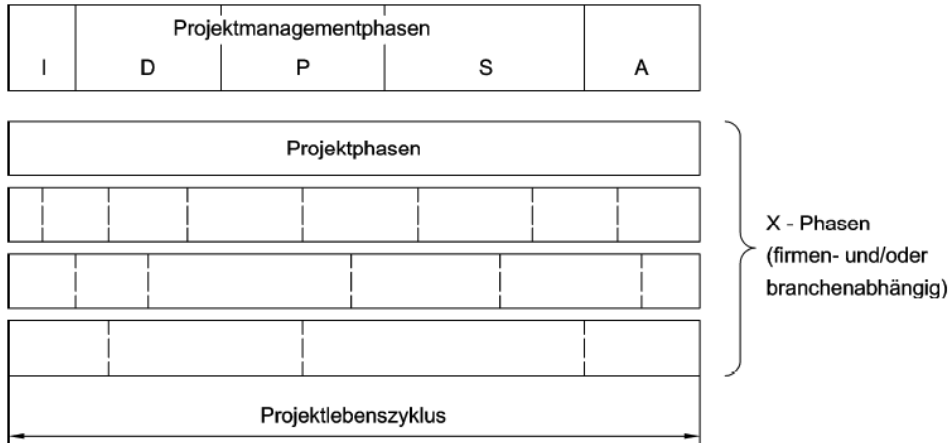


Bild 5.8 Projektmanagementphasen und Projektphasen – Quelle: 472, 2009

5.2.2 Prozesse im Projektmanagement

Die DIN 69901 beschreibt Projektmanagement als das fortwährende

»Planen, Organisieren, Überwachen, Lenken, Berichten und Ergreifen notwendiger Korrekturmaßnahmen in allen Projektprozessen, die benötigt werden, um die Projektziele zu erreichen. ... Das gewünschte Ergebnis wird wirksamer erreicht, wenn Tätigkeiten und damit verbundene Ressourcen als Prozess geleitet und gelenkt werden.« (472, 2009)

Von diesem Ansatz ausgehend bildet die Norm alle für das Projektmanagement wesentlichen Tätigkeiten als Prozesse ab und ordnet diese den Projektmanagementphasen zu.

In Kapitel 2 in Abschnitt 2.1.1 wurde erläutert, dass die Geschäftsprozesse eines Unternehmens typischerweise den drei Gruppen *Kernprozesse*, *Managementprozesse* und *Unterstützungsprozesse* zugeordnet werden. Eine daran angelehnte Unterscheidung nimmt die DIN 69901-2:2009-01 für die projektbezogenen Prozesse mit dem Modell des sogenannten *Prozesshauses* vor.

- Zu den *Wertschöpfungsprozessen* zählen alle Prozesse, die mit der Erfüllung der fachlich-inhaltlichen Aufgabenstellung des Projekts zu tun haben.
- Die Prozessgruppe *Führungsprozesse* stellt die Prozesse dar, die aus Projektmanagement-sicht eine übergeordnete Rolle spielen. Hierzu zählen beispielsweise die Projektbeauftragung durch die Geschäftsleitung und die Prozesse des Multi-Projektmanagements.

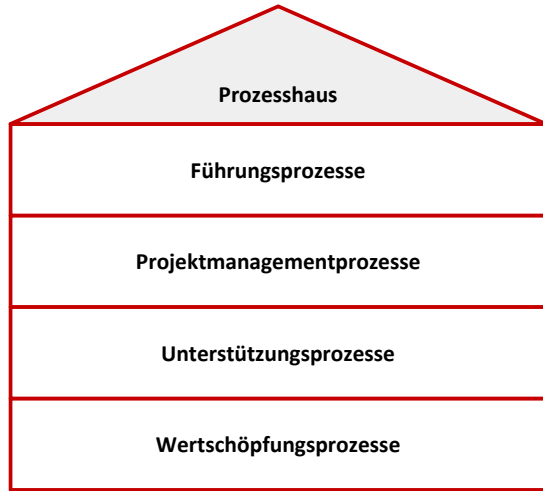


Bild 5.9 Projektmanagementprozesshaus – Quelle: 472, 2009

- Alle Prozesse, die dem Management einzelner Projekte dienen, sind der Prozessgruppe der *Projektmanagementprozesse* zugeordnet.
- Zur Gruppe der *Unterstützungsprozesse* gehören alle Prozesse, die nicht unmittelbar dem Projektmanagement zuzuordnen sind, aber Unterstützung für ein Projekt bieten. Hierzu zählen beispielsweise Einkaufsprozesse oder die Prozesse des Personalwesens.

Wie bereits zuvor dargestellt, werden die Projektmanagementprozesse im Rahmen von Projektmanagementphasen ausgeführt. Damit können die Prozesse nicht nur den Prozessgruppen, sondern auch den Phasen zugeordnet werden.

Alle Projektmanagementprozesse liefern als Output ein oder mehrere Projektmanagementdokumente. Tabelle 5.2 zeigt die Projektmanagementprozesse gemäß DIN 69901-2 im Phasenverlauf sowie deren Output-Dokumente. Alle Prozesse, die entsprechend der Norm mindestens zu implementieren sind (Mindeststandard), sind in der Tabelle kursiv ausgezeichnet.

Tabelle 5.2 Übersicht über die PM-Prozesse und deren Output-Dokumente nach DIN 69901-2

Phase	Projektmanagementprozess	Output-Dokumente
Initialisierung (I)	Zuständigkeiten klären	▪ Liste mit Verantwortlichen (Projektleiter) und gegebenenfalls Teammitglieder
	Ziele skizzieren	▪ Skizze der Projektziele ▪ Entscheidungsvorlage
	PM-Prozesse auswählen	▪ Liste der zu berücksichtigenden Prozesse
	Freigabe erteilen	▪ Freigabeprotokoll mit Liste offener Punkte ▪ Projektauftrag für die kommende Phase

Phase	Projektmanagementprozess	Output-Dokumente
Definition (D)	Projektkernteam bilden	▪ (Vorläufiges) Organigramm
	Information, Kommunikation, Berichtswesen festlegen	▪ Verfahren zum Umgang mit Informationen (z. B. Dokumentation, Archivierung) ▪ Kommunikationsverfahren (z. B. Kommunikationsmatrix) ▪ Berichtswege und -mittel sowie Entscheidungs- und Eskalationswege
	Umgang mit Risiken festlegen	▪ Verfahren zum Umgang mit Risiken ▪ Berichtswege und -mittel
	Umgang mit Verträgen definieren	▪ Verfahren zum Umgang mit Verträgen ▪ Aufgaben, Kompetenzen und Verantwortlichkeiten im Umgang mit Verträgen
	<i>Ziele definieren</i>	<i>Beschreibung der Projektziele</i>
	Projektumfeld/Stakeholder analysieren	▪ Darstellung der relevanten Umfeldfaktoren und Stakeholder einschließlich einer Bewertung der jeweiligen Einflüsse sowie geeigneter Maßnahmen
	Projekthalte abgrenzen	▪ Projekthalte
	Meilensteine definieren	▪ Beschreibung der Meilensteine ▪ Meilensteinplan
	Grobstruktur erstellen	▪ Grobstruktur
	Aufwände grob schätzen	▪ Grobe Aufwandsschätzung
	Vertragsinhalte mit Kunden festlegen	▪ Vertragsentwurf
	<i>Machbarkeit bewerten</i>	<i>Bewertung der Machbarkeit</i>
	Erfolgskriterien definieren	▪ Darstellung der Erfolgskriterien und deren Messgrößen ▪ Entscheidungsvorlage für Freigabe
	Projektmarketing definieren	▪ Ziele und Zielgruppen des Projektmarketings ▪ Mittel und Wege des Projektmarketings (z. B. Intranetportal, Projekt-Newsletter)
	Freigabe erteilen	▪ Freigabeprotokoll mit Liste offener Punkte ▪ Projektauftrag für die kommende Phase
Planung (P)	<i>Projektstrukturplan erstellen</i>	<i>Projektstrukturplan (PSP)</i>
	Arbeitspakete beschreiben	▪ Arbeitspaketbeschreibungen
	Vorgänge planen	▪ Ablaufplan ▪ Aktivitätenplan
	Vorgänge beschreiben	▪ Vorgangsbeschreibung
	Umgang mit Änderungen planen	▪ Verfahren zum Umgang mit Änderungen

Tabelle 5.2 Übersicht über die PM-Prozesse und deren Output-Dokumente nach DIN 69901-2 (Fortsetzung)

Phase	Projektmanagementprozess	Output-Dokumente
Planung (P)	<i>Terminplan erstellen</i>	<i>Terminplan</i>
	Kosten- und Finanzmittelplan erstellen	▪ Kosten- und Finanzmittelplan ▪ Businessplan
	Qualitätssicherung planen	▪ Qualitätssichtungsplan
	<i>Ressourcenplan erstellen</i>	<i>Ressourcenplan</i> ▪ <i>Vorgaben für Lieferantenmanagement</i>
	Projektorganisation planen	▪ Projektorganigramm ▪ Funktionendiagramm ▪ Funktionsbeschreibungen (Rollen)
	Information, Kommunikation, Berichtswesen und Dokumentation planen	▪ Plan über Informations-, Kommunikations- und Berichtswesen
	<i>Risiken analysieren</i>	▪ <i>Risikoportfolio mit der jeweiligen Eintrittswahrscheinlichkeit</i>
	<i>Gegenmaßnahmen zu Risiken planen</i>	▪ <i>Maßnahmenplan (gegebenenfalls Notfallplan)</i>
	Vertragsinhalte mit Lieferanten festlegen	▪ Entwurf Lieferantenvertrag mit Liefer- und Leistungsumfang sowie Schnittstellenvereinbarung ▪ Grober Umfang der Beschaffung
	Projektplan erstellen	▪ Projektplan
	Freigabe erteilen	▪ Freigabeprotokoll mit Liste offener Punkte ▪ Projektauftrag für die kommende Phase
Steuerung (S)	Kick-off durchführen	▪ Ergebnisprotokoll mit Commitment aller Projektbeteiligten bezüglich der Projektziele, dem Projektplan und der Rollenverteilung
	Vorgänge anstoßen	▪ Auftrag zur Umsetzung der einzelnen Vorgänge
	<i>Änderungen steuern</i>	<i>Dokumentation der Änderungen</i> <i>Gegebenenfalls Anpassung der Projektdokumente (z. B. Projektplan)</i> ▪ <i>Dokumentation von Nachforderungen (Claims)</i>
	Information, Kommunikation, Berichtswesen und Dokumentation steuern	▪ Statusbericht zur Situation im Informations-, Kommunikations- und Berichtswesen ▪ Gegebenenfalls Steuerungsmaßnahmen
	Kosten und Finanzmittel steuern	▪ Status zu den Kosten und den Finanzmitteln ▪ Gegebenenfalls Steuerungsmaßnahmen und Anpassung der Projektdokumente (z. B. Finanzplan)

Phase	Projektmanagementprozess	Output-Dokumente
Steuerung (S)	Projektteam bilden	▪ Rollenverteilung mit gegenseitigem Commitment ▪ Regeln für die Zusammenarbeit im Projektteam
	Projektteam entwickeln	▪ Regeln für die Zusammenarbeit im Projektteam
	<i>Ressourcen steuern</i>	<i>Status bezüglich der Ressourcen</i> ▪ Gegebenenfalls Steuerungsmaßnahmen und Anpassung der Projektdokumente ▪ Informationen für das Lieferantenmanagement
	<i>Risiken steuern</i>	<i>Aktuelle Risikobewertung</i> ▪ Gegebenenfalls Steuerungsmaßnahmen und Anpassung der Projektdokumente
	Verträge mit Kunden und Lieferanten abwickeln	▪ Status zur Vertragsabwicklung ▪ Gegebenenfalls Steuerungsmaßnahmen und Anpassung der Projektdokumente ▪ Informationen für das Rechtswesen und das Lieferantenmanagement
	<i>Zielerreichung steuern</i>	<i>Status zur Zielerreichung</i> <i>Gegebenenfalls Steuerungsmaßnahmen und Anpassung der Projektdokumente</i>
	<i>Termine steuern</i>	<i>Status der Terminsituation</i> <i>Gegebenenfalls Steuerungsmaßnahmen</i>
	Nachforderungen steuern	▪ Festgestellte und dokumentierte Nachforderungen ▪ Gegebenenfalls Steuerungsmaßnahmen und Anpassung der Projektdokumente ▪ Informationen für das Rechtswesen und für das Lieferantenmanagement
	Qualität sichern	▪ Statusbericht zur Qualitätssicherung ▪ Gegebenenfalls Steuerungsmaßnahmen und Anpassung der Projektdokumente
	Abnahme erteilen	Abnahmeprotokoll
Abschluss (A)	Nachkalkulation erstellen	▪ Nachkalkulation und Erfolgsrechnung ▪ Abweichungsanalyse
	Verträge beenden	▪ Beendete Verträge (u. a. realisierte Nachforderungen, gegebenenfalls in die Linie überführte Verträge) ▪ Informationen für das Rechtswesen und für das Lieferantenmanagement
	Projektabschlussbericht erstellen	▪ Projektabschlussbericht

Tabelle 5.2 Übersicht über die PM-Prozesse und deren Output-Dokumente nach DIN 69901-2 (Fortsetzung)

Phase	Projektmanagementprozess	Output-Dokumente
Abschluss (A)	Abschlussbesprechung durchführen	▪ Protokoll der Abschlussbesprechung mit weiteren Maßnahmen
	Leistungen würdigen	▪ Informationen an Personalwesen über geeignete Maßnahmen
	<i>Projekterfahrungen sichern</i>	▪ Maßnahmen zur Sicherung der gesammelten Projekterfahrungen (»lessons learned«) ▪ Informationen für das Wissensmanagement
	Projektdokumentation archivieren	▪ Projektarchiv
	Ressourcen rückführen	▪ Protokoll über Rückführung der Ressourcen ▪ Informationen an Personalwesen
	Projektorganisation auflösen	▪ Entlastung des Projektleiters ▪ Abschlussprotokoll

Die DIN 69901 enthält aber nicht nur Auflistungen der erforderlichen Projektprozesse, sondern stellt auch phasenbezogen die Beziehungen der PM-Prozesse in Ablaufdiagrammen dar und beschreibt jeden Prozess in einem Prozesssteckbrief (siehe Bild 5.10). Beides kann eine gute Basis für die eigene Dokumentation der Projektmanagementprozesse liefern.

Bestellt werden kann die DIN kostenpflichtig beim Beuth Verlag. Empfehlenswert ist der Kauf des DIN-Taschenbuchs 472 (472, 2009), das alle wichtigsten Normen zum Projektmanagement mit Stand August 2009 enthält.

Vorgängerprozesse:	– D.9.1 Grobstruktur erstellen	Nachfolgeprozesse:	– D.4.1 Aufwände grob schätzen
Zweck und Hintergrund:	Nach der Abgrenzung der Projekthalte und der Erstellung der Grobstruktur dient dieser Prozess dazu, die Zwischenereignisse/-ergebnisse in eine zeitliche Reihenfolge zu bringen. Dies ist u. a. Voraussetzung für die Abschätzung der Aufwände und die Bewertung der Machbarkeit sowie Grundlage für die Erstellung eines Terminplanes.		
Prozessbeschreibung (Vorgehen):	Zuerst werden die Meilensteine inhaltlich definiert (Meilenstein-Beschreibung), in eine zeitliche Reihenfolge gebracht und mit (groben oder vorläufigen) Terminen versehen (Meilensteinplan).		
Input		PM-Methoden	Output
– Projektziele – Projekthalte – Grobstruktur		– Terminplanung*	– Beschreibung der Meilensteine – Meilensteinplan

Bild 5.10 Beispiele einer PM-Prozessbeschreibung in DIN 69901-2:2009-01 – Quelle: 472, 2009

5.2.3 Strukturierung der Projektmanagementdokumente

Eine Möglichkeit zur Strukturierung der Dokumente bietet der phasenbezogene Ansatz. Dieser ist jedoch nicht für alle Dokumente darstellbar, da diese phasenübergreifend verwendet werden. Sinnvoller ist es meist, zusammengehörige Prozesse und die daraus resultierenden Dokumente thematisch zusammenzufassen. Dies erleichtert die Orientierung über den Projektlebenszyklus hinweg.

Zusätzlich können die Dokumente den Projektphasen bzw. Projektmanagementphasen mittels einer Kennung (*P* für *Planungsphase* z. B.) zugeordnet werden. Auch hierfür bietet die DIN 69901 eine gute Vorlage. Bild 5.11 zeigt einen Ausschnitt aus einer möglichen Strukturierung der Projektmanagementdokumente nach Themenbereichen mit einigen exemplarisch zugeordneten PM-Dokumenten. Dabei stehen die erste Ziffer für den Themenbereich und der Buchstabe für die Phase. Zusätzlich kann beispielsweise eine zweite Ziffer für eine fortlaufende Nummerierung verwendet werden.



Bild 5.11 Gliederung der Projektmanagementdokumente nach thematischen Bereichen gemäß DIN 69901

■ 5.3 Wichtige Dokumentationsbereiche

Zu Beginn des Kapitels wurde mehrfach auf den IDW Standard PS 850 verwiesen. Im Rahmen der projektbegleitenden Prüfung werden die maßgeblichen Dokumente u.a. für folgende Aspekte überprüft:

- Projektziele und Projektphasen,
- Inhalte des Pflichten-/Lastenhefts,
- Projektbudget,
- Projektorganisation,
- zeitliche und personelle Planung,
- laufende Berichterstattung,
- Projektcontrolling,
- Risikomanagement und das Eskalationsverfahren bei Planabweichungen,
- Dokumentation der Projektergebnisse.

Einige dieser Dokumentationsbereiche werden im Folgenden exemplarisch vorgestellt.

5.3.1 Berichtswesen als Basis der Projektkommunikation

Das Kommunikations-, Informations- und Berichtswesen ist eine wichtige Basis für eine erfolgreiche Projektdurchführung. Daher gilt den Berichts- und Kommunikationsprozessen an dieser Stelle besondere Aufmerksamkeit.

Die Aufgabe des Berichtswesens ist es, Informationen über das Projekt komprimiert und aussagefähig darzustellen. Es bildet damit die Basis für Abstimmungs- und Entscheidungsprozesse im Projekt. Berichte sollen den aktuellen Stand des Projekts festhalten – sowohl im Hinblick auf das bisher Erreichte als auch im Hinblick auf künftige Entwicklungen. Hierzu stellen Projektstatusberichte eines der wichtigsten Instrumente dar. Daneben gibt es eine Reihe weiterer Berichte zu denen beispielsweise der Projektabschlussbericht gehört. Sinnvoll ist es für das Projekt, einen Berichtsplan zu erstellen, der alle zu erstellenden Berichte zusammenfasst und schnell Auskunft darüber gibt, wer welche Information wann und an wen weiterleiten muss. Die folgende Tabelle zeigt exemplarisch einen solchen Berichtsplan.

Tabelle 6.3 Für jedes Projekt sollte es einen Berichtsplan geben.

Bericht	Ersteller	Empfänger	Rhythmus
Statusberichte der Teilprojekte	Teilprojektleiter	Projektleitung	Wöchentlich
Statusberichte für das Gesamtprojekt	Projektleiter	Lenkungsausschuss, Betriebsrat, Revision	Monatlich
Projektsonderberichte	Projektmitarbeiter oder Projektleiter	Betroffene Organisationseinheiten Lenkungsausschuss	Bei Bedarf, wenn unerwartete Situationen eintreten, die weitere Maßnahmen und Entscheidungen erfordern
Meeting- und Ergebnisprotokolle	Protokollant	Alle Teilnehmer, Projektleitung	Bei Bedarf
Projektabschlussbericht	Projektleiter	Lenkungsausschuss, Geschäftsleitung	Am Ende des Projekts

5.3.2 Lastenheft und Pflichtenheft

Im Lastenheft definiert der Auftraggeber seine Anforderungen und teilt dem Auftragnehmer mit, was er zu liefern hat. Dieser entwickelt aus den Anforderungen des Auftraggebers die genaue Produktspezifikation. Das Pflichtenheft liefert den Lösungsvorschlag des Auftragnehmers. Damit stellt das Lastenheft die Problemstellung des Auftraggebers dar und geht dem Pflichtenheft voraus.

Nun werden diese beiden Dokumente aber nicht nur für die (innerhalb des Projekts) zu entwickelnden Produkte benötigt, sondern auch für das übergeordnete Projekt selbst. Die Anforderungen, die an ein Projekt gestellt werden, und dessen Ziele müssen schriftlich festgehalten werden. In diesem Fall beschreibt das Lastenheft das angestrebte Projektergebnis und das Pflichtenheft, wie dieses umzusetzen ist.



Lasten- und Pflichtenheft in DIN normiert

Sowohl das Lastenheft als auch das Pflichtenheft sind in der *DIN 69905 Projektmanagement, Begriffe* folgendermaßen normiert:

Nach der DIN 69901-5:2009-01 ist das Lastenheft die »vom Auftraggeber festgelegte Gesamtheit der Forderungen an die Lieferungen und Leistungen eines Auftragnehmers innerhalb eines (Projekt-)Auftrags« (472, 2009). Zugleich dient das Lastenheft auch als Grundlage beim Einholen von Angeboten.

Das Pflichtenheft hingegen enthält entsprechend der DIN die »vom Auftragnehmer erarbeiteten Realisierungsvorgaben auf der Basis des vom Auftraggeber vorgegebenen Lastenheftes« (472, 2009).

Lastenheft

Grundsätzlich kann das Lastenheft als ein Anforderungskatalog beschrieben werden, der die Zielsetzungen, Aufgabenstellungen, Anforderungen des Auftraggebers und weitere Leistungsdaten des zu entwickelnden Produkts spezifiziert. Bei Bauprojekten wird das Lastenheft auch als *Leistungsverzeichnis (LV)* bezeichnet.

Im Lastenheft definiert der Auftraggeber demnach das »Was« und das »Wofür«. Es beschreibt jedoch nicht, wie und womit etwas gemacht werden soll. Zusätzlich enthält es eine Beschreibung des Istzustands. Wichtig ist, dass die Anforderungen qualifizierbar und nachprüfbar sind.

Die Inhalte des Lastenhefts sind nicht verbindlich geregelt und hängen insbesondere von der zu erstellenden Lösung ab. Für die Grobgliederung bieten die folgenden Punkte eine Vorlage:

- Allgemeines (Titel, Auftraggeber, terminlicher Rahmen),
- Zielsetzung (Anlass und Zielsetzung, Priorisierung, Begrenzung des Vorhabens),
- Produktfunktionen bzw. Aufgabenstellung (Beschreibung des Istzustands, geforderte Hauptfunktionen, fachliche Anforderungen, Schnittstellen),
- Leistungsanforderungen (Leistungsumfang, Leistungs-, Sicherheits- und Qualitätsanforderungen),
- Produkteinsatz bzw. Umgebung, in der das Produkt eingesetzt werden soll (technisches Umfeld, Standards, Einschränkungen),
- verwendete Standards, Ergänzungen und Randbedingungen.

Wird das Lastenheft als Grundlage für eine Ausschreibung verwendet, ist durchaus eine umfassendere Ausgestaltung möglich, wenn der Auftraggeber zusätzliche Anforderungen definiert.

Pflichtenheft

Aufgabe des Pflichtenhefts ist es, aus den Anforderungen des Kunden (Lastenheft) eine möglichst vollständige konsistente und eindeutige Produktbeschreibung als Basis für das zu erstellende Produkt zu liefern. Während im Lastenheft der Auftraggeber das »Was« und das »Wofür« beschreibt, definiert das Pflichtenheft das »Was«, »Wie viel« und das »Womit«.

Da die Erstellung der Anforderungsdokumente in den Bereich der technischen Dokumentation fällt (siehe hierzu *Kapitel 2 Abschnitt 2.4*) und in der Literatur und im Internet zahlreiche Beschreibungen für Pflichtenhefte und auch Lastenhefte zu finden sind, kann an dieser Stelle auf eine detaillierte Beschreibung verzichtet werden. Einen umfassenden Gliederungsvorschlag liefert beispielsweise Balzert in seinem Buch (Balzert, 2009).

Auf einen Punkt sollte bei der Erstellung des Pflichtenhefts aber immer geachtet werden: Wird das Pflichtenheft aus der Sicht der später zu erstellenden Dokumente erstellt, können meist sehr viele Inhalte aus dem Pflichtenheft in die spätere Betriebsdokumentation (beispielsweise die Systemakte) übernommen werden. Dies kann im Nachhinein viel Arbeit sparen.



Revisionssicher archivieren

Das Lasten- sowie das Pflichtenheft sind wichtige Dokumente der IT-Dokumentation, insbesondere wenn Aufträge extern vergeben werden. Sie dienen als Nachweis für das, was vereinbart wurde, und sind insbesondere bei Streitfällen von hoher Wichtigkeit. Sie sollten daher mit der entsprechenden Sorgfalt erstellt und revisionssicher archiviert werden.

5.3.3 Konzepte, die wichtigsten Ergebnisdokumente

Zu den wichtigsten Ergebnisdokumenten von Projekten zählen *Konzepte*. Wie an so mancher Stelle im vorliegenden Buch, ist es auch hier erforderlich, zunächst einige Begrifflichkeiten zu klären. Wie die Ausführungen bereits gezeigt haben, gibt es zahlreiche Ausprägungen und Verwendungen des Begriffs »Konzept« (Fachkonzept, DV-Konzept, Sollkonzept, Systemkonzept usw.), unter denen fast jeder etwas anderes versteht. Es wurde daher schon mehrfach auf die Notwendigkeit hingewiesen, beim Aufbau der eigenen IT-Dokumentation die Verwendung der Dokumentenbezeichnungen für das eigene Unternehmen zu definieren und diese deutlich voneinander abzugrenzen. Weiter muss die verbindliche Verwendung der Begriffe kommuniziert werden. Dies gilt in hohem Maße auch für die Projektdokumentation. Da hier häufig auch externe Mitarbeiter Dokumente erstellen, sind Vorgaben besonders wichtig. Dies gilt insbesondere für die Definition der zu erstellenden Konzepte.



Grobkonzept und Feinkonzept

Zwei Begriffe, die im Zusammenhang mit Konzepten immer wieder genannt werden, lauten: *Grobkonzept* und *Feinkonzept*. Allerdings werden diese beiden Begriffe in unterschiedlichster Art verwendet.

Wird das Grobkonzept eher aus Projektmanagementsicht betrachtet, ist es bereits in der Projektinitialisierungsphase zu erstellen und es zeigt die Inhalte sowie die wichtigsten Meilensteine des geplanten Projekts auf. Aus Sicht der Softwareentwicklung wird das Grobkonzept hingegen eher im Zusammenspiel mit dem Fachkonzept und dem DV-Konzept gesehen. Die Beispiele zeigen, dass die Verwendung der beiden Begriffe in der Praxis ganz verschieden ist.

Im Buch werden die Begriffe Grob- und Feinkonzept ausschließlich am Detaillierungsgrad ausgerichtet. Es kann nämlich in vielen Fällen durchaus sinnvoll sein, ein dem endgültigen Konzept vorlaufendes Konzept mit einem geringeren Detaillierungsgrad zu erstellen. In einem solchen »Grobkonzept« können beispielsweise auch alternative Lösungswege aufgezeigt werden. Diese Vorgehensweise minimiert das Risiko, mit einem direkt erstellten »Feinkonzept« in die falsche Richtung zu laufen, und bietet frühzeitige Umkehrmöglichkeiten. Auf der Basis eines derart abgestimmten Grobkonzepts kann anschließend das Feinkonzept entwickelt werden.

Aufbau und Inhalt von Konzepten

Der inhaltliche Teil eines Konzepts sollte mit einer Beschreibung der Ausgangssituation bzw. des Istzustands der Umgebung beginnen, für die das Konzept eine Lösung liefern soll. Daran anschließen kann sich ein Überblick über die Anforderungen und Ziele, die mit der beschriebenen Lösung erreicht werden sollen. Den Schwerpunkt bilden die Beschreibung der möglichen Lösung sowie eine Beschreibung der geplanten Prozesse. Die Darstellung der Prozesse kann hier noch auf einem hohen Abstraktionsgrad erfolgen. Zusätzlich sollten Konzepte ein *Management Summary* beinhalten. Diese Zusammenfassung soll Entscheidern die Möglichkeit bieten, sich schnell über die wichtigsten Punkte einen Eindruck zu verschaffen.

Handelt es sich bei dem Konzept um ein vorausgehendes Grobkonzept, sind die bestehende Struktur und – wie der Name bereits sagt – grob die angestrebte Lösung zu beschreiben. Das heißt, die wichtigsten Funktionen werden definiert und im Überblick beschrieben. Das Feinkonzept hingegen umfasst die genauen Anweisungen für die Umsetzung. Hier werden die ermittelten Funktionen weiter analysiert und dargestellt. Dies kann eine Beschreibung der benötigten Infrastruktur (Hardware, Netzwerk, Support, Lizenzen usw.) sowie erste Erläuterungen für den Betrieb des neuen Systems einschließen.

Gibt es Lösungsalternativen zum Erreichen der angestrebten Ziele, ist es sinnvoll, diese im Grobkonzept gegenüberzustellen. Dies schließt eine Benennung von Vor- und Nachteilen der einzelnen Lösungsansätze und einen Vergleich der Lösungsansätze untereinander ein. Auch ein Machbarkeitsnachweis kann durchaus Gegenstand des Konzepts sein. Den Abschluss sollte in diesem Fall eine kurze Zusammenfassung mit einer abschließenden Empfehlung (für die Unternehmensleitung) bilden.

Sofern für das spezifische System sinnvoll, sollte das Konzept auch Aussagen zu Rollen und Berechtigungen enthalten. Außerdem ist es hilfreich, wenn das Konzept bereits Aussagen zu personal- und datenschutzrechtlichen Erfordernissen enthält.

Den Abschluss kann eine Darstellung der Schnittstellen und Zulieferleistungen bilden. Hier sollten Verbindungen zu Schnittstellen aufgezeigt werden, die folgende Fragen beantworten: Welche Lieferleistungen müssen durch andere Projekte bzw. Bereiche erbracht werden? Welche Vorgaben und Anforderungen ergeben sich aus der Lösung für andere Projekte bzw. Bereiche?



Entscheidungsvorlage alternativ möglich

Erfolgt eine vollständige Darstellung der Lösungsalternativen im Konzept, muss mit der Abnahme die gewählte Lösung benannt werden. Alternativ oder auch zusätzlich können Sie eine Entscheidungsvorlage der genehmigenden Stelle vorlegen.

Bild 5.12 zeigt exemplarisch eine Gliederung für ein Konzept. Selbstverständlich muss diese in Abhängigkeit vom Konzeptgegenstand angepasst und gegebenenfalls erweitert werden. Zur Abgrenzung von anderen Konzepten kann beispielsweise, wie im Bild gezeigt, der Begriff „Technisches Konzept“ verwendet werden.

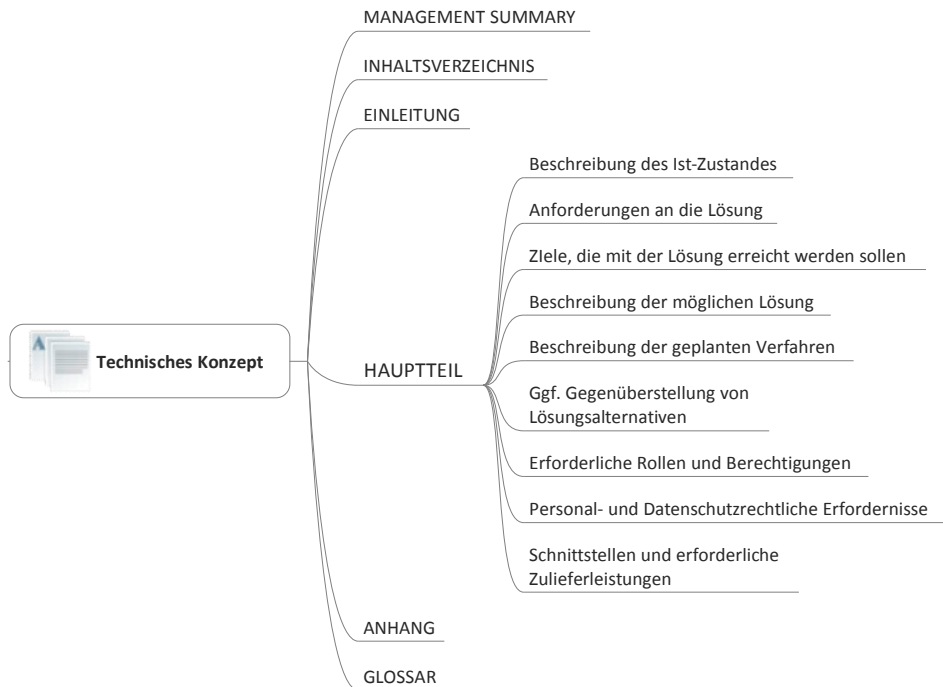


Bild 5.12 Gliederungsvorschlag für ein Konzept

Freigabeprozess für ein Konzept

Wie zuvor ausgeführt wurde, beschreiben Konzepte einen Lösungsweg für eine definierte Aufgabe und liefern damit die Basis für alle weiteren Tätigkeiten. Daher kommt der Qualitätssicherung und der Freigabe von Konzepten ein hoher Stellenwert zu.

Generell sollte gelten, dass eine Verwendung eines Dokuments erst erfolgen darf, wenn dieses den Status »Freigegeben« erreicht und damit den Qualitätssicherungs- und Freigabeprozess erfolgreich durchlaufen hat. Konzepte sollten immer einen Freigabeprozess durchlaufen. Und sofern es sich nicht um ein reines Organisationsprojekt handelt, stellt die Freigabe eines Konzepts insofern eine Besonderheit dar, dass die Freigabe eng verzahnt sein kann mit dem Testprozess.

Der Freigabeprozess ist ein mehrstufiger Prozess. Bei jeder Stufe sollten die folgenden grundsätzlichen Punkte überprüft werden:

- Übereinstimmung mit den in der Dokumentationsrichtlinie definierten formalen Anforderungen,
- Übereinstimmung mit den Anforderungen des Auftraggebers,
- formale und inhaltliche Vollständigkeit,
- technische Angemessenheit und Durchführbarkeit,
- sachliche Richtigkeit,
- Schnittstellen zwischen dem zu prüfenden Dokument und bereits bestehenden Dokumenten.

Wichtig ist bei jeder Qualitätssicherung und Freigabe außerdem die Einhaltung der Regel: Der Qualitätssicherer eines Dokuments darf nicht gleichzeitig der Ersteller sein (Funktions-trennung).



Checkliste für die Qualitätssicherung

Ein Muster für eine Checkliste zur Qualitätssicherung und Freigabe von Dokumenten finden Sie in *Kapitel 6 in Abschnitt 6.4.5*.

Müssen nach der Freigabe noch Änderungen an einem Konzept erfolgen, so sollten diese mittels einer Änderungsanforderung (RFC) beantragt werden. Dieser formale Weg ist erforderlich, da mit der Änderung gegebenenfalls erneute Tests verbunden sind. In diesem Fall sind bei einer Änderung dieselben Schritte wie bei der Neuerstellung zu durchlaufen. Änderungen an Konzepten dürfen nur bis zur Implementierung der im Konzept beschriebenen technischen Lösung und deren Abnahme für den Betrieb erfolgen, danach sind darauf bezogene RFCs nicht mehr zulässig. Nach der Abnahme darf das Konzept nicht mehr geändert werden. Sind später noch Änderungen am System erforderlich, so müssen diese den betrieblichen Änderungsprozess durchlaufen. Die Dokumentation erfolgt dann in den Dokumenten für den IT-Betrieb.

Entscheidungsvorlagen

Auch wenn alle Rahmenbedingungen im Projektvertrag festgelegt sind, wird es in einem Projekt immer wieder Situationen geben, in denen Entscheidungen auf der Leitungsebene erforderlich sind. Außerdem ist es nicht unüblich, in Konzepten alternative Lösungswege aufzuzeigen, über die dann auf Leitungsebene entschieden werden muss. Entscheidungen auf Managementebene können beispielsweise erforderlich sein, wenn damit auch die Freigabe finanzieller Mittel sowie personeller Ressourcen verbunden ist.

Für diese Zwecke werden Entscheidungsvorlagen benötigt. Mit der Entscheidungsvorlage sind den Verantwortlichen alle notwendigen Informationen bereitzustellen, um entscheiden zu können, ob und welcher der beschriebenen Lösungsansätze weiterverfolgt werden soll.

Dazu sollte die Entscheidungsvorlage folgende Informationen liefern:

- **Kontext:** kurze Beschreibung des Kontexts, in dem die Entscheidung zu treffen ist
- **Zielsetzungen:** managementorientierte Beschreibung der mit dem Einsatz der beschriebenen Lösungen verbundenen Ziele
- **Lösungsansätze:** Skizzierung aller alternativen Lösungsansätze einschließlich zu erwartender Kosten und personeller Aufwände
- **Diskussion der Lösungsansätze:** Benennung von Vor- und Nachteilen der einzelnen Lösungsansätze und Vergleich der Lösungsansätze. Falls sinnvoll bzw. möglich, sollte auch eine Gegenüberstellung von Kosten und Nutzen erfolgen.
- **Empfehlung:** begründete Empfehlung eines Lösungsansatzes und Darstellung der zu erwartenden Kosten und Aufwände

Wichtig ist eine prägnante und auf die wesentlichen Informationen reduzierte Darstellung. Diese Anforderungen können am besten durch eine entsprechende Dokumentvorlage sichergestellt werden.

5.3.4 Testdokumentation

Tests sind ein unverzichtbares Element der Qualitätssicherung nicht nur in einem Projekt. Sie dienen zwei Zwecken:

1. Zur Qualitätssicherung. Tests sollen während der Realisierung oder Umsetzung die Anzahl der Fehler möglichst gering halten und dafür sorgen, dass die Entwickler bereits während des Projekts aus erkannten Fehlern lernen können. Im Entwicklungszyklus einer IT-Lösung muss die Qualitätssicherung in den Projektablauf eingebettet sein und darf sich nicht nur auf eine Testphase zum Projektabschluss beschränken.
2. Zur Abnahme der entwickelten IT-Lösung. Mit der Abnahme bestätigt der Auftraggeber, dass seine Anforderungen erfüllt sind, die im Projektauftrag bzw. im Lastenheft beschrieben sind. Entsprechende Prozesse müssen sicherstellen, dass Systeme nicht ohne Tests in den Produktivbetrieb übernommen werden.

Es gibt verschiedene Testarten, die nach ihren Inhalten unterschieden und in verschiedenen Phasen des Projekts durchlaufen werden: Modultests, Funktionstests, Integrationstests, Lasttests, Abnahmetests u. a.



Beispiel – typische Begriffe im Testmanagement

Die Einführung einer neuen Software erfordert zunächst einen *Funktionstest*, in dem die zugesicherten Eigenschaften der Software getestet werden.

Wurde der Funktionstest erfolgreich abgeschlossen, muss die neue Software vonseiten der Fachabteilung getestet werden. Während beim Funktionstest nur geprüft wird, ob alle Funktionen der Software fehlerfrei arbeiten, geht es beim *fachlichen Test* vor allem darum, zu bewerten, ob die Software auch die korrekten Ergebnisse liefert. Die kann nur von den Fachverantwortlichen bzw. den späteren Anwendern bewertet werden.

Auf der nächsten Teststufe wird das Zusammenspiel der neuen Software mit den anderen Systemkomponenten (*Systemintegrationstest*) der Systemumgebung erprobt. Im Vordergrund stehen hier die Überprüfung der Funktionalitäten des Softwaresystems im Zusammenspiel mit dem Gesamtsystem und die Untersuchung möglicher Beeinträchtigungen des Gesamtsystems. Dies gewährleistet eine formalisierte Überprüfung, wie gut Änderungen mit dem produktiven System zusammenarbeiten werden.

Abhängig von der einzuführenden Software kann es nach dem Integrationstest erforderlich sein, weitere Tests zur Verifikation und Einschätzung der Systemkapazitäten und des Systemverhaltens unter Last durchzuführen. Während beim Integrationstest die Funktionen der Software nur anhand weniger Testdaten geprüft werden, dienen diese Tests dazu, das Verhalten der Software bei der Verarbeitung von Massendaten zu testen. Unterschieden werden kann noch zwischen *Lasttests*, die ein System an den (geforderten) Grenzen der Leistungsfähigkeit testen, und *Stresstests*, die das Verhalten bei Überlast, d. h. bei einem temporären Überschreiten der Grenzen, prüfen. Weiter kann es auf dieser Teststufe sinnvoll sein, *Robustheitstest* durchzuführen. Diese Tests überprüfen das Systemverhalten bei einem Ausfall einzelner Teile oder unter anormalen Umgebungsbedingungen und schließen den provozierten Ausfall spezifischer Teilkomponenten ein.

Hat die neu entwickelte Software auch diese Teststufe erfolgreich durchlaufen, erfolgt die Implementierung in der Produktivumgebung. Nach einer nochmaligen ausführlichen *Funktionskontrolle* können dann die Übergabe und Abnahme erfolgen (Abnahmetest). Der formelle *Abnahmetest* soll sicherstellen, dass das System die Forderungen des Pflichtenhefts in dem Verständnis des Auftraggebers erfüllt. Mit der Abnahme gehen schließlich auch die Gefahren auf den Auftraggeber über; die Gewährleistung beginnt.

Alle Tests müssen systematisch und klar definiert durchgeführt werden, was nur mit einer entsprechenden Dokumentation möglich ist. Diese Forderung gilt grundsätzlich und unabhängig davon, ob Änderungsprozesse im Rahmen eines Projekts oder im Regelbetrieb umgesetzt werden; sowie für alle Entwicklungen, egal ob es sich dabei um eine neu entwickelte Softwarelösung oder um einen neu zu implementierenden Server handelt. Beachtenswert, insbesondere für die Durchführung von Softwaretests, ist der erstmals 1998 und 2008 aktualisierte Standard 829 für die Softwaretestdokumentation des *IEEE (Institute of Electrical and Electronic Engineers)* (IEEE-SA). Dieser Standard beschreibt in acht Dokumenten den inhaltlichen Aufbau von Testdokumenten und liefert wichtige Anhaltspunkte für die Dokumentation von Softwaretests. In Anlehnung an das V-Modell sind für den Test mehrere Stufen vorgesehen.

Für alle Tests, die in einem Projekt durchzuführen sind, ist zu gewährleisten, dass die Testfälle umfänglich und vollständig sind und einen definierten und dokumentierten Testprozess durchlaufen. Es werden daher Dokumente für die Testplanung und die Testdurchführung benötigt. Eine wichtige Rolle spielt deshalb das *Testkonzept*. Bezogen auf den IEEE-Standard 829 entspricht dieses Dokument dem dort benannten Testplan. Das Testkonzept bildet den inhaltlichen Leitfaden, also sozusagen das Drehbuch für die Testdurchführung, und beinhaltet sowohl die Testziele sowie Abgrenzung, Vorgehensweise, Anforderungen an Testdaten und Ablaufplan der Testaktivitäten als auch Beschreibungen der Testprozesse. In der Regel werden innerhalb eines Projekts unterschiedliche Teststufen durchlaufen. Hierbei handelt es sich meistens um die nachfolgenden Teststufen. Welche Tests erforderlich sind, ist natürlich vom jeweiligen Projekt abhängig und muss im Einzelfall festgelegt werden. Das Testkonzept sollte Vorgaben für alle Teststufen enthalten und für jede Stufe die folgenden Punkte beschreiben:

- Zielsetzung der Tests und erwartete Ergebnisse,
- Voraussetzungen für die Testdurchführung,
- Hinweise zur Testorganisation,
- Testinhalt und Testabgrenzung (zu testende Leistungsmerkmale und Leistungsmerkmale, die nicht getestet werden),
- Testinfrastruktur (Systemumgebung, Testtools),
- Testablaufplanung (Zeitplanung, Testteilnehmer),
- Prozessbeschreibung für den Testablauf,
- Verantwortlichkeiten und Zuständigkeiten,
- Kriterien für einen Testabbruch und eine Testfortsetzung,
- Testdokumentation (Was ist zu dokumentieren, welche Dokumente werden benötigt?),

- Abnahmekriterien und Freigabeverfahren,
- Risikoanalyse.

Dem Testkonzept kommt als weitere wichtige Aufgabe noch die Definition der Testverfahren und der im Unternehmen zu verwendenden Begriffe zu.

Gemäß IEEE-Standard 829 untergliedern sich die Dokumente für die Testdurchführung wie folgt: *Test-Design-Spezifikation*, *Testfall-Spezifikation* und *Test-Ablauf-Spezifikation*. Unabhängig davon, ob man sich an dieser Unterteilung ausrichtet oder nicht: Es werden Dokumente benötigt, die die einzelnen Testfälle spezifizieren. Ein Testfall ist eine Kombination von Eingabedaten, Verarbeitungsregeln und erwarteten Ausgaben, die einem bestimmten Zweck dienen. Daher müssen für jeden Testfall die zu benutzenden Eingaben und zu erwartenden Ausgaben benannt und alle Schritte zur Durchführung des jeweiligen Testfalls beschrieben werden.

Besonders wichtige Dokumente liefert natürlich die Testdurchführung. Hier müssen Ergebnisse, Fehler, Mängel und unerwartete Ereignisse dokumentiert werden. Der Standard IEEE 829 unterscheidet vier verschiedene Dokumente für die Testbeschreibung: *Testfall-Übertragungsbeschreibung*, *Testprotokoll*, *Test-Störfall-Beschreibung* und die *Test-Zusammenfassung*. Von besonderer Wichtigkeit sind Testprotokolle. Diese dienen zur Aufzeichnung der Ereignisse während eines Tests und enthalten Angaben über alle ausgeführten Testfälle, deren Ergebnisse und aufgetretene Abweichungen vom erwarteten Ergebnis. Das Protokoll dient in erster Linie dazu, die korrekte Arbeit des Testteams zu dokumentieren. Aufgetretene Fehlersituationen sollten besser in einem eigenen Dokument ausgeführt werden. Sinnvoll kann auch der Aufbau einer Fehlerdatenbank sein. (IEEE-SA)



Testdokumentation ist ein eigener Bereich

Wie Ihnen bereits die kurzen Ausführungen zur Testdokumentation zeigen, handelt es sich beim Testmanagement um einen komplexen Bereich, der hier nur angerissen werden kann. Außerdem ist er eher dem Bereich der Technischen Dokumentation als der IT-Dokumentation zuzuordnen (siehe hierzu *Kapitel 2 Abschnitt 2.4*). Möchten Sie sich näher mit dem Thema befassen, finden Sie unter den Stichworten *Softwaredokumentation* und *Testmanagement* entsprechende Literatur.

5.4 Best Practices

In den vorstehenden Kapiteln wurden die Struktur und der Inhalt der Projektdokumentation vorgestellt. Diese Strukturierung zeigt aber nur einen inhaltlichen Aufbau, nicht jedoch die Strukturierung im Filesystem oder in anderen Anwendungen. Ob die Abbildung dann in Form von Ordnern oder beispielsweise als Metadaten im Dokumentenmanagementsystem erfolgt, spielt für die Strukturierung keine Rolle und ist unternehmensspezifisch festzulegen. Im täglichen Umgang mit den Dokumenten in einem Projekt spielt dies jedoch eine erhebliche Rolle.

Abschließend möchte dieser Abschnitt Hilfestellung zur Organisation der Projektdokumentation in der Praxis bieten.

5.4.1 Dokumentationsrichtlinie auch für Projekte

Die im Buch vielfach beschriebenen Anforderungen an die Dokumentation gelten nicht nur für die Betriebsdokumentation, sondern selbstverständlich auch für die Projektdokumentation. So müssen beispielsweise der Projektfortschritt und die Projektergebnisse anhand der vorhandenen Dokumente nachvollziehbar sein.

Die Festlegung von Richtlinien und Vorgaben für die Erstellung, Änderung und Speicherung von Dokumenten und für die Ablage von Aufzeichnungen ist die Voraussetzung zur Durchsetzung einheitlicher Qualitätsstandards und für die Sicherstellung von Dokumentationsanforderungen. Die Implementierung einer unternehmensweiten Dokumentationsrichtlinie ist hierfür der beste Weg. Welche Inhalte eine solche Dokumentationsrichtlinie haben sollte und worauf grundsätzlich bei der Erstellung von Dokumenten zu achten ist, damit diese beispielsweise die Anforderung an die Revisionssicherheit erfüllen, erfahren Sie in *Kapitel 6 in Abschnitt 6.2*.

Auf einige wichtige Punkte soll aber bereits an dieser Stelle hingewiesen werden:

1. Der Projektverlauf muss nachvollziehbar über alle Projektphasen dokumentiert werden. Alle dafür erforderlichen Dokumente sind zudem entsprechend den gesetzlichen Regelungen aufzubewahren. Dies umfasst zwingend alle Dokumente der Projektinitiierungs- und der Projektplanungsphase wie beispielsweise den Projektauftrag und natürlich alle relevanten Ergebnisprotokolle. Aber auch die Ergebnisdokumentation einschließlich aller Test- und Abnahmeergebnisse ist zu dokumentieren und zu archivieren.
2. Dokumente sind einer Versionierung zu unterziehen.
3. Änderungen an Dokumenten dürfen nur im Rahmen standardisierter Änderungsprozesse erfolgen und müssen nachvollziehbar sein.
4. Das Löschen von Projektdokumenten sollte eine Ausnahme darstellen und ist stets zu dokumentieren. Dem Löschen immer vorzuziehen ist das Setzen des Bearbeitungsstatus »Ungültig«.
5. Nach dem Abschluss des Projekts dürfen keine Änderungen mehr an den Projektdokumenten erfolgen. Nur die in den Betrieb überführten Dokumente werden als Dokumente des IT-Betriebs weitergepflegt. Die gesamte Projektdokumentation sollte deshalb mit der Beendigung des Projekts »eingefroren«, das heißt als kompletter Dokumentensatz unveränderbar archiviert werden. Da manchmal auch nach Projektabschluss noch Nacharbeiten erforderlich sind, ist dies nicht immer möglich.

In diesem Zusammenhang haben einige Landesverwaltungen Dokumentationsrichtlinien für IT-Projekte verabschiedet, die auf den *Mindestanforderungen der Rechnungshöfe des Bundes und der Länder zum Einsatz der Informations- und Kommunikationstechnik (IuK-Mindestanforderungen)* beruhen und für die landeseigenen Behörden gelten (IuK-Mindestanforderungen, 2011).

5.4.2 Problemfelder der Projektdokumentationen

Die meisten Projekte weisen im Hinblick auf den täglichen Umgang mit den Projektdokumenten ähnliche Probleme auf. Einige typische Probleme sowie mögliche Lösungswege werden im Folgenden vorgestellt.

Typische Probleme im Dokumentationsumfeld

Im Folgenden werden einige typische Dokumentationsprobleme vorgestellt, denen die Autoren im Projektalltag immer wieder begegnen.

Problem: Der Projektleiter als Dokumentenverwalter

Eine der Anforderungen an die Ordnungsmäßigkeit von Dokumenten lautet, dass die Lesbarkeit während der gesamten Aufbewahrungsdauer zu gewährleisten sowie die Datensicherheit in Bezug auf den Zugriffsschutz und die Unveränderbarkeit der Daten sicherzustellen ist. Um diese und die übrigen oben genannten Anforderungen zu erfüllen, sind entsprechende Dokumentationsprozesse sowie eine möglichst zentrale Dokumentenverwaltung erforderlich.

Vergessen wird dabei häufig die Projektdokumentation. In den meisten Projekten obliegt die Verwaltung der Projektdokumente dem Projektleiter, gegebenenfalls in Zusammenarbeit mit dem Projektmanagement Office. Umfang und Ausprägung liegen dabei in seiner Verantwortung, einheitliche Vorgaben fehlen meist. Wie die Erfahrungen zeigen, ist dies aber nur bei kleinen Projekten ein gangbarer Weg. Bei größeren Projekten bleibt dem Projektleiter im täglichen Projektgeschäft meist kein Freiraum dafür. In diesen Fällen entwickeln sich im praktischen (hektischen) Projektalltag häufig individuell strukturierte Dokumentationsablagen, die die Verständlichkeit und Nachvollziehbarkeit der erarbeiteten Ergebnisse erheblich erschweren, massiv behindern oder so gut wie unmöglich machen.

Problem: Externe Mitarbeiter

Aber auch die Projektmitarbeiter bekommen es zu spüren, wenn die Projektdokumentation stiefmütterlich behandelt wird. Dies gilt insbesondere, wenn in einem Projekt externe Mitarbeiter beschäftigt werden. Um externen Mitarbeitern die erforderlichen Zugriffe – und nur diese (womöglich auch mit dem eigenen Notebook) – zu ermöglichen, ist allein zur Gewährleistung der erforderlichen Zugriffsrechte einiger Aufwand erforderlich, der vielfach gescheut wird.

Im besten Fall wird den externen Mitarbeitern ein Ordner für die eigenen Arbeitsdokumente zugewiesen. Darüber hinaus gibt es noch einen Gruppenordner, in dem ebenfalls Arbeitsversionen und Dokumente mit wichtigen Informationen gespeichert werden. Häufig aber arbeiten externe Mitarbeiter mit dem eigenen Notebook und speichern die Dokumente lokal. Bei Bedarf werden die Dokumente dann per E-Mail versendet. Änderungen und Abstimmungen erfolgen ebenfalls per E-Mail und sind somit für Dritte aufgrund der Ablage in lokalen E-Mail- und Dateiverzeichnissen in keiner Weise mehr nachvollziehbar. Und wohl jeder Berater ist in derartigen Umgebungen schon in die Situation geraten, dass im vermeintlich letzten Stand eines Dokuments »plötzlich« die Anmerkungen des Kollegen fehlten. Abgesehen davon, dass durch die Mehrfachspeicherung unnötigerweise wertvoller (Postfach-)Speicher belegt wird.

Problem: Redundante Datenhaltung

Aus der unstrukturierten oder sogar lokalen Speicherung der Projektdokumente erwachsen aber noch andere Probleme: Ein Grundsatz bei der Dokumentenerstellung muss lauten, dass Informationen grundsätzlich nur in einem Dokument stehen dürfen. Die häufig angewandte Methode, Informationen mittels Kopieren und Einfügen in ein anderes Dokument zu übernehmen, anstatt auf das Dokument zu verweisen, führt zwangsläufig zu Inkonsistenzen und erhöhtem Pflegeaufwand. Die gleichen Folgen hat die Erfassung von Informationen in einem Dokument, ohne die Inhalte anderer Dokumente zu berücksichtigen.

Um diesem Problem zu begegnen, muss sichergestellt werden, dass jedem Projektteammitglied die Inhalte der anderen (für ihn relevanten) Dokumente bekannt sind und ein Verweis auf diese Dokumente möglich ist. Zusätzlich ist zu gewährleisten, dass Änderungen an Dokumenten immer an der gültigen aktuellen Version eines Dokuments erfolgen.

Mit einer typischen wild wachsenden »Projektteam-Dokumentenablage«, in der in Dutzenden von Ordnern mindestens zehn Arbeitsversionen eines Dokuments liegen und die aktuelle Version sich auf dem lokalen Notebook des Beraters befindet, ist diese Forderung allerdings nicht durchzusetzen.

Problem: Verweise auf Inhalte, die es gar nicht gibt

Und noch ein weiteres Phänomen steht mit dem vorgenannten in unmittelbarem Zusammenhang und ist typisch für Projektdokumente. In einem Projekt werden häufig verschiedene Dokumente parallel von unterschiedlichen Personen erstellt. Mangels genauer Kenntnis der Dokumente und der Tatsache, dass das andere Dokument ebenfalls noch in der Erstellung ist, wird vielfach »blind« auf andere Dokumente verwiesen. Es wird hierbei davon ausgegangen, dass der andere Projektmitarbeiter dieses Thema in sein Dokument noch aufnehmen wird. So kommt es, dass man in Dokumenten Verweise auf Inhalte oder sogar auf Dokumente findet, die es gar nicht gibt.

Organisatorische Lösungen

Um den genannten typischen Problemen der Dokumentation in Projekten zu begegnen, sind sowohl organisatorische als auch technische Maßnahmen erforderlich.

Wie die Ausführungen zeigen, ist es ohne eine zentrale Verwaltung der Projektdokumente kaum möglich, den genannten Problemen zu begegnen. Bei umfangreichen oder langfristigen Projekten ist daher die Benennung eines Verantwortlichen für die projekteigene Dokumentenverwaltung dringend zu empfehlen. Typischerweise übernimmt dieser die folgenden Aufgaben:

- Erstellen eines Konzepts für die Verwaltung der Projektdokumente (eventuell als Teil des Projektmanagement-Handbuchs),
- Registrieren aller Dokumente,
- Kennzeichnen aller Projektdokumente mit einer eindeutigen ID,
- Einrichten einer geeigneten Ablagestruktur und sicherstellen, dass diese auch eingehalten wird,
- Sicherstellen, dass die Projektmitarbeiter Zugriff auf alle erforderlichen Referenzdokumente, d.h. auf Dokumenten haben, die relevant für das Projekt sind aber nicht vom Projekt erstellt und gepflegt werden,

- Überwachen von Dokumentenänderungen und Bereitstellung der geänderten Dokumente,
- Informieren der Projektmitarbeiter über wichtige Änderungen an Dokumenten,
- Vorbereiten und Durchführen von Dokumentenübergaben an den IT-Betrieb.

Einsatz eines Dokumentenmanagementsystems

Realistischerweise sind die genannten Anforderungen und Aufgaben nur kleinen Projektteams und bei kleinen Projekten mit nur wenigen Dokumenten ohne den Einsatz eines elektronischen Dokumentenmanagementsystems (DMS) nur schwer umsetzbar. Die Hauptaufgabe des DMS liegt darin, die definierten Dokumentationsprozesse automatisiert zu steuern.

Für die Projektdokumentation sind insbesondere die Funktionen zum Erstellen und Ändern von Dokumenten wichtig. Das Versionsmanagement eines DMS beispielsweise kann die Bearbeitung von Dokumenten kontrollieren. Das heißt, Dokumente müssen zur Bearbeitung aus dem System ausgecheckt werden und können während der Bearbeitungszeit von anderen Benutzern nur angezeigt, jedoch nicht geändert werden. Nach der Bearbeitung wird das Dokument wieder eingchecked. Das DMS vergibt dann eine neue Versionsnummer. Hierdurch wird verhindert, dass zwei oder mehrere Projektmitarbeiter gleichzeitig an einem Dokument arbeiten und ihre Arbeitsergebnisse im schlimmsten Fall gegenseitig vernichten. Abhängig vom eingesetzten System sind diese Abläufe mehr oder weniger anpassbar und durch Workflows zu erweitern. Außerdem stellt ein DMS sicher, dass immer die aktuell gültige Version eines Dokuments verfügbar ist. Dies erst macht die Verwendung von Verlinkungen auf andere Dokumente möglich.

Darüber hinaus bieten die meisten Dokumentenmanagementsysteme Workflows für die Dokumentensteuerung. Beispielsweise können Review- und Freigabeprozesse eingerichtet und die Abnahme von Dokumenten damit deutlich erleichtert werden. In *Kapitel 7* finden Sie in *Abschnitt 7.7.2* exemplarisch Erläuterungen zur Dokumentenverwaltung mit Microsoft SharePoint.

5.4.3 Dokumentenübergabe an den Betrieb

Auch wenn dies in der Praxis nicht immer durchzuhalten ist, sollten neue geänderte Systeme und Verfahren erst dann in die Produktionsumgebung übernommen werden, wenn auch die fertige Dokumentation dafür vorliegt. Das bedeutet: Die Systemakten müssen erstellt und die Verfahrensdokumentation muss fertiggestellt und freigegeben sein. Nur so kann die Dokumentation in die Abnahme einbezogen werden – und was noch wichtiger ist: Nur so kann mit dem neuen System vorgabengerecht gearbeitet werden. Ein weiteres wichtiges Argument für eine Erstellung der Dokumente parallel zur Implementierung ist, dass zu diesem Zeitpunkt alle Informationen noch präsent sind und aktuell vorliegen. Ebenso ist derjenige, der das System entwickelt und gegebenenfalls implementiert hat, noch greifbar.

Soll beispielsweise eine neu entwickelte Software in den Betrieb übernommen werden, so wird der Aufwand für die Erstellung der Systemakte reduziert, wenn derjenige, der das System programmiert hat, es auch zu dem Zeitpunkt, an dem die Information anfällt, dokumentiert. Dies ist insbesondere wichtig, wenn die Erstellung der Software durch externe

Auftragnehmer erfolgte. Hierbei ist die neue Software so zu dokumentieren, dass zu einem späteren Zeitpunkt Wartung sowie Einarbeitung in das System effektiv und fehlerfrei möglich sind.

Ebenfalls sollten bis zum Zeitpunkt der Übernahme eines neuen oder geänderten Systems bzw. Verfahrens in den Betrieb alle erforderlichen Änderungen an den bestehenden Betriebsdokumenten (beispielsweise Anpassungen im Rollenkonzept) bereits erfolgt sein.

Das, was sich in Bild 5.13, also in der Theorie, noch recht einfach darstellt, klappt erfahrungsgemäß in der Praxis nur selten oder gar nicht. Gerade die Dokumentenschnittstelle, also die Erstellung der Dokumente für die Betriebsdokumentation und die Anpassung vorhandener Betriebsdokumente, funktioniert häufig nicht gut oder gar nicht. Während sich alle auf die Übergabe der Systeme und Verfahren konzentrieren, fällt die Erweiterung und Anpassung der Betriebsdokumentation häufig »hinten runter«.

Ein wesentlicher Grund hierfür ist, dass für die Betriebsdokumente andere Personen verantwortlich sind, und meist zwischen Projekt und Betrieb kein oder nur wenig Kontakt besteht. Hinzu kommt, dass diejenigen Projektmitarbeiter, die die Dokumentation erstellen, häufig (weil extern beauftragt) keine Kenntnis vom Betrieb und von dessen Anforderungen haben und auch nicht wissen können, welche Dokumente vonseiten des Betriebs benötigt werden. Diese Schwierigkeiten führen in der Praxis dann häufig zu dem Fehler, dass überhaupt keine Dokumente für den IT-Betrieb erstellt oder die im Projekt erstellten Betriebsdokumente zwar abgeschlossen, aber nicht offiziell übergeben werden. In der Folge werden Änderungen am System nicht in der Dokumentation berücksichtigt – es gibt somit eine weitere, bald veraltete »Schränk-Dokumentation«.

Wie kann diesen Problemen begegnet werden?

Der wichtigste Punkt ist eine gut strukturierte und gepflegte Dokumentation für den IT-Betrieb. Denn wie sollen die Projektmitarbeiter geeignete Dokumente an den Betrieb übergeben, wenn es keine adäquate Betriebsdokumentation gibt?

Vonseiten des Betriebs müssen klare Anforderungen an die zu übergebenden Dokumente definiert werden. Das heißt, die Dokumentationsanforderungen sollten Bestandteil des Lastenhefts sein. Die Erstellung der Betriebsdokumente muss als Arbeitspaket in den Projektaufgaben verankert werden. In vielen Projekten wird viel Aufwand auf die Erstellung der Projektdokumente verwandt, der Erstellung der Betriebsdokumentation aber kaum Raum eingeräumt. Ebenfalls sollten bis zum Zeitpunkt der Übernahme eines neuen oder geänderten Systems bzw. Verfahrens in den Betrieb alle erforderlichen Änderungen an den bestehenden Betriebsdokumenten (beispielsweise Anpassungen im Rollenkonzept) bereits erfolgt sein.

An dieser Stelle machen sich die immer noch vorhandenen Akzeptanzprobleme gegenüber der Dokumentation allgemein bemerkbar. Im Projekt müssen Dokumente erstellt werden und viele Auftraggeber sind bereit, für ein Konzept viel Geld zu bezahlen. Zusätzlich Geld ausgeben für Betriebsdokumente möchte man aber nicht. Dem kann nur durch die Einführung verbindlicher Übergabeverfahren begegnet werden.

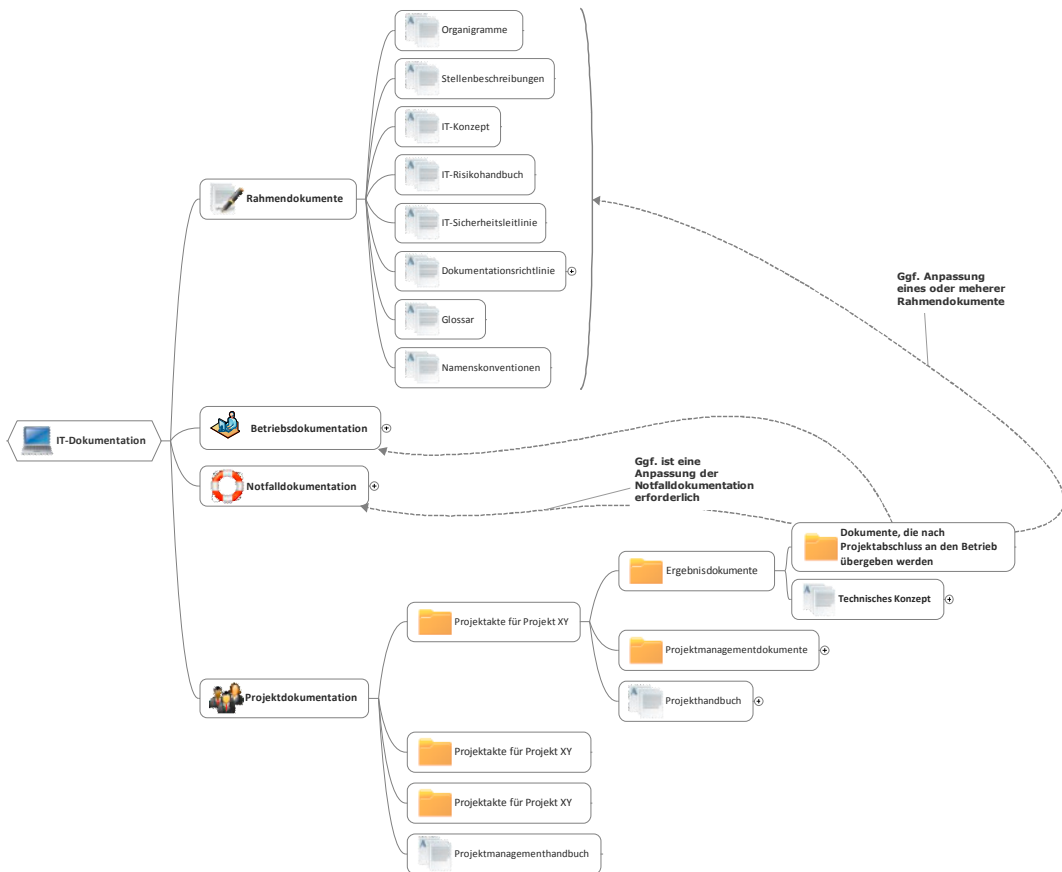


Bild 5.13 Erweiterung bzw. Anpassung der Betriebsdokumentation nach Projektabschluss

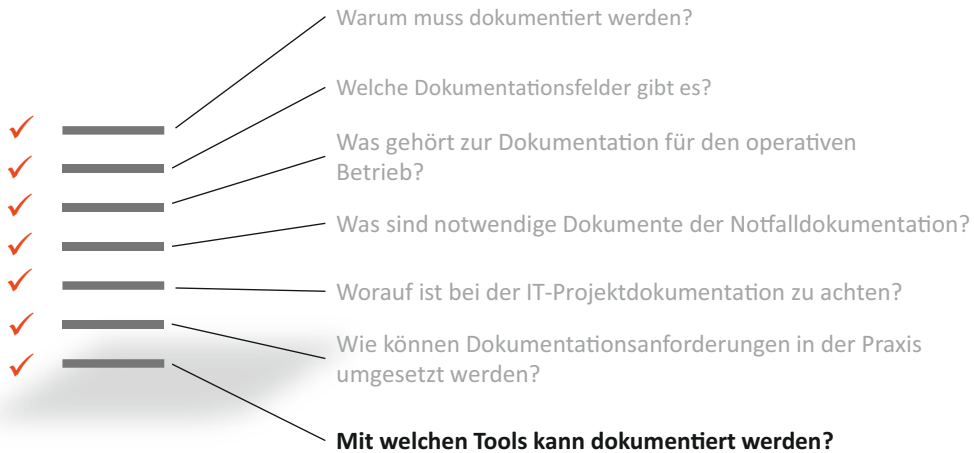
5.5 Zusammenfassung

IT-Projekte dienen dazu, Neuerungen, Anpassungen und Optimierungen des IT-Betriebs zu realisieren, die aufgrund ihres Umfangs oder ihrer Ausprägung nicht im IT-Regelbetrieb durchführbar sind. Projekte sind gekennzeichnet durch eine eigene Projektstruktur und das Merkmal der Einmaligkeit. Dementsprechend unterscheidet sich die Dokumentation des IT-Betriebs von der Projektdokumentation. Dies manifestiert sich auch, wie das Kapitel gezeigt hat, an typischen Problemen, die in Bezug auf die Organisation der Dokumentation in Projekten bestehen.

Bei Projekten sind die Planung, die Durchführung, das Testen und die Implementierung bedarfsgerecht zu dokumentieren. Neben den Projektmanagementdokumenten spielen deshalb vor allem Konzepte und Testdokumente eine wichtige Rolle.

Lösungen, die in einem Projekt entwickelt werden, müssen nach dem Testen in den IT-Betrieb überführt werden. Nicht nur hierfür muss es dokumentierte Prozesse geben. Wichtig ist, dass nur Systeme in den Betrieb überführt werden, für die auch Betriebsdokumente erstellt wurden. Eine Betriebsüberführung muss also auch die Überführung der Dokumente in den IT-Betrieb einschließen.

Eine Toolbox für die IT-Dokumentation



In den vorstehenden Kapiteln wurde an einigen Stellen darauf hingewiesen, dass die beschriebenen Dokumentationsaufgaben ohne den Einsatz von entsprechenden Tools nicht angemessen erfüllt werden können. Je umfangreicher die Anzahl an Dokumenten und je größer die Komplexität der Abhängigkeiten ist, desto stärker ist das Erfordernis nach einer zentralen IT-gestützten Datenhaltung und Tool-Unterstützung bei der Dokumentation. So ist es in komplexen Systemumgebungen kaum möglich bzw. sinnvoll, Excel-Listen mit den eingesetzten Systemen manuell zu pflegen. Aber auch für andere Aufgaben wie beispielsweise für die Dokumentation der Prozesse, der Erstellung der Sicherheits- und Datenschutzdokumentation oder der Pflege der für Audits und Prüfungen benötigten Referenzdokumente werden Anwendungen benötigt oder sind zumindest sinnvoll.

In diesem Kapitel werden die verschiedenen Einsatzbereiche und exemplarisch einige Anwendungen vorgestellt. Das Ziel ist allerdings nicht, das »beste« Tool für die IT-Dokumentation zu präsentieren. Vielmehr sollen die Beispiele zeigen, wie Anwendungen bei der Bewältigung der verschiedenen Dokumentationsaufgaben unterstützen können und Anregung für die zwingend notwendige Evaluierung bieten.

In diesem Kapitel finden Sie die folgenden Themenschwerpunkte:

- Die Suche nach der »Eierlegenden Wollmichsau«
- Tools für verschiedene Aufgabenbereiche

■ 7.1 Die Suche nach der »Eierlegenden Wollmichsau«

Eine häufige Frage lautet: Welches Tool können wir für die IT-Dokumentation einsetzen? Diese Frage suggeriert, dass mit einer einzigen Anwendung alle Bereiche der IT-Dokumentation gleichermaßen bedient werden können. Dieses eine Tool aber gibt es nicht. Vielmehr muss vor der Auswahl einer Anwendung zur Unterstützung der Dokumentation zunächst die wichtigste Frage beantwortet werden: Welches Ziel verfolgen wir mit dem Einsatz einer Softwarelösung?

Denn auf diese Frage kann es viele Antworten geben:

- Wir wollen unsere Systeme dokumentieren und dafür die Systeme möglichst automatisch erfassen.
- Wir wollen unsere Prozesse erfassen und dokumentieren.
- Wir wollen eine CMDB einrichten.
- Wir wollen eine Notfalldokumentation erstellen.
- Wir wollen unsere Dokumente effizienter verwalten.
- Wir wollen eine ISO-27001-konforme Dokumentation.
- ...

Allein diese wenigen Fragen machen deutlich, dass es unmöglich ist, dass ein einziges Tool alle Aufgabenbereiche gleichermaßen gut unterstützen kann. Es ist daher zunächst einmal erforderlich, den Einsatzbereich zu identifizieren. Hierbei will dieses Kapitel Sie unterstützen. Ausgehend von den in den vorhergehenden Kapiteln ausführlich vorgestellten Dokumentationsbereichen werden die folgenden Einsatzbereiche erläutert und Beispiele vorgestellt:

- Tools für die Systemdokumentation,
- Tools für die Prozessdokumentation,
- Tools für das IT-Servicemanagement und CMDB-Tools,
- Tools für das Informationssicherheitsmanagement (ISMS-Lösungen),
- Tools für die Notfalldokumentation,
- Tools für die Governance Risk Compliance (GRC)-Dokumentation,
- Dokumentenmanagementsysteme.

Vorhandene Anwendungen einbeziehen

Bei der Auswahl einer neuen zusätzlichen IT-Lösung muss zwingend immer die bestehende Anwendungslandschaft betrachtet werden. Eine wichtige Rolle spielen dabei die Möglichkeiten einer Anwendung zur Anpassung an die eigene Methodik und Vorgehensweise, schließlich soll sich das Tool an die Vorgehensweise des Unternehmens anpassen und nicht umgekehrt (was jedoch nicht immer durchsetzbar ist).

Um zu verhindern, dass Insellösungen oder Redundanzen entstehen, sollten sich alle eingesetzten Tools im Idealfall ergänzen und miteinander agieren. So kann zum Beispiel eine

Scan-Software zur automatisierten Erfassung der Systemdaten eingesetzt werden, die dann wiederum in die Datenbank einer CMDB-Lösung und/oder einer GRC-Anwendung einfließen. In jedem Fall sollte vermieden werden, dass Daten redundant in mehreren Systemen gepflegt werden müssen. Dies betrifft vor allem Unternehmen, die bereits *Netzwerkmanagementanwendungen* und *Netzwerkmonitoringanwendungen* einsetzen.

- **Netzwerkmanagement:** Die ISO benennt in ihrem *FCAPS-Modell* die folgenden funktionalen Aufgaben von Netzwerkmanagement: Fehlermanagement, Konfigurationsmanagement, Abrechnungsmanagement, Leistungsmanagement und Sicherheitsmanagement. Netzwerkmanagement-Tools unterstützen demnach die drei Bereiche *Operation*, *Administration and Maintenance (OAM)* von IT-Netzwerken und Telekommunikationsnetzen.
- **Netzwerkmonitoring:** Unter Netzwerkmonitoring versteht man die Überwachung und regelmäßige Kontrolle von Netzwerken, deren Hardware (z. B. Server, Router, Switches) und Diensten (z. B. Webserver, DNS-Dienste, E-Mail-Dienste). IP-Netze werden häufig mittels Simple Network Management Protocol (SNMP) und/oder Windows Management Instrumentation (WMI) verwaltet und überwacht.

Die Softwarelösungen der großen Systemmanagementspezialisten wie Computer Associates, Hewlett-Packard und IBM, aber auch einige OpenSource-Lösungen bieten neben der Verwaltung und Überwachung auch Funktionen für die Softwareverteilung und CMDB-Unterstützung. Hat eine IT-Organisation bereits ein solches Tool im Einsatz, stellt sich die Frage nach einer Inventarisierungslösung nicht mehr.

Doch nicht jede Organisation kann und will sich den Einsatz einer der »großen« Netzwerkmanagementlösungen leisten. Außerdem liegt der Fokus dieser Anwendungen nun einmal nicht im Bereich Dokumentation, so dass die Ableitung der aus Compliance-Anforderungen resultierenden Dokumente meist mit einigen Mühen verbunden ist.

Bei der Auswahl der hier vorgestellten Programme standen hingegen die Dokumentationsfunktionen im Vordergrund. Die Vorstellung der Anwendungen beschränkt sich dabei auf einen Überblick der aus Sicht der vorgestellten IT-Dokumentation relevanten Funktionen und stellt keine Anleitung für den Betrieb der Anwendungen dar. Hierfür sei auf die Dokumentation der Hersteller verwiesen.

■ 7.2 Tools für die Systemdokumentation

Systeme bilden die Basis für die Bereitstellung von IT-Dienstleistungen, unabhängig davon, auf welcher Reifegradstufe sich eine IT-Organisation befindet. Die Einrichtung und Pflege einer Systemdokumentation als Bestandteil der IT-Betriebsdokumentation sind daher zwingend erforderlich. Wie in den ausführlichen Erläuterungen der Systemdokumentation in *Kapitel 3 in Abschnitt 3.2* vorgestellt, schließt diese die folgenden Systemgruppen ein:

- **Hardwaresysteme:** Mainframe-Systeme, Clientrechner und Server, Speichersysteme, Drucker und Videokonferenzsysteme gehören u. a. in diese Kategorie.
- **Softwaresysteme:** Hierzu zählen u. a. Betriebssysteme und IT-interne Anwendungen. Letztere umfassen u. a. alle Anwendungen und Dienste zur Steuerung und Verwaltung

des IT-Betriebs, wie beispielsweise Active Directory, aber auch Backup-Anwendungen oder Virtualisierungslösungen.

- **Netzwerkkomponenten:** Hierbei handelt es sich um Systeme, die der Vernetzung und der Kommunikation der Einzelkomponenten untereinander dienen. Dies beinhaltet sowohl Switches, Router und Gateways als auch beispielsweise Verteilerschränke und Patch-Felder.
- **Infrastruktur:** Hierzu zählen Gebäude, Serverräume, Klimaanlage usw. Diese Komponenten werden heute unter dem Begriff Facility zusammengefasst. Dem Facility-Management werden üblicherweise technische Anlagen und Einrichtungen, Geräte, Gebäude, aber auch Arbeitsmittel und Energie zugeordnet.

7.2.1 Hinweise für die Evaluierung

Die Komplexität heutiger Systemumgebungen macht eine Verwaltung all dieser Komponenten ohne die Unterstützung entsprechender Tools auch bei kleinen Unternehmen nahezu unmöglich. Hierbei haben Tools zwei Funktionen: Sie können die SNMP-, Netbios- oder WMI-Daten automatisiert erfassen und auswerten und/oder sie bieten eine datenbankgestützte Verwaltung und Bereitstellung der Daten und ermöglichen unterschiedliche Sichten auf die Informationen. Automatisiert erfasst werden können jedoch nur aktive Komponenten, passive Komponenten wie Kabel oder Patchpanel bleiben außen vor. Eine Dokumentation aller Netzwerkschichten erfordert also zwingend immer auch manuellen Pflegeaufwand.

Der Markt bietet eine ganze Reihe verschiedener Lösungen an. Es würde aber den Rahmen dieses Buchs sprengen, einen bewertenden Vergleich verschiedener Lösungen anzubieten, zumal ein solcher Vergleich wohl nur für kurze Zeit einen Anspruch auf Aktualität hätte. Außerdem, und dieser Punkt ist noch wichtiger, haben alle Softwarelösungen unterschiedliche Ausrichtungen und unterstützen die Dokumentation unterschiedlicher Komponenten. Bei der Auswahl einer Software sind die individuellen Anforderungen Ihres Unternehmens entscheidend. Und möglicherweise ist auch der parallele Einsatz mehrerer Tools erforderlich.

Auch die im Folgenden vorgestellten Tools decken unterschiedliche Bereiche der IT-Dokumentation ab und sollen dafür jeweils exemplarisch einen Eindruck vermitteln: Während *Docusnap* von der Firma Itelio GmbH die automatisierte Inventarisierung von Systemen im Windows-, Linux- und Macintosh-Umfeld adressiert, unterstützt *SM-Docu* der SHD System-Haus-Dresden GmbH die Dokumentation aktiver und passiver Netzwerkkomponenten und das Tool *FaciPlan* von der Firma FaciWare GmbH ist eine Software für die Dokumentation von Facility-Komponenten.

7.2.2 Docusnap

Die folgenden Ausführungen zu Docusnap (Itelio GmbH) beziehen sich auf die aktuelle Version 6.1 (Stand Juli 2013).

Docusnap ist eine Software für die automatisierte Inventarisierung von Hardware und Software. Neben den Daten der einzelnen Windows-, Linux- und Macintosh-Systeme inventari-

siert und dokumentiert Docusnap auch das Microsoft Active Directory, die Microsoft-Exchange-, SQL-, DHCP/DNS-Server-, SharePoint- und Virtualisierungsumgebungen (inkl. VMware, HyperV, Xen).

Neben der reinen Datenerfassung bietet Docusnap zusätzliche Dokumentationsfunktionen und unterstützt einen strukturierten und automatisierten Dokumentationsprozess. Im Gegensatz zu den meisten Netzwerkmanagement- und Inventarisierungstools, die meist nur die Erstellung programminterner Berichte ermöglichen, unterstützt Docusnap die Ausgabe der Informationen in Berichten, Übersichtsplänen und Datenblättern. Zusätzlich können alle Ergebnisse als vollständig verlinkte HTML-Dokumentation bereitgestellt und damit in die eigene IT-Dokumentation eingebunden werden.

Wichtig ist hierbei, dass Docusnap agentenfrei arbeitet. Das heißt, es muss keinerlei Software auf den auszulesenden Systemen installiert werden und diese müssen sich nicht am Docusnap-Rechner anmelden. Auch erfolgen durch Docusnap, mit Ausnahme der Eintragungen in die Inventarisierungsdatenbank, ausschließlich lesende und niemals schreibende Zugriffe auf die gescannten Systeme.

Darüber hinaus ist Docusnap beliebig skalierbar, da die Daten sowohl in einer Access- als auch in einer SQL-Datenbank abgespeichert werden können. Aufgrund einer Preisstaffelung und des damit relativ niedrigen Einstiegspreises ist Docusnap auch für den Einsatz in kleineren Netzwerkumgebungen interessant. Dabei wird Docusnap als Basispaket erworben. Diesem können zu einem beliebigen Zeitpunkt nachträglich die folgenden optionalen Module hinzugefügt werden: Exchange Server, SQL Server, DHCP/DNS-Server, Macintosh, Linux, VMware, Lizenzverwaltung, Rechteanalyse und Customizing.

Inventarisierung und Dokumentation

Die Datensammlung kann von jeder Workstation im Netzwerk aus durchgeführt werden. Wird zusätzlich *Docusnap-Server* eingesetzt, kann dies auch zeitgesteuert erfolgen, ohne dass ein manueller Eingriff seitens des Anwenders notwendig ist. Nach der Installation von Docusnap, dem Einspielen der Lizenzdatei und der Anlage eines neuen Firmenobjekts kann die erste Datenerfassung erfolgen. Die Ergebnisse der System- und Netzwerkerfassung zeigt Docusnap im eigenen Daten-Explorer an. Hier können die Informationen zu den untersuchten Systemen in diversen standardmäßig erzeugten und anpassbaren Berichten ausgewertet werden. Außerdem bietet Docusnap mit der Schnittstelle DocusnapConnect die Möglichkeit, Daten für andere Systeme zur Verfügung zu stellen und den Export von Daten in SQL-Datenbanken, XML-Dateien oder CSV-Dateien zeitgesteuert auszuführen.

Die Stärke von Docusnap aus Sicht des Buchs liegt aber in den vielfältigen Dokumentationsfunktionen. Direkt im Anschluss an die Inventarisierung oder auch zu jedem späteren Zeitpunkt kann eine vollständige Dokumentation (in Deutsch oder Englisch) erzeugt werden. Für jedes gescannte System erstellt Docusnap ein Dokument mit allen relevanten Systeminformationen. Zusätzlich können eine Reihe von Plänen, u. a. Netzwerk- und Routingpläne sowie Übersichten über Computer, Software, Betriebssystem, Hardwarekomponenten, Benutzer und Gruppen, generiert werden. Sofern das entsprechende Modul erworben wurde und Microsoft Visio installiert ist, werden DHCP-, DNS-, Exchange-Server- und SQL-Server-Pläne bereitgestellt. Dokumente können als PDF-Dokument, Word-Dokument, Excel-Dokument, Visio-Dokument und ODT-Dokument ausgegeben werden.

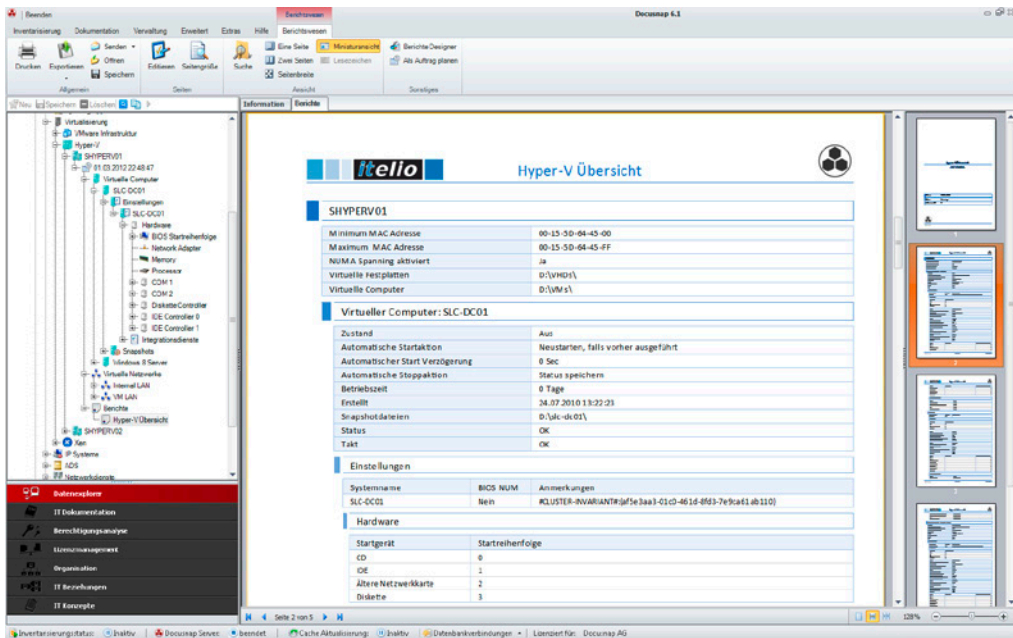


Bild 7.1 Ausschnitt aus einem Datenblatt



Beispieldokumentation

Hervorzuheben ist die Möglichkeit, die komplette Dokumentation als verlinkte HTML-Dokumentation bereitzustellen. Damit ist es beispielsweise möglich, Mitarbeitern Zugriff auf die Systemdokumentation zu geben, ohne dass diese Docusnap installiert haben müssen. Auf der Website unter [<http://www.docusnap.de/Showroom/Musterdoku.aspx>] finden Sie hierfür Beispiele.

Wie mehrmals im Buch ausgeführt, genügt es aber nicht, einmalig den Zustand eines Systems zu erfassen. Vielmehr muss nicht nur die Dokumentation laufend gepflegt und aktualisiert werden, sondern es ist darüber hinaus erforderlich, den jeweils aktuellen Zustand mit einem älteren Zustand abgleichen zu können, was bei manueller Pflege einen hohen Aufwand bedeutet. Docusnap bietet mit der *Snapshotverwaltung* hierbei Unterstützung, da jeder Scan für jedes System unter dem entsprechenden Datum und der Uhrzeit gespeichert wird. Standardmäßig archiviert Docusnap die letzten fünf Scan-Ergebnisse; außerdem können einzelne Scans von der Löschung ausgenommen werden.

Für jedes System werden zusätzlich Informationen benötigt, die nicht automatisiert erfasst bzw. dokumentiert werden können. Hierzu zählt beispielsweise die Erfassung von Störungen (zum Beispiel Hardwareprobleme). Derartige Informationen erleichtern eine spätere Nachvollziehbarkeit und bieten Hinweise im Hinblick auf mögliche, zukünftige Störungen und Probleme mit dem System. Auch Informationen zum Herstellersupport und Wartungsverträge müssen sich zuordnen lassen.

Diese Anforderungen unterstützt Docusnap in der aktuellen Version mit entsprechenden Funktionen. Es können Kommentare, Finanzverwaltungsdaten, Verträge und Erinnerungen mit dem System verknüpft sowie Dateianhänge angefügt werden, so dass eine vollständige Systemdokumentation in Docusnap möglich ist. Dies ist vor allem wichtig für Unternehmen, deren Dokumentation sich gemäß dem in *Kapitel 3* dargestellten Reifegradmodell Stufe 1 oder 2 zuordnen lässt. Darüber hinaus bietet die Passwortverwaltung die Möglichkeit, für alle Systeme Passwörter (verschlüsselt) zu hinterlegen. Die Kommentare wiederum können (frei definierbaren) Klassen zugeordnet und mithilfe benutzerdefinierter Reports dokumentiert werden. Alternativ können die Systemakten als normale Office-Dokumente erstellt werden, die wiederum Verlinkungen auf die automatisiert erstellten Datenblätter enthalten. Im Einzelfall muss das gewünschte Ausgabeformat unter Berücksichtigung der verfügbaren Ausgabeformaten (HTML-Dokumentation, SharePoint Server usw.) gewählt werden.

Rechteanalyse und Lizenzverwaltung

Aus Compliance-Sicht sind die beiden Module *Rechteanalyse* und *Lizenzverwaltung* interessant. Das optionale Modul »Rechteanalyse« liest die Berechtigungen von Windows-Rechnern auf Basis von NTFS- und Freigabeberechtigungen. Die Berechtigungsanalyse ist für alle Windows-Systeme bzw. Systeme möglich, die das SMB- oder CIFS-Protokoll (z.B. Samba, Netapp Filer) unterstützen. Zusätzlich zur Berechtigungsanalyse von Verzeichnissen und Freigaben sowie Microsoft SharePoint können auch die Berechtigungen für Exchange-Postfächer, Postfachordner und öffentliche Ordner inventarisiert und analysiert werden. Mithilfe grafischer Übersichten und diverser Filtermöglichkeiten kann Docusnap einen Überblick über die Berechtigungssituation liefern.

The screenshot shows the Docusnap 9.1 interface with the 'Rechteanalyse' (Rights Analysis) module active. The left pane shows a tree view of the file system. The central pane displays the analysis results for a selected path, showing a list of permissions and their status (checked/unchecked) for different users and groups. The right pane shows a detailed table of permissions, including columns for 'Typ', 'Basis Berechtigungen', 'SMB Berechtigungen', and 'Verzeichnis'. The table lists various permissions (e.g., Read, Write, Execute) and their status (checked/unchecked) for different users and groups. The bottom status bar indicates the current state of the analysis and the selected file system.

Bild 7.2 Die ermittelten Rechte können in verschiedenen Berichten dargestellt und gedruckt werden.

Die Lizenzverwaltung liefert nach einer entsprechenden Erfassung der erforderlichen Daten zu den im Unternehmen eingesetzten Anwendungen u. a. Übersichten über Unter- und Überlizenzierungen oder ablaufende Gültigkeiten. Außerdem können Soll-Ist-Abgleiche der installierten Software erstellt und dokumentiert werden. Damit kann Docusnap auch die Prozesse zur Softwareverwaltung bzw. zur Softwareverteilung unterstützen.

IT-Beziehungen

Die Notwendigkeit zum Einsatz von Datenbanken zur Verwaltung der IT-Systemdokumentation nimmt mit steigendem Reifegrad zu. IT-Organisationen, die service- und prozessorientiert aufgestellt sind, werden zumindest Teile der Systemdokumentation sinnvollerweise in einer CMDB verwalten. Die wichtigste Aufgabe einer solchen CMDB ist die Verknüpfung der Systeme mit den Prozessen und den Services.

Zwar bietet Docusnap nicht die Möglichkeiten komplexer CMDB-Tools, doch abhängig von den Anforderungen kann die Funktion *IT-Beziehungen*, mit der sich Beziehungen zwischen einzelnen Komponenten darstellen lassen, ausreichende Möglichkeiten bieten. IT-Beziehungen können einerseits auf einer organisatorischen Ebene und andererseits auf einer eher technischen IT-Ebene gestaltet werden. Auf der organisatorischen Ebene kann dargestellt werden, welche Server, Arbeitsstationen etc. miteinander in Beziehung stehen. Dadurch kann z. B. festgestellt werden, welche Systeme vom Ausfall einer Komponente betroffen wären oder wie ein Service einzelner Komponenten durchgeführt werden sollte. Werden die IT-Beziehungen auf der IT-Ebene genutzt, kann festgelegt werden, um welche Art von Verbindung es sich handelt und welches Protokoll bei dieser Verbindung verwendet wird.

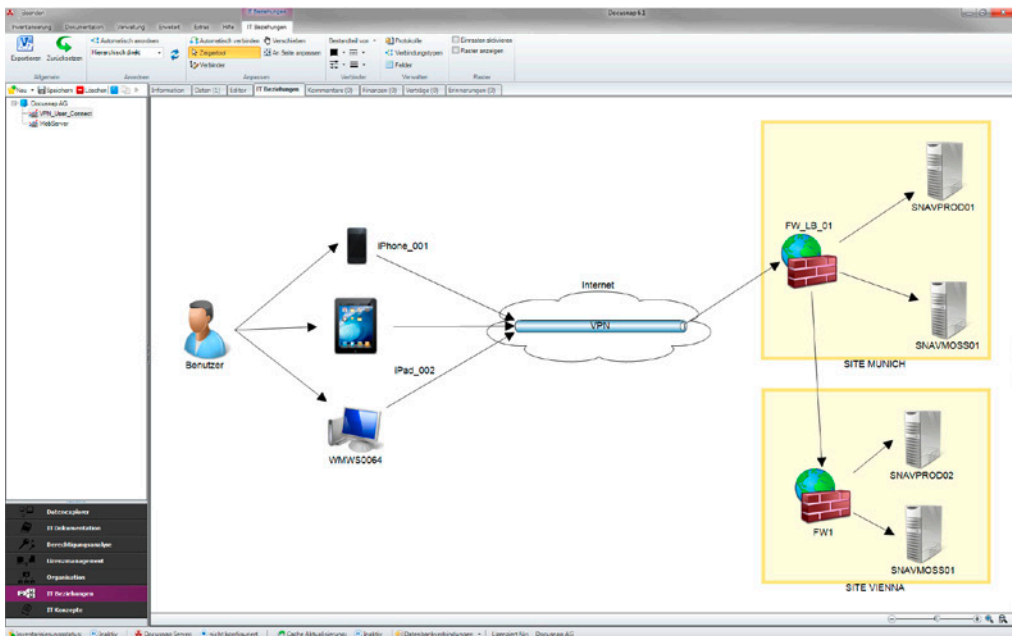


Bild 7.3 Darstellung von IT-Beziehungen

IT-Konzepte

Es gibt kein Tool, das die gesamte Systemdokumentation automatisiert erstellen kann. Beispielsweise müssen eine Reihe weiterer Anwendungen dokumentiert und weitgehend manuell beschrieben werden. Typische Vertreter sind das Backup-Konzept und das Archivierungskonzept. Und auch die Beschreibung der administrativen Tätigkeiten – sofern diese Bestandteil der Systemakte sind – erfordert eine manuelle Dokumentation.

Das Modul *IT-Konzepte* in Docusnap bietet die Möglichkeit, derartige Konzepte unter Verwendung aller erfassten Daten, Dokumentationen und IT-Beziehungen zu erstellen. Hierbei besteht die Möglichkeit, Variablen wie den Namen einer Arbeitsstation oder das letzte Inventarisierungsdatum in Fließtextbereiche einzufügen. Diese werden zusammen mit den inventarisierten Daten aktualisiert, so dass das Konzept zu jeder Zeit auf dem neuesten Stand ist. Nach Fertigstellung des Konzepts kann das Dokument in verschiedene Formate (.docx, .doc, .pdf, .html und .rtf) exportiert werden.

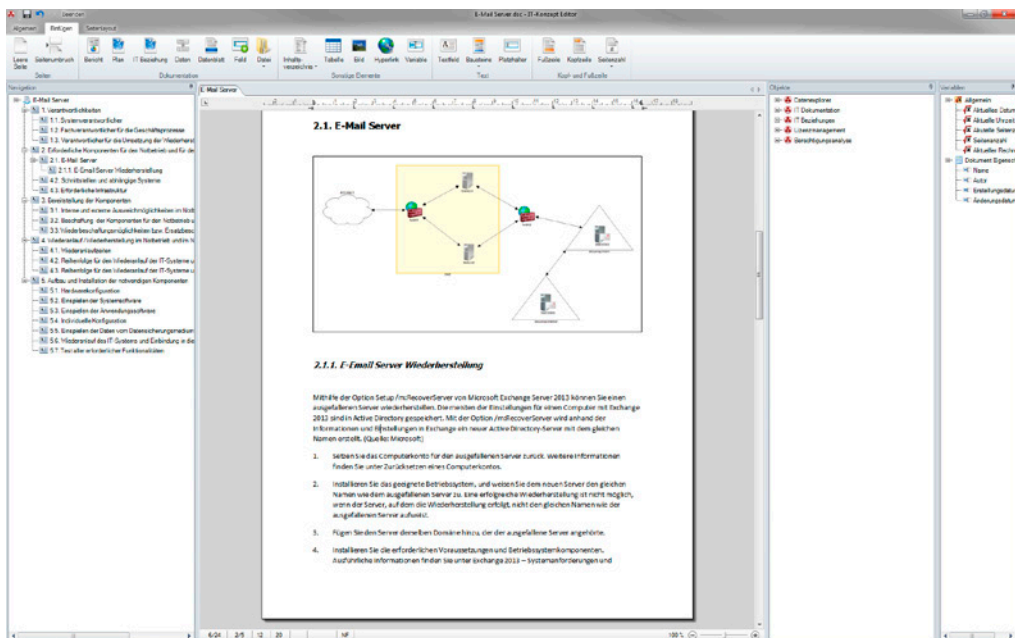


Bild 7.4 IT-Konzepte können in einem eigenen Editor erstellt werden.

7.2.3 FaciPlan

Die folgenden Ausführungen zu FaciPlan (FaciWare GmbH) beziehen sich auf die aktuelle Version 2010 (Stand Juli 2013).

In Kapitel 3 in Abschnitt 3.2.1.4 wurde ausgeführt, dass es aus dem Facility-Bereich eine Reihe von Systemen gibt, deren Dokumentation für den IT-Betrieb wichtig sind. Hierzu zählen zum Beispiel Klimaanlage, Löschsysteme oder Serverräume. Für die Dokumentation der Facility-Komponenten ist in der Regel nicht die IT-Organisation verantwortlich,

sondern das Gebäudemanagement (bzw. das Facility-Management). In jedem Fall aber gibt es Schnittstellen zur IT-Dokumentation.

Die Verwaltung der Facility-Komponenten im Rahmen des Facility- oder Gebäudemanagements ist – zumindest in größeren Unternehmen – ohne Softwareunterstützung kaum zu bewältigen. Anwendungen, die dies unterstützen, werden der Gruppe *Computer Aided Facility Management (CAFM)* zugerechnet. Hierbei handelt es in der Regel um Datenbankanwendungen, die eine Facility-Inventarisierung unterstützen. Zu den wichtigsten Funktionen gehören das Speichern, Aufbereiten und Bereitstellen der Informationen zum Beispiel für das Umzugsmanagement.

Die vorgestellte Software *FaciPlan* ist eine auf Visio basierende CAFM-Lösung und ermöglicht eine datenbankunterstützte Verwaltung und Dokumentation von Gebäuden und Infrastrukturanlagen. Es beinhaltet Module für Flächenmanagement, Belegungs- und Umzugsplanung, Inventarverwaltung, Wartungsmanagement, Informationstechnologiemanagement, Sicherheit, Schlüsselverwaltung, Mietvertrags-, Reinigungs- sowie Produktionsanlagenmanagement.

Faciware setzt auf Visio 2010 auf und erweitert die Grafikfähigkeiten von Visio um Funktionen zur Darstellung von Facility-Komponenten. Damit ist FaciPlan in erster Linie ein Werkzeug zur Visualisierung, das Flächen- und Sachdaten miteinander verknüpft. Bild 7.5 zeigt die Arbeitsoberfläche von FaciPlan, also die Visio-Oberfläche mit den Erweiterungen von FaciPlan, zu denen eine Reihe zusätzlicher Shapes, Symbolleisten und entsprechend konfigurierte Vorlagen zählen.

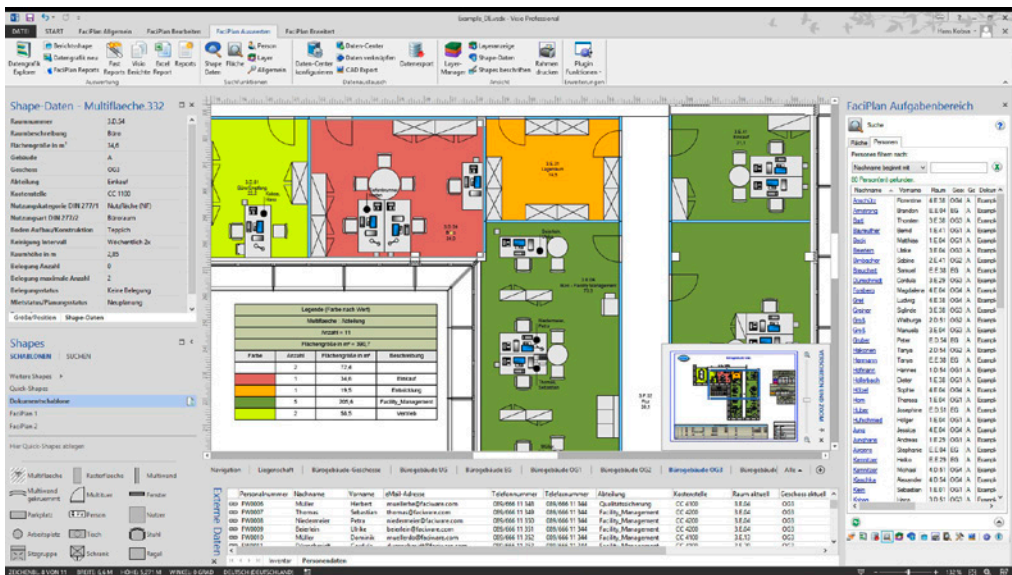


Bild 7.5 FaciPlan bindet sich als Add-on in Visio ein.

Schnittstelle zu Docusnap

Interessante Möglichkeiten ergeben sich daraus, dass Faciware eine Schnittstelle zur Inventarisierungssoftware Docusnap bietet. Damit ist es möglich, die in Docusnap automatisiert erfassten Systeme (Rechner, Drucker, Netzwerkgeräte usw.) an FaciPlan zu übergeben, dort

mit zusätzlichen Informationen zu verknüpfen und diese wiederum in Form von Gebäude- und Raumplänen zu visualisieren. Hierzu können in Docusnap Gebäude, Etagen und Räume angelegt und die inventarisierten Geräte den angelegten Räumen zugeordnet werden.

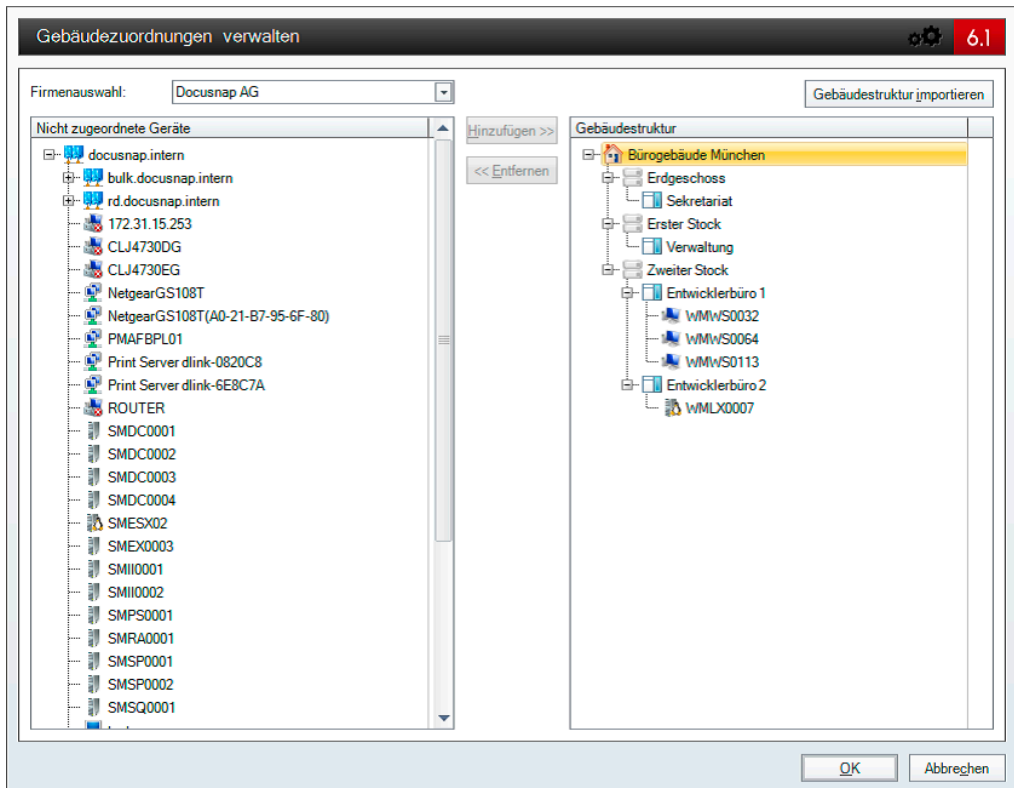


Bild 7.6 Die Schnittstelle zu Docusnap ermöglicht Zuordnungen von Geräten zu Räumen.

7.2.4 SM-Docu

Die folgenden Ausführungen zu SM-Docu (SHD System-Haus-Dresden GmbH) beziehen sich auf die aktuelle Version 6.01 (Stand Juli 2013).

Wie am Beispiel der anderen Anwendungen gezeigt wurde, lassen sich aktive Geräte wie Switches, Storage-Systeme, Server und auch Anwendungen mit Inventarisierungstools automatisiert erfassen und auswerten.

Für eine umfassende Dokumentation über alle Netzwerkschichten – also auch die physische Schicht, d. h. OSI Layer 1 – sind zwei Informationsarten jedoch zwingend per Hand zu pflegen: die Position der Geräte in einem Datenschränk und die Portzuordnung der einzelnen Patches. In der täglichen Praxis spielen aber gerade diese Daten eine wichtige Rolle. Die logische Verknüpfung der Portinformationen der Switches mit den Verkabelungsdaten ist die Grundlage für die Ableitung einer Reihe von Informationen, wie beispielsweise welches Gerät in welchem Raum an welcher Datendose angeschlossen ist, oder die Verfügbarkeit freier Datendosen und Switchports sowie überflüssiger Patche.

Die datenbankbasierte Anwendung SM-Docu unterstützt zum einen die manuelle Dokumentation der physikalischen Netzwerkschicht durch grafische Oberflächen für die manuelle Datenerfassung. Dies umfasst Standorte, Räume, Schränke, Patche und Verbindungen. Zum anderen ermöglicht es SM-Docu, die physische Schicht des Netzwerks, mit den in den höheren Netzwerkschichten zwei und drei (MAC- und IP-Adresse, Hostname etc.) vorhandenen Daten zu den aktiven Geräten zu verbinden.

Hierbei ist die manuelle Dokumentation aller aktiven Endgeräte zwar ebenfalls möglich, aber nicht sinnvoll. Das Konzept von SM-Docu beruht vielmehr auf einer Verbindung der manuell erfassten Daten mit importierten Informationen. Die Schnittstelle zwischen den in den aktiven Geräten vorhandenen Informationen zu den physischen Verbindungen sind die Portadressen der Switch- oder Router-Ports. Die entsprechenden Informationen liefert z. B. in homogenen Cisco-Netzwerken Cisco Works. Außerdem hat SM-Docu eine Schnittstelle zu Macmon, einem Tool der Firma Mikadosoft.

Erfassung der manuell zu pflegenden Daten

In der grafischen Oberfläche von SM-Docu müssen in einem ersten Schritt die Stammdaten, d. h. das eigentliche Inventar an Geräten und Patch-Feldern sowie die dazugehörigen Informationen zu Standort, Haus, Etage, Raum und Schrank eingegeben werden.

Im Bereich *Bewegungsdaten* können dann der Einbau eines Geräts in einen Datenschrank oder die Verbindung zweier Ports im Datenschrank (Patch) per Mausklick erfolgen. Die Porthistorie dokumentiert den Bearbeiter und das Datum der Datenpflege. Zusätzlich stehen hier eine Tabellendarstellung der Portbeschaltung, eine Trace-Liste zur automatischen Ermittlung von Schaltwegen und die Anzeige der Switchport-Informationen zur Verfügung.

Der Aufbau eines Datenschranks wird im Menü *Schranksinhalt* gestaltet. Hier kann der Bearbeiter aus einem Container für Geräte und Patch-Felder per Drag & Drop ein Gerät an seiner Position im Schrank ablegen. Zu Nachweiszwecken können eine Reihe von Dokumenten (Einbauauftrag, Quittung der Ausführung sowie Ausdruck des Schranklayouts) erzeugt werden.

Mit dem Modul *DXF-Dateien* ist es zusätzlich möglich, vorhandene Grundrisszeichnungen im CAD/DXF-Format in SM-DOCU einzubinden. Damit lassen sich beispielsweise Geräte einer Raumnummer zuordnen.

Zur Nutzung der erfassten Daten können beliebig anpassbare Reports erstellt werden. So können zum Beispiel nicht belegte Ports mit Hilfe von Differenzlisten ermittelt werden. Außerdem können die Daten über eine API einer übergeordneten CMDB zur Verfügung gestellt werden.

Erweiterte Dokumentationsmöglichkeiten bietet das integrierte Modul *LinkAnalyzer*, das die automatische Visualisierung von Netzwerkstrukturen und damit eine grafische Sicht auf die strukturiert vorliegenden Daten ermöglicht. Die Java-basierte Komponente analysiert die in der SM-Docu-Datenbank dokumentierten Verbindungen und ermöglicht die Ausgabe verschiedener grafischer Topologiedarstellungen (zum Beispiel die Darstellung der Standorte, Häuser, Räume und Schränke mit all ihren Verbindungen). Interessant sind hierbei die Verknüpfungsmöglichkeiten der Layer-1-Daten mit Layer 2 bzw. Layer 3 und die daraus resultierenden automatisierten Dokumentationsmöglichkeiten.

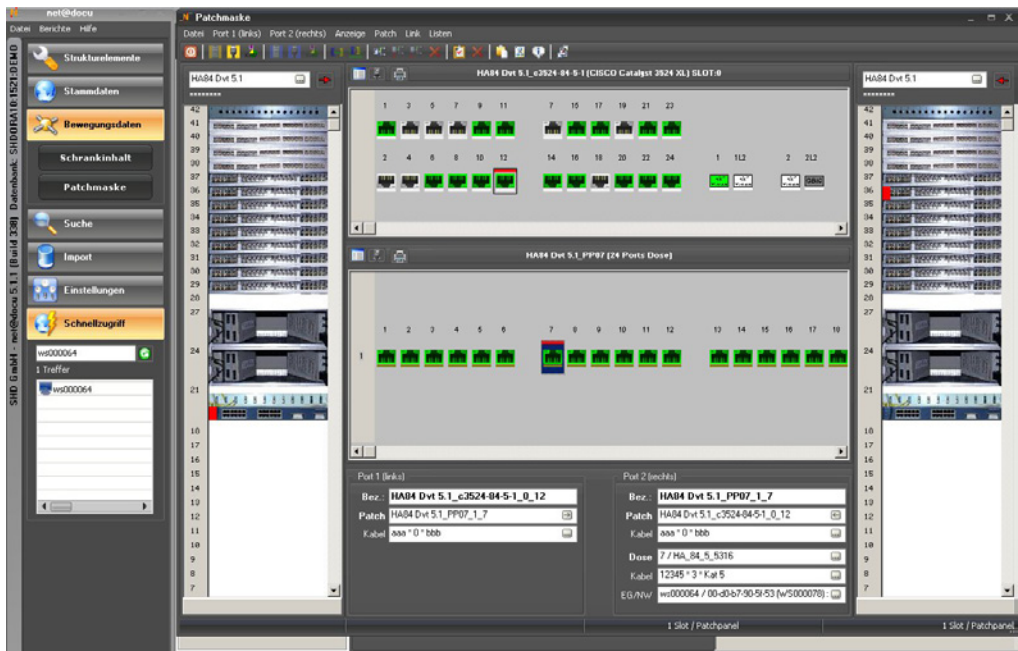


Bild 7.7 Die Benutzeroberfläche von SM-Docu

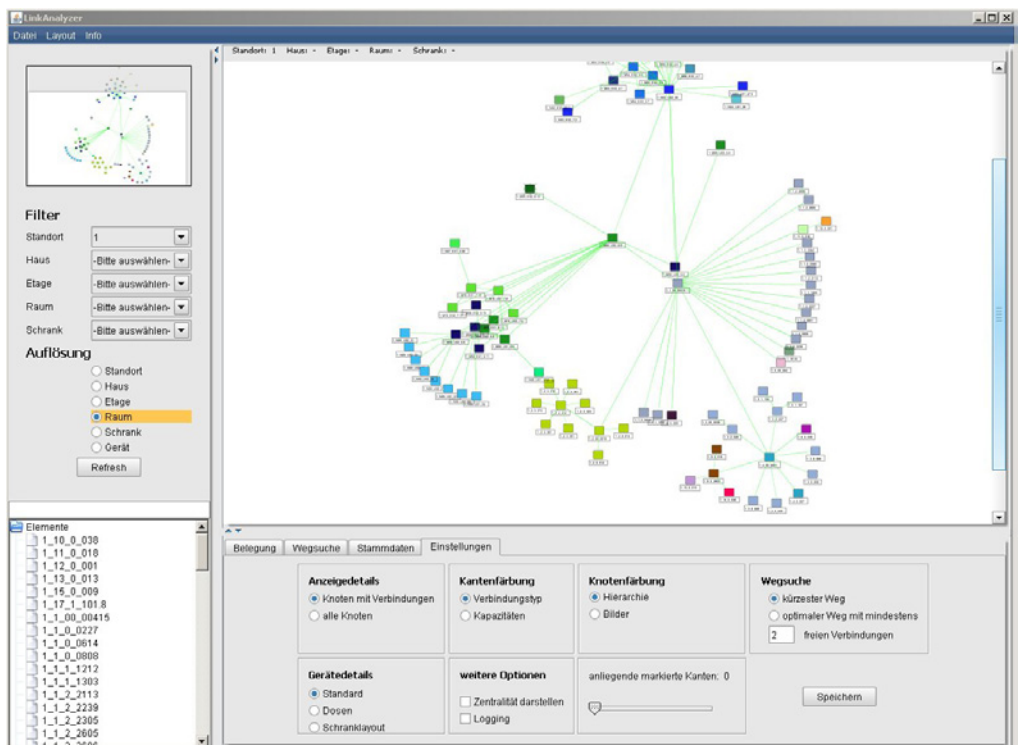


Bild 7.8 Mit dem Link-Analyz器 erstellter Topologieplan

■ 7.3 Tools für die Prozessdokumentation

Einer der wichtigsten Schritte bei der Umsetzung der Prozessorientierung ist die Ermittlung und Visualisierung der Prozesse. Denn nur dokumentierte Prozesse sind für die Mitarbeiter transparent und können Audits und Optimierungprozessen unterzogen werden. Benötigt wird für jeden Prozess eine Prozessbeschreibung, die auf Basis einer Modellierungsmethode alle für einen Prozess relevanten Informationen enthält. Zwar ist es auch möglich, alle Informationen rein textlich zu erfassen, zu einer allgemeinen Veranschaulichung der Abläufe sind solche Dokumente aber natürlich nicht geeignet. Vielmehr ist es sinnvoll, die Prozessabläufe toolgestützt grafisch zu visualisieren.

7.3.1 Hinweise für die Evaluierung

Die Dokumentation von Prozessen ohne speziell ausgelegte Programme zur Prozessvisualisierung ist kaum durchführbar. Diese wiederum lassen sich in zwei Gruppen unterteilen:

- *Grafikorientierte Tools:* Das bekannteste und am häufigsten eingesetzte grafikorientierte Werkzeug für die Prozessvisualisierung ist Microsoft Visio. Ein derartiges Programm stellt das Zeichnen von Diagrammen in den Mittelpunkt. Zur Erstellung von Prozessdiagrammen bieten sie in der Regel Vorlagen und stellen verschiedene Symbole zur Modellierung bereit. Alle gezeichneten Symbole werden ausschließlich als Grafikelement behandelt, nicht als Objekt. Daher können keine speziell auf das Prozessmanagement ausgelegten Funktionen bereitgestellt werden. Damit verbunden ist zwangsläufig, dass es keine Unterstützung oder Vorgaben hinsichtlich der Notation gibt.
- *Objektorientierte Tools:* Programme dieser Gruppe sind speziell auf die Modellierung von Prozessen ausgerichtet. Sie unterstützen die Modellierung, so dass diese zwingend einer definierten Notation folgt. Dadurch ist sichergestellt, dass alle Prozesse einheitlich beschrieben sind. Die Prozesse werden objektorientiert und nicht als Grafik gespeichert, was beispielsweise durchgängige Änderungen und das Erfassen der Abläufe in der dahinterliegenden Datenbank ermöglicht. Auch kann damit ein Prozess von verschiedenen Anwendern mit unterschiedlichen Rollen bearbeitet werden. Zu den bekanntesten Vertretern dieser Gruppe zählt das ARIS-Toolset.

Viele Organisationen, die mit der Modellierung ihrer Prozesse beginnen, setzen zunächst Microsoft Visio ein. Da Visio sowohl für die EPK-Notation als auch für die Darstellung von Flussdiagrammen eine Reihe von Vorlagen mit den erforderlichen Symbolen bereitstellt, ist dies problemlos möglich. Doch mit der steigenden Anzahl an Prozessen werden auch die Nachteile der »Visio-Methode« deutlich:

- Die Durchsetzung von Standards (Darstellungssystematik, Namenskonventionen) für die Prozessdiagramme ist kaum möglich, sobald Prozesse von mehreren Mitarbeitern modelliert werden. Dies gilt insbesondere für die Darstellung von Flussdiagrammen.
- Nachträgliche Änderungen an den Prozessdiagrammen erfordern einen hohen manuellen Aufwand.

- Eine verteilte Modellierung durch unterschiedliche Rolleninhaber ist kaum darstellbar. Wenn diese stattfindet, werden häufig nur Unterprozesse modelliert und dokumentiert, da kein übergeordnetes Modell existiert, das das Abbilden der gesamten Prozesskette sicherstellt.
- Die Veröffentlichung der Prozesse und deren Aktualisierung werden nicht unterstützt, so dass viele Prozessdokumentationen zu »Schrackware« werden.
- Es fehlen Schnittstellen zu Programmen wie SAP und Biztalk, Simulationsmöglichkeiten und Möglichkeiten, um die Prozesse auszuwerten.

Die genannten Probleme sind typisch für grafikorientierte Werkzeuge. Aufgrund der benannten Einschränkungen dieser Tools stellt sich daher die Frage nach den Alternativen. Es gibt eine ganze Reihe von speziellen Programmen, die als Vertreter der zweiten Gruppe die Erfassung, Dokumentation und die Optimierung von Prozessen unterstützen. Allerdings sind diese Anwendungen häufig sehr komplex und vom Anwender nur nach einer intensiven Einarbeitung nutzbar. Außerdem sind diese Tools nicht ohne Anpassungen einsetzbar; der Konfigurationsaufwand ist vielfach hoch.

Bei der Wahl der »richtigen« Prozessdokumentationslösung besteht die Schwierigkeit deshalb darin, zwischen Programmen wie Visio und komplexen Modellierungswerkzeugen wie dem ARIS Toolset das für das eigene Unternehmen passende Programm zu finden. Hierbei ist es wichtig, zunächst die eigenen Anforderungen zu definieren, um aus den diversen Werkzeugen zur ausschließlichen Modellierung von Prozessen und einer Reihe von Tools mit zusätzlichen Simulation- und Workflow-Funktionen das geeignete zu finden.

Das im Folgenden vorgestellte Tool ViFlow von der Firma Vicon GmbH wurde aus Sicht der IT-Dokumentation ausgewählt und hat in diesem Bereich in den vergangenen Jahren einen hohen Verbreitungsgrad erreicht. Die Vorstellung dient dazu, beispielhaft die Möglichkeiten einer Anwendung für die Prozessmodellierung aufzuzeigen.

7.3.2 ViFlow

Die folgenden Ausführungen zu ViFlow (Vicon GmbH) beziehen sich auf die aktuelle Version 5 (Stand Juli 2013).

Bei ViFlow handelt es sich um ein grafikorientiertes Prozessmodellierungstool der Firma Vicon, das auf Visio aufsetzt und dessen Eigenschaften mit den Vorteilen einer Datenbank verbindet. Das bedeutet, dass alle Prozessobjekte zwar grafisch erstellt werden können, für diese aber zusätzlich in einer Eigenschaften-Dialogbox relevante Informationen zu erfassen sind. Diese Daten werden zusammen mit der Grafik in der integrierten XML-Datenbank gespeichert. Dies bietet den Vorteil, dass einmal erfasste Informationen zu einem Prozess auch für andere Prozesse zur Verfügung stehen und Änderungen in einem Prozess durchgängig allen verbundenen Bereichen und Prozessen bekannt werden.

Da das Tool auf Microsoft Visio basiert, ist es im Prinzip genauso zu verwenden. Die Anwender finden sich in einer vertrauten Umgebung wieder, die sie mit wenig Schulungsaufwand nutzen können. Und ViFlow-Dokumente sind Visio-Dokumente. Sie können deshalb genauso einfach per Mail verschickt, versioniert und abgelegt werden. Dank der Objektorientierung

bietet es aber zusätzliche Funktionen, die die Erstellung von Prozessen deutlich vereinfachen, eine Standardisierung im Unternehmen ermöglichen und verschiedene Dokumentationsmöglichkeiten unterstützen. So wird beispielsweise die Konsistenz der Prozessmodelle bereits während ihrer Erstellung sichergestellt und bei der Detaillierung von Arbeitsabläufen werden die erforderlichen internen Ein- und Ausgänge automatisch erstellt und verlinkt. Da außerdem alle Objekte miteinander verknüpft sind, sind diverse Auswertungen und Simulationen über alle Prozessebenen hinweg möglich.

Beim ersten Start von ViFlow muss eine neue Datenbank angelegt werden. Seit der Version 4 enthält ViFlow eine Reihe von Datenbankvorlagen, die beim Erstellen einer neuen Datenbank ausgewählt werden können. Wird eine solche Vorlage verwendet, enthält die neue Datenbank bereits inhaltsbezogene vordefinierte Objekte (Bereiche, Prozesse und Daten).

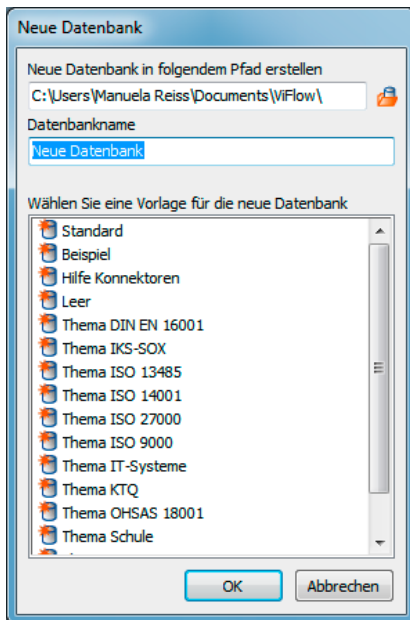


Bild 7.9

ViFlow enthält Datenbankvorlagen, die eine anforderungsgerechte Prozessdokumentation unterstützen.

Die Prozessmodellierung in ViFlow erfolgt häufig mit der Swimlane-Methode bzw. -Darstellung. Hierbei unterscheidet ViFlow drei Einzelsichten:

- Aktivitätensicht/Prozesshierarchie zur Darstellung der Tätigkeiten aus ablauforientierter Sicht,
- Informationssicht zur Darstellung der für den Prozess erforderlichen Daten und Dokumente,
- Organisationssicht zur Darstellung der am Prozess beteiligten Bereiche, Rollen und Ressourcen.

Bei der Modellierung können wie bei Visio die Prozesssymbole aus der ViFlow-Schablone auf das Zeichenblatt bezogen werden. In dem sich öffnenden Fenster für die Dateneingabe sind anschließend die Objekteigenschaften einzutragen. Alle in der Datenbank vorhandenen Prozesse, Daten und Bereiche werden in einer hierarchisch gegliederten Struktur im

linken Teil des ViFlow-Fensters dargestellt. Für den in der Übersicht markierten Prozess wird im rechten Teil des Fensters die Prozessgrafik angezeigt. Bereits bestehende Prozesse, Daten und Bereiche können per Drag&Drop aus der Baumstruktur auf das Zeichenblatt gezogen werden. Um die gespeicherten Informationen zu einem Objekt abzurufen, genügt ein Doppelklick auf das gewünschte Objekt.

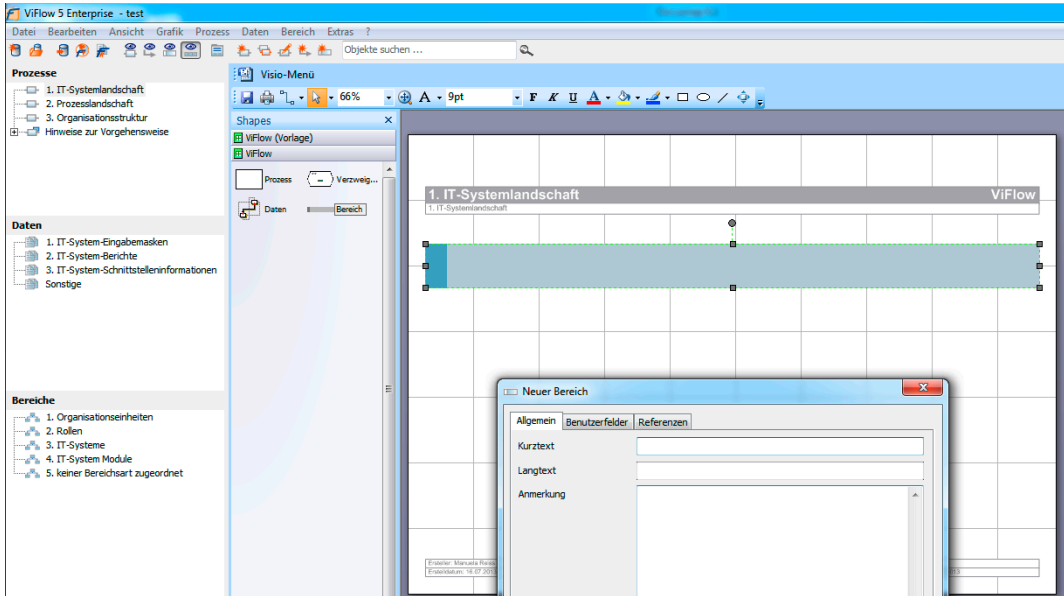


Bild 7.10 Erstellung eines neuen Bereichs in der Modellierungsansicht von ViFlow

Hilfreich ist bei der Modellierung, dass für Prozesse, Bereiche und Daten eine individuell anpassbare Klassifizierung möglich ist. Prozessmodellarten beispielsweise ermöglichen eine Einteilung der Prozesse in verschiedene Prozesstypen, wie »Führungsprozess« oder »Kernprozess«. Beteiligungsarten erlauben eine Differenzierung, ob zum Beispiel ein Mitarbeiter an einem Prozess mitwirkt oder prozessverantwortlich ist. Und Datenarten können beispielsweise verwendet werden, um Daten verschiedenen Dokumentarten (Arbeitsanweisungen, Berichte) zuzuweisen. Datenübertragungsarten wiederum beschreiben das Medium des Informationsflusses, z.B. mündlich oder per E-Mail, und Vernichtungsarten beschreiben bei Dokumenten, nach welchem Zeitraum alte Dokumente vernichtet werden können.

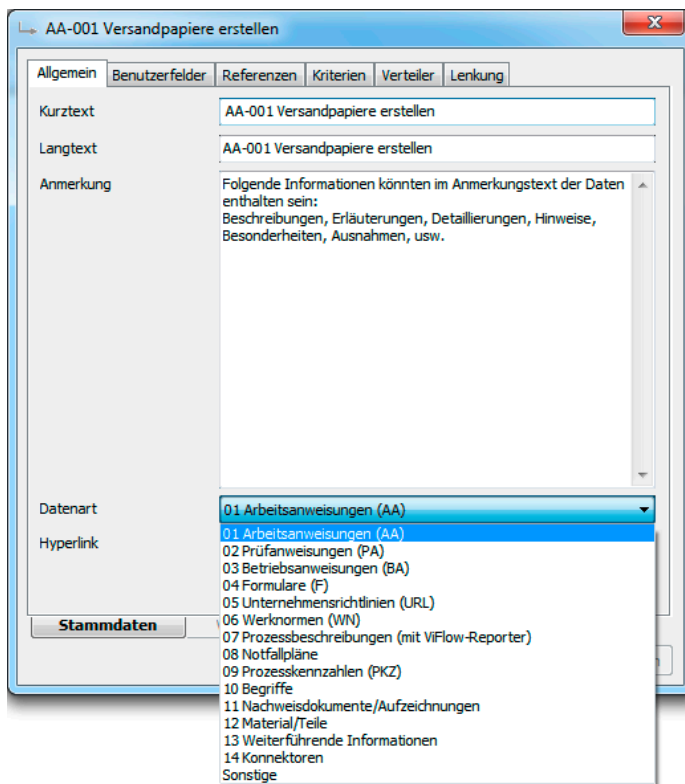


Bild 7.11 Daten können verschiedenen Dokumentenklassen zugeordnet werden.

Einbindung der Prozesssteckbriefe

Wie in *Kapitel 3 in Abschnitt 3.8.8* beschrieben, sollte für jeden Prozess ein Prozesssteckbrief erstellt werden. Der Prozesssteckbrief liefert einen schnellen Überblick über alle wichtigen Prozessmerkmale. Prozesssteckbriefe werden in der Regel als Textdokumente erstellt. ViFlow bietet mit dem »Turtle Chart« (auch als Schildkrötengrafik oder Igelgrafik bezeichnet) eine Möglichkeit zur visuellen Darstellung von Prozesssteckbriefen.

Wie in Bild 7.12 dargestellt, stellen Kopf und Schwanz den Input sowie den Output des Prozesses dar. Die vier Beine bilden die Einflussfaktoren des Prozesses ab. Bei Verwendung des Turtle Chart wird nicht nur eine Grafik gezeichnet, sondern ein interaktives Informationssystem erzeugt, mit dem die Darstellung der Wechselwirkungen von Prozessen abgebildet werden kann. Damit eignen sich ViFlow Turtle Charts sehr gut als Einstiegsseite in den darunterliegenden modellierten Prozess, aber auch als Entscheidungsgrundlage für das Management.

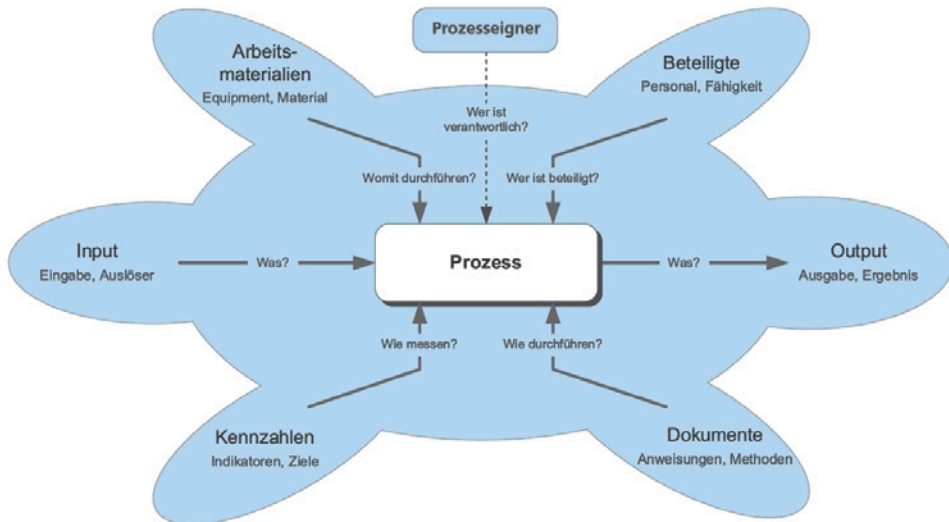


Bild 7.12 Turtle-Chart-Beispiel –

Quelle: http://www.vicon.biz/tl_files/downloads/IB_viflow_turtle_chart.pdf

Pflege der Prozesslandkarte

Wie in Kapitel 3 in Abschnitt 3.8.8 dargestellt, ist es sinnvoll, in einer Prozesslandkarte alle wesentlichen Geschäftsprozesse mit ihren logischen Zusammenhängen darzustellen. In ViFlow ist es möglich, die Prozesslandkarte bzw. das Prozessmodell vollständig abzubilden. Hierbei können die Kernprozesse als Prozesse der obersten Ebene modelliert und mit den Prozessen der darunterliegenden Detaillierungsebenen verlinkt werden. Bild 7.13 zeigt beispielhaft eine solche Prozesslandkarte.

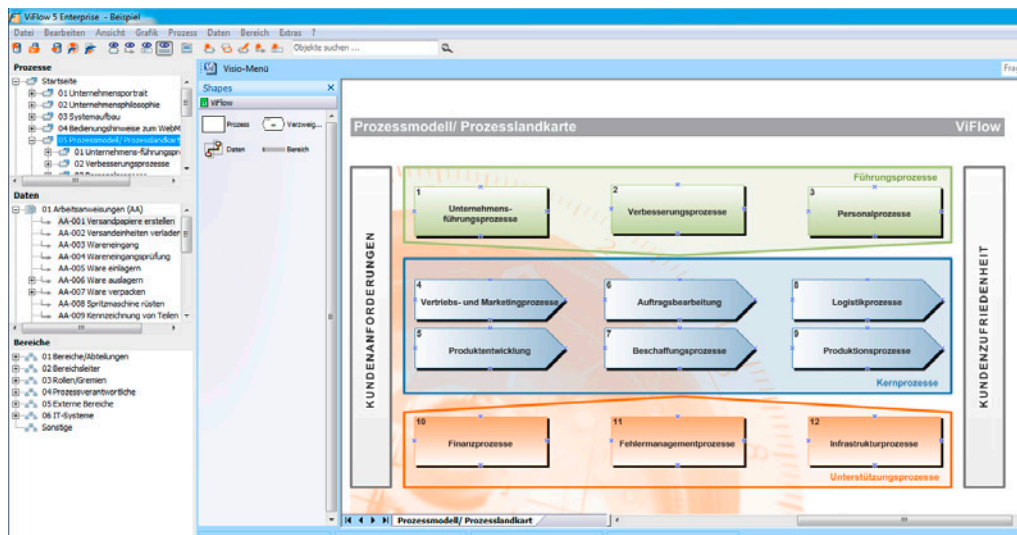
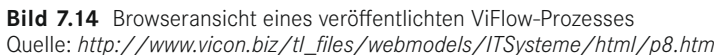


Bild 7.13 Erstellung einer Prozesslandkarte in ViFlow

Zusätzlich bietet Vicon mit dem Modul WebModel Viewer einen für die Betrachtung von ViFlow-Prozessmodellen optimierten Browser an. Dieser unterstützt ausschließlich die ViFlow-Prozesse und bietet hierfür spezielle Funktionen, wie Such- und Filterfunktionen, optimierte Navigationsmöglichkeiten und die Möglichkeit, eine barrierefreie Version darzustellen. Das barrierefreie WebModel stellt die grafischen Informationen in einer textlichen Form dar, so dass diese z. B. von sogenannten »Screenreader-Programmen« vorgelesen werden können. WebModel Viewer ist unabhängig vom Internet Explorer einsetzbar.



ViFlow Reporter ist das Zusatzmodul für die Erstellung schriftlicher Dokumentationen und für die Analyse der in ViFlow erfassten Daten und Prozessinformationen. Das Zusatzmodul bietet u. a. die folgenden Berichts- und Analysemöglichkeiten:

- unternehmensweites Prozessmodell,
- verschiedene Prozessbeschreibungen,
- Prozesskennzahlen,
- Verbesserungspotenziale,
- Liste aller Maßnahmen zur Prozessverbesserung,
- Liste gelenkter Nachweis- und Vorgabedokumente,
- Datenliste und Datenverwendung,
- Stellenbeschreibungen.

■ 7.4 Tools für das IT-Servicemanagement und CMDB-Tools

IT-Servicemanagement ohne die Unterstützung entsprechender Tools ist nur schwer darstellbar. Zwar werden Prozesse nicht allein mit einer Tool-Implementierung eingeführt oder verbessert, sie können aber nur dann effektiv funktionieren, wenn die notwendigen Aktivitäten optimal durch Tools unterstützt werden. So ist der Betrieb eines Service Desk ohne ein Ticketsystem wohl nur in Ausnahmefällen möglich. Es gilt also auch die passenden Tools für die Erbringung von IT-Services auszuwählen. Klassische Tools für das ITSM sind u. a.:

- Ticket-Systeme für das Incident-, Change- und/oder Problemmanagement
- CMDB (Configuration Management Database)-Tools zur Speicherung von Konfigurationsdaten

Mit der Implementierung ITIL®-konformer Prozesse entsteht zusätzlich häufig der Bedarf nach einem Management-Werkzeug zur Abbildung des ITIL®-Modells und zur Steuerung der Prozessstrukturen in der IT-Organisation.

7.4.1 Hinweise für die Evaluierung

Wie bei jeder Auswahl einer Softwarelösung sind die individuellen Anforderungen entscheidend. Einerseits spielt die Unternehmensgröße eine wesentliche Rolle, andererseits sind der Reifegrad und die Komplexität der ITIL®-Prozesse zu berücksichtigen. Wichtig ist daher zunächst einmal zu analysieren, welche Bereiche die Anwendung abdecken muss. Möglich sind u. a.:

- Funktionen für das Servicemanagement
 - Erstellung von Risikoanalysen und Notfallplänen
 - Servicekatalogverwaltung (Erstellung eines Servicekatalogs durch Modellierung der IT-Services und der den Services zugrunde liegenden Komponenten)
 - Strukturierung der IT-Services und Generierung von web-basierten Servicekatalogen
 - Definition von ITIL®-konformen Serviceprozessen und Abbildung von IT-Prozessen
 - Serviceüberwachung und Reporting
 - Machbarkeitsanalysen zum Abgleich zwischen Leistungsumfang der IT-Services und konkreten Kundenanforderungen
 - Verwaltung und automatische Generierung von Verträgen (Service Level Agreements)
 - Zuordnung von Verantwortlichen zu IT-Services und Servicekomponenten
 - Unterstützung des kontinuierlichen Verbesserungsprozesses (Verwalten von Kontrollen, Maßnahmen und Ergebnissen)
 - Management-Reporting
 - Funktionen zur quantitativen Bewertung von IT-Services bzw. der gesamten IT-Architektur

- Bewertung der IT-Servicemanagement-Prozesse hinsichtlich Prozess- und Personalkosten.
- Erstellung von Risikoanalysen und Notfallplänen
- Funktionen für die Serviceerbringung
 - Configuration-Management
 - Service Desk sowie Incident und Problemmanagement (einschließlich Dokumentation von Eskalationsmechanismen und Festlegung von Verantwortlichkeiten)
 - Prozessbasierte Verfahrensanweisungen für Workarounds und Fehlerbehebung
 - Change- und Release-Planung und Überwachung
 - Inventar- und Asset-Management
 - Überwachung der Infrastruktur
 - Planung von Verfügbarkeiten und Kapazitäten
 - Reporting-Funktionen
 - Workflow-Funktionen
 - Dashboard-Funktionen

Am Markt gibt es eine Reihe von Produkten zur Unterstützung von IT-Servicemanagement und IT-Architekturmanagement. Allerdings adressieren viele der Lösungen eher große Unternehmen, da die betreffenden Tools besonders auf hohe Anwenderzahl und große Datenmengen ausgelegt und in der Lage sind, sehr komplexe Prozessstrukturen abzubilden. Hier müssen bei der Evaluierung neben der Wirtschaftlichkeit, vor allem auch der Implementierungs- und Betriebsaufwand berücksichtigt werden. Allerdings gibt es durchaus Tools, die sowohl Organisationen in mittelständischen als auch Organisationen in großen Unternehmen unterstützen können und geeignet sind, mit den Anforderungen von Anwendern und Organisation zu wachsen.

Die Vorstellung einer komplexen Anwendung zur Unterstützung des Servicemanagements würde den Rahmen des Buchs sprengen. Aufgrund der Bedeutung für die IT-Dokumentation ist stattdessen an dieser Stelle noch ein Blick auf die Evaluierung einer CMDB-Lösung sinnvoll.

CMDB-Tools

ITIL® fordert ein zentrales Repository in Form einer Datenbank, in der alle IT-Komponenten und deren Zusammenhänge beziehungsweise Abhängigkeiten beschrieben sind, so dass sich daraus diejenigen Daten extrahieren lassen, die man zum Beispiel für die Erbringung eines Service oder für eine Serviceoptimierung benötigt. Um IT-Services über deren gesamten Lebenszyklus zu unterstützen reichen technische Daten allein nicht aus. Neben den technischen Daten für z. B. einen Server einschließlich Software und Netzanbindung, werden auch Angaben zum Standort, zu den Benutzern und den Vertragsdaten wie Lizenzen, Garantien, Service-Level-Agreements oder Wartungsabkommen benötigt.

Entscheidend ist, dass in einer CMDB die verschiedenen Konfigurationsdaten in Beziehung zueinander gesetzt werden. So werden auf der obersten Betrachtungsebene die Geschäftsprozesse angeordnet und diesen werden dann die sie jeweils unterstützenden Anwendungen zugeordnet und den Anwendungen wiederum die IT-Systeme, auf denen die Anwen-

dungen betrieben werden. Auf diese Weise entstehen Strukturen, die es beispielsweise ermöglichen, Risiken von IT-Systemen zu Anwendungen und von Anwendungen bis »ganz nach oben« zu den Geschäftsprozessen zu aggregieren und so den Geschäftsprozessverantwortlichen und dem Management das Gesamtrisiko zu verdeutlichen. In umgekehrter Richtung könnten zum Beispiel die Ergebnisse aus der Schutzbedarfsfeststellung für den Geschäftsprozess automatisch nach »unten« auf die Anwendungen und IT-Systeme vererbt und so in die Risikoberechnung mit einbezogen werden.

Damit kann eine CMDB zielgruppengenaue verschiedene Sichten auf die Informationen liefern, beispielsweise alle Daten, die der Service-Desk-Mitarbeiter bei der Erfassung und Lösung einer Störungsanfrage benötigt, oder alle Wartungsverträge für ausgewählte Server. Doch CMDB ist nicht gleich CMDB. Schließlich liefert ITIL® keine konkreten Aussagen darüber, wie eine CMDB aufgebaut, gepflegt und verwaltet wird. Der Aufbau und die Funktion einer CMDB sind also zwangsläufig individuell zu definieren. Hinsichtlich der Architektur der CMDB können zwei grundsätzliche Ansätze unterschieden werden: Verteilte oder zentrale Datenhaltung.

- Bei einer CMDB mit verteilter Datenhaltung werden die Daten nicht in einer zentralen Datenbank gepflegt. Stattdessen werden hier die Daten zusammengeführt, die in anderen Datenbanken gepflegt werden. Die CMDB-Engine führt dazu aufgrund von definierten Merkmalen ein Mapping über die verschiedenen Datenquellen durch und erstellt Verknüpfungen. Der Fokus liegt hierbei auf einer möglichst schnellen und flexiblen Integration der Quellen. Allerdings ist bei dieser Lösung ein geregeltes Change-Management nur schwer durchsetzbar.
- Der zentralisierte CMDB-Ansatz umfasst die Datenhaltung der automatisiert einlesbaren Daten im jeweiligen Quellsystem sowie in mehreren Schichten einer CMDB. Hierzu werden die Daten im Quellsystem erzeugt, in die CMDB eingelesen, mit dem zentralen Datenbestand abgeglichen und im Rahmen von Pflegeprozessen standardisiert. CMDB-Tools mit weitergehenden Funktionen ermöglichen es zudem alle Daten regelgestützt zu untersuchen sowie fehlerhafte Datenbestände zu erkennen und zu korrigieren.



Zusätzliche Informationen

Weitere Informationen zu Nutzen und Einsatzzweck einer CMDB finden Sie u. a. in *Kapitel 3 in Abschnitt 3.6.1.*

Ziel bei der Einrichtung einer CMDB sollte ein hoher Automatisierungsgrad sein. Denn aktuelle Daten sind wichtig, damit zu jeder Zeit ein genauer Überblick über die IT-Infrastruktur und die Prozesse im Unternehmen gewährleistet ist. Die der IT innewohnende Dynamik mit kurzen Innovationszyklen bedingt aber schnelle Änderungszyklen, so dass eine manuelle Pflege sehr schwierig ist. Discovery-Funktionen zum automatischen Auffinden und Speichern von IT-Komponenten sind daher wichtig, wenn die CMDB sinnvoll zu nutzen sein soll. Hierbei sollte die CMDB-Engine in der Lage sein, Informationen, die aus den verschiedenen Quellen in die CMDB einfließen, automatisch miteinander zu verknüpfen. Trotzdem wird man nicht darum herumkommen, Zusatzangaben etwa aus dem nicht-technischen Bereich manuell zu vervollständigen.

Die großen Systemmanagementspezialisten wie Computer Associates, Hewlett-Packard und IBM haben alle eine CMDB im Portfolio, doch haben diese Lösungen auch ihren Preis. Insbesondere kleinere Unternehmen werden hier auf andere Lösungen zurückgreifen müssen. Exemplarisch wird im folgenden Abschnitt das OpenSource-CMDB-Tool i-doit vorgestellt.

7.4.2 i-doit

Die folgenden Ausführungen zu i-doit (synetics GmbH) beziehen sich auf das aktuelle Release 1.1 (Stand Juli 2013).

i-doit wird von der Firma synetics entwickelt und sowohl in einer kostenlosen Variante als auch als kostenpflichtige Pro-Version vertrieben. Die kostenpflichtige Version unterscheidet sich von der Open-Version durch zusätzliche Funktionen sowie Gewährleistung und Support. Es ist eine webbasierte OpenSource-Software (GNU AGPLv3) zum Aufbau und zur Pflege einer CMDB mit den folgenden Schwerpunkten:

- zentrale Speicherung und Pflege aller erforderlichen Systeminformationen an einer Stelle,
- Dokumentation von Services, die als logische Gruppierung von Objekten untereinander in Beziehung gesetzt (modelliert) werden können,
- Konsolidierung von IT-Servicemanagement-Daten durch Schnittstellen zu anderen ITSM-Anwendungen,
- automatisches Discovery aller aktiven Netzkomponenten,
- Funktionen zur Unterstützung des IT-Sicherheitsmanagements u. a. durch Importmöglichkeiten der BSI-Grundschutzkataloge.

Inventarisierung und Dokumentation

Zu den wichtigsten Komponenten gehören natürlich die Erfassung und die technische Dokumentation aller eingesetzten IT-Komponenten. Möglich ist die Verwaltung der folgenden Objekttypen bzw. Umgebungen:

- Standardkomponenten wie Server, Clients, Switches, Router, Cluster-, Middleware- und Datenbanksysteme,
- Abbildung von Datennetzen inklusive aller Verbindungen,
- Abbildung virtueller Umgebungen,
- Software- und Lizenzdokumentation,
- Dokumentation der Stromversorgung,
- SAN-Dokumentation inklusive aller Verbindungen,
- Standorte, Räume und Racks, Klimaanlage, USV etc.

Als Objekte werden in i-doit jegliche Arten von Einträgen bezeichnet, die die Kernelemente der CMDB bilden, d. h., Objekte sind Configuration Items. Ein Objekt ist jede einzelne dokumentierte logische oder physikalische Einheit in i-doit, z. B. ein Server, ein Gebäude, eine Software oder ein Kabel. i-doit kategorisiert diese grob in Software, Infrastruktur und

andere. Alle typischen Elemente einer Infrastruktur wie etwa Gebäude, Raum, Schrank, Server, Arbeitsplatz, Client, Telefonanlage, USV u. a. sind in der Standardkonfiguration bereits vorbereitet.

Traditionell erfolgte die Datenerfassung in i-doit entweder manuell oder über Schnittstellen. Seit Mai 2013 stellt synetics mit dem Modul JEDI (JDISC Essential Discovery for i-doit) eine agentenfreie Lösung zur automatisierten Erfassung und Pflege von aktiven Netzkomponenten in i-doit zur Verfügung. Der Discovery-Prozess ermittelt neben klassischen Komponenten auch erweiterte Informationen in komplexen Infrastrukturen und ist so in der Lage, z. B. Verbindungsdaten von Switches, SAN-Konfigurationen, Cluster oder virtualisierte Umgebungen zu erkennen und auszuwerten und diese Daten unter Berücksichtigung aller damit einhergehenden Beziehungen in i-doit einzulesen.

Das Logbuch in i-doit protokolliert alle Änderungen, die an einem Objekt vorgenommen wurden. Verbunden mit einer (optionalen) Kommentierungsfunktion können diese Logbucheinträge zudem mit weiteren Informationen versehen werden, um z. B. den Grund einer Änderung festzuhalten. Darüber hinaus dient das Logbuch für verschiedene Erweiterungen als Archiv, um darin den Status oder Ereignisse aus dem Echtbetrieb abzulegen.

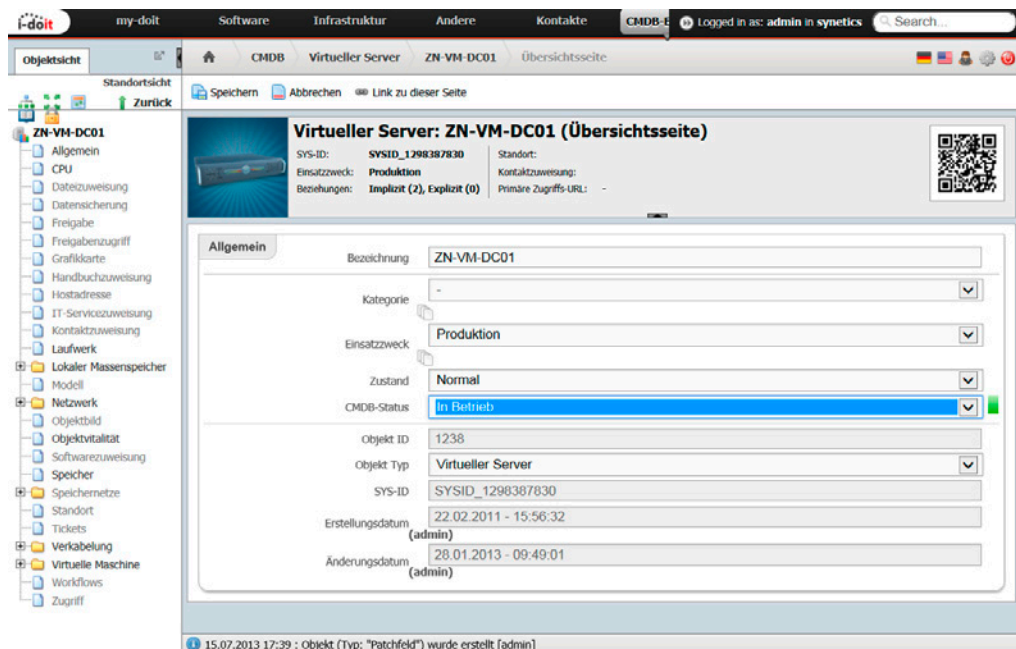


Bild 7.15 Bearbeitung eines Objekts in i-doit –
Quelle: <http://www.i-doit.com/ressourcen/online-demo/>

Über Zuweisungen von Objekten zu anderen Objekten entstehen innerhalb von i-doit Beziehungen zwischen diesen. Als Beziehung wird dabei jede Verbindung zwischen zwei Objekten betrachtet. Hierzu zählen beispielsweise die Dokumentation einer Netzwerkverbindung, eine Standortzuordnung oder eine Kontaktzuweisung. i-doit kennt aktuell über 30 verschiedene Beziehungsarten zwischen Objekten. Welche Software ist wo installiert, welche Stromanschlüsse werden genutzt oder welche Verträge sind einem Objekt zugeordnet? Diese sind

entweder implizit dokumentiert, indem sie aus Eigenschaften wie Clustermitgliedschaften, Standortzuweisungen oder Kontaktzuweisungen hervorgehen, oder sie werden manuell erstellt, um eine explizite Abhängigkeit zwischen Objekten herzustellen. Die Beziehungen in i-doit haben Richtungen, welche anzeigen, welches Objekt von welchem Objekt abhängig ist bzw. wessen Funktionsfähigkeit gefährdet ist, wenn ein anderes Objekt ausfällt.

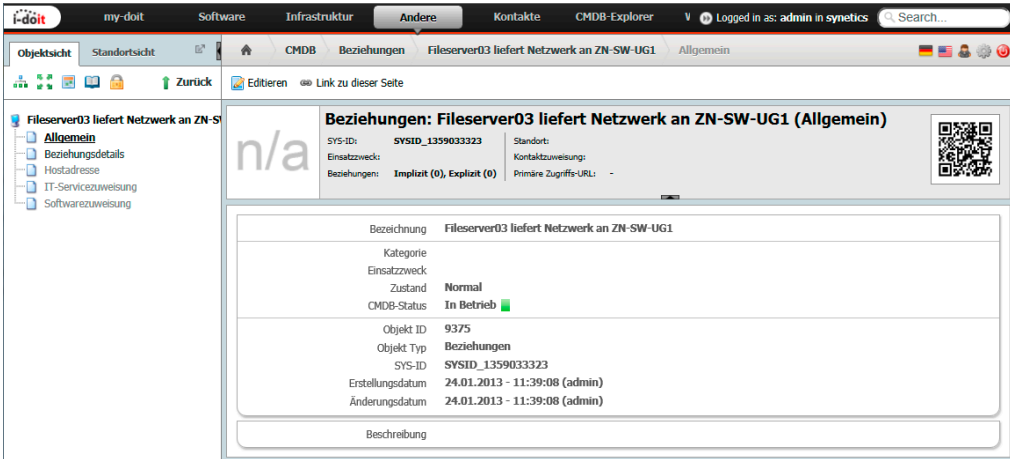


Bild 7.16 Eigenschaften einer Beziehung –
Quelle: <http://www.i-doit.com/ressourcen/online-demo/>

Auf Basis dieses Prinzips unterstützt i-doit auch die Dokumentation von IT-Services, die als logische Gruppierung von Objekten untereinander in Beziehung gesetzt (modelliert) werden können. Das wiederum liefert die Grundlage für Serviceprozesse wie das Change- oder Problemmanagement und hilft bei der Kontrolle und Verwaltung von SLAs. Außerdem können die Geschäftsprozesse erfasst, modelliert und in Beziehung zu den bestehenden Objekten gebracht werden.

Aufbauend auf dem Beziehungsmodell gibt es mit dem CMDB-Explorer eine Komponente, mit der die Beziehungsbäume grafisch aufbereitet und angezeigt werden. Der Explorer bietet Bearbeitungs- und Steuerungsfunktionen, um innerhalb der Bäume zu navigieren oder Aktionen auszuführen. Neben der Servicesicht, die eine Auffächerung vom abstrakten Geschäftsfall bis hin zu hierfür notwendigen Stromversorgungen alles einschließt, können so z. B. auch virtuelle Umgebungen oder Cluster-Systeme mit all ihren Beziehungen und Abhängigkeiten dargestellt werden.

Neben der Dokumentation von Services und Infrastrukturen unterstützt i-doit die Erfassung und Zuordnung von Vertrags- und Betriebsdaten zu den dokumentierten Objekten. Erfasst werden können beispielsweise Wartungsverträge mit Kontaktdaten, Ablaufdatum und Benachrichtigungsfunktion, die Notfallplanung für Komponenten und Systeme, digitale Handbücher, Konfigurationsdaten oder SLA-Richtlinien. Die Dateien unterliegen einer Versionsverwaltung, so dass hier Änderungen und Anpassungen nachvollziehbar bleiben.

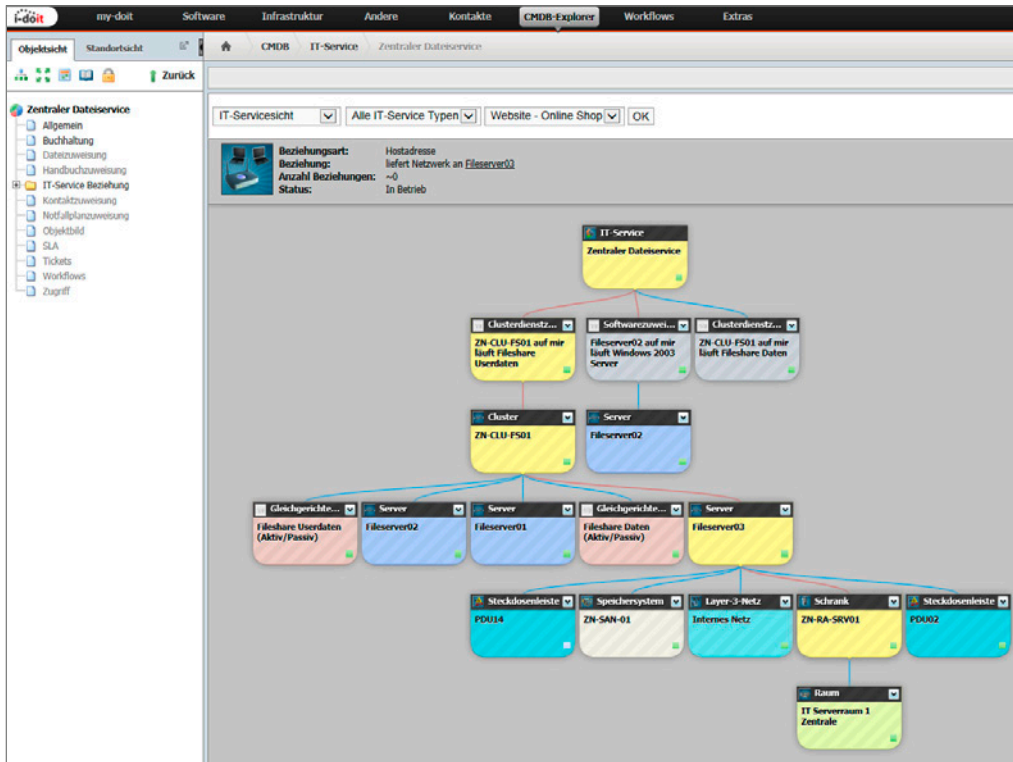


Bild 7.17 Darstellung der Beziehungen für einen Service im CMDB-Explorer –
Quelle: <http://www.i-doit.com/ressourcen/online-demo/>

IT-Grundschutzdokumentation

Eine interessante Ergänzung bietet i-doit mit dem seit Mai 2013 verfügbaren Modul VIVA. Dahinter verbirgt sich die vollständige Neuentwicklung der bereits seit 2011 bestehenden, rudimentären Grundschutzunterstützung nach BSI. Das Modul importiert die IT-Grundschutzkataloge des BSI in i-doit und nutzt für eine Zuordnung der Gefährdungen und Maßnahmen die bereits in der CMDB/Dokumentation modellierten Objekte und Beziehungen. Mit entsprechenden Views und Reports können diese Daten ausgewertet und analysiert werden. Außerdem können die für eine Zertifizierung nach IT-Grundschutz und/oder ISO27001 erforderlichen Referenzdokumente in i-doit generiert werden.

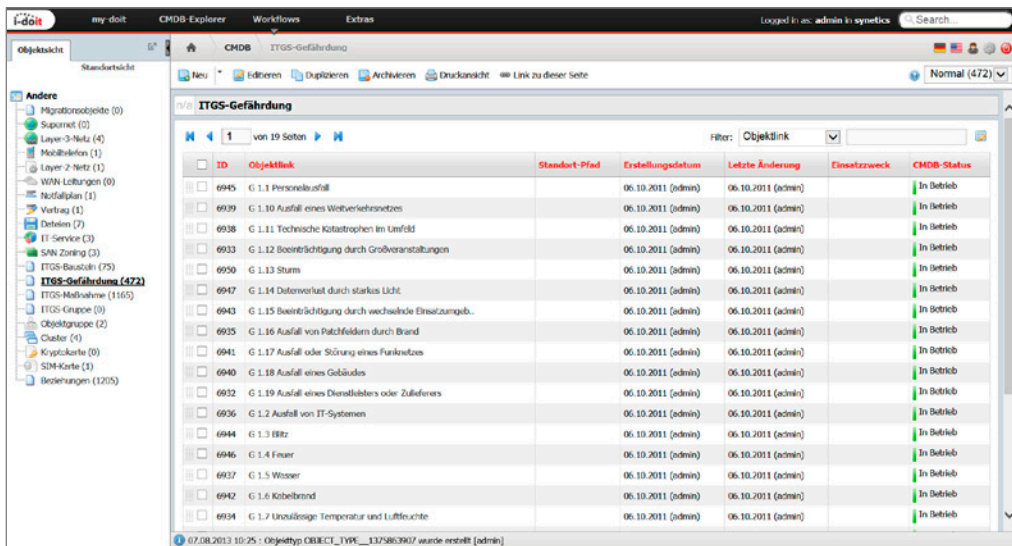


Bild 7.18 i-doit unterstützt die Integration der IT-Grundschrutskataloge –
Quelle: <http://www.i-doit.com/ressourcen/online-demo/>

Berichts- und Exportfunktionen

Aus Sicht der im Buch betrachteten IT-Dokumentation sind zum einen die integrierten Berichtsfunktionen und zum anderen die Schnittstellen interessant. Die Reporting-Funktionen reichen von vorgefertigten Abfragen aus einem Online-Repository bis hin zu einem Abfrageeditor, über den auch komplexere Abfragen gegen den i-doit-Datenbestand durchgeführt und abgespeichert werden können. Daneben gibt es noch einen SQL-Editor, mit dem Abfragen manuell geschrieben oder z. B. mit dem Abfrageeditor erstellte Queries verfeinert werden können. Zur Weiterverarbeitung können die Ergebnisse in diversen Formaten bereitgestellt werden.

Eine CMDB ist kein abgeschlossenes System, sondern dient dem Austausch mit anderen Systemen. CMDB lebt von der Interaktion mit anderen Systemen, um Daten zu erheben, auszutauschen oder anderen Systemen zur Verfügung zu stellen. Hierfür besitzt i-doit neben einer allgemeinen API Schnittstellen u. a. zur OpenSource-Software Nagios, zu Open Computer and Software Inventory Next Generation (kurz OCS Inventory NG), zu LOGINventory und zu Request Tracker und OTRS Help Desk. Zu den beiden letztgenannten besteht eine zweiseitige Schnittstelle, d. h., bei der Erstellung eines neuen Tickets können die in der CMDB hinterlegten CIs referenziert werden. Innerhalb von i-doit können für jede CI sowohl die bisher referenzierten Tickets angezeigt werden als auch neue Tickets mit direktem Bezug zur aktuell angezeigten CI erstellt werden.

■ 7.5 Tools für das Informations-sicherheitsmanagement

Eine Zertifizierung nach BSI-Grundschutz oder ISO 27001 stellt für jedes Unternehmen eine Herausforderung dar und macht viel Arbeit. Ohne Einsatz einer Softwarelösung ist diese kaum zu meistern.

7.5.1 Hinweise für die Evaluierung

Unabhängig davon, welches Testat angestrebt wird, ist die wichtigste Anforderung der Auditoren die Dokumentation: In ihr muss festgehalten sein, welche Systeme mit welchen Gefährdungen und Risiken eingesetzt werden, welche Sicherheitsprozesse definiert sind, wie sie aufgesetzt sind und welche Sicherheitsrichtlinien existieren.

Eine Frage, die es daher grundsätzlich zu klären gilt, ist die, ob eine spezielle Lösung erforderlich ist oder ob die ISMS-Dokumentation in einem anderen Tool, das möglicherweise bereits eingesetzt wird, mit erstellt werden kann. So können beispielsweise alle in diesem Kapitel vorgestellten Softwarelösungen in der einen oder anderen Weise das Informations-sicherheitsmanagement unterstützen. In den verschiedenen Phasen des ISM-Prozesses kann auch der Einsatz unterschiedlicher Lösungen sinnvoll sein.

Möchte man ein spezielles ISMS-Tool einsetzen, findet man am Markt eine Reihe von Softwarelösungen zur Unterstützung von IT-Sicherheits- und Risikomanagement. Diese Tools fokussieren häufig den Aufbau eines ISO-27001-konformen ISMS sowie dessen Zertifizierung. Um die Evaluierung zu erleichtern, hat der TÜViT ein standardisiertes Prüfverfahren für ISMS-Tools entwickelt, das der Erlangung des Zertifikats *Trusted Product ISO 27001 Tool* dient. Bislang jedoch haben kaum Hersteller ihre Software zertifizieren lassen, so dass dies keine Hilfe bei der Auswahl darstellt. Allerdings können die von TÜViT benannten Anforderungen durchaus auch bei der eigenen Evaluierung hilfreich sein.

Einige ISMS-Tools unterstützen auch die Umsetzung der BSI-Standards und den Grundschutzprozess. Diese bieten nicht nur Funktionen zur Bewertung von Sicherheitsrisiken für alle Systeme und zur Ableitung von Maßnahmen, sondern helfen auch bei der Erstellung der erforderlichen Dokumente. Einige Werkzeuge integrieren auch umfangreiche Report-funktionen.

Auf der Suche nach einem ITSM-Tool kann ein Blick auf die Website des BSI sinnvoll sein: [https://www.bsi.bund.de/DE/Themen/ITGrundschutz/ITGrundschutzKataloge/Hilfsmittel/GrundschutznaheTools/grundschutznahetools_node.html]. Hier nennt das BSI eine Reihe von Tools mit sehr unterschiedlicher Ausprägung. Die im Folgenden vorgestellten beiden Tools verinice und das GSTOOL zeigen exemplarisch Funktionen derartiger Anwendungen. Dabei nimmt das GSTOOL insofern eine Sonderrolle ein, als es vom BSI selbst bereitgestellt wird und zumindest bei Behörden zum Teil verbindlich einzusetzen ist.



IT-Grundschatzkataloge können kostenfrei heruntergeladen werden

Die Grundschatzkataloge sind eine Lose-Blatt-Sammlung, die regelmäßig aktualisiert wird. Zusätzlich können Sie die Kataloge als HTML- und PDF-Dateien kostenfrei herunterladen. Der Kern der Kataloge sind Bausteine, die sehr unterschiedliche Bereiche beschreiben, in denen Sicherheit eine Rolle spielt. Ihr Umfang reicht von völlig untechnischen Fragestellungen wie der Personalpolitik eines Unternehmens in Hinsicht auf sicherheitskritische Bereiche bis hin zu konkreten Systemen, wie Terminalserver oder TK-Anlagen. Der Katalog der zwölften Ergänzungslieferung von 2011 enthält über 80 Bausteine. Ein zweiter Katalog listet die Gefährdungsarten auf.

Ein Beispiel aus dem Bereich »Technisches Versagen« ist der Verlust gespeicherter Daten und im Bereich »Vorsätzliche Handlungen« finden Sie Gefährdungen, wie das Abhören von Leitungen und die Manipulation an Leitungen. Ein dritter Katalog enthält Maßnahmen, die den genannten Gefährdungen entgegenwirken. Einige sind eher allgemeiner Natur, andere gehen auf konkrete Details ein. Die Maßnahme M 3.5 fordert zum Beispiel, Schulungen zu IT-Sicherheitsmaßnahmen durchzuführen, die Maßnahme M 5.21 befasst sich dagegen detailliert mit dem sicheren Einsatz von telnet, ftp, tftp und rexec.

7.5.2 GSTOOL

Die folgenden Ausführungen beziehen sich auf die aktuelle Version 4.8 (Stand Juli 2013).

Mit dem Tool *IT-Grundschatz (GSTOOL)* stellt das BSI eine Software bereit, die bei der Erstellung und Verwaltung des IT-Sicherheitskonzepts basierend auf dem IT-Grundschatz nach den BSI-Standards 100-1 bis 100-3 unterstützt. Unmittelbare Bundes-, Landes- und Kommunalverwaltungen erhalten das GSTOOL kostenfrei. Daher wundert es nicht, dass es in vielen Behörden (zum Teil auch verpflichtend) eingesetzt wird. Darüber hinaus jedoch findet es kaum Verwendung.

Das GSTOOL bildet die IT-Grundschatzvorgehensweise gemäß BSI vollständig ab und unterstützt mit Hilfe u. a. der nachstehenden Funktionen die Erstellung eines entsprechenden IT-Sicherheitskonzepts:

- Erfassung von IT-Systemen, Anwendungen, Netzwerkkomponenten und Infrastrukturkomponenten,
- Schutzbedarfsfeststellung,
- Risikoanalyse auf der Basis von IT-Grundschatz gemäß BSI-Standard 100-3,
- Modellierung nach IT-Grundschatz,
- Basissicherheitscheck,
- Maßnahmenumsetzung,
- Berichterstellung,
- Kostenauswertung.

Zusätzlich unterstützt das GSTOOL das ISO-27001-Zertifikat auf der Basis von IT-Grundschatz.

Ob sich der Einsatz des GSTOOLS lohnt, muss im Einzelfall geprüft werden. Vorteilhaft ist, dass die Vorgaben für einen IT-Grundschutz bereits mitgeliefert werden und mit Hilfe des Tools die Bausteine, Maßnahmen und Gefährdungen des IT-Grundschutzes systematisch erarbeitet, dokumentiert und fortgeschrieben werden.

Allerdings müssen sämtliche hierfür benötigten Daten ohne eine individuelle Schnittstellenprogrammierung in Bezug auf die vorhandene IT- und Sicherheitsinfrastruktur von Hand eingegeben werden. Eine automatische Erfassung der Systemlandschaft erlaubt das Tool derzeit noch nicht. Auch eine Datenübernahme aus anderen Systemmanagementtools wird nicht unterstützt. Erschwerend kommt hinzu, dass die Veröffentlichung der neuen Version 5.0 von Seiten des BSI auf unbestimmte Zeit verschoben werden musste. Die komplette Neuentwicklung des aktuell in Version 4.7 existierenden GSTOOL war nötig geworden, da mit dem auf Visual Basic 6 und MS-SQL Server 2000 basierenden Werkzeug zum einen Weiterentwicklungen wirtschaftlich kaum sinnvoll zu realisieren sind und es zum anderen keine weiteren Betriebssysteme unterstützen kann.

Ausführliche Informationen zum GSTOOL stellt das BSI unter dem folgenden Link zur Verfügung: [<http://www.bsi.de/gstool/index.htm>]. Hier kann auch eine kostenlose 30-Tage-Testversion heruntergeladen werden.

7.5.3 verinice

Die folgenden Ausführungen zu verinice (Sernet GmbH) beziehen sich auf die aktuelle Version 1.6.2 (Stand Juli 2013).

verinice ist ein Java-basiertes ISMS-Tool für das Management von Informationssicherheit und kann als OpenSource-Software kostenfrei als Einzelplatzversion von der folgenden Seite heruntergeladen werden [<http://www.verinice.org/>]. Es unterstützt die Betriebssysteme Windows, Linux und Mac OS und hat die Grundschutzkataloge des BSI lizenziert. Zusätzlich gibt es eine kostenpflichtige mehrbenutzerfähige Serverversion mit erweitertem Funktionsumfang.

verinice unterstützt beim Aufbau und beim Betrieb ISMS. Hierfür bietet es u. a. die folgenden Leistungsmerkmale:

- Unterstützung bei der Implementierung von BSI-IT-Grundschutz und bei der Umsetzung der Anforderungen aus den Standards ISO 27001, ISO 27002, ISO 27005 und dem Standard IDW PS 330. Prinzipiell lassen sich auch andere Standards umsetzen. Diese können in Form eines Anforderungskatalogs importiert werden, wenn dieser im CSV-Format vorliegt.
- Durchführung einer Risikoanalyse auf Basis der Gefährdungskataloge des BSI-Grundschutzes oder eigener Risikokataloge. verinice.PRO enthält zusätzlich einen Katalog mit generischen Risikoszenarien.
- Unterstützung von Self Assessments auf Basis von integrierten Fragenkatalogen
- Information Security Assessment des VDA – der Verband der Automobilindustrie hat einen eigenen Anforderungskatalog basierend auf den Vorgaben der ISO 27001/27002 herausgebracht. Dieser wird mit verinice ausgeliefert und kann in einer eigenen Perspektive bearbeitet werden.
- Unterstützung bei Zertifizierungsaudits durch spezielle Eingabemasken und angepasste Reports insbesondere zur Verifikation des Basis-Sicherheitschecks

Insbesondere die PRO-Version bietet noch einige weitere Funktionen. Hierzu zählt beispielsweise ein Workflow-gestütztes Vulnerability-Tracking zur Nachverfolgung von Schwachstellen.

Nach dem ersten Start fordert verinice zur Auswahl der Startperspektive auf:

- **ISM-Perspektive:** Die ISM-Perspektive ist für die Umsetzung der ISO-Standards 2700x ausgelegt. Insbesondere die Durchführung einer Risikoanalyse nach ISO 27005 und die Ausgabe des Risk Assessment als Report lässt sich hier durchführen. Als generische Perspektive kann sie aber auch zum allgemeinen Risikomanagement oder zur Umsetzung organisationsinterner Vorgaben verwendet werden.
- **IT-Grundschutzperspektive:** Die Perspektive BSI-Grundschutz unterstützt bei der Erstellung und Aufrechterhaltung eines ISMS gemäß der IT-Grundschutzvorgehensweise und den BSI-Standards 100-1, 100-2, 100-3 und 100-4.
- **Audit-Perspektive:** Die Audit-Perspektive ist eine weitere Perspektive, die für die Durchführung von möglichen Audits herangezogen werden kann. Diese Perspektive ist untergliedert in ein Organisations-View, Audit-View, Asset-View und Control-View und ist auf die Durchführung von Audits ausgelegt.

IT-Grundschutzperspektive

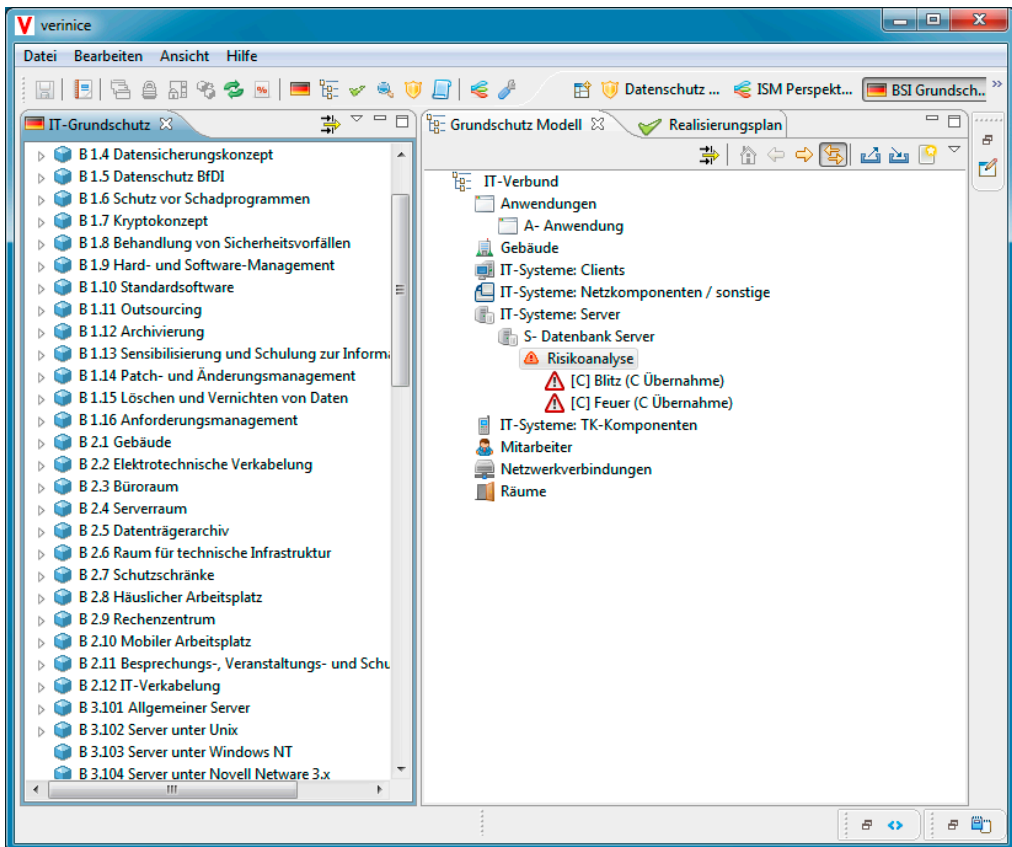


Bild 7.19 verinice-Benutzeroberfläche in der BSI-Grundschutzansicht

Die Grundschutzkataloge des BSI sind lizenziert, müssen beim ersten Start jedoch noch geladen werden. Hierfür können sie kostenlos als freie Inhalte von der BSI-Website heruntergeladen werden. Alternativ kann verinice aber auch direkt auf die öffentlich zugänglichen Webseiten des BSI zugreifen und sich von dort alle Daten holen. Die eingebauten XML-Parser laden die Bausteine und Module dann in die integrierte Datenbank. Das BSI hat für jeden Baustein bereits eine Reihe von Bedrohungen und Maßnahmen definiert. verinice zeigt diese Abhängigkeiten in einer Baumdarstellung.

Innerhalb des IT-Verbunds lässt sich für die Zielobjekte der Schutzbedarf festlegen und dokumentieren. In der entsprechenden Dialogbox kann der notwendige Schutzbedarf *Normal*, *Hoch* oder *Sehr hoch* für die drei Grundwerte *Vertraulichkeit*, *Verfügbarkeit* und *Integrität* festgelegt werden.

Bild 7.20 Für jedes Objekt kann der Schutzbedarf festgelegt werden

In verinice ist es möglich, für alle Objekte assistentenunterstützt zusätzlich eine Risikoanalyse durchzuführen. Hierzu werden in einer Gefährdungsübersicht über alle Gefährdungen aus den Grundschutzkatalogen aufgelistet. Zusätzlich können eigene Gefährdungen hinzugefügt werden. Alle Objekte, die eine Risikoanalyse erfahren haben, sind mit dem Symbol gekennzeichnet (siehe Bild 7.19).

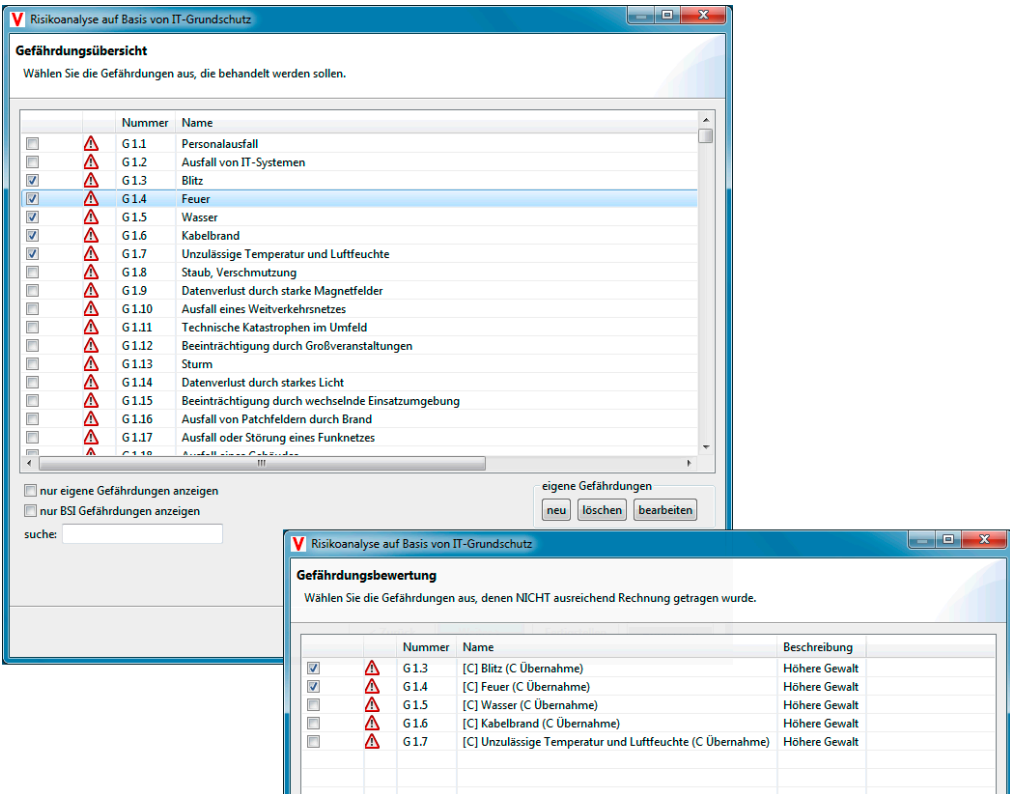


Bild 7.21 Risikoanalyse auf Basis von IT-Grundschutz in verinice

Grundlage aller weiteren Arbeiten ist eine Erfassung aller Anwendungen und Systeme. Das Grundschutzmodell verwendet dafür den Begriff IT-Verbund. Die Erfassung kann entweder manuell erfolgen oder auf Basis der Scan-Ergebnisse der Software Greenbone (von Greenbone Networks GmbH). Der *Greenbone Security Manager (GSM)* ist eine Produktlinie zweckorientierter Appliances für Schwachstellen-Scanning und -Management. Eine Kopplung der Produkte ist ab der verinice-Version 1.6 möglich.

Außerdem verfügt verinice über eine Importfunktion, mit der Daten aus dem GSTOOL des BSI übernommen werden können.

Dokumentenerstellung

Aus Sicht der IT-Dokumentation sind natürlich die Möglichkeiten für die Erstellung der sicherheitsrelevanten Dokumente wichtig. Im Rahmen von Reporting-Funktionen ermöglicht verinice das Erstellen von Berichten für Prüfer, Geschäftsleitung und Prozessverantwortliche. Alle Berichte lassen sich in einer Vielzahl von Formaten (PDF, HTML, DOC, XLS, ODT, ODS) ausgeben und veröffentlichen oder weiterbearbeiten. In der PRO-Version können die Reportvorlagen auch angepasst oder zusätzlich eigene Vorlagen erstellt werden.

Außerdem können die für die Zertifizierung nach ISO 27001 auf Basis von IT-Grundschutz erforderlichen Referenzdokumente (siehe hierzu *Kapitel 1 Abschnitt 1.6.2.*) in verinice erstellt werden.

Pflege eines datenschutzrechtlichen Verfahrensverzeichnisses

Zur Einhaltung eines gesetzeskonformen Datenschutzmanagements sind unter anderem die Pflege und Veröffentlichung eines sogenannten »Verfahrensverzeichnisses« für alle Unternehmen vorgeschrieben. Das Verfahrensverzeichnis muss alle automatisierten Verfahren einer Organisation auflisten, mit denen im Rahmen eines automatisierten Verfahrens ermittelte personenbezogene Daten gespeichert werden. Dem betrieblichen Datenschutzbeauftragten kommt gemäß § 4 g 2 S. 2 die Aufgabe zu, die ihm im Unternehmen gelieferten Informationen jedermann in geeigneter Weise verfügbar zu machen. Das Verfahrensverzeichnis wird beim betrieblichen Datenschutzbeauftragten geführt. Dieser muss das Verfahrensverzeichnis aber nicht selbst erstellen. Vielmehr werden ihm die datenschutzrelevanten Verfahren von den Fachabteilungen benannt und beschrieben.

Innerhalb der Grundsatzperspektive verbirgt sich mit der Option »Datenschutz-Perspektive« eine nützliche Funktion zur Erstellung und Pflege eines Verfahrensverzeichnisses. Diese spezielle Sicht greift auf die als Anwendungen angelegten Objekte zurück und bietet die Möglichkeit, zu jeder Anwendung (in der Perspektive als Verfahren dargestellt) die nötigen Angaben zur Verarbeitung personenbezogener Daten zu hinterlegen.

■ 7.6 Tools für die Notfalldokumentation

In Kapitel 4 wurden ausführlich die Unterschiede zwischen *Business Continuity Management (BCM)* und *IT-Service Continuity Management (IT SCM)* erforderliche Unterscheidung dargestellt. Demnach adressiert das *BCM* (wie der Name bereits aussagt) die Businessprozesse, d. h. die unternehmensweiten Kernprozesse. Hierbei stehen die Analyse und das Management der Risiken im Vordergrund, damit das Unternehmen jederzeit die erforderliche Mindestproduktionskapazität bzw. die Mindestservices gewährleisten kann. Vorrangige Aufgabe von *IT SCM* ist hingegen die Unterstützung des übergeordneten Business Continuity Managements, indem sichergestellt wird, dass jederzeit das definierte Mindestmaß an IT-Services zur Verfügung steht. *IT SCM* muss demnach integraler Bestandteil eines übergeordneten Business Continuity Management sein und vom Umfang aus den geschäftlichen Zielvorgaben abgeleitet werden. Hierbei übernimmt das *BCM* die Gesamtverantwortung für den Notfallmanagementprozess und die Planung für die Wiederherstellung aller Services.

Dementsprechend müssen auch die Einrichtung und der Betrieb einer Anwendung für das Notfallmanagement in der Verantwortung des unternehmensweiten Notfallmanagements liegen. Die Einführung eines Tools zur Unterstützung der Aufgaben von *IT SCM* ist zwar möglich, muss dann aber mit den für das *BCM* Verantwortlichen abgestimmt sein.

Im Folgenden wird deshalb im Überblick vorgestellt, welche Kriterien bei der Auswahl einer Softwarelösung für das *BCM* wichtig sind, auf die exemplarische Vorstellung von Tools wird jedoch verzichtet. Außerdem bieten die meisten der in diesem Kapitel vorgestellten Anwendungen auch Funktionen, die die Erstellung einer Notfalldokumentation unterstützen.

Hinweise für die Evaluierung

Steht in einem Unternehmen die Auswahl eines Tools zur Unterstützung des Notfallmanagements an, muss im ersten Schritt die Frage nach dem Einsatzzweck beantwortet werden. Im Vordergrund sollte die Frage stehen, welche Bereiche das Tool unterstützen soll. Ist lediglich eine Unterstützung bei der Erstellung der Dokumente für die Notfallbewältigung erforderlich oder soll das Tool alle unternehmensweiten Notfallmanagementprozesse unterstützen?

Tools, die ein komplettes Business-Continuity-Management-Framework zur Verfügung stellen, haben nämlich ihren Preis, der in der Regel im fünfstelligen Bereich oder darüber liegt. Preiswerte Tools für ein paar Hundert Euro bieten hingegen nur selten Funktionen, die über eine Systeminventarisierung plus Dokumentation hinausgehen.



Marktübersicht Notfalltools

Die Ausführungen der folgenden Abschnitte behandeln einige wesentliche Punkte, die bei der Auswahl einer BCM-Softwarelösung zu beachten sind. Darüber hinaus finden Sie unter dem Link [<http://www.bcm-news.de/bcm-tools/>] eine Website, die in einer Marktübersicht eine Auswahl der aktuell verfügbaren Notfall- und BCM-Tools vorstellt.

Viele Unternehmen verbinden mit der Einführung eines Tools für das Notfallmanagement den Wunsch, alle Aufgaben, wie die Systeminventarisierung, die Abbildung der Notfallprozesse und die Bereitstellung des Notfallhandbuchs sowie die Dokumentation der Notfallvorsorgemaßnahmen, in einem Tool zusammenzuführen. Allerdings besteht nur selten die Möglichkeit, »auf der grünen Wiese« zu starten. In der Regel sind bereits einzelne Tools im Einsatz, die es einzubinden gilt. Wer bereits eine Inventarisierungssoftware und/oder eine CMDB im Einsatz hat, wird diese nicht einfach ablösen können. Daher bieten viele Tools die Möglichkeit, auf Daten zu Hardware und Software sowie Personenstammdaten aus vorhandenen Datenbanken automatisiert zuzugreifen. Diese Funktion ist wichtig, um doppelte Datenhaltung zu vermeiden.

Weiterhin muss zwingend analysiert werden, welche Aufgaben unterstützt werden sollen. Ist lediglich eine Unterstützung bei der Erstellung und Verwaltung von Notfallszenarien und Wiederanlaufplänen gewünscht? Soll die Lösung die Implementierung von Notfalltests und Notfallübungen unterstützen? Ist eine Unterstützung bei der Erstellung von Risiko- und Business-Impact-Analysen erforderlich? Soll das Tool die Notfallbewältigung und die Arbeit des Krisenstabs im Notfall unterstützen? Ist eine Zertifizierung geplant, für die das Tool eine anforderungsgerechte Dokumentation liefern soll?

Allein die kleine Auflistung der Fragen zeigt die Vielschichtigkeit der Einsatzmöglichkeiten. Die nachstehende Liste zeigt einige Kriterien, die bei der Evaluierung eines Notfallmanagementtools herangezogen werden können. Welche davon wichtig sind, muss unternehmensspezifisch entschieden werden.

- Zugriffsmöglichkeiten auf externe Daten,
- Unterstützung beim Aufbau der Notfallorganisationsstruktur auf der Basis vorhandener Unternehmensdaten,

- automatische Benachrichtigung aller Beteiligten per E-Mail und SMS einschließlich der Alarmierung des Krisenstabs,
- Multiuser- und Mandantenfähigkeit,
- Ausgabe des Notfallhandbuchs als Textdokument entweder online, auf Papier oder im HTML-Format,
- Online-Unterstützung bei der Durchführung von Notfallübungen,
- Dokumentation von Notfallmanagementprozessen,
- Unterstützung bei der Erstellung und Verwaltung von Geschäftsfortführungsplänen und Wiederanlaufplänen,
- Online-Begleitung bei der Durchführung von Notfallplänen einschließlich automatischer Erstellung von Ablaufprotokollen,
- Unterstützung des Redaktionsprozesses für Notfalldokumente (Versionierung, Benachrichtigung bei Änderungen usw.),
- Möglichkeit der automatisierten Speicherung des Systems und der Daten auf mobilen Datenträgern,
- Unterstützung von Risiko- und Business-Impact-Analysen,
- Dokumentenmanagementsystem-Funktionen,
- funktionsübergreifende Komponenten für das SLA- und Lizenzmanagement,
- Bereitstellung einer integrierten CMDB,
- Unterstützung bei Zertifizierungen beispielsweise nach 22301, 27001 oder IT-Grundschutz.



Hinweis

Die vorstehende Liste wurde zusammengestellt aus dem Funktionsangebot diverser Notfallmanagementtools. Sie erhebt keinen Anspruch auf Vollständigkeit und soll lediglich Ideen für die Evaluierung liefern.

7.7 Tools für die GRC-Dokumentation

Die Abkürzung GRC steht für *Governance, Risk & Compliance* und beschreibt die Einhaltung von geltenden nationalen und internationalen Gesetzen, Vorschriften, Normen und Standards (Compliance) durch verantwortungsvolle und zielgerichtete Führung und Überwachung (Corporate Governance). Ein wichtiger Faktor dabei ist das frühzeitige Auseinandersetzen mit Risiken und die Erarbeitung von Strategien zur Risikominimierung (Risk). GRC-Tools unterstützen bei der Einhaltung von Compliance-Vorgaben und bei der Dokumentation.

7.7.1 Hinweise für die Evaluierung

Die Anforderungen, die sich aus den in *Kapitel 1* beschriebenen Gesetzen und Standards wie GdPdU, Sarbanes-Oxley Act, HIPAA, Basel II und II und Euro-SOX ergeben, und die daraus resultierenden Datenaufbewahrungs- und Risikomanagementprozeduren haben in den letzten Jahren zu einer Zunahme an GRC-Lösungen am Markt geführt. Hersteller wie SAP, Oracle, IBM und CA bieten Unternehmen Frameworks, die sie bei der Überwachung und der Erzwingung von Richtlinien und Prozeduren unterstützen. Die Implementierung umfasst in der Regel komplexe Installationen, die unter anderem die Koordination der Daten zwischen mehreren Abteilungen (kaufmännische Abteilung, IT, Sicherheit, Compliance u. a.) unterstützen. Nach der Installation ermöglichen Tracking-Funktionen, Dashboards und Datenanalysetools die Überwachung und Einhaltung der Anforderungen und die Steuerung von Risiken. Die Zielgruppe derartiger Anwendungen sind u. a. Führungskräfte, die Risiken identifizieren und steuern müssen und Finanzmanager, die sich mit regulatorischen Anforderungen auseinandersetzen. An dieser Stelle bewegt man sich im Bereich des unternehmensweiten Managements, was auch für die Einführung derartiger Lösungen verantwortlich ist.

Auf der anderen Seite geraten IT-Organisationen zunehmend unter Druck, die aus Gesetzen und anderen Regularien ableitbaren Datenaufbewahrungs-, Sicherheits- und Risikomanagementprozeduren umsetzen und nachweisen zu müssen. IT-Governance, IT-Compliance und IT-Risikomanagement erhalten damit eine immer größere Bedeutung. IT-GRC-Werkzeuge sind meist speziell auf das Informationssicherheitsmanagement (ISM) und auf das IT-Risikomanagement ausgerichtet.

Die Hersteller von IT-GRC-Lösungen liefern meist fertige Maßnahmenkataloge mit, die sich beispielsweise an den Controls aus den ISO-Standards 27001 oder an den COBIT-Control-Objectives orientieren. Häufig ist es aber auch möglich, andere Kataloge zu integrieren, zum Beispiel die Maßnahmen der IT-Grundschutzkataloge oder unternehmensspezifische Maßnahmenkataloge. Nach Auswahl der zu betrachtenden Maßnahmen lässt sich der Umsetzungsgrad bei den meisten Produkten dann entweder in Interviewform über elektronische Fragenkataloge ermitteln oder durch Auswahl eines konkreten Umsetzungsgrads direkt angeben.

Andere IT-GRC-Lösungen unterstützen zusätzlich eine detaillierte Risikoanalyse in Anlehnung an den Standard ISO/IEC 27005, bei der zunächst Bedrohungen ermittelt und anschließend bewertet werden. Sind die Risiken bekannt, erfolgt im nächsten Schritt die Ermittlung des Umsetzungsgrads von Gegenmaßnahmen. Die Auswahl der zum Risiko »passenden« Maßnahmen kann dabei ebenfalls durch das Tool unterstützt werden, da in vielen Produkten die Bedrohungen des Bedrohungskatalogs mit den Maßnahmen des Maßnahmenkatalogs verknüpfbar sind. Die in *Abschnitt 7.1* beschriebenen Anwendungen GSTOOL und verinice können demnach auch den IT-GRC-Tools zugeordnet werden.

Wie bereits mehrfach betont, ist eine sorgfältige Produktauswahl erforderlich, denn die Anwendungen unterscheiden sich in ihrem Funktionsumfang teils erheblich. Ziel sollte es sein, so viele Compliance-Bereiche wie möglich in einheitlicher, durchgehender Form zu behandeln. Werden verschiedene Übersichten geführt und verschiedene Tools eingesetzt, erhöht dies den Verwaltungsaufwand immens. Oft werden die einzelnen Bereiche separat bearbeitet, ohne auf mögliche Doppelprüfungen und Überschneidungen zu achten. Dies

erhöht den internen Compliance-Aufwand und bestärkt die Mitarbeiter in ihrer Abneigung gegen Prüfungen und Audits.

Und aus Sicht der IT-Dokumentation sind natürlich die integrierten Dokumentationsfunktionen entscheidend. Hier spielen Fragen nach mitgelieferten Templates, Dokumentenmanagementfunktionen und Möglichkeiten für eine revisionssichere Dokumentation eine Rolle. Ein Beispiel für eine Anwendung, die das Thema GRC-Dokumentation fokussiert, ist DocSetMinder, das im folgenden Abschnitt exemplarisch vorgestellt wird.

7.7.2 DocSetMinder

Die folgenden Ausführungen zu DocSetMinder (GRC Partner GmbH) beziehen sich auf die aktuelle Version 2012 (Stand Juli 2013).

DocSetMinder ist ein Microsoft-SQL-basierendes Tool zur Unterstützung bei der Erfüllung von Dokumentationspflichten in Unternehmen, Körperschaften und Behörden. Auf der Basis der erfassten Unternehmensbasisdaten und diverser Module ist es mit DocSetMinder möglich, eine an den Compliance-Anforderungen des Unternehmens ausgerichtete Dokumentation aufzubauen. Die Module bilden die Struktur der Dokumentation ab und spiegeln die Vorgaben von Gesetzen und internationaler Standards bzw. branchenspezifischer Anforderungen der Unternehmen wider. Sie bestehen aus Dokumentvorlagen, die auch modulübergreifend eingesetzt werden können.

In der aktuellen Version von DocSetMinder stehen die folgenden Module zur Verfügung:

- Unternehmensorganisation als Grundlage für alle Module
- Compliance
 - Umweltmanagement (DIN EN ISO 14001)
 - Qualitätsmanagement (DIN EN ISO 9001)
 - Sarbanes-Oxley Act (COSO, SOX)
 - Internes Kontrollsystem (IKS)-Prüfung gemäß IDW PS 951 und IDW PX 261
 - IKS-Prüfung gemäß ISAE 3402
 - Verrechnungspreisdokumentation (§ 90 AO)
 - Datenschutz (BDSG und DSGVO)
 - Verfahrensdokumentation (GoBS, GDPdU)
- IT-Governance
 - IT-Dokumentation (ISO-OSI-Referenzmodell)
 - IT-Grundschutz (BSI)
 - IT-Notfallmanagement (BSI 100-4 und ISO 22301)
 - IT-Service-Management gemäß DIN EN ISO 20000
 - IT-Systemprüfung gemäß IDW PS 330
 - PCI-DSS-Standard

Der modulare Aufbau von DocSetMinder ermöglicht es, die jeweilige Dokumentation im Kontext der Geschäftsprozesse zu dokumentieren. Dabei greifen alle Module auf die gleichen Daten zu, so dass eine konsistente Dokumentation für alle Anforderungsbereiche sichergestellt ist. Ändert sich also beispielsweise der Verantwortliche eines Prozesses, wird dieses allen damit verbundenen Dokumenten automatisch bekannt gemacht und die Änderung wurde zudem durch die mitgeführte Historie revisionssicher dokumentiert. Das Ziel ist es, jederzeit für unterschiedliche Audits und Anforderungen eine aktuelle und vollständige Dokumentation bereitstellen zu können.

Aufbau und Arbeitsweise von DocSetMinder

Die Hauptkomponente von DocSetMinder bildet das Basismodul *Unternehmensorganisation*. Die Kenntnis über die Organisation des Unternehmens und dessen Prozesse, die mit Unterstützung der IT-Ressourcen realisiert werden, sind Voraussetzung für ein effektives IT-Servicemanagement. Das Modul stellt die notwendigen Strukturen und Vorlagen für die Dokumentation der Aufbauorganisation (Organisationseinheiten und Verantwortlichkeiten u. a.) sowie für die Ablauforganisation (Abbildung der Geschäftsprozesse) eines Unternehmens bzw. einer Behörde bereit.

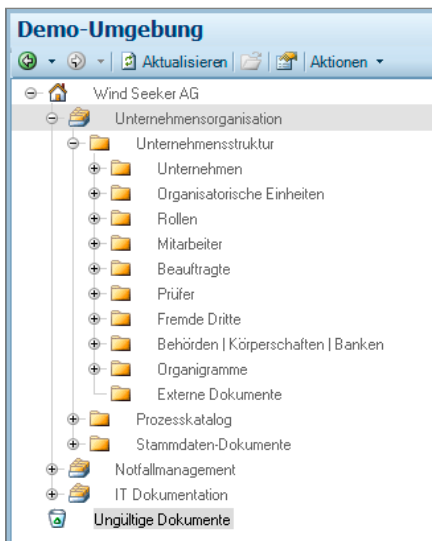


Bild 7.22

Abbildung der Aufbau- und der Ablauforganisation im Modul *Unternehmensorganisation*

Wie bereits ausgeführt, greifen alle Module auf die im Basismodul gepflegten Daten sowie auf die Komponenten und Inhalte der anderen Module zu. Diese einzelnen Elemente werden jeweils untereinander intern verlinkt. Dadurch wird die Vollständigkeit sichergestellt und der Zugriff auf die jeweils aktuelle Version gewährleistet. Das bezieht sich auch auf bereits vorhandene Dateien wie MS-Office-Dokumente, Handbücher, Zeichnungen, Formulare etc.

01 Referenz Nr. (Raumnr.)	RM22
02 Bezeichnung	Rechenzentrum (1)
03 Raumart	Rechenzentrum
04 Beschreibung	Mit Rechenzentrum bezeichnet man sowohl das Gebäude bzw. die Räumlichkeiten, in denen die zentrale Rechentechnik (z. B. Rechner aber auch die zum Betrieb notwendige Infrastruktur) einer oder mehrerer Unternehmen bzw. Organisationen untergebracht sind, als auch die Organisation selbst, die sich um diese Computer kümmern. Ihr kommt damit eine zentrale Bedeutung in der Unternehmens-EDV zu.
05 Etage	4. OG
06 Gebäude	
07 Zutritt geregelt?	Ja
08 Zutritt geregelt durch?	1. Unternehmensweite Richtlinie 2. Prozess "Zutrittsregelung" 3. Schliessanlage
09 Zutrittsberechtigte Personen	LT02 - Leiter IT LT10 - Leiter RZ LT11 - Leiter Service Desk MA10 - Softwareentwicklung
91 Notfallplan	
98 Detailinformationen (Dokumente)	RZ22
99 Detailinformationen (Text)	

Bild 7.23 Dokumente werden in DocSetMinder als Tabellen verwaltet.

Über das DocSetMinder Application Programming Interface (API) besteht die Möglichkeit, Teile der Dokumentation automatisch generieren zu lassen. Dies ist insbesondere dann sinnvoll, wenn bestimmte Informationen ohnehin in anderen operativen Systemen vorliegen und dort gepflegt werden oder durch andere Systeme zusammengetragen werden. Bereits erfasste oder generierte Daten bzw. Dokumente können somit medienbruchfrei in die Dokumentation übernommen werden. Dies reduziert den Aufwand an manueller Dokumentationsarbeit erheblich. Grundsätzlich können Daten aus den meisten operativen Systemen übernommen werden:

- Datensätze aus relationalen Datenbanken, zum Beispiel Microsoft SQL Server, Oracle, MySQL,
- Datensätze aus strukturierten Dateien, zum Beispiel XML, CSV, Microsoft Access (MDB), Microsoft Excel (XLS), Textdateien (TXT),
- Inhalte aus HTML-Dateien,
- sonstige Daten aus Anwendungen über Component Object Model (COM).

Ebenso wie beim manuellen Schreiben und Editieren der Dokumentation stellt DocSetMinder auch bei diesem automatisierten Verfahren sicher, dass alle Änderungen versioniert werden und dass die Integrität der Verknüpfungen zwischen Dokumenten gewahrt bleibt.

Dokumentenmanagementfunktionen

Hinsichtlich der in der Datenbank hinterlegten Dokumente bietet DocSetMinder einige Funktionen, welche die Anforderungen an Revisionssicherheit, Integrität, Vollständigkeit und Historie sicherstellen. Hierzu zählen u. a. die Folgenden:

Sämtliche Dokumente und Daten werden im Hintergrund unter Berücksichtigung von Zugriffsrechten in einem zentralen DocSetMinder Repository (SQL-Datenbank) nachvollziehbar, unveränderbar und verfälschungssicher gespeichert. Die dort hinterlegten Daten können grundsätzlich nicht gelöscht, also physikalisch entfernt werden. Nicht mehr benötigte Dokumente werden als ungültig deklariert und dadurch automatisch in ein Systemverzeichnis zur Verwaltung ungültiger Dokumente verschoben. Solche ungültigen Dokumente

sind für den Standardbenutzer nicht mehr sichtbar. Dieser Vorgang kann mit der entsprechenden Berechtigung rückgängig gemacht werden.

Bereits im Unternehmen existierende Dokumente können per Drag&Drop in das DocSet-Minder Repository integriert werden. Die Eigenschaften der Revisionssicherheit und Versionierung werden dabei automatisch auf die integrierten Dokumente übertragen. Das gilt für alle Office-Dokumente, aber auch für andere Dokument- bzw. Dateitypen wie beispielsweise jpg, bmp, tif, ini, pdf etc.

Jede Änderung der in der DocSetMinder-Struktur gespeicherten Dokumente unterliegt einem automatischen Versionierungsvorgang, d.h., nach der Änderung eines Dokuments und erneutem Einchecken in die Struktur bekommt das Element eine neue Revisionsnummer. Dabei wird die Vorgängerversion nicht überschrieben, sie bleibt in der Datenbank gespeichert. Weiterhin kann ein bestimmter Stand der Dokumentation endgültig pro Geschäftsperiode abgeschlossen und als eigenständige Version der gesamten Dokumentation gespeichert bzw. ausgegeben werden. Durch diesen Versionsabschluss ist die Abgrenzung der für die Prüfung benötigten Dokumentation wesentlich vereinfacht. Bei einem Audit können damit dem Prüfer bzw. Auditor sowohl eine aktuelle wie auch eine Dokumentation für in der Vergangenheit liegende Geschäftsperioden ausgehändigt werden.

Bereitstellung der Dokumentation

Die Bereitstellung der Dokumentation kann auf verschiedene Weise geschehen: Zum einen bietet DocSetMinder die Darstellung aller Dokumente auf dynamischen Webseiten an. Mit Hilfe von Microsoft SQL Reporting Services kann die Dokumentation dynamisch ausgewertet und den Betrachtern als Webdienst im Intranet zur Verfügung gestellt werden. Die Speicherung eines HTML-Extrakts ist aber auch auf einem USB-Stick möglich, gedacht vor allem zur Lagerung außerhalb der IT-Infrastruktur. Ein Notfallhandbuch zum Beispiel ist dadurch jederzeit verfügbar, benötigt wird lediglich ein einfacher PC mit Internetbrowser.

Zum anderen kann die ausgewählte Dokumentation wahlweise auch nach Microsoft Word exportiert werden, wo mithilfe einer angepassten Dokumentenvorlage ein druckfähiges Dokument mit Inhaltsverzeichnis und aktiven Hyperlinks entsteht. Es ist außerdem möglich, alle Berichte in verschiedenen Formaten wie z.B. PDF oder Microsoft Office Excel zu exportieren. In der Druckauswahl können dazu gewünschte Dokumente in den Druckvorgang einbezogen bzw. ausgeschlossen werden. Ebenfalls lässt sich definieren, welche Versionen der Dokumentation aus der Vergangenheit gedruckt werden sollen. In den Druckoptionen können die Deckblätter und die Indizierung der Inhalte vorgegeben werden.

Druckprofile für regelmäßige Ausgaben

Eine getroffene Druckauswahl der Dokumente kann in den sogenannten Druckprofilen gespeichert werden. Ein wiederholtes Drucken von gleichen Inhalten kann somit einfach realisiert werden. Das Layout (HTML-Format) der gedruckten Dokumentation kann dem Unternehmensstandard angepasst werden. Die Schriftarten, Logos, Formatierungen etc. werden in einer CSS-Datei gemäß den Kundenanforderungen definiert.

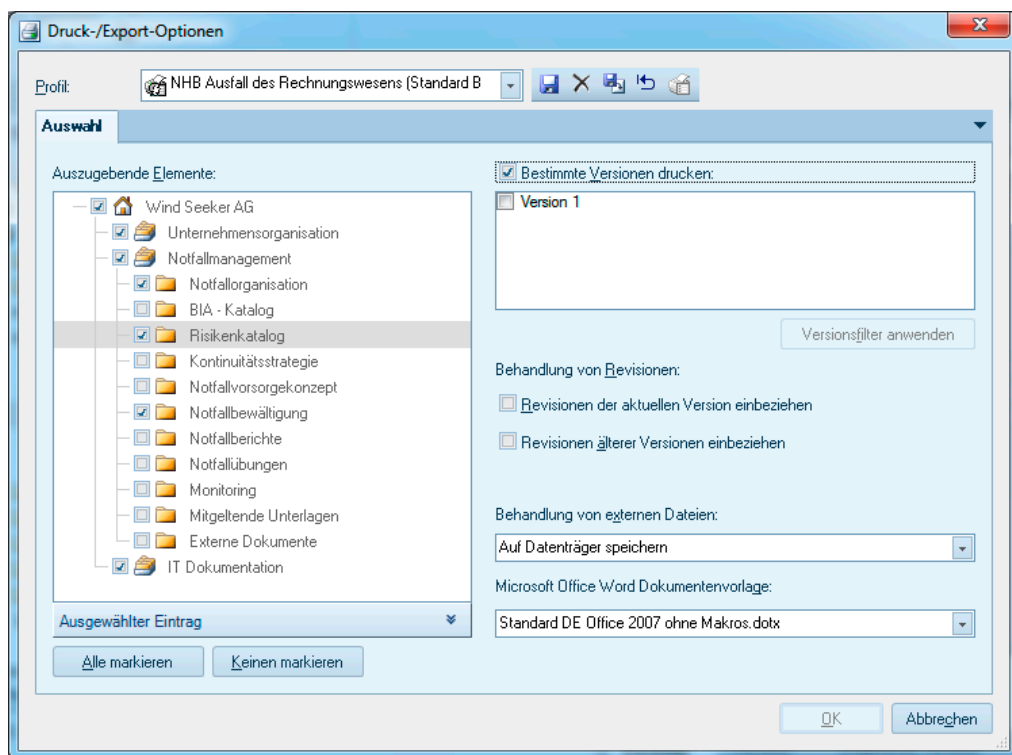


Bild 7.24 Profile ermöglichen eine regelmäßige Erstellung aktueller Dokumente.



Isolierter Einsatz für die IT-Dokumentation möglich

DocSetMinder unterstützt den Aufbau und die Pflege einer anforderungsgerechten Unternehmensdokumentation. Der Bereich IT-Governance ist ein Teilbereich davon.

Es ist jedoch auch möglich, die Anwendung auf den Einsatz in der IT-Organisation zu beschränken. In diesem Fall können die Aufbau- und die Ablauforganisation des IT-Bereichs auf der obersten Ebene abgebildet und die daran angehängte Dokumentation ausschließlich auf diesen Bereich beschränkt werden.

Die Module im Überblick

Die folgenden Ausführungen geben einen Überblick über die IT-Governance-Module.

Modul IT-Dokumentation

Das DocSetMinder-Modul *IT-Dokumentation* ist speziell für die Dokumentation der IT-Landschaft im Unternehmen konzipiert worden. Die Struktur entspricht in ihrem Aufbau dem ISO-OSI-7-Schichtenmodell und beschreibt neben den technischen Informationen auch die administrativen Komponenten (Verträge, Lieferanten, Dienstleister etc.). Durch Verlinkungen können die jeweiligen beteiligten Systeme Verfahren exakt zugeordnet werden.

Über die verfügbare API-Schnittstelle lassen sich die erforderlichen Daten aus externen Systemen (Inventory, DMS, ERP etc.) regelmäßig und automatisiert importieren.

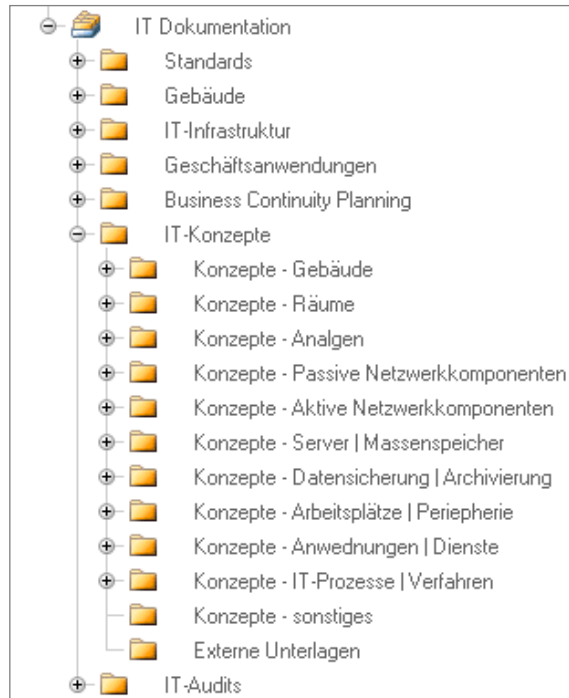


Bild 7.25 Standardmäßiger Aufbau des Moduls IT-Dokumentation

Modul IT-Grundschutz

Im DocSetMinder-Modul *IT-Grundschutz* werden die IT-Grundschutz-Kataloge des BSI abgebildet. Die Modulstruktur unterstützt den BSI-Standard 100-2 bei der Etablierung und Erhaltung eines ISMS im Unternehmen. Das Modul nutzt die bereits im Modul *Unternehmensorganisation* erfassten Informationen sowie die im Modul *IT-Dokumentation* beschriebenen IT-Ressourcen.

Das Modul *IT-Grundschutz* kann vor allem Sicherheitsbeauftragte bei der Umsetzung des betrieblichen IT-Grundschatzes und bei der Vorbereitung für eine Zertifizierung nach DIN EN ISO 27001 unterstützen.

Modul IT-Notfallmanagement

Das DocSetMinder-Modul *IT-Notfallmanagement* basiert auf dem BSI-Standard 100-4 und bildet die Methodik zur Etablierung des Notfallmanagements im Unternehmen gemäß dem Standard ab. Das Modul unterstützt die Erstellung und Pflege der Dokumentation im Bereich Notfallmanagement in allen Phasen des Prozesses und erfüllt die Mindestanforderung an die Kennzeichnung der Dokumente zum Notfallmanagement. Dazu werden Informationen aus anderen Modulen z. B. bei der Ermittlung der kritischen Unternehmensprozesse (Business-Impact-Analyse) benötigt.

Für die Bewältigung von Notfällen kann mithilfe von DocSetMinder ein Notfallhandbuch entsprechend den Vorgaben des Standards BSI 100-4 erstellt werden. So sind bereits für eine Reihe typischer Notfälle entsprechende Vorlagen vorhanden, die die Erstellung von Maßnahmenplänen für ausgewählte Szenarien erleichtern. Auch für die notwendigerweise zu erstellenden Wiederanlaufpläne werden Vorlagen mitgeliefert. Die gesamte Dokumentation kann in diversen Dateiformaten extrahiert und auf einem Datenträger aufbewahrt werden. Dabei lässt sich das Notfallhandbuch bei Bedarf auch in der Cloud und auf mobilen Geräten wie z.B. einem iPhone zur Verfügung stellen.

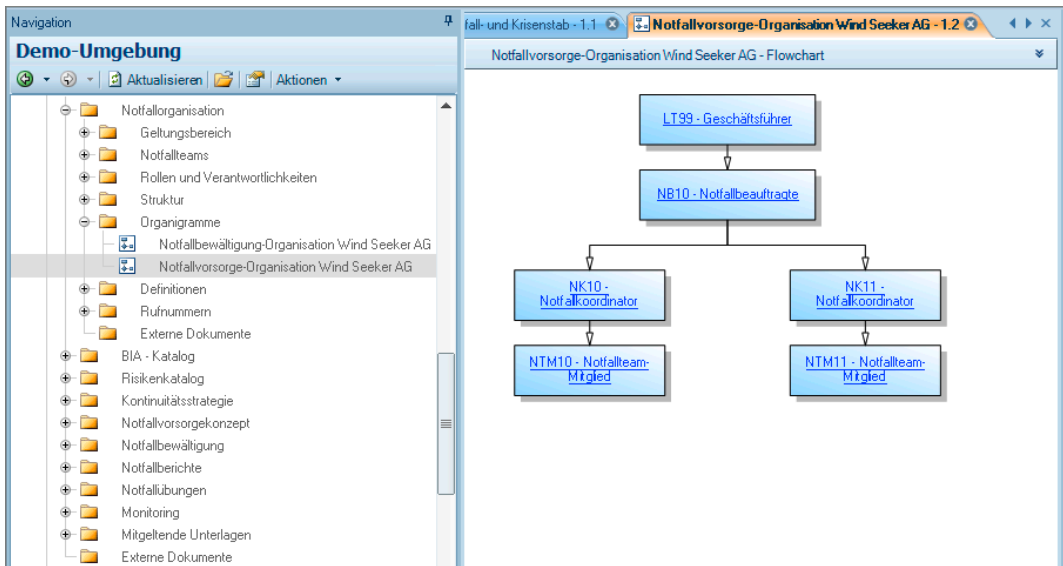


Bild 7.26 Modul *Notfallmanagement* mit Beispiel zur Abbildung der Notfallorganisation

Modul IT-Servicemanagement

Das DocSetMinder-Modul *IT-Servicemanagement* basiert auf der ITIL®-Modulstruktur und ist standardmäßig im DocSetMinder-Basismodul *Unternehmensorganisation* im Bereich der Unterstützungsprozesse integriert. Die Prozessstruktur bildet alle wesentlichen Bereiche ab, die notwendig sind, um das IT-Servicemanagement nach ITIL® zu etablieren, und unterstützt die IT-Verantwortlichen auch bei der Vorbereitung für eine Zertifizierung nach ISO 20000. Darüber hinaus können alle für das IT-Servicemanagement relevanten Verträge (SLAs) und Richtlinien im Bereich Stammdatendokumente des Grundmoduls dokumentiert und archiviert werden.

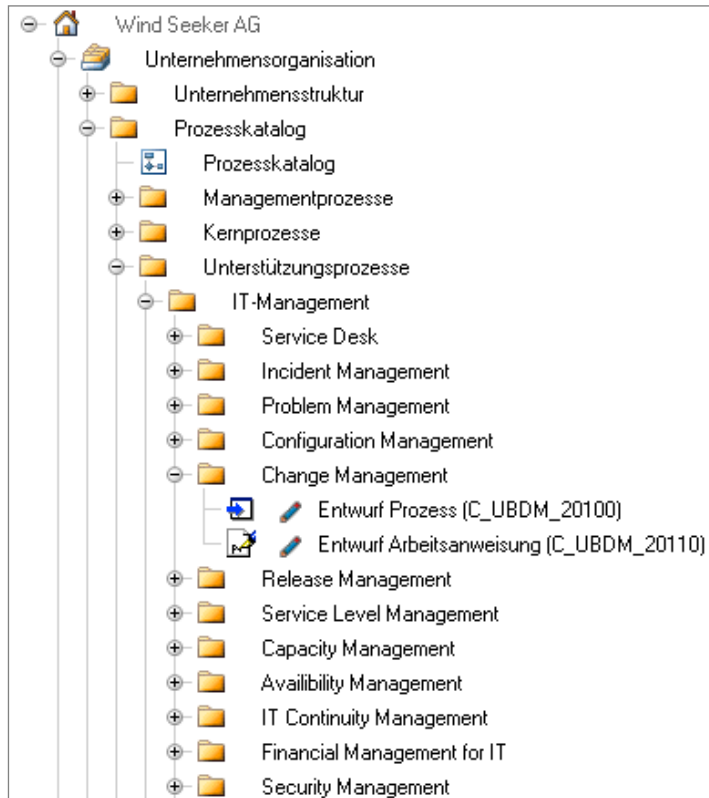


Bild 7.27 Standardmäßiger Aufbau des Moduls Servicemanagement-Dokumentation

Modul IT-Systemprüfung

Mit dem Modul *IT-Systemprüfung* unterstützt DocSetMinder beispielsweise Audits nach dem Prüfstandard PS 330 des Instituts der Wirtschaftsprüfer (IDW). Diese IT-Systemprüfung oder auch IT-Revision findet im Rahmen der Prüfung des Jahresabschlusses eines Unternehmens statt. Der Abschlussprüfer prüft, ob die eingesetzten IT-gestützten Buchführungssysteme (heutzutage unter dem Begriff »Enterprise Resource Planning« oder ERP bekannt) und die IT-Organisation den gesetzlichen Anforderungen entsprechen. Die IT-Systemprüfung wird gemäß den Anforderungen bestimmter Regelwerke des IDW durchgeführt und beurteilt die Angemessenheit und Ordnungsmäßigkeit der elektronischen Rechnungslegung. Für die Einhaltung einer gleichbleibend hohen Qualität der IT-Systemprüfung stellt der IDW eine Checkliste, den sogenannten IDW-Prüfungshinweis (PH 9.330.1), zur Verfügung. In dem DocSetMinder-Modul *IT-Systemprüfung* wird diese Checkliste vollständig abgebildet.

PCI-DSS-Standard

Der PCI-DSS-Standard ist ein Regelwerk im Zahlungsverkehr, das sich auf die Abwicklung von Kreditkartentransaktionen bezieht und von allen wichtigen Kreditkartenorganisationen unterstützt wird. In den Modulen *IT-Dokumentation* und *(IT-)Notfallhandbuch* werden die zwölf Richtlinien für die Anforderungen des Standards an die Rechnernetze und die

einzelnen IT-Assets abgebildet. Im Vordergrund steht der Schutz aller persönlichen Daten der Karteninhaber.

■ 7.8 Dokumentenmanagementsysteme

Dokumentenmanagement beschreibt die, meist datenbankgestützte, Verwaltung elektronischer Dokumente. Elektronische Dokumente sind entweder digital erzeugte bearbeitbare Dateien oder digitale Kopien eingescannter Papierdokumente.

Heute wird das Dokumentenmanagement häufig als eine Komponente des übergreifenden *Enterprise Content Management (ECM)* betrachtet. ECM ist ein modernes Kunstwort, das Produkte, Lösungen sowie eine ganze Branche beschreibt und Technologien zur Erfassung, Verwaltung, Speicherung, Bewahrung und Bereitstellung von Daten (Content) und Dokumenten zur Unterstützung von organisatorischen Prozessen im Unternehmen kombiniert.

7.8.1 Hinweise für die Evaluierung

Die Hauptaufgabe eines Dokumentenmanagementsystems (DMS) liegt darin, die definierten Dokumentationsprozesse über ein System abzubilden, zu steuern und zu überwachen. Das DMS organisiert dabei Entwurf und Erstellung, Weitergabe und Verteilung, Auffinden sowie die Ablage und Übergabe an ein Archiv oder Löschung der Dokumente. Dabei kann zwischen Dokumentenmanagementsystemen im engeren und im weiteren Sinne unterschieden werden.

Unter »klassischen« Dokumentenmanagementsystemen, d.h. Systemen im engeren Sinne, sind solche Lösungen zu verstehen, die die Erstellung, Nutzung und Änderung von Dokumenten unterstützen. Bei ihnen stehen folgende Funktionen im Vordergrund:

- strukturierte Speicherung von Dokumenten,
- Überwachung des Zugriffs auf Dokumente,
- indexgestützte Dokumentensuche,
- Ein- und Auschecken von Dokumenten,
- Versionsmanagement.

Demgegenüber unterstützen erweiterte Systeme den vollständigen Lebenszyklus von Dokumenten von ihrer Entstehung über Nutzung, Speicherung, Archivierung und Ausgabe bis zur Entsorgung. Erweiterte Systeme ergänzen die klassischen Dokumentenmanagementfunktionen mindestens um die beiden Komponenten Workflow und Archivierung. Dabei müssen nicht alle Komponenten zwangsläufig von einem Hersteller kommen.

Mit Hilfe der Workflow-Komponente werden die eigentlichen Prozesse und Arbeitsabläufe abgebildet. Beispielsweise können Review- und Freigabeprozesse mit Hilfe einer Workflow-Komponente gesteuert werden. Sind die Rollen, Ausführungsparameter und die Prozessteilnehmer definiert, kann die Workflow-Komponente den Transfer der Informationen zwi-

schen den Prozessteilnehmern steuern, die Ausführung überwachen und warnen, wenn zum Beispiel Bearbeitungszeiten überschritten werden. Verbunden mit einem DMS ermöglicht das Workflow-Management die vollständige Bearbeitung eines Vorgangs in einem elektronischen Medium vom Anfang bis zum Ende, d. h. bis zur Aussonderung zur Archivierung. Die gesamte Vorgangsbearbeitung wird so elektronisch gesteuert. Technisch kann es sich bei der Workflow-Komponente um ein Workflow-Management-System oder ein Business Process Management System (BPM) handeln.

Unterschiedliche Einsatzzwecke beachten

Traditionell werden Dokumentenmanagementsysteme in Unternehmen zur Unterstützung der Geschäftsprozesse eingeführt, denn ein Großteil der Dokumente in Unternehmen hat kaufmännischen Charakter. Hierbei ist entscheidend, dass auch die elektronische Archivierung dem Umfeld Dokumentenmanagement zugerechnet wird. Denn ein häufiger Einsatzzweck ist die Archivierung von Handelsbriefen, steuerrelevanten Daten und anderen Vertrags- und Geschäftsinformationen zur Einhaltung gesetzlicher Aufbewahrungsfristen gemäß Abgabenordnung, GoBS und GdPdU. Dazu müssen diese vollständig, indexiert und unverändert in eine revisionssichere elektronische Archivierung überführt werden. Das Dokumentenmanagement von kaufmännischen Dokumenten wird dabei häufig mit ERP-Systemen verbunden, da in diesen Kunden- und Transaktionsdaten zu den Dokumenten verwaltet werden. Zunehmend werden aber auch IT-Organisationen mit derartigen Anforderungen konfrontiert. Beispielsweise können auch E-Mails kaufmännische Dokumente darstellen und sind entsprechend zu verwalten und aufzubewahren.

In der Praxis nicht nur von IT-Organisationen haben sich in den letzten Jahren aber noch weitergehende Anforderungen an derartige Systeme entwickelt:

- Inhaltsverwaltung (Dokumente, Listen, Formulare, externe Daten usw.),
- Suchfunktionen (umfangreiche Suchfunktionen; auch in externen Daten),
- Portaldienste (Web-Content-Management, Webseitenerstellung, Abbildung Unternehmensportal usw.),
- Collaboration-Dienste (Aufgaben, Kalender, Workflow, Blog, Wiki, Office-Integration, Projektmanagement usw.),
- Business Intelligence (KPI, serverbasierte Excel-Kalkulationen, Dashboards, Berichte usw.).

Diese Liste entspricht weitgehend der Liste der Leistungsmerkmale des SharePoint Servers 2013, wie sie im Buch von Dirk Larisch (Larisch, 2013) zu finden ist. Nicht umsonst hat Microsoft SharePoint gerade im IT-Umfeld in den letzten Jahren zunehmend an Bedeutung gewonnen. Hier gibt es häufig Anforderungen, nach denen ein DMS vor allem die Verwaltung der aktuell benötigten Dokumente unterstützen bzw. eine Collaboration-Plattform bieten soll. In der Praxis wird die Anforderung der revisionssicheren Archivierung häufig sogar nachrangig behandelt.



Zusätzliche Informationen

In Kapitel 6 *Abschnitt 6.2.2.1* finden Sie zusätzliche Informationen zu Einsatz und Nutzen von Dokumentenmanagementsystemen.

7.8.2 Dokumentenverwaltung mit SharePoint

Die folgenden Ausführungen zu Microsoft SharePoint beziehen sich auf die aktuelle Version 2013. (Stand Juli 2013)

Microsoft SharePoint Server ist eine Portalsoftware zur Zusammenführung verschiedenster Anwendungen, Informationen und Datenquellen unter einer einheitlichen Weboberfläche. Von besonderer Bedeutung ist hierbei die nahtlose Integration der Microsoft-Office-Produkte.

SharePoint Foundation (ehemals WSS = Windows SharePoint Services) kennzeichnet die Basistechnologie von Microsoft für die Nutzung der SharePoint Services, die auch die Grundlage für SharePoint Server bildet. SharePoint Foundation kann auch getrennt und vor allem kostenlos bezogen werden, d.h., es fallen keine über die Server- und CAL-Lizenzen hinaus gehenden Lizenzkosten an. Mit ihren Funktionen zur Bereitstellung von Informationen und der Unterstützung der gemeinsamen Arbeit an Inhalten stellen sie eine durchaus brauchbare Lösung dar, um die Zusammenarbeit von Teams überschaubarer Größe zu optimieren. SharePoint Foundation eignet sich zur Koordination von Zeitplänen, Organisation von Dokumenten und Teilnahme an Diskussionen in Teamarbeitsbereichen, Blogs und Wikis. Für einen unternehmensweiten Einsatz, bei dem Informationen für sämtliche Benutzer bereitgestellt werden sollen, ist hingegen der kostenpflichtige Microsoft SharePoint Server erforderlich.

Welche Möglichkeiten bietet nun aber der Microsoft Office SharePoint Server in Bezug auf die Dokumentenverwaltung?

Generell stehen bei allen Dokumentenmanagementsystemen vier Funktionen im Vordergrund:

- gemeinsame Bearbeitung von Dokumenten,
- Versionsmanagement,
- Genehmigungsprozesse,
- Dokumentensuche.

Die Dokumentenmanagement-Optionen von SharePoint liefern für alle vier der genannten Anforderungen Standardfunktionen, die an die eigenen Verfahren angepasst werden können.

Die zentrale Komponente zur Verwaltung von Dokumenten sind die sogenannten »Bibliotheken«. Hierbei handelt es sich um eine spezielle Form von Listen, die als Sammelbecken für verschiedenste Dateien unterschiedlichen Typs dienen. So kann es sich dabei um Bilddateien, Textdateien oder auch Formulare oder Vorlagen handeln. Unter Microsoft SharePoint Server 2013 wird automatisch eine Dokumentbibliothek mit dem Namen »Dokumente« angelegt. Weitere Bibliotheken können als sogenannte »App« hinzugefügt werden.

Zu den am häufigsten verwendeten Bibliotheken gehören sicherlich die »Dokumentbibliotheken«. In ihnen können Dateien beliebiger Art abgelegt und verwaltet und in Ordnern strukturiert werden.

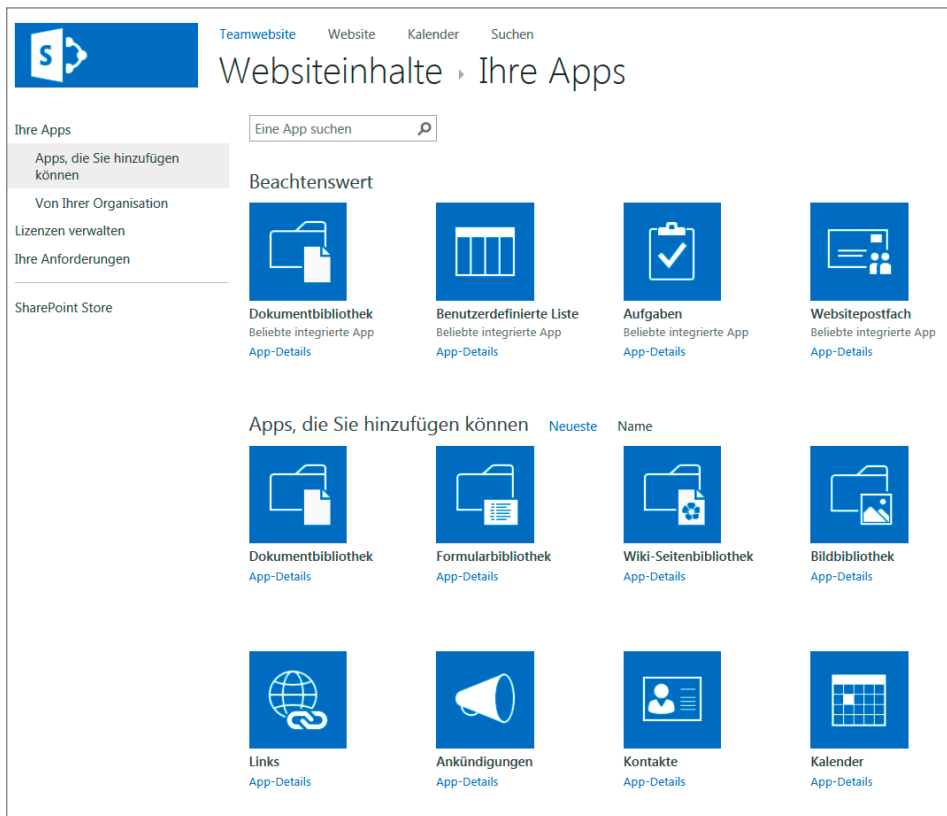


Bild 7.28 Auch in Microsoft SharePoint haben Apps Einzug gehalten.

Zusammenarbeit an Dokumenten und gemeinsame Dokumenterstellung

Dokumente gemeinsam bearbeiten zu können, ist eine der Hauptforderungen an ein DMS. Vor allem in Kombination mit Office 2010 und 2013 bietet SharePoint zahlreiche Möglichkeiten, sei es für die gemeinsame Erstellung einer Kalkulationstabelle oder das gleichzeitig Review eines Word-Dokuments.

- **Bearbeitung ausgecheckter Dokumente:** Klassischerweise unterstützen DMS-Lösungen das Auschecken von Dokumenten, um die gleichzeitige Bearbeitung von Dateien durch mehrere Personen zu verhindern. Ein Benutzer, der ein Dokument ausgecheckt hat, ist exklusiv berechtigt, an dem Dokument zu arbeiten. Um anderen Benutzern die Änderungen verfügbar zu machen, muss er nach der Überarbeitung das Dokument wieder einchecken. Um Probleme zu verhindern, wenn ein Benutzer beispielsweise vor seinem Urlaub vergessen hat, ein Dokument wieder einzuchecken, können ausgecheckte Dokumente zentral verwaltet werden. Wieder eingeecheckte Dateien werden automatisch mit einer fortlaufenden Versionsnummer versehen, falls die Versionsverwaltung für die Bibliothek aktiviert ist, was die Nachvollziehbarkeit vereinfacht und eine leichte Wiederherstellung älterer Versionen ermöglicht. Hierbei kann konfiguriert werden, wie SharePoint Versionen verwalten soll.

- **Gemeinsame Dokumentenbearbeitung:** Mit der gemeinsamen Dokumentenerstellung bietet SharePoint eine weitere Funktion, die es mehreren Personen erlaubt, gleichzeitig ein Dokument zu bearbeiten, ohne dabei Konflikte bei den Änderungen zu erzeugen. Diese Funktion ist jedoch nicht mit dem Aus- und Einchecken von Dokumenten in eine SharePoint-Bibliothek kompatibel. Wird eine Datei ausgecheckt, können andere Benutzer nicht gleichzeitig daran arbeiten. Dies aber ist gerade das Ziel. SharePoint erlaubt es, dass zwei oder mehr Benutzer ein Word-Dokument oder eine PowerPoint-Präsentation, die in einer SharePoint-Bibliothek gespeichert ist, gleichzeitig bearbeiten. So kann beispielsweise ein Autor in einer Präsentation an einer Folie arbeiten, während ein anderer Autor eine andere Folie bearbeitet. Jeder Autor kann dabei immer anhand von Symbolen, Statusleistenindikatoren und Navigationsbereichen des Dokuments oder der Präsentation sehen, an welchen Stellen andere Autoren Änderungen vornehmen. Diese Funktionalität ist standardmäßig eingerichtet und muss nicht konfiguriert werden.

Ob ein Auschecken eines Dokuments vor der Bearbeitung obligatorisch ist, kann in den Versionsverwaltungseinstellungen für jede Bibliothek gesondert festgelegt werden.

Inhaltsgenehmigung für gesendete Elemente erforderlich?

☐ Ja ☒ Nein

Jedes Mal neue Version erstellen, wenn eine Datei in 'Dokumentbibliothek' bearbeitet wird?

☐ Keine Versionskontrolle

☐ Hauptversionen erstellen
Beispiel: 1, 2, 3, 4

☒ Haupt- und Nebenversionen (Entwürfe) erstellen
Beispiel: 1.0, 1.1, 1.2, 2.0

Geben Sie optional einen Grenzwert für die Anzahl von Versionen an, die beibehalten werden:

☐ Folgende Anzahl von Hauptversionen beibehalten:

☐ Entwürfe für die folgende Anzahl von Hauptversionen beibehalten:

Wer Entwurfselemente in 'Dokumentbibliothek' anzeigen darf

☒ Alle Benutzer, die Elemente lesen dürfen

☐ Nur Benutzer, die Elemente bearbeiten dürfen

☐ Nur Benutzer, die Elemente genehmigen dürfen (und der Autor des Elements)

Auschecken von Dokumenten erfordern, bevor sie bearbeitet werden können?

☒ Ja ☐ Nein

OK Abbrechen

Bild 7.29 Standardmäßig ist das Auschecken eines Dokuments vor der Bearbeitung nicht erforderlich.

Versionsverwaltung

Mit der Versionierung von Dokumenten wird erreicht, dass durchgeführte Änderungen, je nach gewähltem Grad der Versionierung, jederzeit nachvollziehbar sind. Dabei werden die unterschiedlichen Versionsstände der einzelnen Dokumente einer Bibliothek gespeichert, so dass jederzeit ein älterer Stand wiederhergestellt werden kann.

Standardmäßig ist die Versionsverwaltung deaktiviert. Eine Aktivierung ist für jede Bibliothek gesondert im Bereich *Versionsverwaltung* (siehe Bild 7.29) möglich. Hierbei stehen die folgenden Optionen zur Auswahl:

- **Keine Versionskontrolle:** Diese Einstellung bewirkt, dass immer nur die zuletzt gespeicherte Version einer Datei oder eines Dokuments verfügbar ist.
- **Hauptversionen erstellen:** Für die einzelnen Dokumente der Bibliothek werden bei jeder Änderung neue Hauptversionen erstellt, die dann auch direkt veröffentlicht werden.
- **Haupt- und Nebenversionen (Entwürfe) erstellen:** Diese Option ermöglicht neben der Erstellung veröffentlichter Hauptversionen auch das Anlegen sogenannter Nebenversionen. Diese dienen einzig und allein dem Bearbeitungsmodus und werden standardmäßig nur dem Ersteller oder einer Person angezeigt, die das Dokument genehmigen darf.

Abhängig von der gewählten Konfiguration der Versionierung kann beim Einchecken zwischen Haupt- und Nebenversionen unterschieden werden. Hierbei können Kommentare hinzugefügt werden, um den Versionsverlauf zu erläutern.

Einchecken [X]

Version
Wählen Sie den Versionstyp aus, den Sie einchecken möchten.

Welche Version soll eingecheckt werden?

☒ 1.1 Nebenversion (Entwurf)

☐ 2.0 Hauptversion (veröffentlichen)

Auschecken beibehalten
Andere Benutzer können Ihre Änderungen erst nach dem Einchecken sehen. Wenn Sie die Bearbeitung fortsetzen möchten, können Sie das Auschecken beibehalten, nachdem Sie eingecheckt haben.

Auschecken nach dem Einchecken beibehalten?

☐ Ja ☒ Nein

Kommentare
Geben Sie Kommentare dazu ein, was sich in dieser Version geändert hat.

Kommentare:

[Text area for comments]

OK Abbrechen

Bild 7.30 Optionen beim Einchecken eines Dokuments

In der Versionshistorie können jederzeit die gespeicherten Versionen angezeigt und bei Bedarf gelöscht werden.

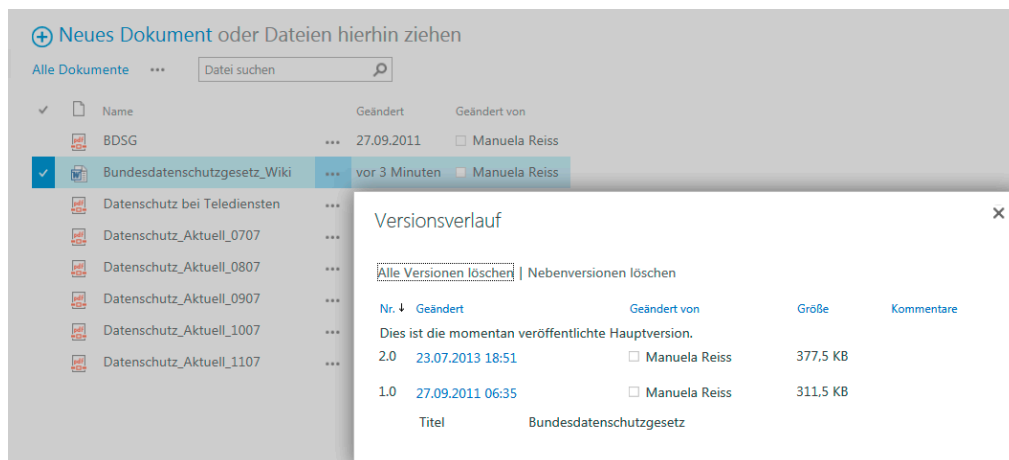


Bild 7.31 Vorhandene Versionen werden in der Versionshistorie angezeigt.

Abläufe mit Workflows automatisieren

Eine wichtige Funktion erfüllen Workflows. Ein Workflow ist hier als eine Abfolge fest definierter elektronischer Arbeitsabläufe definiert. Mit dem Einsatz von Workflows steht in einer SharePoint-Umgebung eine Möglichkeit zur Verfügung, bestimmte Arbeitsschritte automatisiert bzw. in elektronischer Form durchzuführen bzw. durchführen zu lassen. So kann man beispielsweise mit einem Workflow den Genehmigungs- oder Freigabeprozess für ein Dokument steuern.

Workflows werden auf Bibliotheksebene eingerichtet. Standardmäßig enthält SharePoint 2013 die folgenden Workflows:

- **Genehmigungsworkflow:** automatische Weiterleitung von Dokumenten oder Elementen, die genehmigt oder abgelehnt werden müssen,
- **Workflow zum Sammeln von Feedback:** automatische Weiterleitung von Dokumenten oder Elementen, für die Feedback erfasst werden soll,
- **Workflow für die Signaturerfassung:** automatische Weiterleitung von Dokumenten, Arbeitsmappen oder Formularen, die digital signiert werden sollen,
- **Workflow mit drei Status:** Verfolgen von Problemen, Projekten oder Aufgaben in drei Zuständen oder Phasen,
- **Workflow für die Veröffentlichungsgenehmigung:** automatische Weiterleitung von Dokumenten für Prüfung und Genehmigung.

Wenn der Autor eines Dokuments beispielsweise den Genehmigungsworkflow für ein Dokument startet, erstellt der Workflow Aufgaben zur Dokumentgenehmigung, weist diese den Workflow-Teilnehmern zu und sendet dann E-Mail-Benachrichtigungen an die Teilnehmer. Diese enthalten Anweisungen zur Aufgabe und eine Verknüpfung mit dem zu genehmigenden Dokument. Abhängig vom definierten Freigabeverfahren wird das Dokument in einem

weiteren Schritt genehmigt und ist anschließend in der aktuellen Version für alle verfügbar. Bis zur Genehmigung bleibt das Dokument, abhängig von der Einstellung, beispielsweise nur für die Benutzer sichtbar, die Dokumente genehmigen dürfen. Dabei kann festgelegt werden, welche Personen im Freigabeprozess zu informieren sind. Der Besitzer des Workflows und die Teilnehmer des Workflows können während der Ausführung des Workflows jederzeit auf der Seite *Workflowstatus* überprüfen, welche Teilnehmer ihre Workflow-Aufgaben abgeschlossen haben. Wenn alle Workflow-Aufgaben abgeschlossen sind, wird der Workflow-Besitzer automatisch über den Abschluss benachrichtigt. Wichtig ist, dass hierbei in keinem Fall Dateien im Anhang verschickt werden, sondern lediglich Aufgabenbeschreibungen inklusive einem Link auf die entsprechende Dokumentenversion.

Workflow
Wählen Sie einen Workflow aus, der diesem Inhaltstyp hinzugefügt werden soll. Wenn ein Workflow in der Liste fehlt, muss Ihr Webteamadministrator diesen ggf. veröffentlichen oder aktivieren.

Wählen Sie eine Workflowvorlage aus:
Dieser Status

Beschreibung:
Mit diesem Workflow können Sie Elemente in einer Liste verfolgen.

Name
Geben Sie einen Namen für diesen Workflow ein. Mit diesem Namen wird der Workflow für Benutzer dieses Inhaltstyps identifiziert.

Geben Sie einen eindeutigen Namen für diesen Workflow ein:

Aufgabenliste
Wählen Sie den Namen der Aufgabenliste aus, die mit diesem Workflow verwendet werden soll, oder erstellen Sie eine neue Liste.

Wählen Sie eine Aufgabenliste aus:
Aufgaben (neu)

Beschreibung:
Es wird eine neue Aufgabenliste für diesen Workflow erstellt.

Verlaufsliste
Wählen Sie den Namen der Verlaufsliste aus, die mit diesem Workflow verwendet werden soll, oder erstellen Sie eine neue Liste.

Wählen Sie eine Verlaufsliste aus:
Workflowverlauf (neu)

Beschreibung:
Dieser Workflow verwendet eine neue Verlaufsliste.

Startoptionen
Geben Sie das Verfahren zum Starten des Workflows an.

☒ Manuelles Starten dieses Workflows durch einen authentifizierten Benutzer mit Elementbearbeitungsberechtigungen zulassen.
☐ Zum Starten dieses Workflows sind Berechtigungen zum Verwalten von Listen erforderlich.

☐ Dieser Workflow wird gestartet, wenn ein neues Element erstellt wird.

Bild 7.32 Vorhandene Versionen werden in der Versionshistorie angezeigt.

Wenn Sie einen integrierten Workflow flexibler gestalten möchten, können Sie ihn mit Tools wie SharePoint Designer 2013 weiter anpassen. Sie können auch völlig neue, eigene Workflows erstellen.

Gespeicherte Dokumente wiederfinden

In welchem Dokument habe ich nur die Funktion XYZ beschrieben? Diese Frage kennt jeder, der mit der Erstellung von Dokumenten zu tun hat. Im Firmenumfeld, wo Dateien (hoffentlich) nicht lokal, sondern in zentralen Dateiablagen, Postfächern, Datenbanken und öffentlichen Ordnern gespeichert werden, gestaltet sich die Beantwortung der Frage schon schwieriger.

Die Möglichkeiten, Dokumente einfach und schnell wiederzufinden, gehört zu den wichtigsten Funktionen, die der Einsatz eines Dokumentenmanagementsystems bietet. Die in SharePoint Server 2013 integrierten Suchoptionen sind sehr vielfältig und umfangreich. Die Such-Engine entkoppelt die Inhalte von den Strukturen, in denen diese in SharePoint gespeichert sind, und stellt sie in einem zentralen Index bereit, katalogisiert und mit den beschreibenden Meta-Daten. Damit ermöglicht die in SharePoint integrierte Form der Suche den Aufbau einer unternehmensweiten »Suchzentrale«, die beispielsweise auch Datenbestände durchsucht, die nicht in SharePoint, sondern an anderer Stelle, beispielsweise im Netzwerk in der Dateifreigabe eines Servers, abgelegt sind.

Der Vorteil für die Anwender besteht darin, dass diese nichts tun müssen, um die Suchfunktionen nutzen zu können. Die Inhalte für die Suchergebnisse werden dynamisch generiert. Hierbei ermöglicht, neben den standardmäßig bekannten Crawl-Vorgängen VOLLSTÄNDIG und INKREMENTELL, die Option KONTINUIERLICH einen permanenten Crawl-Vorgang, um so die Suchergebnisse permanent aktuell zu halten. Eine derartige Echtzeitindizierung ermöglicht es, dass Dokumente oder Listen, die in SharePoint bearbeitet oder hochgeladen werden, unmittelbar anschließend im Suchindex verfügbar sind.

Die Suche innerhalb eines Index erfolgt grundsätzlich über alle Inhaltsquellen und mithilfe sämtlicher Crawl-Regeln, also innerhalb der gesamten Indexdatenbank. Tatsächlich angezeigt werden aber nur die Daten, auf die er im Rahmen der zugewiesenen Berechtigungen Zugriff hat. So wird sichergestellt, dass Unbefugte nicht auf Daten zugreifen können, zu denen sie in der SharePoint-Umgebung keine Berechtigung haben.

Die Ergebnisse der Suche werden dem Benutzer standardmäßig in einer Liste angezeigt, die er nach Autor, Ergebnistyp und Änderungsdatum sortieren bzw. filtern kann. Hilfreich bei der Auswahl ist die bei SharePoint 2013 neu hinzugekommene Vorschaufunktion.

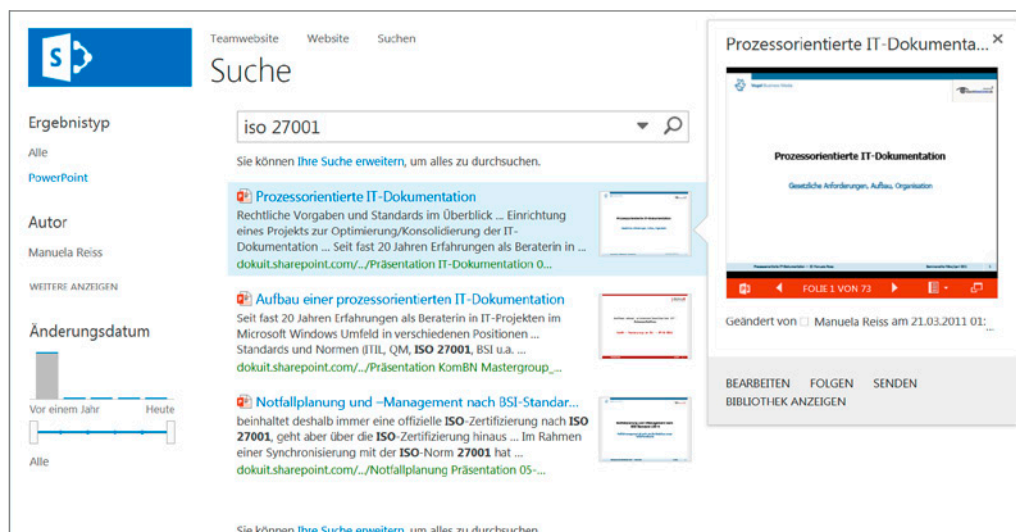


Bild 7.33 Beispiel: Ergebnisanzeige einer Suche bei SharePoint 2013